TAMGA NETWORK

TAMGA NETWORK WHITEPAPER

A Digital Trust Infrastructure for Türkiye and the Turkic World

Extended edition: how it works, why it was built this way, where it is going

Tamga Network

NOVEMBER 2026 · VERSION 1.0

© 2026 Tamga Network. This work is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0): it may be shared and adapted with attribution. https://creativecommons.org/licenses/by/4.0/

Abstract

Tamga Network is a trust network designed for Türkiye and the Turkic world that speaks the same technical language as the European Union's digital identity framework. In the network an institution issues a credential, the person carries it in a wallet on their phone and decides for themselves whom to show it to, and a verifier checks it within seconds without asking the issuing institution. Credentials are encoded in the open standards the EU has chosen (SD-JWT VC and ISO/IEC 18013-5 mdoc); issuance and presentation follow the OpenID4VCI and OpenID4VP profiles; every credential is bound to a key in the device's secure hardware, and the person shows only the fields that are asked for. Today trust comes from signed trust lists that anyone can download and check, and from an anchor log that advances hour by hour. The code for a shared ledger has been written and tested, but the ledger is not in production and is switched off, and it will not be switched on without at least two independent operators. None of the shared records contains personal data.

This document explains, in twenty-four chapters, how this structure works, why each important choice was made and where the network is heading. Trust lists, institution certificates, credential formats, issuance and presentation flows, the verification pipeline, revocation, wallet rules, the provisional identity service, privacy engineering and the threat model are each taken up in turn; every choice is given together with the decision record that binds it and the alternatives that were weighed. Sovereignty is a condition the design sets from the start. Each state is the only writer of its own registry, and every role that is carried out provisionally on behalf of a state today has been built so that it can be handed over without changing any credential, institution identity or credential type. Today only the Türkiye slot is active in the lists; for the other states a slot has only been reserved.

The text states the status of every claim plainly: functions that are live, functions that have been decided but are not yet live, and functions that are still research are kept apart, and the roadmap is given in terms of conditions rather than dates. The final chapters bring together all the decisions, the declared residual risks and the open questions. This document is not a legal opinion or a certification claim, and it is not the announcement of an agreement with any state or institution.

Keywords: digital trust infrastructure · trust lists · eIDAS 2.0 · EUDI ARF · SD-JWT VC · mdoc · OpenID4VCI · OpenID4VP · selective disclosure · unlinkability · sovereignty · Turkic world

CITATION
Tamga Network (2026). A Digital Trust Infrastructure for Türkiye and the Turkic World. Whitepaper, version 1.0. https://tamga.network/whitepaper-en.pdf

Contents

Reading guide 6
1 Introduction: From Copy to Proof 7
1.1 An application scene 7
1.2 Tamga's short answer 7
1.3 Contribution and plan of this document 9
1.4 The name: tamga 9
2 Problem Space and Requirements 10
2.1 The cost of the copy economy 10
2.2 Trust stopped at the border 10
2.3 The second problem: privacy 11
2.4 The question of sovereignty 11
2.5 Requirements 12
3 Background: eIDAS 2.0, the EUDI ARF and Open Standards 13
3.1 From eIDAS to eIDAS 2.0 13
3.2 Credential types: PID, EAA, QEAA, PuB-EAA 14
3.3 The ARF's roles and trust lists 14
3.4 Map of technical standards 16
3.5 Looking from outside the EU 17
4 Design Principles and Positioning 18
4.1 Seven principles 18
4.2 Three layers 19
4.3 What the network is not 20
4.4 A non-profit network, a foundation and provisional operation 21
5 Roles and Components 21
5.1 The set of roles 22
5.2 Rules of role separation 23
5.3 Components and service addresses 24
5.4 The network and wallets 25
5.5 Direction rules 26
6 Trust Model: Signed Trust Lists and the Anchor Log 27
6.1 What a signature proves, what a list proves 27
6.2 The list of lists and the country lists 27
6.3 List rules 29
6.4 The anchor log 30
6.5 The out-of-band trust anchor 31
6.6 A single interface: TrustSource 31
6.7 Identifiers 32
6.8 ETSI views 33
6.9 Federation: someone else's list 34
7 Institution Identity and Certificates 34
7.1 Why X.509, why not DID 35
7.2 National root and provisional operation 35
7.3 The issuer certificate profile 35
7.4 The verifier access certificate 36
7.5 The registration certificate 36
7.6 The institution's key stays at the institution: remote signing 37
8 Credentials: Formats, Types and the Catalogue 38

8.1 Anatomy of an SD-JWT VC ... 39
8.2 Why device binding has no exceptions ... 41
8.3 mdoc: the second representation ... 42
8.4 Credential type identity and the catalogue ... 43
8.5 Today's types ... 45
8.6 Category signal and assurance ... 45
9 Issuance: The OpenID4VCI Profile ... 46
9.1 Two starting points ... 46
9.2 The authentic source stays at the institution ... 47
9.3 Only to genuine wallets ... 49
9.4 DPoP, nonce and key proof ... 49
9.5 Batch issuance: ten copies, ten keys ... 51
9.6 Silent renewal ... 52
9.7 Notification and "if this wasn't you" ... 52
10 Presentation: OpenID4VP, DCQL and Proximity ... 53
10.1 The signed request and the verifier's identity ... 53
10.2 What is requested, with DCQL ... 54
10.3 The consent screen and over-asking ... 55
10.4 Response and encryption ... 56
10.5 Fetch branches against a fake decline ... 57
10.6 Presentation from the browser ... 58
10.7 Logging in to websites ... 59
10.8 Proximity: bridges and the target ... 59
10.9 Gates and tickets ... 60
11 The Verification Pipeline: Five Layers, Three Outcomes ... 61
11.1 Why a fixed pipeline ... 61
11.2 The layers ... 62
11.3 Time-bound authorisation ... 63
11.4 The three-valued outcome ... 63
11.5 The hosted verifier ... 64
12 Revocation and Lifecycle ... 64
12.1 Withdrawing without tracking ... 65
12.2 Why not on the chain ... 66
12.3 Bit size and suspension ... 66
12.4 Privacy rules ... 67
12.5 Freshness and time to take effect ... 68
12.6 Revocation policy ... 69
12.7 Wallet unit revocation ... 70
13 The Wallet: Rules, Keys and Attestations ... 70
13.1 How the network sees the wallet ... 70
13.2 Key architecture and levels ... 70
13.3 WIA and KA ... 71
13.4 Copies ... 73
13.5 The person's control ... 74
13.6 "Listed on Tamga Network" ... 75
13.7 No age limit ... 75
14 Identity: The Provisional Identity Credential Provider ... 75
14.1 What to do when there is no PID ... 76
14.2 Remote identity verification ... 76

14.3 Levels 78
14.4 Class: not qualified 79
14.5 Attributes 79
14.6 Credentials that grow out of identity 80
14.7 Retention and deletion 81
14.8 App store review code 82
15 Privacy Engineering 82
15.1 Linkability as a threat 82
15.2 A copy per verifier and rounded time 83
15.3 Per-site pseudonym 83
15.4 Zero-knowledge proof 85
15.5 No data in shared records 87
15.6 Legal framework 88
15.7 Remaining privacy risks 88
16 Security Model and Threats 88
16.1 Assets and trust assumptions 88
16.2 Attacker models 89
16.3 Threat table 89
16.4 Secure defaults 91
16.5 Conformance and testing 91
16.6 Incident response and responsible disclosure 92
17 Sandbox, Open Packages and Reference Services 92
17.1 Sandbox 92
17.2 Ten packages 93
17.3 Reference services 94
17.4 The three doors to the documentation 95
18 Governance and Sovereignty 95
18.1 Three-layer sovereignty 95
18.2 Today’s bodies 97
18.3 Stages 97
18.4 Hand-over plan 98
18.5 Measurable thresholds and transparency 99
18.6 Participation gates and the conformance regime 99
18.7 Funding principle 100
18.8 The rulebook arrangement 100
19 The Shared Ledger: Why Not Now, and How It Will Come 101
19.1 When a ledger adds something 101
19.2 Why Besu and QBFT 102
19.3 The projection principle 102
19.4 Threshold anchoring and competing candidates 103
19.5 Namespace, cross-state links, quotas 105
19.6 Upgrade delay 105
19.7 Permissioning and operation 106
19.8 Transition 106
19.9 The value layer: suspended 107
20 EU Alignment and Third-Country Recognition 107
20.1 Three levels of interoperability 107
20.2 Standards alignment map 107
20.3 EU registration data and certificates 109

20.4 Legal recognition is not in the network's hands 109
20.5 How we show alignment 110
20.6 Name and mark 111
21 Decisions and Their Rationale 112
21.1 How a decision is made 112
21.2 Ten major decisions 112
21.3 All decisions 114
21.4 Decisions that changed 118
22 Status, Roadmap and Open Decisions 119
22.1 What is live today 119
22.2 Roadmap 121
22.3 The decision in the proposed state 121
22.4 Open decisions and next steps 122
23 Limits and Open Questions 122
23.1 Declared residual risks 122
23.2 Questions that do not yet have an answer 123
23.3 Research directions 124
24 Conclusion 124
Appendix A — Glossary 125
Appendix B — Decision records index 127
Appendix C — Standards index 130
Appendix D — Abbreviations 131
Appendix E — Document set index 132
References 134

Reading guide

This document describes Tamga Network from beginning to end: how it works, why each important choice was made and where the network is heading. Not every reader needs every chapter. A public administrator looks for something different from a wallet developer; Table 1 suggests a short path for each group of readers. A suggested path is not a limit. Chapters refer to one another by chapter number, so a reader can go back or forward from the place where a concept first appears.

KEY POINT

What this document is not

This document is not a legal opinion; its statements about KVKK [9], eIDAS or any other legislation do not replace the assessment of a lawyer. Nor does it make any certification claim; Tamga's conformance tests are self-tests and do not imply the approval of any body. It is not the announcement of an agreement with any state or institution, or of negotiations under way; for the states named in the text, a slot has only been reserved in the lists. The document is a living text and is updated in place within version 1.0. Where it conflicts with the source documents, the source prevails: first the decision records, then the specifications, then the framework documents.

Table 1. Suggested reading paths by reader group.

Reader	What they look for	Suggested chapters
Public administrator, regulator, state representative	sovereignty, handover, relationship with the EU, legal boundary	1–4, 18, 20, 22–23
Institution (university, professional body, ticket seller)	how do I join, what do I gain, who keeps the signing key	1–2, 5, 7–9, 12, 17
Verifier, website	how do I verify, what do I see, what are my obligations	5, 10–11, 15
Wallet developer	how do I get listed, which attestations are required, what are the rules	5, 13, 17, 20
Academic, researcher, security specialist	the rationale of the model, threats, residual risks	3, 6, 11, 15–16, 19, 21, 23
Journalist, general reader	what is being solved, why it matters	Abstract, 1–2, 4, 15, 24

Every claim in the document belongs to one of three statuses, and the text says so explicitly throughout. When you see a status label in bold next to the name of a function, read it with the meaning given in Table 2. The status of every function is collected in a single table in Chapter 22.

Table 2. Status labels.

Label	Meaning	Example
Live	Live on the real network or in the sandbox, and can be shown from the source	signed trust lists, Tamga Verify, sandbox
Planned	Bound to a decision and has code or a design, but is not live	proximity presentation over Bluetooth, XML trust list on the real network
Research	No decision exists, or the decision is suspended	pseudonym derivation with zero-knowledge proofs, value layer

Decisions are cited by their decision records (ADR, *Architecture Decision Record*), technical rules by specifications (SPEC) and framework rules by the documents of the Tamga Architecture and Reference Framework (FW). Wherever you see "ADR-0042" in the text, the full text of the decision is under `docs.tamga.network/adr/` wherever you see "SPEC-TRUST-0001 §5", the relevant section of the specification is under `docs.tamga.network/specifications/` and wherever you see "FW-ARF-0001 §6.1", the framework document is under `arf.tamga.network/` . The mapping of identifiers

to addresses is in Appendix E [63, 64, 65]. Identifiers are permanent: even if a document's title or location changes, its identifier stays the same.

At the time this edition was prepared, Tamga's open packages had been published on npm as the 0.8.2 test release; the framework documents are at version 1.0. Every version-dependent sentence is written as of that date.

1 Introduction: From Copy to Proof

1.1 An application scene

In the first article of this series [67] we met Aynur, who had finished her bachelor's degree in Baku and wanted to do a master's in Istanbul. Aynur has now graduated and is applying for a position advertised by a company in Istanbul. The advertisement is clear: candidates are asked for a diploma, a transcript and an identity document. Timur, the company's recruiter, likes Aynur's CV among the applications and invites her to an interview.

Before the interview, the documents arrive. Aynur sends a scanned copy of her diploma by e-mail; since Timur cannot read the Azerbaijani text, he asks for a notarised translation. Aynur finds a translation office, books an appointment with a notary, and spends several days and some money. In the end Timur holds two pieces of paper: a copy of a diploma and a translation of that copy. But Timur's real question is still unanswered. Is this diploma genuine?

To find out, Timur writes an e-mail to the student affairs office of the university in Baku. The e-mail sits for a while; perhaps it reaches the right person, perhaps it does not. If an answer comes, it comes weeks later; if it does not, Timur has to choose between trusting the copy and losing the candidate. Meanwhile Aynur's diploma, a photocopy of her identity card and her transcript sit in the company's recruitment folder, on its e-mail server and perhaps in an applicant tracking system. Aynur will never learn where these copies are kept, for how long, or who can access them.

No one in this scene means any harm. Aynur is honest, Timur is careful, the university is helpful. The problem lies in the way documents travel. The arrangement we inherited from the paper world does three things badly at once. A copy does not prove that the original is genuine, because editing a file is far easier than forging a seal. Verification depends on the source answering; if the source is slow, speaks another language or does not answer at all, verification stops too. And every application produces yet another copy of the person's data: Timur needs only a few items from the diploma, yet he receives the whole document, and the identity card along with it.

1.2 Tamga's short answer

Let us follow the same application along the path Tamga Network has designed (Figure 1).

Aynur's university issues the diploma as a **digitally signed credential**, and this credential settles into a **wallet** on Aynur's phone, that is, an application that holds and presents credentials. This credential differs from an ordinary file: its contents are signed with the university's key, and it is bound to a key generated in the secure hardware of Aynur's phone. This binding prevents the credential from being copied to another phone and used there (Chapter 8).

When Timur's company asks Aynur for a credential, the company's site produces a **request**. The request is signed and carries who the company is, the purpose it is registered for and which fields it wants: say, "the title of the degree, the field of study and the year of graduation". Aynur's wallet first checks whether the company really is a registered verifier, then shows the request to Aynur: who is asking, why they are asking, which fields they want. Aynur approves with her PIN or fingerprint. Only these three fields leave her phone; her grade average, date of birth or identity number do not.

Within a few seconds Timur's verification software looks for the answers to four questions. Was the credential really signed, and has nothing changed since it was signed? Is the signer really a university, and is it authorised to issue diplomas; was it authorised on the day the credential was issued? Has the university since revoked this credential? Is the phone presenting the credential the phone it is bound to? None of these questions requires calling the university. The answer to the second question sits in a **signed trust list** that anyone can download and check, and the answer to the third sits in a **status list** that the university has published in advance (Chapters 6 and 12). Nor does the university learn to whom, or when, Aynur showed her diploma.

TECHNICAL DETAIL

The same scene in protocol terms

The table below shows the messages in the scene in order. Chapter 10 (presentation) and Chapter 11 (the verification pipeline) give the details; here we give only the skeleton.

1	`Timur → Aynur`	**Request.** The company's verifier produces a signed OpenID4VP request; the request reaches Aynur as a QR code or a link.	$\text{client identifier} = \text{x509_hash}$
2	`Aynur's wallet`	**Check and consent.** The wallet checks the verifier's entry in the trust list and its registration certificate, shows the requested fields and obtains consent.	$\text{no registration certificate} \Rightarrow \text{reject}$
3	`Aynur → Timur`	**Response.** The wallet sends, encrypted, only the approved fields and a device signature bound to this request.	$\text{vp_token} = \text{SD-JWT VC} + \text{disclosed fields} + \text{device signature}$
4	`Timur's verifier`	**Verification pipeline.** Signature, credential type, trust list, revocation status and policy are checked in order.	$\text{result} \in \{\text{accept}, \text{reject}, \text{could not be verified}\}$

Each term in the table is explained in the chapter where it first appears: OpenID4VP [31] in Chapters 3.4 and 10, the registration certificate in Chapter 7.5, SD-JWT VC [16] in Chapter 8, and the three-valued result in Chapter 11.

It should be said plainly that this scene describes a design. Tamga Network's structure has a place for each country's own trust list, but today only the Türkiye list is active. A slot has been reserved in the lists for Azerbaijan; this is not the announcement of an agreement or of negotiations, only an empty slot in which a state can publish its own list once it joins. For Aynur's university in Baku to issue credentials along this path, that slot must be filled (Chapter 6.2). In the Türkiye list, too, at the time this edition was prepared the only active issuer was the network's provisional identity service (Chapter 14); institutional credentials will be issued along the same path as the first institutions join. The whole flow can be tried today with sample institutions in the sandbox, that is, a test network kept entirely separate from the real network (Chapter 17). Which functions work today is shown one by one in Chapter 22.

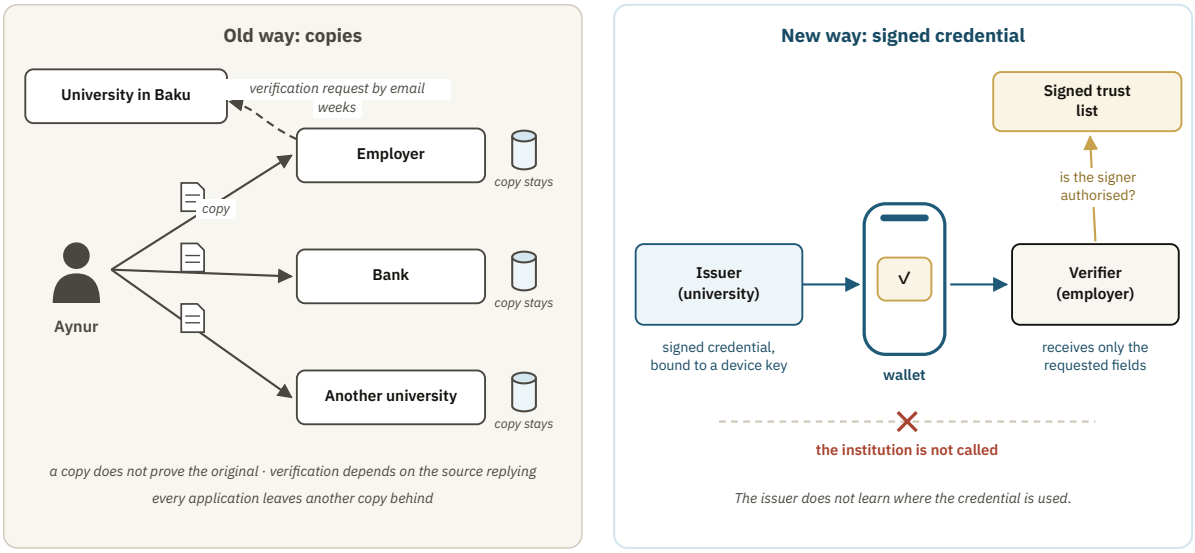


Figure 1. The old way and the new way: a chain of copies versus verification without asking the source

1.3 Contribution and plan of this document

We described Tamga Network earlier in a short whitepaper; this extended edition replaces it. The manifesto [62] and the developer documentation stand alongside it. This edition was written to answer three questions together and in detail.

The first question is **how it works**. We describe every step, from the issuance of a credential to its verification, from its revocation to its life in the wallet, without assuming any prior knowledge. We do not skip technical detail, but we place it in separate boxes; a reader who skips the boxes can still follow the text. The second question is **why it was chosen this way**. Every important decision of the network is bound to a decision record, and these records state not only what was chosen but also which options were set aside and why. Throughout the document, when we describe a choice we give its decision record and its alternatives together. The third question is **where it is going**. We separate what works today, what has been decided but is not yet live, and what is still research; we give conditions instead of a timetable.

The document consists of six parts. **Part I** (Chapters 1–4) describes the problem, the European Union's answer to it and Tamga's design principles. **Part II** (Chapters 5–8) builds the structure of trust: roles, trust lists, institution certificates and credential formats. **Part III** (Chapters 9–12) follows the flows: issuance, presentation, verification and revocation. **Part IV** (Chapters 13–16) moves to the person's side: wallet rules, the provisional identity service, privacy engineering and the security model. **Part V** (Chapters 17–20) covers the ecosystem and governance: the sandbox and open packages, sovereignty and handover, why there is no shared ledger today, and the relationship with the EU. **Part VI** (Chapters 21–24) brings the decisions together and gives the roadmap and the open questions. The appendices contain the glossary, the decision index, the standards index and the index of the document set.

The network that publishes this document also publishes a series of articles. For readers who want to explore a concept such as selective disclosure, unlinkability, trust lists or revocation in full depth, we point in the text to the relevant article of the series; here we explain each concept only as far as is needed to understand Tamga.

1.4 The name: tamga

The Turkic tribes of Central Asia struck marks called *tamga* on their herds, their belongings and on rocks. A tamga on a horse's croup told even someone who did not know the owner which tribe the

horse belonged to. The first article of the series describes the idea this mark carries in detail: a sign that everyone in a community recognises gives you reliable information about someone you do not know.

A verifiable digital credential is the modern counterpart of this idea, but it departs from it in two respects. First, the ancient tamga could be forged, whereas a digital signature cannot be produced without the signer's private key. Second, recognising a tamga required knowing it beforehand; in the digital world there is a signed list that says which mark belongs to whom, and this list is open to everyone. The name of the network brings these two ideas together: a seal that anyone can recognise, and a record that anyone can check, saying to whom that seal belongs.

2 Problem Space and Requirements

2.1 The cost of the copy economy

The problem in Aynur's application is not one person's misfortune; it is the ordinary outcome of an arrangement in which documents circulate as copies. No one sees the cost of this arrangement on a single invoice, but everyone pays a part of it. In this section we describe the cost in terms of who pays for what, and we give no figures, because giving a reliable and comparable number is beyond the scope of this document and we make it a principle not to write unsourced statistics.

The first cost is **forgery**. A scanned copy of a diploma can be altered in a few minutes with an image-editing program. The party receiving the copy cannot notice this unless it sees the original. The easier forgery is, the less trust is placed in the honest applicant: even if Timur believes that Aynur's diploma is genuine, he cannot prove it.

The second cost is **repeated verification**. Aynur's diploma is verified separately by an employer, a bank, a master's programme and a scholarship application. Each institution asks the same question from scratch and lives with the same uncertainty. There is no infrastructure in which verification is done once and everyone can benefit from it.

The third cost is **the separation of data from its owner**. Every application leaves a copy of the person's data on a server the person cannot see. The person does not know when this copy will be deleted, who will see it, or where it will end up in a data breach. To prove a document the person hands over the whole document, even though the other party usually needs only one or two items.

The fourth cost is **the burden on the source**. University student affairs offices answer e-mails, phone calls and official letters about their graduates' documents. The more of this work there is, the later the source answers; the later the answer, the greater the pressure to trust the copy.

2.2 Trust stopped at the border

These costs multiply when a border is crossed. The Turkic world shares a language family, a culture and a long history; students, workers and families move between these countries more and more. Yet today there is no short way to trust an institution of one country in another. How is an employer in Istanbul to know that a university in Baku really is a university? How is a hospital in Tashkent to find out whether a professional licence issued in Kazakhstan is still valid?

Today these questions are mostly answered with paper and intermediaries: translations, notarisations, chains of legalisation, correspondence from institution to institution. Each intermediary adds a delay and a cost, but none of them answers the real question, "is the institution that signed this document really an authorised institution?", mathematically. Tamga's Trust Framework writes its vision around this gap: a shared trust infrastructure in which the member and observer states of the Organization of Turkic States, their institutions and their citizens can verify one another's credentials without asking the source (FW-TF-0001 §1.1). This sentence is a goal; today no state has joined the

network, and this document announces no agreement or negotiations with any state. In describing the problem space we use country names to make the everyday face of the problem concrete.

2.3 The second problem: privacy

Replacing the copy with a signed digital credential solves the first problem, but if it is not designed carefully it creates a new one. A digital verification can **leave traces** in a way paper never could. There are four kinds of trace, and each calls for a separate design measure.

First, if the verifier asks the issuer at every verification, the issuing institution learns where and when the person used their credential. This is the problem known in the digital identity literature as "phoning home". Second, a verifier may ask for more than it needs: a site that wants to verify your age may collect your date of birth, your name and your address together. Third, if different verifiers combine what they receive, the person can be matched as the same person across visits that were supposed to be unrelated; this matching becomes easier if the same credential is shown each time with the same signature and the same identifier. Fourth, if shared records (lists, logs, a possible ledger) carry personal data or credential hashes, these records turn into a tracking tool that anyone can read.

These four traces are the subject of the series' articles on selective disclosure and unlinkability [68, 70]. Tamga's main framework document lists seven measures against them (FW-ARF-0001 §7.2): no personal data in shared records, a separate copy for each verifier and a pseudonym per site, zero-knowledge proofs, status lists published at fixed intervals, consent at every presentation together with an over-asking warning, no retention of images in identity verification, and publication of usage statistics only in groups of at least fifty. Chapter 15 describes them one by one. Here we stress only this: privacy cannot be a feature added afterwards. Which information goes into which record is a decision the architecture makes from day one.

2.4 The question of sovereignty

As the world moves to portable digital credentials, a country has roughly two paths before it. The first is to import this transformation: to use another country's or a company's infrastructure, rules and keys. The second is to build its own infrastructure on the same open standards and keep its keys in its own hands. Tamga chooses the second path and sums it up in its manifesto as "the same standards, our own network".

But saying "our own network" does not mean wanting a single authority. In a network that several states will join, the real question is who decides what. Tamga's governance decision asks this question with a simple example: why should a state wait for another state's vote when it registers its own university as an issuer? (ADR-0002). It should not. In the European Union, too, each member state publishes its own trust list independently, and no state votes on which institutions another state puts on its list. Tamga follows this precedent: each state is the only writer of its own registry, cross-border recognition is each state's own decision, and a state leaving the network does not invalidate its citizens' credentials. The details of these principles are in Chapter 18.

The question of sovereignty also has a face that looks at the present. Since no state has joined the network today, the roles that belong to a state (operating the trust list, registering institutions, holding the root certificate) are carried out on the state's behalf by the network's provisional operator. This may appear to contradict the principle of sovereignty; that is why the way each provisional role will be handed over is written down from the start, and the requirement that no credential, record or identifier changes at handover becomes a condition of the design (Chapter 4.1, principle P4).

2.5 Requirements

What has been said so far can be turned into twelve requirements that a trust network must meet. Table 3 lists them and shows where in this document each one is met. The rest of the document returns to this table often; when we describe a design choice, we say which requirement it meets.

Table 3. Requirements and the chapters where they are met.

#	Requirement	Why	Where it is met
G1	Verification without asking the source	The burden and delay of the source; "phoning home"	6, 11, 12
G2	Selective disclosure	The verifier should see only what it needs	8, 10
G3	Unlinkability	Verifiers should not be able to tell one another about the person	9.5, 13, 15
G4	Shared records without personal data	Lists and logs should not turn into tracking tools	6, 12, 15.5, 19
G5	Device-bound credential	A credential should not be usable on someone else's phone	8.2, 13
G6	Publishing revocation without tracking	Revocation should not reveal where the person was verified	12
G7	State sovereignty	Each state should be the only writer of its own registry	4.1, 18
G8	No single-operator assumption, and transferability	Provisional roles should be transferable; identifiers should not change at handover	4.4, 6.7, 18.4
G9	Interoperability with EU standards	Being able to work with wallets and verifiers that speak the same language	3, 20
G10	Open code and no lock-in	No institution should depend on a single vendor	5.3, 17
G11	Distinguishing "could not be verified" from "invalid"	An outage should not make an honest credential look forged	11.4
G12	Test network and proof of conformance	Participants should be able to try things before entering the real network; conformance should be demonstrable	16.5, 17, 20.5

We want to draw attention to one feature of the table. Some of the requirements are in tension with one another. Selective disclosure and unlinkability (G2, G3) ask the person to leave as few traces as possible; yet for a verifier to be able to check a credential, the credential must be signed and revocable, that is, it must carry a structure that is traceable somewhere (G1, G6). Sovereignty (G7) asks every state to set its own rules; interoperability (G9) asks everyone to speak with the same rules. A large part of Tamga's design describes how these tensions are balanced. Figure 2 shows the stakeholders and the main tensions between them together.

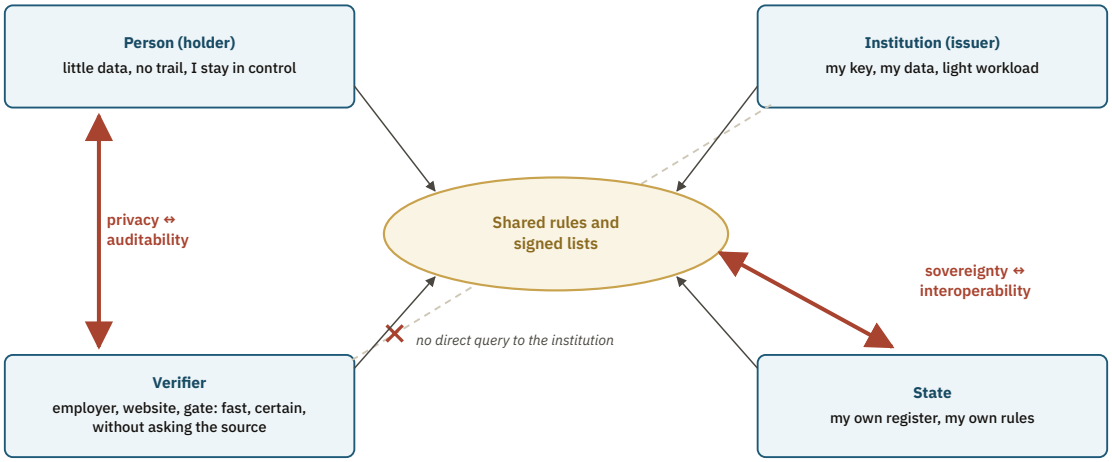


Figure 2. Stakeholders and tensions

3 Background: eIDAS 2.0, the EUDI ARF and Open Standards

Tamga Network was not designed in a vacuum. Its technical layer rests on the digital identity framework the European Union has built over the last decade. This chapter describes that framework as far as is needed to understand Tamga. For readers who want EU law in full detail, the series' article on eIDAS 2.0 [76] is a separate resource.

3.1 From eIDAS to eIDAS 2.0

The European Union's regulation on electronic identification and trust services, **eIDAS** for short, was adopted in 2014 as Regulation 910/2014 [1]. The regulation stood on two pillars. The first pillar was electronic identification: if a member state notified its electronic identification scheme, the public services of the other member states had to recognise it. The second pillar was trust services: electronic signatures, electronic seals, time stamps and the supervision of the bodies that provide them. The **trust lists** on which Tamga's trust model rests are a product of this second pillar: each member state publishes, in a signed list, the qualified trust service providers it supervises.

The electronic identification pillar did not reach the expected uptake. People did not carry a credential; at every login they were redirected to their own country's identification system. This is the model we called the federation era in the first article of the series [67]. In 2021 the Commission proposed amending the regulation and, on the same day, called on the member states to work on a common technical framework [3]. The amendment was adopted as **Regulation 2024/1183** of 11 April 2024 and entered into force on 20 May 2024. This text is today known as **eIDAS 2.0**.

The essence of eIDAS 2.0 is a transition: from a model in which the person is redirected to an identity provider every time, to a model in which the person carries credentials in their own wallet. The regulation obliges every member state to offer its citizens at least one **European Digital Identity Wallet** (EUDI Wallet). The obligation lies with the state; for people, using the wallet is voluntary and free of charge. The regulation also provides that institutions requesting data from the wallet must register first, that wallets must be certified by independent bodies, and that public bodies and certain private-sector organisations must accept the wallet.

The regulation itself sets out principles, roles and obligations; but it does not write the technical rules needed for a French wallet to talk to a German bank. These rules are found in the **implementing regulations** the Commission adopts (*Commission Implementing Regulation*, CIR). The first five implementing regulations concerning the wallet (2024/2977–2982 [5]) were adopted on 28 November

2024 and entered into force on 24 December 2024; the 24-month period the regulation provides for the wallet started running from that date. In May 2025 a second package that also covers the registration of relying parties (2025/846–849 [6]) was published, and in July 2026 amending regulations updating the referenced standards (2026/1730 [7], 2026/1731, 2026/1735) followed. An implementing regulation usually does not copy a standard; it refers to it. That is why the binding technical rule in the EU is often a specific version of the standard the regulation refers to.

3.2 Credential types: PID, EAA, QEAA, PuB-EAA

eIDAS 2.0 divides the credentials carried in the wallet into two broad groups. The first group is **person identification data** (*Person Identification Data*, **PID**): data such as first name, family name, date of birth and nationality that establish a person's identity. Only the state, or a body the state has authorised, can issue PID, and it forms the foundation of the wallet. The second group is **electronic attestations of attributes** (*Electronic Attestation of Attributes*, **EAA**): a diploma, a student certificate, a professional licence, a membership card, a ticket; in short, every credential other than PID.

The regulation further divides EAAs into three according to who issues them and what assurance they carry. A **qualified electronic attestation of attributes** (QEAA), issued by a qualified trust service provider, has the same legal effect as its paper counterpart. An **attestation issued by a public body** (PuB-EAA), issued by a public body responsible for an authentic source or by a body designated on its behalf, is a separate class, and it too has the same legal effect as its paper counterpart (Article 45b(2)). Anyone outside these, such as a university, a ticket seller or a sports club, can issue a **non-qualified attestation of attributes**. The distinction determines the legal effect; the technical format is usually the same.

The first rule in Tamga's relationship with these concepts is that the network **does not issue PID**. The main framework document treats PID issuance as out of scope and reserves this role for the state (FW-ARF-0001 §1.7). The trust list has a place for PID providers, but today that place is empty. Because a credential that verifies a person's identity is still needed, the network runs a **provisional identity credential provider** until the state's PID provider is designated; the credential this service issues is not PID but a non-qualified EAA, and it gives way to the state's PID when that arrives (ADR-0011, ADR-0022; Chapter 14). Table 4 places the four concepts and their Tamga counterparts side by side.

Table 4. EU credential concepts and their counterparts in Tamga.

Concept	Who issues it (EU)	Assurance and legal effect	Counterpart in Tamga
PID	The state or a body the state has authorised	Highest assurance; the foundation of the wallet	Not issued; a slot is reserved in the list and is empty. The provisional identity service does not stand in for PID
EAA (non-qualified)	Any institution	Legal effect under general rules	Institutional credential types (student certificate, diploma, ticket) and the provisional identity credential
QEAA	Qualified trust service provider	Same legal effect as its paper counterpart	None today; "qualified" requires independent assessment and supervision (ADR-0022)
PuB-EAA	Public body responsible for an authentic source	Rests on a public source	The institution classes include a place for the public class (PUB); today there is no public-body issuer

3.3 The ARF's roles and trust lists

Following the Commission's 2021 call, experts from the member states and the Commission began to write the technical framework of the wallet ecosystem together. This framework is called the **Architecture and Reference Framework** (**ARF** [11]). The ARF is not a binding legal text; it is a technical

document developed in the open and updated regularly. But the implementing regulations build on the work in the ARF; in practice, the ARF shows in advance what will become binding in the next regulation. At the time this edition was prepared, the current version of the ARF was 3.0.0, dated 23 July 2026.

One of the ARF's most lasting contributions is a **set of roles**. What each role does, and to whom it is accountable, is clearly defined:

- The **Wallet Provider** offers the wallet application and produces signed statements proving that the wallet is a genuine, secure wallet.
- The **PID provider** issues person identification data; **attestation providers** issue the other credentials.
- The **Relying Party**, that is, the verifier, requests credentials from the wallet. An **intermediary** acting on behalf of a relying party is also a kind of this role.
- The **Registrar** registers relying parties and which data they may request for which purpose.
- The **Access Certificate Authority** issues relying parties the certificates with which they identify themselves to the wallet; the **registration certificate provider** produces the signed document that carries the registered scope.
- The **trust list provider** publishes in signed lists who has taken on these roles.

Above all these roles stands the trust list architecture that has been in operation since the first eIDAS regulation. Each member state signs and publishes its own **national trust list** the Commission publishes a **list of lists** (*List of Trusted Lists*, LOTL) showing the addresses and signers of these lists. With eIDAS 2.0 this architecture extends to the new roles of the wallet ecosystem: which bodies are wallet providers, PID providers or access certificate authorities is also notified through similar lists.

One consequence of this arrangement is that verification is **two-way**. While the verifier checks the credential, the wallet also checks the verifier: is the body that signed the request really registered, and are the fields it asks for within the scope of its registration? In the scene in Chapter 1.2, Aynur's wallet checking Timur's company is an application of this principle. Figure 3 shows the roles in the EU's terms.

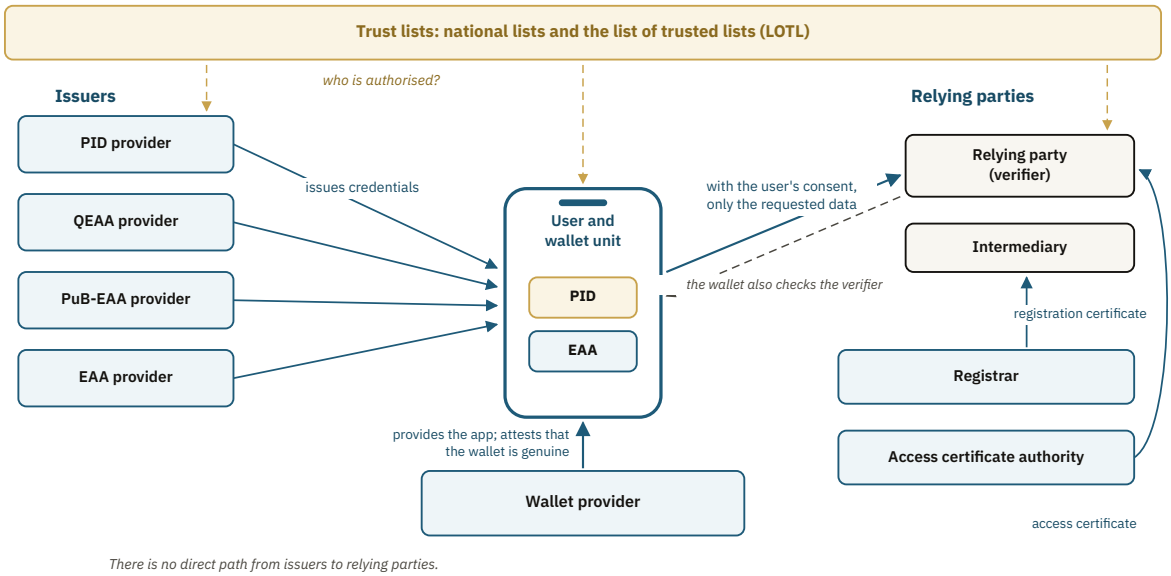


Figure 3. Roles in the EUDI ecosystem (in EU terms, simplified)

3.4 Map of technical standards

Instead of tying itself to a single technology, the ARF selects a set of mature standards written by different standards bodies. The EU does not write these standards; bodies such as the IETF, ISO, the OpenID Foundation, ETSI and the W3C do. What the EU does is choose among these standards and define **profiles** that narrow their options. Tamga uses this choice and these profiles as they are. Table 5 lists the standards by layer; how each is used in Tamga is described in the relevant chapter. Figure 4 shows the same standards as layers.

Table 5. The main standards Tamga relies on.

Layer	Standard	Author	What it does	In this document
Credential format	SD-JWT (RFC 9901) and SD-JWT VC (IETF draft)	IETF	Signed JSON credential whose fields can be hidden one by one	Chapter 8
Credential format	ISO/IEC 18013-5 mdoc	ISO/IEC	Binary (CBOR) format developed for the mobile driving licence; proximity	Chapters 8.3, 10.8
Issuance	OpenID4VCI 1.0	OpenID Foundation	An institution issuing a credential to a wallet	Chapter 9
Presentation	OpenID4VP 1.0 and the query language DCQL	OpenID Foundation	A verifier requesting a credential from a wallet	Chapter 10
Profile	HAIP 1.0	OpenID Foundation	Profile narrowing the OpenID4VC options for high assurance	Chapters 9, 10
Browser	Digital Credentials API; ISO/IEC 18013-7	W3C; ISO/IEC	A website requesting a credential through the browser	Chapter 10.6
Revocation	Token Status List (IETF draft)	IETF	Finding out whether a credential has been revoked without asking the issuer	Chapter 12
Trust	ETSI TS 119 612 and TS 119 602	ETSI	Trust lists and lists of trusted entities	Chapter 6
Institution identity	X.509 (RFC 5280); ETSI TS 119 412-6, TS 119 411-8, TS 119 475	IETF; ETSI	Profiles for institution, verifier and registration certificates	Chapter 7
Identity proofing	ETSI TS 119 461	ETSI	Policy and security requirements for remote identity proofing	Chapter 14

The word “draft” in the table indicates the maturity stage of the standard. SD-JWT itself was published in 2025 as RFC 9901 [15]; SD-JWT VC [16] and Token Status List [17], which build on it, are at the final stage in the IETF. In its implementing regulations the EU refers to specific versions of these drafts, and Tamga follows those versions. OpenID4VP 1.0 [31] was published as a final version in July 2025, OpenID4VCI 1.0 [30] in September 2025 and HAIP 1.0 [32] in December 2025.

TECHNICAL DETAIL

What does a “profile” of a standard mean?

A general-purpose standard leaves options open in many places to serve different use cases: several signature algorithms, several client identifier formats, several ways of binding keys. An abundance of options gives flexibility but makes interoperability harder. If wallet A implements one option and verifier B another, both conform to the standard, yet they do not understand each other. A **profile** is a document that selects a subset of these options and makes it mandatory. HAIP 1.0 is the profile of OpenID4VCI and OpenID4VP for uses that require high assurance. The record that settles Tamga’s conformance to this profile (ADR-0034) gives two examples: in a signed request the verifier uses as its client identifier only the hash of its own access certificate (`x509_hash`), and the wallet accepts only that; and the `sub` value in the attestation the wallet receives from its provider is shared by all installations that use the same wallet solution. The rationale for the second rule is an explicit provision of HAIP, but the rule also has a privacy consequence: the “who” field of the attestation does not carry a value specific to a single phone, only the name of the wallet solution.

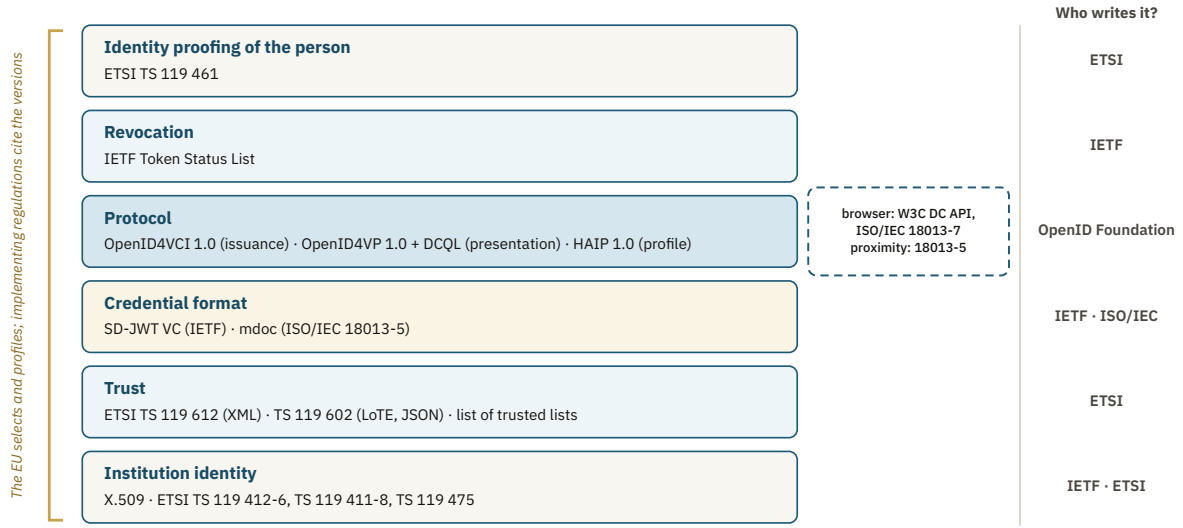


Figure 4. Layers of standards

3.5 Looking from outside the EU

For someone outside the EU who uses these standards, the first question is what they may call themselves. “EUDI Wallet”, or European Digital Identity Wallet, is not a technical definition but **a legal title**: it describes a wallet that an EU member state provides or recognises and that is certified under EU rules. A wallet from an organisation outside the EU cannot take this title, nor can it use the EU’s wallet trust mark (FW-ARF-0001 §1.4). The expression Tamga uses in public texts is therefore “EU-compatible”: using the same credential formats, the same protocols and the same trust model, and demonstrating this with tests.

The second question is whether an EU-compatible credential will be valid in the EU. The answer to this question lies in the domain of law, not technology, and it is not in the network’s hands. The legal note added to Tamga’s positioning decision says so plainly (ADR-0035): Article 5f of the regulation, which places an obligation on the public and private sectors to accept wallets, is not a route for recognising a wallet or list from outside the EU. The explicit basis for non-EU countries is Article 14, which provides for an agreement between the Union and that country concerning trust services, and the parties to such an agreement are states. The network’s role is technical preparation: lists in ETSI format, certificates with ETSI profiles and transferable state roles. In the short term an EU verifier can accept Tamga credentials only of its own accord, by adding Tamga’s trust list to its own trust sources;

this is not legal recognition and is not described as such. The question of recognition as a whole is in Chapter 20.

4 Design Principles and Positioning

A short way to understand an architecture is to look at the place where its builders say what they will never do. Tamga's main framework document gathers these rules into seven principles (FW-ARF-0001 §1.6). This chapter first describes these principles, then how the network positions itself, what it does not do and by whose hand it is operated today.

4.1 Seven principles

P1. Each state is the only writer of its own national registries. No other state votes on which institutions a state registers as issuers. Membership of the network is decided, once the council is established, by a two-thirds vote of the member states; cross-border recognition, on the other hand, is each state's unilateral decision. Why? Because no state enters a structure in which its own internal institutional decisions depend on others' votes, or in which its citizens' credentials would lose their value if it were one day removed from the network (ADR-0002). A guarantee of sovereignty is a precondition for participation.

P2. No shared record contains personal data. There is no personal data in the trust list, the anchor log, a possible shared ledger or the logs; neither the content of a credential nor a hash of it. Why not even a hash? Because to someone who knows the credential, a hash is as identifying as the credential itself: a person holding a diploma can compute its hash and search for it in a public record. The only reliable way to keep shared records from turning into tracking tools is to put no personal information in them at all.

P3. The technical layer is the same as the EU standards. Every Tamga-specific addition is made through an extension point of the standard and does not break standard clients. The value of interoperability comes from no one having to write a special adaptation. An EU-compatible wallet should be able to receive a credential from a Tamga institution, and a Tamga verifier should be able to process a credential coming from an EU-compatible wallet.

P4. No identifier, role or structure assumes a single operator. Every state role the network takes on provisionally today is designed to be transferable. Why? Because if a structure is built around a single operator, everything has to be rewritten on the day of handover: institution identities change, credentials become invalid, wallets are updated. In Tamga a handover changes only a list's operator field and its signer; the identities of institutions, the credential types and the credentials already issued stay the same (Chapters 6.7, 18.4).

P5. A shared ledger is a choice of signers, not a choice of storage. Today trust comes from signed lists. A shared ledger is set up when there are at least two independent operators. Why? Because a four-node chain run by a single operator produces no more trust than a list signed by the same operator (ADR-0009). What makes a ledger valuable is that its records are kept under the joint signature of parties independent of one another. That is why in Tamga the code for the chain has been written and tested but is not in production and is switched off; it will not be switched on without a second independent operator, and when it is, it will carry only digests and fingerprints of the records in the signed lists (ADR-0051, ADR-0074; Chapter 19).

P6. Every credential is bound to a key in the device's secure area. A credential cannot be copied or transferred. A credential without such a binding can be shown by anyone who gets hold of it; someone who takes a diploma's file can act as if they were its owner. Without device binding, a digital credential continues to carry the weakness of a paper copy (ADR-0006; Chapter 8.2).

P7. Every power that cannot be limited by code is limited by policy, by a measurable handover threshold and by a transparency report. Powers such as hosting, domain names, record keeping and statistics cannot be blocked by code, but they can be abused. The Trust Framework calls this principle "soft power is limited too" (FW-TF-0001 §1.2, G-B). Why? Because a network's neutrality is tested not only by the rules it writes but also by the powers of the operator that fall outside the rules. For example, if the share of hosted issuers exceeds a certain threshold, the matter goes onto the governance agenda, and the transparency report is published every three months (Chapter 18.5).

The Trust Framework adds one more governance-specific rule to these seven principles and calls it "registration is not authorisation" (FW-TF-0001 §1.2, G-A). Registering with the network does not give an institution the authority to issue credentials; a university's authority to issue diplomas comes from outside the network, from its own legislation. The network holds only the scope within the network, that is, which credential types the institution may issue and with which fields. Table 6 links the principles to the requirements in Chapter 2.5 and to the chapters that set them out in detail.

Table 6. Principles, the requirements they meet and the chapters with the details.

Principle	Essence	Requirement	Details
P1	Each state the only writer of its own registry	G7	6.2, 18.1
P2	No personal data in shared records	G4, G6	6, 12.4, 15.5, 19.3
P3	Technical layer the same as the EU standards	G9, G10	3, 8–10, 20
P4	No single-operator assumption, transferable roles	G8	6.7, 7.2, 18.4
P5	Ledger a choice of signers; at least two independent operators	G8, G4	6.4, 19
P6	Every credential bound to a device key	G5	8.2, 13
P7	Soft power limited by policy and thresholds	G8	18.5

4.2 Three layers

Tamga's positioning decision (ADR-0035) divides the structure into three layers that sit on top of one another and requires each layer to carry value on its own (Figure 5).

Base: EU compatibility. Credentials, protocols and trust lists follow EU standards. Even if the network never grew and not a single state joined, this layer would still carry value for institutions and wallets: an institution can issue EU-compatible credentials with Tamga's open packages, and a verifier can verify EU-compatible credentials.

Tamga Network: a light trust federation. The network's real job is to bring countries' trust lists together and make them known to one another. "Federation" here describes the model in which each list is operated by its own owner and shown in a shared list of lists. The network recognises every wallet provider that follows the published rules; it does not pick wallets. Today the network operates the Türkiye list provisionally, on behalf of the state. When a state publishes its own list, the list of lists shows that list's address and signer. No heavy institution is set up from day one: when one or two states are willing to join, a council or foundation is established, the lists are handed over and the shared ledger arrives.

On top of the network. Wallets and service providers that follow the network's rules are in this layer. They are not considered part of the network; they are its participants or users. In the first decision this layer was defined as "products and services"; a structure in which the network itself offered services was being considered. The same decision record also noted that this carried a tension: in the EU model, the party that governs the list selling services counts as a conflict of interest. The next decision

removed this tension and settled that the network is only a network, and that commercial services are offered by companies outside the network under their own names (ADR-0037). The decision after that made it clear that wallets, too, are outside the network (ADR-0042; Chapter 5.4).

Why three layers? The decision record weighs three paths. The first was only an EU-compatible wallet and the services around it; this path is fast, but it does not build common ground for trust in the Turkic world and leaves nothing distinctive once state wallets arrive. The second was to set up a heavy, EU-like institution first; but setting up such an institution before any state joined would have been both premature and without foundation. The third path, the layered structure, combines the good sides of the first two: the base produces value immediately, the federation layer grows as states join, and when state lists arrive the value is not lost; on the contrary, the value of the federation increases.

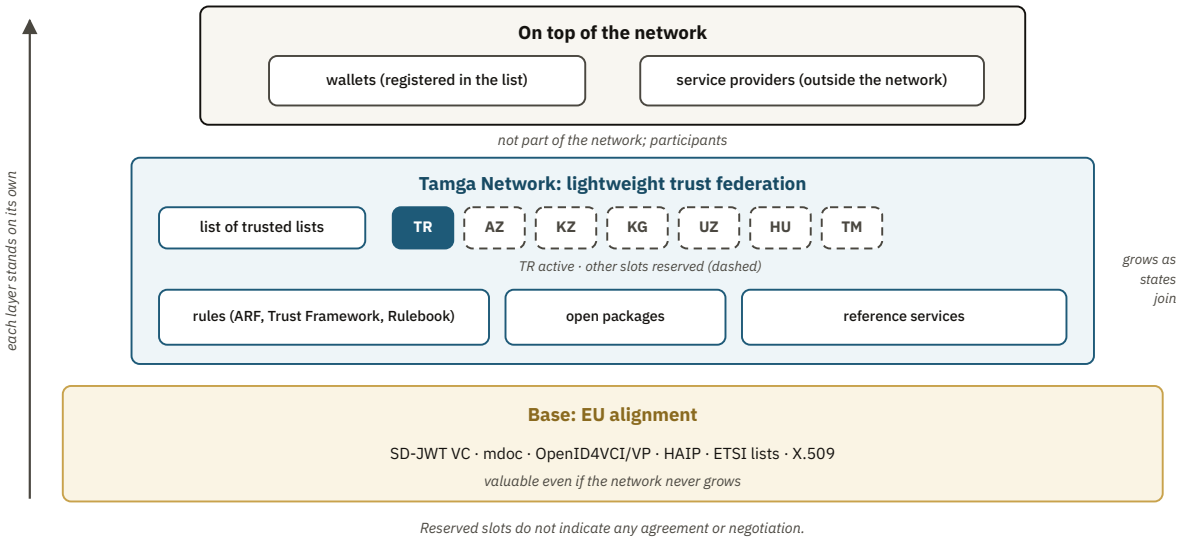


Figure 5. Tamga's three layers

4.3 What the network is not

One way to describe a structure is to say what it is not. Tamga Network's decisions explicitly list the jobs the network will not take on; these boundaries protect the network's neutrality and its transferability.

The network **does not sell products or services**. It writes the rules, publishes the trust lists, and runs the open code and the reference services needed for the network to function; none of these is sold. Commercial services such as integration, support or consulting are offered by companies outside the network under their own names, and the network's reference services and its registration process are open to all participants on the same terms (ADR-0037).

The network **does not operate wallets**. It does not operate the application, wallet provider, website or support service of any wallet; it recognises wallets only through their entries in the trust list (ADR-0042).

The network **does not issue PID**. This role is reserved for the state. The network's provisional identity service issues a provisional identity credential that is not PID (Chapters 3.2, 14).

The network **does not process payments or issue tokens**. In the network's early design, some places had been reserved for a value layer that could be built on top of a possible ledger. These places were made non-binding and remained as a suspended research direction; reopening them requires a decision by the governance body, an independent security review and a new decision record (ADR-0072). The main framework document also treats payments and value transfer as out of scope (FW-ARF-0001 §1.7).

The network **does not keep personal records**. People's credentials are read from the institutions' own systems and carried in the person's wallet; there is no personal data in the network's shared records (P2). The only narrow exception is the provisional identity service: this service is the data controller for the people whose identity it verifies, and it limits the data it keeps to short, defined periods (Chapter 14.7).

The main framework document's out-of-scope list also names the institutional wallet in which institutions are the holders of credentials, a second credential representation in the W3C VCDM [37] format, and qualified electronic signatures. These are not permanently excluded; each can be opened only by a separate decision.

4.4 A non-profit network, a foundation and provisional operation

Tamga Network is designed as a non-profit trust network, and its permanent home is a foundation. But a network, unlike a company, has no legal personality of its own, and the foundation has not yet been established. On the other hand, some tasks need a legal person already today: an organisation identifier to be written into the subject field of a certificate, the registration of a domain name, registration as a data controller under personal data legislation, and participation agreements.

This gap has been filled by a decision (ADR-0070). Until the foundation acquires legal personality, a **provisional operator** runs the network's own services, that is, list publication, the registrar role carried out on behalf of the state, the identity service, Tamga Verify, the websites and the domain names, "on behalf of Tamga Network". Every act that requires a legal person is carried out in its name and with this wording; participation agreements carry a succession clause providing for the transfer to the foundation. In the trust lists, on the other hand, the name of the list operator is always "Tamga Network", and its status is marked as provisional (`provisional`).

The options the decision weighed show why this design was chosen. Writing the company's name directly as the operator name in the lists was rejected, because ownership of the list belongs to the network and the list's identity would change at handover. Holding back every task that requires a legal person until the foundation is established was also rejected; the identity service, verifier registration and app store review needed a legal person already. Keeping the details separately in each record was rejected as well, because it would be scattered and impossible to audit. On the chosen path, the provisional operator's details come from a single configuration value, and the list publisher checks it before every publication; if the details are inconsistent, publication stops. Handover to the foundation changes only this value and the records and certificates tied to it; the name of the list operator, the identity of the root certificate, the credential type identifiers and the permanent identities of institutions do not change.

Even if the provisional operator has other products, each of them is a separate participant in the network and acquires no privilege. The network's principle on funding is short too: the network is non-profit, during the provisional period it charges no participant, that is, no issuer, verifier, wallet provider or person, and it is always free for people (ADR-0071; FW-TF-0001 §5.5). The relationship between funding and governance is in Chapter 18.7.

5 Roles and Components

Chapter 3 described the EU's set of roles. This chapter shows the same set from inside Tamga: who takes on each role today, who will take it on when a state joins, which service runs where, and in which direction information flows.

5.1 The set of roles

Tamga's set of roles is taken from the EU ARF [11] and begins with a rule: every country list reserves a place for each of these roles; even if the place stays empty, it exists (FW-ARF-0001 §3). In practice this means that when a state joins, no new field is added to the structure; an existing place is filled. Table 7 gives the roles together with who holds them today and who will hold them when a state joins.

Table 7. Roles: today and when a state joins.

Role (EU name)	What it does	Today	When a state joins
Trust list operator (*Trusted List Scheme Operator*)	Compiles, signs and publishes the country list	The network, provisionally, on behalf of the state	The national authority or a body it authorises
Registrar (*Registrar*)	Registers issuers, verifiers and wallet providers; grants no legal authority	The network, provisionally, on behalf of the state	The state's registrar
National root certificate authority	Root of the institution certificates	The network, provisionally; the root's identity does not change at handover	The state's root or an authorised certificate provider
Access and registration certificate provider	Issues access and registration certificates to verifiers	The network, provisionally	The state
PID provider	Issues person identification data at the highest assurance	**Empty** the network does not take on this role	The state
Provisional identity credential provider	Issues an identity credential through remote identity proofing while there is no PID provider	The network's identity service	The PID provider takes over
Issuer (*Attestation Provider*)	Issues attestations of attributes and revokes them when necessary	Institutions (such as universities, ticket sellers)	Institutions and public bodies
Authentic source (*Authentic Source*)	Holds the original record of the information	The institution's own record system	The same; public sources as well
Wallet provider (*Wallet Provider*)	Provides the wallet; signs wallet and key attestations	The organisations that provide wallets; the network does not operate one, it lists them	Every provider that follows the rules
Verifier (*Relying Party*)	Requests and verifies credentials; registered and limited in scope	Employer, website, gate	The same
Intermediary verifier (*Intermediary*)	Requests and verifies credentials on behalf of a verifier	Tamga Verify	The same
Holder (*Holder*)	Carries the credential and decides whom to show it to	Student, graduate, user	Citizen
Ledger operator	Operates a node of the shared ledger	**None**	At least two independent institutions

Three rows of the table deserve a separate explanation. The **PID provider** row is empty, and this is a deliberate gap: the network does not fill this role, which belongs to the state; it only holds its place. The **provisional identity credential provider** provisionally meets the need that this gap creates; the credential it issues is not PID, and it gives way to the state's PID provider once that is designated (ADR-0011). The **intermediary verifier** is a service that does the work on behalf of a verifier that does not want to run its own verification software; the wallet shows the person the name of the actual verifier. Tamga Verify, hosted by the network, is in this role (Chapter 11.5).

An institution can take on more than one role. A ticket seller, for example, is both the party that issues the ticket and the party that verifies it at the gate; it registers separately for each role and complies separately with the rules of each (FW-ROLE-0001 §1). One role that does not appear in the table

is the **auditor**. Today conformance is shown through self-declaration and open conformance tests; when states join, independent conformity assessment bodies and national accreditation will follow (FW-ROLE-0001 §10; Chapter 18.6).

TECHNICAL DETAIL

A country slot in the list of lists

The rule that roles "have a place even if empty" can be seen in every country entry in the list of lists. The example below is shortened from the source file of the network's list publisher; the values are illustrative, and in the published list the format is a signed JWS.

JSON Example: the Türkiye slot and a reserved slot in the list of lists (shortened)

```json
{
  "national_lists": [
    {
      "state_code": "TR",
      "status": "ACTIVE",
      "membership": "TDT_MEMBER",
      "list_url": "https://trust.tamga.network/tl-tr.jws",
      "operator": {
        "name": "Tamga Network",
        "status": "provisional",
        "on_behalf_of": "TR national authority (to be designated)"
      },
      "roles": {
        "registrar":        { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "tlso":             { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "access_ca":        { "status": "PROVISIONAL", "operated_by": "Tamga Network" },
        "national_root_ca": { "status": "ACTIVE", "operated_by": "Tamga Network (provisional)" },
        "pid_provider":     { "status": "RESERVED" }
      },
      "recognition": { "mode": "unilateral", "recognizes": ["TR"] }
    },
    { "state_code": "AZ", "status": "RESERVED", "membership": "TDT_MEMBER" },
    …
  ]
}
```

Three details stand out. The operator block (`operator`) says that the network operates this list provisionally on behalf of a national authority that has not yet been designated; during the list stage this field cannot be left empty (SPEC-TRUST-0001 §3, §8 TL1). The PID provider's place stands as `RESERVED` the network does not fill it (SPEC-TRUST-0001 §8, TL8). The recognition mode is `unilateral` , that is, one-sided: which countries' credentials a country recognises is its own decision. The Azerbaijan row, on the other hand, is only a reserved slot; it contains no list address, signer or role. Reserved slots of the same kind also exist for Kazakhstan, Kyrgyzstan and Uzbekistan (members of the Organization of Turkic States) and for Hungary and Turkmenistan (observers). These slots are not the announcement of an agreement or of negotiations with any state.

5.2 Rules of role separation

What a role cannot do matters as much as who holds it. Tamga's framework documents set three rules of separation.

The first rule is that **the institution's signing key stays with the institution**. The network does not hold an institution's signing key in any service it hosts; even if the issuance service runs on the network's server, the credential's signing key belongs to the institution (FW-ARF-0001 §3; FW-ROLE-0001 §1). This rule resolves the tension between the convenience of a hosted service and the institution's sovereignty. The decision record states how this is done (ADR-0057): the institution's key stays in its own hardware security module or with a trust service provider of its choice; the hosted service requests the signature through the Cloud Signature Consortium's [54] remote signing interface and sends the other side only the SHA-256 hash of the data to be signed. Neither the content of the credential nor personal data goes to the signing service. The returned signature is verified locally against the institution's certificate in the trust list; if it does not verify, the credential is not

issued. On the real network, reading the institution's key from a file on the service's server is rejected at configuration level. Status: the code and tests for remote signing are ready, but there is not yet an institution on the real network that uses it (**Planned** details in Chapter 7.6).

The second rule is that **registration does not count as authorisation**. The registrar registers; it does not approve (FW-TF-0001 §1.2, G-A). A university's authority to issue diplomas comes from higher education legislation, and a professional body's authority to issue credentials from its own statute; the network neither grants nor supervises this authority. What the network holds is the scope within the network: which credential types can this institution issue, and with which fields? This distinction keeps the network from behaving like a legal authority and leaves each state's own system of authorisation as it is.

Under the third rule, **the authentic source is at the institution**. The original record of the information in a credential, for example a student's programme or graduation date, stays in the institution's own record system. The hosted issuance service does not store this information; it reads it from the institution's query endpoint at the moment the credential is signed and discards it from memory once the credential has been issued (ADR-0020). The decision defines two paths. On the first, the institution creates an offer bound to the person's identity and sends the link itself; the person presents their identity in the wallet, and if the identity matches the offer, the credential is issued. On the second, the person chooses the institution in the wallet and presents their identity; the service queries the institution's endpoint with a signed request. On neither path does the network keep records of people. The alternative that was considered was to keep people's records in the network's institution console; this path was rejected, and the record register in the console remained only as a test source in the sandbox. The details of the flow are in Chapter 9.2.

5.3 Components and service addresses

The software components running behind the roles fall into two groups. One group is **open source libraries**: packages that read and write credential formats, verify trust lists, and issue and verify credentials. These are open to everyone under the Apache-2.0 licence, and an institution can build its own issuance or verification software with them. The other group is **hosted reference services**: the issuance service the network runs itself, the Institution Console, Tamga Verify, the identity service, the list publisher and the catalogue. The libraries are open, the hosted services are with the operator; but the rules are the same for both (FW-ARF-0001 §4.1). An institution is not obliged to use the hosted service.

Table 8 gives the services together with their addresses. At the time this edition was prepared, all the services in the table were live (**Live**), as were the test copies under `*.sandbox.tamga.network`.

Table 8. Components, their tasks and service addresses.

Component	Task	Address
Public website	Presentation of the network; root key fingerprints	`tamga.network` (`/trust-anchor`)
Framework documents	Tamga ARF and its annexes	`arf.tamga.network`
Developer documentation	Guides, concepts, specifications, decision records	`docs.tamga.network`
Trust list publisher	List of lists, country lists, anchor log, archive	`trust.tamga.network`
Credential type catalogue	Definitions and schemas of credential types, immutable files	`schemas.tamga.network`
Hosted issuance service	Issuance with OpenID4VCI on behalf of institutions, status list publication	`issuer.tamga.network/{institution}`

Component	Task	Address
Status lists	Credential status lists	`status.tamga.network`
Institution Console	Screen where institution staff manage credentials, records and keys	`console.tamga.network`
Tamga Verify	Hosted intermediary verifier	`verify.tamga.network`
Identity service	Provisional identity credential; pseudonym seed	`id.tamga.network`
Sandbox	Test copies of the same services running under a separate root	`*.sandbox.tamga.network`

A rule needs to be added beneath the table. **A domain name is the address of a service, not an identity** (FW-ARF-0001 §4.2). When an institution moves from the hosted service to a service on its own domain, only the address in its trust list entry changes; the institution's identity and the credentials it has issued do not. The institution's identity is derived from its certificate (Chapter 6.7). This rule protects two things at once. It frees the institution from dependence on the hosted service (G10), and it ensures that the eventual handover of the network's domain names to the foundation affects no credential (G8).

Figure 6 shows the components and the flows between them. The protocol names on the arrows are explained one by one in the following chapters.

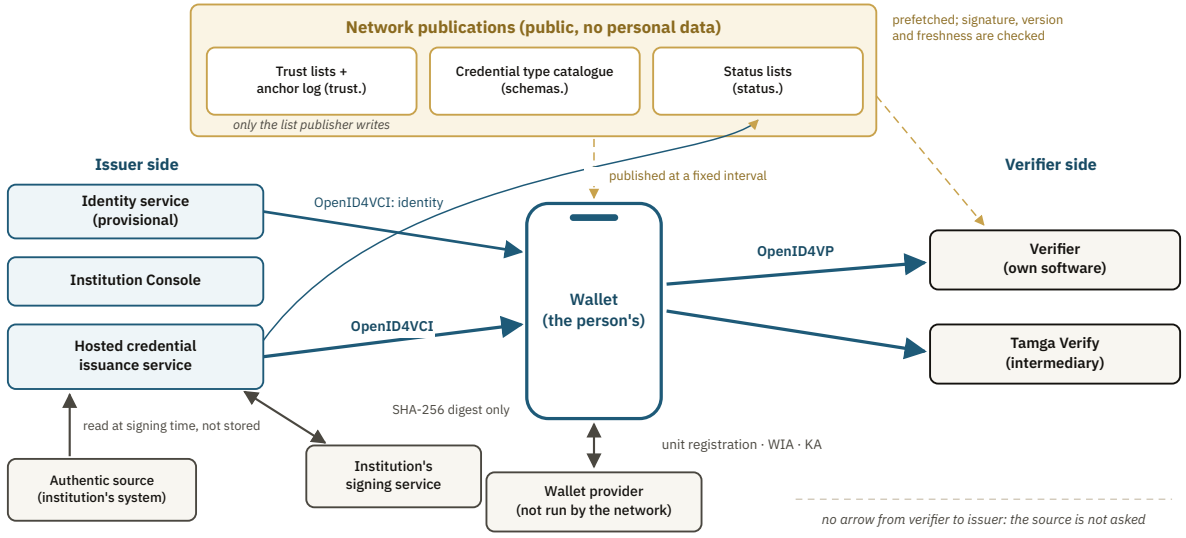


Figure 6. Components and data flow

5.4 The network and wallets

To an outside observer, a trust network's relationship with wallets is often the most confusing topic. Tamga's decision on it fits in a single sentence: the network does not operate wallets, **it lists wallets** (ADR-0042).

The network's relationship with wallets consists of three things. The first is rules: rules such as how a wallet keeps keys, what it shows on the consent screen and where it stores history are written in the specification and the framework documents (Chapter 13). The second is open packages: a wallet developer can use the network's wallet core package to receive credentials, run local checks and present credentials. The third is the **wallet provider entry** in the trust list. The `wallet_providers[]` field in the list of lists carries the identity, signing certificates and wallet solutions of every recognised wallet provider. Before issuing a credential, an issuer checks whether the attestation presented by

the wallet comes from a provider in this list; no credential is issued to the wallet of a provider that is not on the list (Chapter 9.3).

Why does the network not operate its own wallet? The decision record grounds this in the EU's separation of roles: in the EU structure each wallet is operated by the organisation that provides it, and the trust framework only lists wallet providers. If the network operated a wallet's provider itself, its neutrality would be compromised, and on the day of handover to the foundation a wallet's service would remain tied to the network. The other option considered was to set up a separate test environment for wallets; this too was rejected, because the same institutions, verifier and rules would have been set up twice. There is one sandbox and it belongs to the network: a wallet developer has their own provider registered in the sandbox list and tries their wallet there with the sample institutions, the identity service and the verifier. No wallet service runs on the network's domain names either.

The first wallet to enter the network's trust list is Tamga Wallet; it is developed as a separate product in its own repository, runs its provider service on its own domain, and entered the list by the same path, and under the same rules, as any other wallet would. The provider entry is active in the real network and sandbox lists (**Live** FW-ARF-0001 §2.8). The network's interfaces and documents do not single out any one wallet; from here on this document, too, refers to wallets generically.

Being listed also has a counterpart visible to the person. Because the trust mark the EU defines for wallets cannot be used outside the EU, the network defines a written indicator for the wallets on its list: "Listed on Tamga Network" (ADR-0049). The indicator has no logo; the EU stars, the EU colours and the words "trust mark" are not used. When the person taps the indicator, they see the provider's entry in the signed list; if the wallet unit is revoked or the provider leaves the list, the indicator is hidden (Chapter 13.6).

5.5 Direction rules

How information flows is as much a security and privacy decision as how the components connect to one another. The main framework document fixes this with four short rules (FW-ARF-0001 §4.5).

1. **Only the list publisher writes to the trust lists.** Issuance services cannot write to the list; they can only ask for an entry to be added to the anchor log. This rule ensures that even if an issuance service is compromised, the attacker cannot add itself to the list as an authorised institution.
2. **Readers do not use a list without checking it.** Verifiers and wallets use no list entry without checking its signature, its version chain and its freshness. The open packages implement these checks out of the box; all clients ask their trust questions through a single interface (ADR-0015; Chapter 6.6). In this way a rolled-back old version of a list, or an unsigned copy of it, cannot be accepted silently.
3. **The status list is not downloaded at every verification.** The verifier fetches status lists in advance and in bulk. This rule is the architectural answer to the "phoning home" problem in Chapter 2.3: when checking a credential, the verifier sends no request about that credential to the issuer or its server, so the issuing institution cannot learn which credential was verified when (Chapter 12.4).
4. **No Tamga service records IP addresses.** Logs also do not contain the values of credential fields or a credential's position in the status list. This rule is the application of P2 to service logs: a log must carry no trace sufficient to identify a person.

Read together, these four rules summarise the network's whole architecture. Trust comes from a single direction, from signed publications. The reading party checks everything itself. The source is not asked during verification. And the shared records do not know the person. The following chapters elaborate each part of this skeleton: Chapter 6 describes the trust lists and the anchor log, Chapter 7 the institution certificates, Chapter 8 the credential formats.

6 Trust Model: Signed Trust Lists and the Anchor Log

Timur is a recruiter at a company in Istanbul. An application lands on his desk; the applicant, Aynur, has sent her diploma not on paper but from her phone. Timur's software opens the credential and reports that the signature is valid. The first question that comes to Timur's mind, however, is not about the signature: "Is Example University, which made this signature, really a university, is it authorised to issue diplomas, and is it still active today?" This chapter describes how Tamga Network answers that question. At the centre of the answer are two structures: signed **trust lists** that anyone can download and check, and an **anchor log**, kept alongside these lists, that advances hour by hour. Today all trust in the network rests on these two structures; although the code for a shared ledger (chain) has been written and tested, it is not in production and is switched off, and it will not be switched on without a second independent operator (Chapter 19).

6.1 What a signature proves, what a list proves

A digital signature proves a single thing: the document was signed by the holder of a particular private key and has not changed since then. The software verifying the signature holds only a public key; the signature itself cannot say that this key belongs to "Example University". Nor does an attacker try to break the signature; the attacker tries to get the verifier to accept the attacker's own key as if it were the right one. That is why every trust infrastructure needs a second layer: a record that establishes the link between the key and the institution and says what that institution is authorised to do. The sixth article of the series [71] describes the history of this problem and its solution in the EU in detail; here we follow the path Tamga has chosen.

In Tamga this record is a signed list. The list says "the holder of this certificate is this institution; it has been authorised to issue these types since this date; its current status is this". The verifier does not call the institution; it has downloaded the list in advance. The arrangement is the same as the EU's trust list model (FW-ARF-0001 §6.1); the difference is that in Tamga the list is published today by the network, provisionally on behalf of the state, and the list says so explicitly.

6.2 The list of lists and the country lists

Trust sits in a two-tier arrangement of files (Figure 7). The published files are gathered in Table 9. At the top is the **list of lists** (`lotl`, *List of Trusted Lists*). This file shows the address of each country list, the keys authorised to sign that list and the country's recognition settings. The records shared at network level are here too: the network's common credential types and the catalogue address, the recognised wallet providers, the accepted zero-knowledge proof circuits and the category vocabulary. The field reserved for person identification data (PID) providers is empty; Tamga does not issue PID (SPEC-TRUST-0001 §3, TL8).

Below are the **country lists** (`tl-<cc>`). A country list carries that country's root certificates, its issuers (with their classes, assurance levels and the types they are authorised to issue), its registered verifiers and its national credential types (SPEC-TRUST-0001 §4). Each country slot holds a separate place for each of the roles in the EU architecture: list operator, registrar, person identification data provider, access certificate provider and national root certificate authority. Even if a role stays empty, its place exists.

Today only the Türkiye slot is active. Places have been reserved in the list of lists for the members of the Organization of Turkic States, Azerbaijan, Kazakhstan, Kyrgyzstan and Uzbekistan, and for the observers, Hungary and Turkmenistan; this is not the announcement of an agreement or of negotiations with any state. That is why the bachelor's diploma Aynur received in Baku cannot be verified through the network today; Azerbaijan's slot is filled when a state joins and publishes its own list. The `operator` field of the Türkiye list records that the operator is provisional (`status: "provisional"`) and on whose behalf it acts (`on_behalf_of`); this field cannot be left empty (TL1). Each list also states

`production` or `sandbox` in its `environment` field; a wallet connected to the real network does not load the sandbox list (ADR-0038).

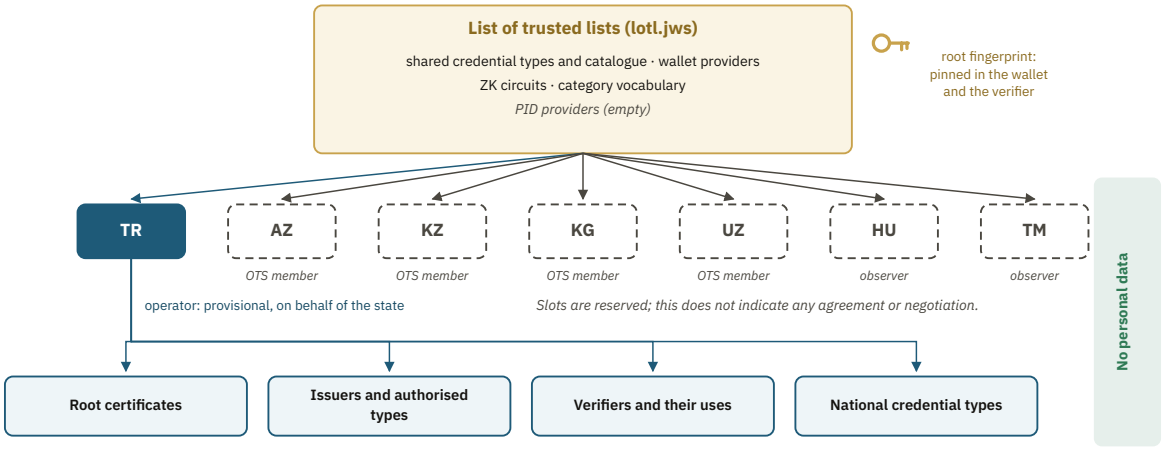


Figure 7. The list of lists, country lists and entries

Table 9. The main files published at `trust.tamga.network` (SPEC-TRUST-0001 §2).

File	Content	Status
`lotl.jws` (`lotl.json` readable copy)	list of lists: country slots and their signers, common types, wallet providers, ZK circuits	live
`tl-tr.jws` (`tl-tr.json`)	Türkiye: root certificate, issuers and their authorisations, verifiers and gate groups	live
`tl-<cc>.jws`	the other country slots; empty today, only reserved	reserved
`anchors.jsonl`	anchor log: each line signed separately, at least one line per hour	live
`keys/root-fingerprints.json`	fingerprints of the certificate that signs the list of lists and of the national root	live
`wrprc/`, `status/wrprc/`	registration certificates and their 1-bit status list (Chapter 7.5)	live
`zk/<circuit>`	ZK circuit files named in the list	live
`lote/<type>.jws`	ETSI TS 119 602 views (Chapter 6.8)	planned (generator ready, publication switched on by a setting)
`tl-<cc>.xml`, `tl-<cc>.sha2`	ETSI TS 119 612 XML view (Chapter 6.8)	live in the sandbox, planned on the real network
`archive/`	every past list version and the log archive; nothing is deleted	live
`CHANGELOG.md`	public change log	live

TECHNICAL DETAIL

What an issuer entry looks like

Every issuer entry in a country list carries a set of fixed fields: the institution's identity and certificate fingerprint, its class and assurance level, which credential types it is authorised for and over which

date range, the address root of its status lists and its status history. The EU's common registration data set (official name, identification number, address, contact, data protection authority) is in the same entry (ADR-0024). The example below is for the fictional Example University and is shortened. The `issuer_id` and the fingerprint were actually computed from a sample P-256 certificate generated for this document; the `schema_id` values were taken from the catalogue on the day of writing and verified by recomputing them. The values are illustrative.

JSON Example: a shortened issuer entry from tl-tr

```
{
  "issuer_id": "0xe41abbb087864814f3de55b27c9ce923537485bcc08e349c7c0b2209e8db1b60",
  "slug": "example-university",
  "legal_name": "Örnek Üniversitesi",
  "category": "EDUCATION",
  "assurance": "I2",
  "class": "EAA",
  "cert_fingerprint_sha256": "fb58ea8de393d34d2b73ce7672a08c3e2908028edbd5fce9a4c10fb4ad2577ce",
  "issuer_url": "https://issuer.sandbox.tamga.network/example-university",
  "status": "ACTIVE",
  "valid_from": "2026-09-01T00:00:00Z",
  "status_history": [
    { "status": "ACTIVE", "since": "2026-09-01T00:00:00Z", "reason": "initial-registration" }
  ],
  "schema_authorizations": [
    { "vct": "urn:tamga:edu:DiplomaCredential:1",
      "schema_id": "0x9d6d0e873ee0466cf1cdc8a8bd73f9435022635f0b6e46cd478e70f6e6aed26b",
      "allowed": true, "valid_from": "2026-09-01T00:00:00Z", "valid_until": null }
  ],
  "identifiers": [ { "scheme": "TR-VKN", "value": "…" } ],
  "delegate_keys": [ { "fingerprint_sha256": "…", "purpose": "status_list", "status": "ACTIVE" } ]
}
```

Authorisation is **time-windowed**: `schema_authorizations` carries a start and an optional end for each type. The verifier checks whether the institution was authorised for this type at the moment it issued the credential (`iat`). A diploma issued earlier by a university that has since closed therefore remains valid, while new issuance stops the moment the institution's status changes (SPEC-TRUST-0001 §4; Chapter 11.3).

6.3 List rules

Being signed is not enough; the reader must be able to be sure that the version it holds is the latest, genuine version. To this end the lists follow a few simple rules (FW-ARF-0001 §6.3; SPEC-TRUST-0001 §1, §8). Each list has a **version number**, and this number only increases. Each new version carries the SHA-256 hash of the previous version's signed file in the `previous_version_hash` field; the versions are thus linked to one another like a chain. The list **does not delete** entries: when an institution is suspended or withdrawn from the list, its entry stays in place, and only the change of status is appended to the `status_history`. Only in this way can old credentials be assessed against the date on which they were issued.

The lists have a **freshness schedule**. Each list carries the date of its next update (`next_update`), and this date is at most 90 days ahead; even if nothing changes, the list is re-signed within this period. A change, on the other hand, is published within 24 hours at the latest. A verification made with an expired or unreachable list produces neither "accept" nor "reject"; the result is "could not be verified" (TL5); for Timur, "this diploma is forged" and "I cannot check right now" are not the same thing (Chapter 11.4). The loader also stops at a format version it does not recognise, rather than silently misinterpreting it (TL6).

For the signatures of the list and the anchor log, the rules require **at least two rolling certificates**: a key change is announced at least 30 days in advance, and the new key is introduced by being signed with the old one (TL3). On the day of writing, a single signing certificate was active in the published lists; bringing the second certificate into service and moving the signing key into a hardware key store

are recorded in the specification as open work (SPEC-TRUST-0001, Open Issues 3). *Status: planned.* Every change is also written to a public change log.

TECHNICAL DETAIL

The version chain and catching a rollback

A verifier remembers, for each list, the latest version it has accepted and the hash of that version. An incoming version is assessed according to three rules (the `TrustSource` loader in the packages, TL2):

$$h_n = \text{SHA-256}(\text{list}_n\ \text{.jws})$$

$$\text{prev}(\text{list}_{n+1}) = h_n$$

$$v_{\text{incoming}} < v_{\text{known}} \Rightarrow \text{reject (rollback)}$$

$$v_{\text{incoming}} = v_{\text{known}} \ \text{ and } \ h_{\text{incoming}} \neq h_{\text{known}} \Rightarrow \text{reject (same version, different content)}$$

The hash is written in the list as a hexadecimal string prefixed with `sha256:`. If an attacker presents an old list to a verifier, for example the version in which an institution had not yet been suspended, the list is rejected because its version number lags behind. Changing the version number breaks the signature, and re-signing requires the signing key of the list of lists.

6.4 The anchor log

There are two things in the network that change far more often than the lists: institutions' status lists, which are republished every few minutes (Chapter 12.5), and credential type definitions. Writing these into the country list would bloat it; Tamga therefore keeps a second structure: the **anchor log** (`anchors.jsonl`).

Every line of the log is a JWS signed in its own right. A line carries a sequence number (`seq`), the SHA-256 hash of the previous line (`previous_hash`), a timestamp and a kind. There are four kinds (SPEC-TRUST-0001 §5): a status list publication (`status_list`: which list of which institution, which version, the hash of its content), the hash of a credential type definition (`schema`), an hourly liveness signal (`heartbeat`) and a checkpoint written during archiving (`checkpoint`). At least one line is added to the log every hour; even if nothing changes, a liveness signal is written. Lines are not deleted, the log is public, and the lines contain no personal data or credential hashes (TL11). The log's signing keys are also published in the list of lists.

Where the log earns its keep is in catching rolled-back status lists. Suppose someone presents a verifier with the status list from before a revocation, in order to use a revoked credential. Because the list carries the institution's signature, the signature is valid. But the anchor log has recorded the number and the content hash of the latest version of that list; the verifier compares the hash of the list it received with the hash in the log and does not use a list that does not match (SPEC-TRUST-0001 §5; step D of the verification pipeline). The log itself is protected against staleness by its hourly cadence: a log whose last line is too old makes the list count as stale (Figure 8).

As the log grows, the time to load it grows too. So at a certain threshold the lines are moved into an archive, and the new log starts with a signed checkpoint that is bound to the archive's last line and to the hash of the archive file and carries the final state the archive produced. The chain is not broken, no line is deleted, and the full history can be rebuilt from the archives (TL12). *Status: live.*

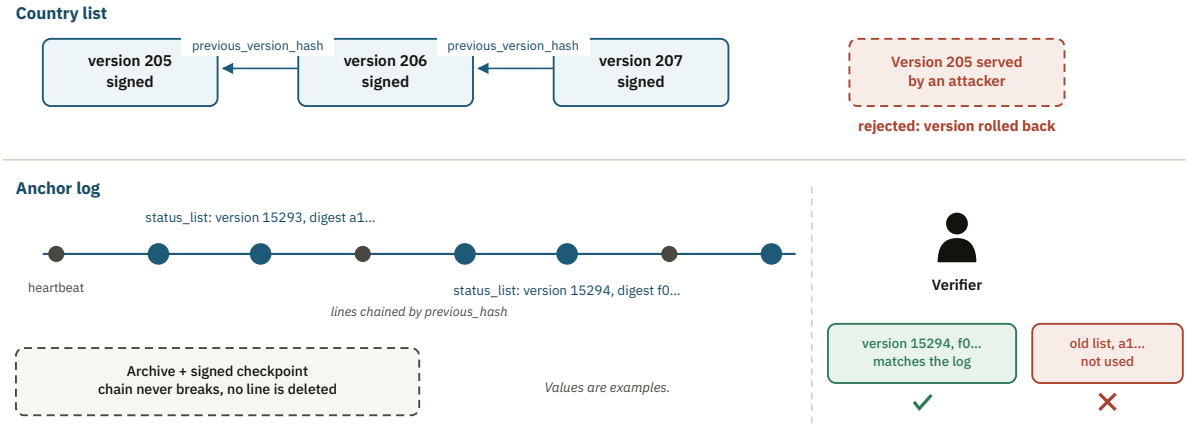


Figure 8. Hash-chained list versions and the anchor log: how a rolled-back publication is caught

TECHNICAL DETAIL

A line from the anchor log

The line below shows how an institution's status list publication is written to the log. The format is the same as in the real log; the values are illustrative and shortened. The list address (`list_uri`) is opaque: it does not give away the institution, the year or the student group (S8).

JSON Example: a status list publication in the anchor log (JWS payload, decoded)

```json
{
  "seq": 51588,
  "previous_hash": "sha256:73f6842108c0…a694c408",
  "ts": "2026-11-03T23:10:06Z",
  "kind": "status_list",
  "list_id": "0x…4101234c731b7165",
  "issuer_id": "0xe41abbb0…e8db1b60",
  "list_uri": "https://status.sandbox.tamga.network/4101234c731b7165",
  "content_hash": "sha256:f037c5749daa…e9f4851d50",
  "list_version": 15294
}
```

6.5 The out-of-band trust anchor

This whole chain must have a starting point. From the outset, the wallet and the verifier trust only **one thing**: the fingerprint of the certificate that signs the list of lists. This value is called the **trust anchor**. Everything else, that is, the signers of the country lists, the institutions, the verifiers and the wallet providers, is stated by lists whose signatures are chained to this anchor.

The anchor is published through a channel separate from the lists themselves, that is, "out of band". The same value appears in the same form in three places: the trust anchor page of the public website (`tamga.network/trust-anchor`), the key file on the trust list site (`keys/root-fingerprints.json`) and the participation agreements (FW-ARF-0001 §6.1); changing all three places at once is much harder than changing a single one. Listed wallets pin this fingerprint inside the application. The sandbox has a separate root, and no wallet or verifier on the real network trusts it (ADR-0038).

6.6 A single interface: TrustSource

Reading the lists requires applying the rules of signature, version chain, freshness, format version and anchor log together; writing these separately in each client produces implementations that drift apart. Tamga therefore decided that all trust questions are asked through a single interface (ADR-0015): `TrustSource`. The issuance service, the verifier, the identity service and the wallet ask the same questions of the same interface: "Was this institution acceptable on the date it issued this credential?", "Was it authorised for this type?", "What is this verifier's entry?", "Does this key belong

to a wallet provider on the list?", "How fresh are the lists?" (SPEC-TRUST-0001 §6). No component outside the interface interprets the list files (TL4).

The interface's answer is three-valued: `YES`, `NO` or `UNKNOWN`. An unknown answer turns into the result "could not be verified" in verification; it is never presented as a rejection. The interface's second benefit looks to the future: today signed lists sit behind it, and if a shared ledger is set up, the ledger goes behind the same interface and the wallet, verifier or issuance code does not change (Chapter 19.8).

When the decision was taken, three alternatives were weighed: the wallet separately verifying the list in its own code (the two implementations would drift apart over time), adding adaptations to the wallet that carry the server libraries (fragile), and the wallet asking every trust question of a network server. The last was the easiest, and it was rejected: that server would learn which wallet asked about which institution when. On the chosen path the verification core is a platform-independent subpackage and the lists are fetched in bulk; the client makes no call to the network that could be linked to a person (ADR-0015, TS3 [12]).

6.7 Identifiers

In a trust network, names can change, domain names can change hands and operators can be handed over. Identities must not be affected by any of this. Tamga's permanent identifiers are therefore derived from the certificates and type names themselves; neither the institution's name nor the network's domain name enters the calculation (FW-ARF-0001 §5.3; SPEC-ID-0002 §2).

TECHNICAL DETAIL

Deriving the identifiers

Root certificate and institution identities are obtained by concatenating the UTF-8 bytes of the country code with the SHA-256 hash of the certificate's DER encoding and hashing the result with Keccak-256. The credential type identity is the Keccak-256 hash of the type name (`vct`) itself:

$$\text{ca_id} = \text{keccak256}(\text{utf8}(\text{cc}) \parallel \text{SHA-256}(\text{DER}(\text{root certificate})))$$

$$\text{issuer_id} = \text{keccak256}(\text{utf8}(\text{cc}) \parallel \text{SHA-256}(\text{DER}(\text{institution certificate})))$$

$$\text{schema_id} = \text{keccak256}(\text{utf8}(\text{vct}))$$

Here $\parallel$ means concatenation. With sample values: in the entry in Chapter 6.2 the fingerprint of the institution certificate is `fb58ea8d…2577ce`, and with the country code `TR` the result is `issuer_id = 0xe41abbb0…e8db1b60`. For the diploma type name `urn:tamga:edu:DiplomaCredential:1` the result is `schema_id = 0x9d6d0e87…e6aed26b` this value is the same as the entry in the catalogue.

Why Keccak-256 rather than SHA-256? Once a shared ledger is set up, the identifiers will be the keys of the records in the contracts, and in the EVM environment the built-in hash function is Keccak-256. An identity derived in the list stage becomes, without any change, the key of the same record in the ledger stage (SPEC-TRUST-0001 §7; Chapter 19).

Table 10. Identifiers: how they are formed, when they change (FW-ARF-0001 §5.3).

Identifier	How it is formed	When it changes
Root certificate identity (`ca_id`)	country code + fingerprint of the root certificate	if the root changes
Institution identity (`issuer_id`)	country code + fingerprint of the institution certificate	when the certificate is renewed; the new entry is linked to the old one as its successor (`successor_id`)

Identifier	How it is formed	When it changes
Credential type identity (`vct`, `schema_id`)	`urn:tamga:<domain>:<Type>:<major version>` and its hash	only when the major version changes
Verifier client identifier (`client_id`)	hash of the access certificate (`x509_hash`)	when the certificate is renewed
Verifier permanent record (`dns_name`)	the domain name in the registration	does not change; copies and pseudonyms are bound to it
Person	no global identity	a device key per credential, a copy per verifier, a pseudonym per site

The fact that the institution's identity changes when its certificate is renewed is the price of the identity being impossible to counterfeit; continuity is provided by the successor link, and credentials issued with the old certificate continue to be verified against the old entry (SPEC-ID-0002, XC2). At handover only the list's `operator` field changes; the root, institution and type identities stay fixed (SPEC-TRUST-0001 §1). A domain name is the address of a service, not an identity (FW-ARF-0001 §4.2).

6.8 ETSI views

The EU's trust list ecosystem has worked with ETSI standards for years. Tamga's authoritative source is its own JSON lists; but offering the same content in formats that EU tools can read is the technical condition for the network to interoperate with the EU. Two views are defined.

ETSI TS 119 602 [42] (LoTE). For the wallet roles (wallet providers, issuers, access certificate providers) the EU uses the JSON-based "Lists of Trusted Entities" format. The list publisher can produce three views in this format from the Tamga lists; instead of the ETSI URIs that carry the meaning "notified by a member state", it uses Tamga's own URI root, and, because ETSI has no counterpart for a non-qualified issuer, it writes its own type URI (SPEC-ID-0002 §8.1.1). Publication is switched on by a setting at the source. *Status: generator ready; publication planned.*

ETSI TS 119 612 [41] (XML). The EU's signature validation tools, and the intermediate route opened for countries outside the EU, expect the national list in this XML format, with a XAdES [53] signature. Tamga produces this view from the same signed country list and **with the same version number** the XML cannot contain any entry that is not in the JSON, and if the two conflict, the JSON prevails (ADR-0066, TX1). No ETSI URI that carries a claim of being "qualified" or "notified" in the EU sense is used in the XML; the list type, status and scheme URIs come from the Tamga root, and every XML file carries the notice "not a list notified under 910/2014 [1]; the list contains no qualified trust service" (TX2). The XML is signed by a separate signing certificate; this certificate follows ETSI's list signing profile and cannot sign the JSON lists. Verifiers do not go into the XML, because they are not trust service providers; their entries are in the JSON list and in the registration certificates.

The rejected options were these: to keep postponing publication (the promise of offering a tool to a state would remain empty), to produce the XML from a separate register (the two sources would drift apart) and to use ETSI's "qualified" status URIs (a claim Tamga cannot make). Tamga's XML list does not enter the EU's third-country lists; those lists are for signature and seal services supervised by states. The gain is that when a Turkic state wants to publish its own list, a tested tool and template are ready (ADR-0066). *Status: published in the sandbox (*`trust.sandbox.tamga.network/tl-tr.xml`*, with placeholder addresses marked "TEST"); on the real network, planned together with the foundation that will operate the list, its postal addresses and its signer.* The question of legal recognition is in Chapter 20.

6.9 Federation: someone else's list

Tamga does not need to own a country list. When a state, a body the state authorises, or the EU publishes its own list, the list of lists can show that list as a **pointer** (ADR-0036; FW-TF-0001 §6.1). A pointer carries four pieces of information: the list's original address, the fingerprints of the certificates that sign the list, **pinned** in the list of lists signed by Tamga, a **scope** saying which roles and which credential types the list may vouch for, and an **approval** record showing by which decision the list was added (Figure 9).

The rules are short and strict. An external list whose signer does not match the pinned fingerprint is not loaded (FD1). An external list cannot step outside its scope: a list that vouches only for identity providers cannot add an institution that issues diplomas, and even if it does, that entry is ignored (FD2). The freshness of each external list is tracked separately: even if one is missing or stale, the Tamga lists are not affected; only the questions that depend on that list return "unknown" (FD3). Adding, changing or removing an external list is done with the approval of project management and is written in the record (FD4). For the network's own types the integrity hash of the type definition is mandatory; for external types (such as the EU person identification data or the mobile driving licence) the trust in the type comes from the signed entry of the external list (FD5).

The chosen path is the EU's own model. Copying external entries into the Tamga list would show them under Tamga's signature and blur ownership and handover; letting each verifier choose external lists for itself would do away with the single trust anchor (ADR-0036). The packages read external lists in the ETSI TS 119 602 and 119 612 formats and recognise the EU person identification data and mobile driving licence types. Having the mechanism ready and trusting a particular list are separate decisions. *Status: the mechanism is live; today there is no external list in the list of lists.*

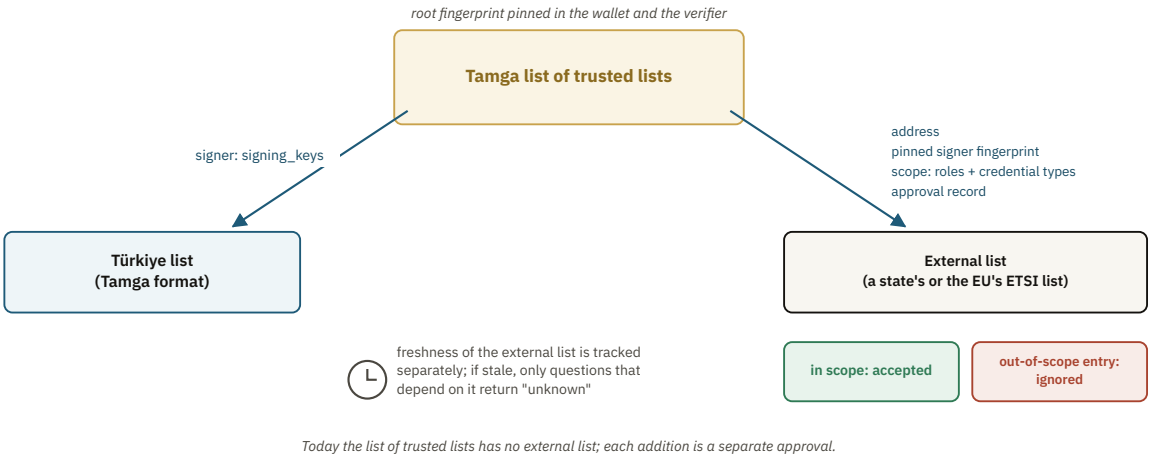


Figure 9. Federation: someone else's list is a pointer in the list of lists

7 Institution Identity and Certificates

Elif works in the student affairs office of Example University. As the university joins the network, Elif's team is told to generate a key pair and send only a certificate request; the private key will never leave the university's hardware security module. A few days later the university has a certificate chained to the Türkiye root certificate, and the certificate's fingerprint enters the country list. This chapter explains why this certificate is X.509 [28], what is written in it, which certificates the verifiers and the registrar use, and how the hosted service obtains a signature without touching the institution's key.

7.1 Why X.509, why not DID

There were two candidates for institution identity: a network-specific decentralised identifier (`did:tamga`) profile, and the X.509 certificates that institutions already use. Project management chose X.509 and invalidated the DID institution profile (ADR-0004). Institutions already use X.509 for electronic seals and signatures, and they have regulatory records. The sentence "identity was verified with a qualified certificate" has a counterpart in legislation; the sentence "verified with a DID" does not yet. The EU's arrangement of qualified certificates and qualified signature creation devices is also built on X.509; using the same ground makes EU compatibility easier.

The same decision sets a principle in the opposite direction for people: **a person is not given a global identifier.** A fixed identity number would string a person's education, health and employment relationships onto a single thread. In each relationship the person appears with a different key, a different copy and, where necessary, a different pseudonym (Table 10, last row; Chapter 15). The identity of institutions, by contrast, is as open and fixed as is needed for anyone to check it.

7.2 National root and provisional operation

Each state has its own national root certificate, and institution certificates are chained to this root. A verifier goes from the signature on the credential to the institution certificate and from there to the root; it looks up the root's fingerprint in the country list (SPEC-ID-0002 §1). Today the Türkiye root is operated by the network's provisional operator, and this is stated explicitly next to the role in the list. The root's name stays fixed at handover: the state either takes over the operation of the same root, or adds its own root through a rollover and the old root is retired (FW-TF-0001 §7, step 3).

A root certificate is not eternal either. When it is about to expire, or when the key is to be strengthened, a **rollover** is applied: the new root is registered, the old root's status becomes `ROLLING_OVER`, and both roots are accepted during an overlap period; institutions move their certificates to the new root, and at the end of the period the old root becomes `RETIRED`. A retired root continues to be accepted for verifying credentials issued during its own period. If the root is compromised, things are different: the root becomes `REVOKED`, and all certificates chained to it become invalid (SPEC-ID-0002 §4). The length of the overlap period (proposed: 12 months) and whether states will use intermediate certificate authorities are recorded in the specification as open questions (Figure 10).

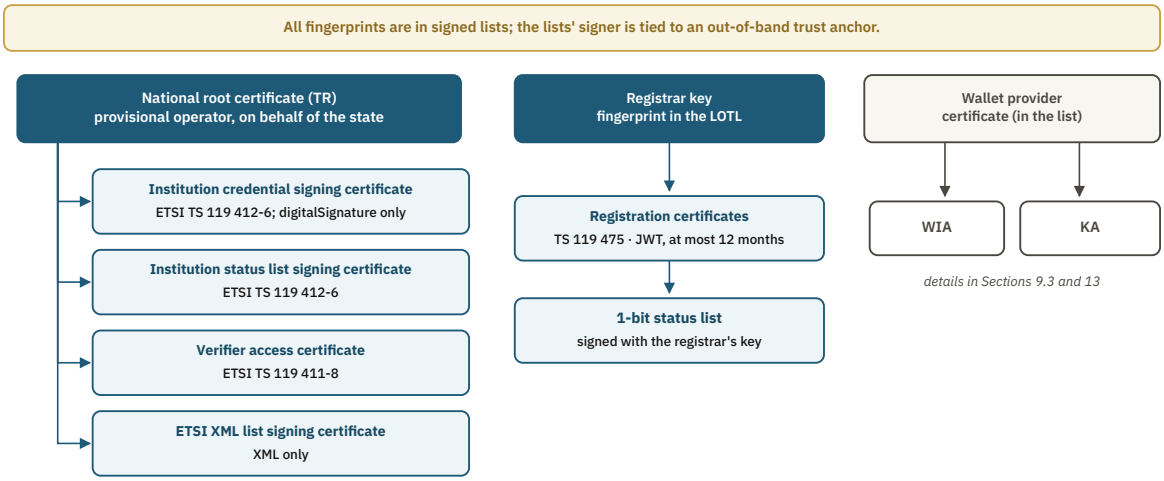


Figure 10. Certificate tree: who signs whom

7.3 The issuer certificate profile

What is written in a certificate determines whether the tools that read it can recognise the institution. The certificate profile the EU has written for providers of identity credentials, wallets and attestations

of attributes is ETSI TS 119 412-6 [43]; when the subject is a legal person, EN 319 412-3 [44] applies. In Tamga, the credential signing and status list signing certificates of issuing institutions, including the identity service, are written according to this profile (ADR-0050).

The most important field of the profile is the **organisation identifier** in the subject section (`organizationIdentifier`). This field carries a semantic identifier derived from the institution's tax or registry number and identical to the number in the registration certificate; in Türkiye the format `VATTR-…` is used for the tax identification number and `NTRTR-…` for the trade registry. Thanks to this match, a verifier on the EU side can link the institution that signed the credential to its registration data. Key usage is an extension marked as mandatory (*critical*) and is **of a single kind**: `digitalSignature` only. Because the same certificate is also used for mdoc credential signatures, this is the kind that ISO 18013-5 [34] requires. The subject and authority key identifiers (SKI, AKI) are mandatory; the matching of trusted authorities in verifier requests relies on this identifier. The algorithm is ECDSA with P-256 and SHA-256, and the certificate is valid for at most 3 years.

One of the options considered was to keep the organisation number only in the trust list; it was rejected, because EU tools outside the list look at the certificate itself. Adding content commitment (`nonRepudiation`) to the key usage was also rejected because it conflicts with the mdoc profile. The additional fields needed for qualified or public-class issuers (authority information access, qualified certificate statements) will come by a separate decision when that class is opened; today all issuers on the network issue non-qualified attestations of attributes (ADR-0022, ADR-0050).

7.4 The verifier access certificate

When a verifier requests a credential from a wallet, it signs its request with its own **access certificate**. This certificate's profile is ETSI TS 119 411-8, and the EU's implementing regulation on the registration of relying parties refers to it (ADR-0058). The subject field of the certificate contains the organisation identifier, the official name and the country. The common name (`CN`) field is the trade name or service name the person will recognise; on Aynur's consent screen, Timur's company appears under its familiar name. The certificate's alternative name section carries two things: the domain name in the registration and at least one **contact detail**, in Tamga the support address in the registration. On the real network, no access certificate is issued to a verifier without a support address (AC1). If the same institution requests separate certificates for different services, each certificate carries the service identifier in a separate field (AC2).

Two details show the network's line of honesty. ETSI's policy identifier belonging to EU trust service providers is not written into the access certificate, because that identifier is a statement that the certificate was issued by a supervised EU trust service provider, and Tamga cannot make that statement (AC3). The network's own policy identifier and certification practice statement will be added once the foundation is established. *Status: planned.* The second detail concerns identifiers: when the certificate is renewed, the verifier's client identifier (`x509_hash`) changes, while the domain name, which is its permanent record, does not. That is why, when the certificates of the real and sandbox verifiers were reissued with the same key in October 2026, the pseudonyms on the sites were not affected; the pseudonym is derived from the domain name (ADR-0058; Chapter 15.3).

7.5 The registration certificate

The access certificate says "this request comes from this institution"; the wallet's real question, however, is **what this institution may ask for**. For this the EU provides a second document: the registration certificate, ETSI TS 119 475 [46]. As the provisional registrar on behalf of Türkiye, Tamga produces a registration certificate for each verifier use and for each issuer (ADR-0026). The certificate's content comes only from the entry in the signed trust list: the verifier's purpose, which fields of which credential type it may request, its privacy policy, its organisation identifier. The

certificate is in JWT format (`rc-wrp+jwt`), is signed with a **registrar key** separate from the list signing key, and is valid for at most 12 months. The key's fingerprint is published in the list of lists.

The verifier attaches the registration certificate to its request; the wallet checks the signature, the validity period, that the organisation identifier in the certificate is the same as the one in the access certificate that signed the request, and that the requested fields stay within the fields the certificate allows. A request that carries no registration certificate is rejected today (ADR-0056; FW-ARF-0001 §2.2); for a request that asks for too many fields, the wallet warns the person (Chapter 10.3). Registration certificates also carry Tamga's own policy identifier, the address of the policy document and a status entry; the registrar keeps a 1-bit status list, and when the registration or its content changes, the old certificate is revoked automatically. The wallet rejects a request with a revoked certificate and warns if it cannot check the status (ADR-0068; FW-POL-0003). Table 11 brings together the certificate types described in this chapter. *Status: registration certificates, policy fields and the status list are live on the real network and in the sandbox.*

Table 11. Certificate types: who issues them, what they carry, where they are checked.

Type	Who issues it	What it carries	Profile	Where it is checked
Institution credential signing and status list signing certificate	national root (today the provisional operator)	organisation identifier, official name, country; `digitalSignature` only	ETSI TS 119 412-6, EN 319 412-3	at the verifier (format and trust steps), in the wallet
Verifier access certificate	national root	organisation identifier, trade name, domain name, support address	ETSI TS 119 411-8	in the wallet, when a signed request is received
Registration certificate	registrar (today provisional)	purpose of use, fields that may be requested, policy, status entry	ETSI TS 119 475	in the wallet, compared with the requested fields
List signing certificates (JSON and a separate XML signer)	provisional operator	signatures of the lists	Tamga JWS; for XML, ETSI TS 119 612 §5.7.1	in every client that loads the list
Wallet provider certificate	wallet provider, registered in the list	WIA and key attestation signatures	ETSI TS 119 412-6 (wallet type)	at the issuer (Chapter 9.3)

7.6 The institution's key stays at the institution: remote signing

No service hosted by the network holds institutions' signing keys (FW-ARF-0001 §3); yet credentials issued through the hosted service must also be signed with the institution's key. The path that holds the two together is remote signing (ADR-0057). The institution's credential and status list signing keys are generated in the institution's own hardware security module, or at a trust service provider with which the institution has a contract, and stay there. The hosted service requests the signature through version 2 of the Cloud Signature Consortium [54] API, the established interface in the EU for remote signatures and seals.

The only thing that goes to the service is the SHA-256 hash of the data to be signed. Neither the content of the credential, nor personal data, nor the person's key goes to the signing service; the signing service does not learn to which person a credential was issued (RS2). The returned signature is verified locally against the institution's certificate in the trust list; no credential is issued with a signature that does not verify (RS3). On the real network, reading the institution's key from a file on the service's server is rejected at configuration level; a file key is only for local development, tests and the sandbox (RS4). The institution can withdraw its signing authorisation at any moment; disabling the client identity at the signing service immediately stops the hosted service from issuing credentials on that institution's behalf.

TECHNICAL DETAIL

The steps of remote signing

Each time the hosted service signs a credential, it performs three calls and two local steps (CSC API v2; ADR-0057 K1–K3). The algorithm identifiers are `2.16.840.1.101.3.4.2.1` for SHA-256 and `ecdsa-with-SHA256` (`1.2.840.10045.4.3.2`) for the signature.

1	`Issuance service → Signing service`	**Access.** Obtains a short-lived access token with the client identity the institution has defined (`client_credentials`).	$\text{token} \leftarrow$ signing service
2	`Issuance service`	**Hash.** Computes only the hash of the data to be signed (the JWS signing input or the COSE structure).	$h = \text{SHA-256}(\text{signing input})$
3	`Issuance service → Signing service`	**Authorisation.** Requests a signature authorisation bound to this hash, for a single signature (`credentials/authorize`).	$\text{SAD} \leftarrow \text{authorise}(h)$
4	`Issuance service → Signing service`	**Signature.** Has the hash signed (`signatures/signHash`).	$\sigma \leftarrow \text{sign}_{\text{institution}}(h)$
5	`Issuance service`	**Check.** Verifies the signature locally with the public key of the institution certificate in the list; if it does not match, does not issue the credential.	$\text{verify}(\sigma, h, \text{pk}_{\text{list}}) \stackrel{?}{=} \text{yes}$

If the signing service cannot be reached, the credential is not issued and the person tries again later; just as when the institution's authentic source cannot be reached (Chapter 9.2).

Rejected options: keeping the key as a file on the server (contrary to the network's rule), tying into a single cloud provider's key service (ties the institution to one provider), and a new network-specific signing interface (the standard already exists). The institution running its issuance software on its own server with the open packages remains open as a second path (ADR-0016, ADR-0057). *Status: code and tests ready in the hosted service; there is not yet an institution on the real network using this path, planned.*

8 Credentials: Formats, Types and the Catalogue

Aynur has finished her master's at Example University and has received her diploma into her wallet. What she sees on her phone is a card: the name of the university, the degree, the date of graduation. Behind the card, however, are several tightly linked structures: a core signed by the institution, fields that can each be opened separately, a binding to a key on the phone, and a catalogue entry that defines the credential's type. This chapter opens these structures one by one. Selective disclosure itself is the subject of the series' third article [68]; here we focus on how the Tamga profile narrows it and why.

8.1 Anatomy of an SD-JWT VC

The main format of Tamga credentials is SD-JWT VC [16] (an SD-JWT-based credential format built on IETF RFC 9901 [15]; ADR-0006). The format is the main format of the EU architecture, is JSON-based and carries selective disclosure within its structure. An SD-JWT VC consists of three parts separated by tildes (`~`) (Figure 11): a JWT signed by the institution, **disclosures**, each carrying a single field, and a **key binding JWT** (*KB-JWT*) that the wallet adds at the moment of presentation. When the institution issues the credential, the string ends with the final tilde, because there is no key binding yet. When Aynur presents the credential, she **removes** from the string the disclosures she does not want to show and appends the key binding at the end. The JWT does not change, and the institution's signature remains valid. Hiding means removing, not adding (SPEC-CRED-0002 §2).

The JWT signed by the institution carries not the disclosable fields themselves but only their **salted hashes** (the `_sd` array). For each field a random salt is generated; the salt, the field name and the value are written as a JSON array, encoded with Base64URL, and the SHA-256 hash of this string goes into the JWT. The verifier recomputes the hash of an incoming disclosure and looks for it in the array in the JWT. Without the salt, the hash of a predictable field such as a date of birth could be cracked by a dictionary attack; the salt prevents this.

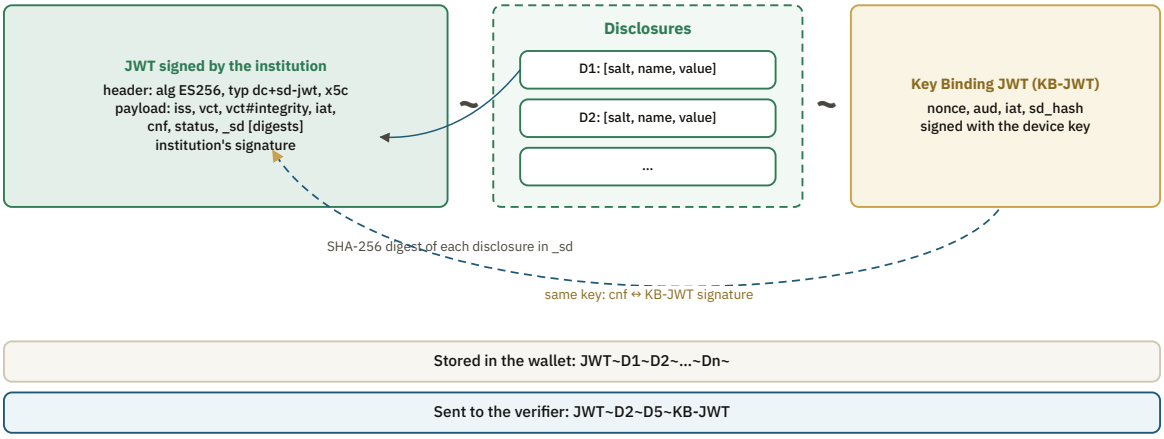


Figure 11. The layers of an SD-JWT VC: which part comes from whom

TECHNICAL DETAIL

Computing a disclosure and its hash

The Tamga profile narrows the options the standard leaves open (SPEC-CRED-0002 §1): signature algorithm ES256 only, `typ dc+sd-jwt` only, hash algorithm (`_sd_alg`) `sha-256` only, a 128-bit salt, the institution certificate chain (`x5c`) mandatory and the root certificate not placed in the chain, key binding mandatory without exception, decoy digests forbidden, nested selective disclosure at most two levels deep, and the `_sd` array always in ascending byte order. A disclosure is computed as follows:

$$A = \mathrm{BASE64URL}(\mathrm{UTF\text{-}8}(\mathrm{JSON}([\mathrm{salt}, \mathrm{name}, \mathrm{value}])))$$

$$d = \mathrm{BASE64URL}(\mathrm{SHA\text{-}256}(\mathrm{ASCII}(A)))$$

$$\text{accept} \Leftrightarrow d \in \text{_sd}$$

Institutions write the array with a fixed convention: a comma and a space between elements, and non-ASCII characters as `\uXXXX` escapes. The values below were actually computed with this convention; the salts were chosen for this example, and the values are illustrative.

TEXT Example: two disclosures from Aynur's diploma

```
Salt (16 bytes, hex)      : 9c41e07b2fd35a8816c4be72031d9fa5
Salt (Base64URL)          : nEHgey_TWogWxL5yAx2fpQ
JSON array                : ["nEHgey_TWogWxL5yAx2fpQ", "given_name", "Aynur"]
Disclosure (Base64URL)    : WyJuRUhnZXlfVFdvZ1d4TDV5QXgyZnBRIiwgImdpdmVuX25hbWUiLCAiQXludXIiXQ
Digest (goes into _sd)    : Ib6OYL63r2BOsXDxfg3agTb5ZL4vjI3nD2Ya5WBqyxs

Salt (Base64URL)          : Wy6P0QR6yT5mELfUL-hcGQ
JSON array                : ["Wy6P0QR6yT5mELfUL-hcGQ", "family_name", "Məmmədova"]
Disclosure (Base64URL)    :
WyJXeTZQMFFSNnlUNW1FTGZVTC1oY0dRIiwgImZhbWlseV9uYW1lIiwgIk1cdTAyNTltbVx1MDI1OWRvdmEiXQ
Digest (goes into _sd)    : 31B1ZwTB5I8Vvg3TjV3_YVjNlgO-dZ39Ftfl_nQhTiA
```

The re-serialisation trap. The hash is the hash of the disclosure *string*, not of a rewritten form of the array. If we write the same family-name array without spaces and with the letter `ə` unescaped (`["Wy6P0QR6yT5mELfUL-hcGQ","family_name","Məmmədova"]`), the data stays the same but the hash becomes `wCd6pAztppTpS9k8d-IPbCifKlRIJFHE_t_eCV_ySa8` and does not match the one in the JWT. That is why the verifier **first hashes the disclosure, then decodes it** an implementation that decodes and rewrites cannot verify even the credentials it produced itself (SPEC-CRED-0002 §3.3, §3.5). The convention applies only to production; the verifier also verifies external credentials written with other conventions.

Why are decoy digests forbidden? The standard allows digests with no counterpart, to obscure the number of hidden fields. In Tamga the type definition is public and already states the number of fields; a number of decoy digests that varies from institution to institution would itself become a fingerprint. The answer to the side channel is for the wallet to present a consistent set of disclosures to the same verifier (SPEC-CRED-0002 §4.4).

At the moment of presentation the wallet appends a key binding JWT at the end. This small JWT is signed with the device key the credential is bound to and carries four fields: the single-use value given by the verifier (`nonce`), the target verifier (`aud`), the moment of presentation (`iat`) and the hash of the presented string (`sd_hash`). The first three prevent replay: a recorded presentation cannot be presented again to another verifier or in another request. The fourth prevents someone in the middle from silently removing some of the presented disclosures (SPEC-CRED-0002 §6).

TECHNICAL DETAIL

Computing the key binding

`sd_hash` is the hash of the entire presented string, excluding the key binding; the tilde after the last disclosure is included, and only the presented disclosures go in:

$$\text{sd_hash} = \text{BASE64URL}(\text{SHA-256}(\text{JWT} \parallel \sim \parallel A_1 \parallel \sim \parallel \cdots \parallel A_k \parallel \sim))$$

$$\text{KB-JWT} = \text{sign}_{\text{cnf}}(\text{nonce}, \text{aud}, \text{iat}, \text{sd_hash})$$

The verifier verifies the signature of the key binding with the `cnf` key in the credential, checks that the `aud` value is itself and that the `nonce` value is the value it gave, applies a window of ±300 seconds for `iat`, and computes `sd_hash` itself and compares it (SPEC-CRED-0002 §8, §8; C17). For Tamga types, a presentation without key binding is rejected (C8).

The example below shows the institution-signed body of Aynur's diploma, with the disclosures decoded. In a presentation only some of these fields are opened (Figure 12).

JSON Example: a decoded diploma body (disclosures put in place, shortened; values are illustrative)

```
{
  "iss": "https://issuer.sandbox.tamga.network/example-university",
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "vct#integrity": "sha256-7Dcy7bWeg5CURNEE+veGmjOE3HWb95ZGJBWX/ZrZgtI=",
  "iat": 1782896400,
  "cnf": { "jwk": { "kty": "EC", "crv": "P-256", "x": "…", "y": "…" } },
  "status": { "status_list": { "idx": 48213, "uri": "https://status.sandbox.tamga.network/…" } },
  "given_name": "Aynur",
  "family_name": "Məmmədova",
  "qualification_title": { "tr-TR": "Bilgisayar Mühendisliği Yüksek Lisans Diploması",
                           "en-US": "Master of Science in Computer Engineering" },
  "eqf_level": 7,
  "isced_f_code": "0613",
  "awarding_body_name": { "tr-TR": "Örnek Üniversitesi", "en-US": "Example University" },
  "awarding_date": "2026-06-30",
  "grade": "3.71",
  "thesis_title": { "tr-TR": "…" },
  "is_graduate": true
}
```

There are three details in the example. `iat` is rounded to the hour, so that copies cannot be matched by their moment of issuance (the packages' release notes; Chapter 15.2). The diploma has no `exp` field; a renewal obligation would tie the graduate to the university for life. The grade and the thesis title are marked "always hideable" in the type definition: Aynur can present her diploma without showing her grade, whereas on a paper diploma everything printed on it is visible (SPEC-SCHEMA-0002 §3.3).

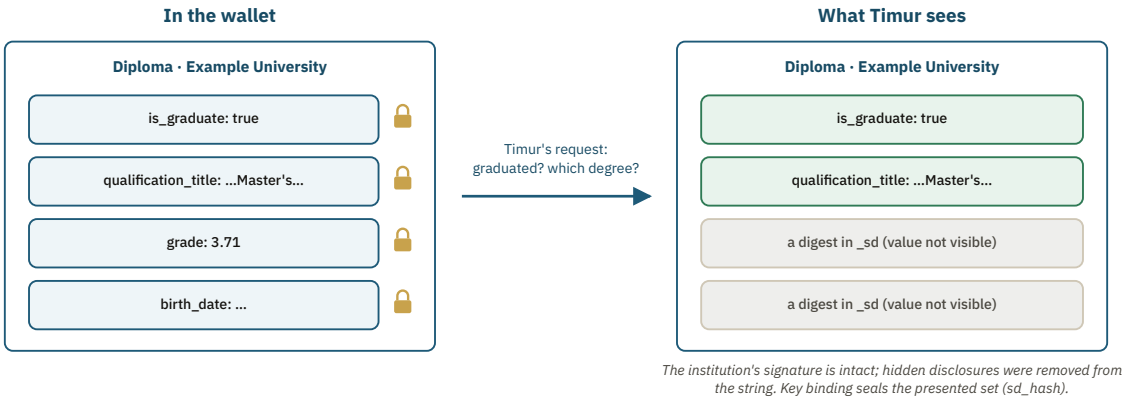


Figure 12. Selective disclosure: showing two fields of a four-field credential

8.2 Why device binding has no exceptions

There is a false assumption, referred to in the specifications as "the hidden flaw in the university idea": "If a student receives a credential with the university's approval, the one carrying the credential is that student." The university verifies that the student exists, but it does not verify that the wallet into which the credential goes belongs to that student. Without a binding, the credential can be collected into a friend's wallet, or received into several wallets and sold; the system raises no error, it silently says the wrong thing (SPEC-CRED-0001 §3).

In Tamga, every credential is bound at the moment of issuance to a key generated on the person's device: the public part of the key is written into the credential's `cnf` field, and the private part never leaves the device's secure area. At presentation the wallet signs the key binding with this key. The binding is mandatory without exception (ADR-0006). What it proves is that the presenter currently holds the private key that was bound when the credential was issued; it does not prove that the human on the other side is the person named in the credential. If the holder gives their phone and unlock code to someone else, no step raises an error. The binding prevents being written into the wrong wallet and transfer; it does not prevent voluntary sharing of a device (SPEC-CRED-0001 §3). To

bind the person themselves, an identity credential is needed: when issuing credentials, institutions match the person's presentation of their identity credential against their own records (Chapter 9.2; Chapter 14).

8.3 mdoc: the second representation

Tamga's identity credential is also issued in the ISO/IEC 18013-5 [34] **mdoc** format alongside SD-JWT VC (ADR-0013). mdoc is a format developed for the mobile driving licence that uses CBOR [29] encoding and COSE signatures. There are three reasons: on the Safari and iOS side, the Digital Credentials API [36], through which credentials are requested from the browser, accepts only mdoc; as ADR-0013 records, the EU architecture makes mdoc mandatory for person identification data; and in proximity, ISO 18013-5 carries mdoc (Chapter 10.8). Staying with SD-JWT VC alone would have cost browser login and alignment with the EU; switching entirely to mdoc would have broken the existing pipeline and abandoned the leaner format for the web.

The rules keep the two representations tightly together. mdoc is only the second representation of the SD-JWT VC; it carries the same fields and the same issuance and expiry times and is bound to **the same device key**: `cnf` in the SD-JWT and `deviceKey` in the mdoc are the same key (MD1, MD2). The two representations are produced in a single issuance flow and share the same revocation bit. The mdoc's `docType` value is identical to the type name (`urn:tamga:id:IdentityAttestation:1`), and its namespace is `tamga.id.1`. Field names and their encoding follow the encoding fixed by the implementing regulation on EU person identification data (EU 2026/1731 [7]): `birthdate` and a `nationalities` array in the SD-JWT, `birth_date` and an array-valued `nationality` in the mdoc (ADR-0045). Types other than the identity credential are SD-JWT VC only today. The short-lived copy used for zero-knowledge proofs is also an mdoc (Chapter 15.4).

TECHNICAL DETAIL

Selective disclosure in mdoc

In mdoc each field is a separate `IssuerSignedItem` structure: a random identifier (`digestID`), a 16-byte random value (`random`), the field name and the value. The structure is CBOR-encoded and wrapped with CBOR tag 24, and the SHA-256 hash of these bytes is written into the **Mobile Security Object** (MSO) signed by the institution. At presentation the wallet sends only the structures it has selected; the verifier verifies the hashes against the MSO, the MSO's signature against the institution certificate, and the device signature over a transcript bound to the session.

$$\text{item} = \text{CBOR}(\text{tag } 24(\text{CBOR}(\{\text{digestID}, \text{random}, \text{elementIdentifier}, \text{elementValue}\})))$$

$$\text{MSO.valueDigests}[\text{tamga.id.1}][\text{digestID}] = \text{SHA-256}(\text{item})$$

When the item `age_over_18 = true` is encoded with the identifier `1438205713` and the random value `8d1f6a20c43b97e5512a0ff6b8c3d471`, the result is an 87-byte sequence whose hash is `b42af3a67628a8e5…a0536d4d`. The computation was done with the encoder of the network's mdoc package; the values are illustrative. The identifiers are random rather than sequential; if they were sequential, the numbers of the disclosed fields would give away the number and order of the hidden fields.

TEXT Example: the MSO of an identity credential (close to CBOR diagnostic notation, shortened; values are illustrative)

```
{
  "version": "1.0",
  "digestAlgorithm": "SHA-256",
  "docType": "urn:tamga:id:IdentityAttestation:1",
  "valueDigests": { "tamga.id.1": { 1438205713: h'b42af3a6…a0536d4d', 902114467: h'…', … } },
  "deviceKeyInfo": { "deviceKey": { 1: 2, -1: 1, -2: h'…', -3: h'…' } },
  "validityInfo": { "signed": 0("2026-07-01T09:00:00Z"),
                    "validFrom": 0("2026-07-01T09:00:00Z"),
                    "validUntil": 0("2028-07-01T09:00:00Z") },
  "status": { "status_list": { "idx": 7310, "uri": "https://…" } }
}
```

The mdoc's revocation entry points to the CWT representation of the same logical list; the JWT and CWT representations carry the same bits (ADR-0048). The MSO carries a COSE_Sign1 signature with the institution's certificate, and the certificate chain is inside the signature; it is chained to the same trust anchor as the SD-JWT (MD3). Table 12 puts the two formats side by side.

Table 12. Comparison of SD-JWT VC and mdoc (FW-ARF-0001 §5.1; ADR-0013).

	SD-JWT VC	ISO/IEC 18013-5 mdoc
Encoding and signature	JSON, JOSE (ES256)	CBOR, COSE_Sign1 (ES256)
Type identity	`vct` (URN)	`docType` (the same URN)
Selective disclosure	salted hashes (`_sd`) and disclosures	`IssuerSignedItem` hashes (MSO)
Device binding	`cnf` + key binding JWT	`deviceKey` + device signature over the session transcript
Revocation	Token Status List (JWT representation)	the same list, CWT representation
Use in Tamga	all types; remote presentation	identity credential; browser, proximity, ZK

8.4 Credential type identity and the catalogue

What says that a credential is a "diploma" is the type name in the credential's `vct` field. In Tamga this name is a URN: `urn:tamga:<domain>:<Type>:<major version>`, for example `urn:tamga:edu:DiplomaCredential:1` (ADR-0010). The meaning of the type, that is, which fields it carries, how it is displayed on screen in which languages and which fields can be hidden, is written in the **type definition** (*Type Metadata*); the data rules are in a separate JSON Schema [39] file. The definitions are published as immutable files in the catalogue at `schemas.tamga.network` (SPEC-SCHEMA-0001).

This was not the first decision. The first schema decision had made the type name a stable HTTPS address (ADR-0007, Decision 1); it was changed two weeks later. The rationale was one of governance: in a network that several states will join, a type identity cannot be tied to a foundation's domain name. The HTTPS option conformed to the standard, but it made the domain name part of the identity forever. The EU's `urn:eudi:pid:1` and its catalogue arrangement follow the same pattern. A non-standard `.well-known` path and a DID-based type identity were also rejected (ADR-0010). The cost was put on record: a verifier that does not know the network's catalogue cannot get from the URN to the definition; the catalogue address is therefore carried in the list of lists and in the packages.

Where the definition lives is stated by the `metadata_url` in the catalogue; if the domain name changes, only these addresses change. Every credential carries the hash of the definition it refers to in the `vct#integrity` field, and in Tamga this field is mandatory (ETSI TS 119 472-1 [49]; optional in the IETF draft). Even if the catalogue server is compromised, the meaning of a field cannot be shifted

silently; because the hash alone identifies the content, the wallet can download the definition once and use it offline too.

TECHNICAL DETAIL

Catalogue entry, integrity hash and resolution

The integrity hash is in W3C Subresource Integrity [38] format: the prefix `sha256-` and the Base64 encoding of the SHA-256 hash of the file's raw bytes. The hash is taken over the byte sequence the server returns; the file is not reformatted, line endings are LF and the encoding is UTF-8 without BOM (SPEC-SCHEMA-0001 §3). The entry below was taken from the catalogue on the day of writing and verified by recomputing it: the hash of the 4,536-byte file of the diploma definition matches the `content_hash` in the catalogue, and the Keccak-256 hash of the type name matches the `schema_id`. Because definitions can be corrected in place during the development phase (see below), the values may change; they should be read as an example.

JSON Example: the diploma entry in the catalogue

```json
{
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "schema_id": "0x9d6d0e873ee0466cf1cdc8a8bd73f9435022635f0b6e46cd478e70f6e6aed26b",
  "metadata_url": "https://schemas.tamga.network/v1/edu/DiplomaCredential/1.0.0/metadata.json",
  "content_hash": "sha256-7Dcy7bWeg5CURNEE+veGmjOE3HWb95ZGJBWX/ZrZgtI=",
  "version": "1.0.0",
  "layer": "NETWORK",
  "status": "ACTIVE"
}
```

JSON Example: an excerpt from the diploma type definition (shortened)

```json
{
  "vct": "urn:tamga:edu:DiplomaCredential:1",
  "extends": "urn:tamga:core:TamgaBaseCredential:1",
  "extends#integrity": "sha256-8ZCjtH26C7Bh0u+Lox3zJA+JLfP4JYtcQPW+8fxoyPU=",
  "schema_uri": "https://schemas.tamga.network/v1/edu/DiplomaCredential/1.0.0/schema.json",
  "schema_uri#integrity": "sha256-AJXIk9o4DlyVFC3PyCeH/4XEeZnh+dYTWVFlvjQjonc=",
  "display": [ { "lang": "tr-TR", "name": "Diploma", "description": "Yükseköğretim mezuniyet belgesi" },
               { "lang": "en-US", "name": "Diploma", "description": "Higher education degree" } ],
  "claims": [ { "path": ["grade"], "sd": "always",
                "display": [ { "lang": "tr-TR", "label": "Not ortalaması" } ] },
              { "path": ["is_graduate"], "sd": "allowed" } ],
  "tamga": { "tier": "NETWORK", "issuer_categories": ["EDUCATION"], "uses_status_list": true,
             "suspension_allowed": true, "min_issuer_assurance": "I2", "min_binding_level": "T2" }
}
```

`schema_uri` and its hash are not in the current version of the IETF draft; Tamga keeps them as its own extension, and a standard reader ignores a field it does not recognise. The verifier's type step does the following in order (ADR-0010 K2; SPEC-SCHEMA-0001 §7): if `vct` or `vct#integrity` is missing, reject; if the type has no catalogue entry or has been withdrawn, reject; take the definition from the cache, otherwise from the `metadata_url` address; if the hash of the received bytes does not match both the value in the credential and the catalogue entry, reject; if the `vct` in the definition is not the same as in the credential, reject; resolve the parent type chain (`extends`) to at most five levels and without cycles; check the credential against the JSON Schema; finally, ask the list whether the institution was authorised for this type on the date the credential was issued. If the definition cannot be obtained from anywhere, the result is not a rejection but "could not be verified".

The major version is part of the URN; a breaking change means a new URN. Minor and patch versions are published under the same URN with a new `metadata_url` and a new hash; the `vct#integrity` in the credential pins down which one is meant. A deprecated (`DEPRECATED`) type can **no longer be issued**, but credentials issued with it **continue to be verified** a diploma issued in 2027 must remain verifiable when a new major version of the type comes out (ADR-0007 Decision 7; ADR-0010 K4). National credential types use their own namespace: `urn:tamga:<cc>:<domain>:<Type>:<major version>` a network type cannot take this form, so a national name can never collide with a network-wide name (ADR-0054).

Today the network is in a **development phase**: until the beta release, type definitions are corrected in place and test credentials are collected again; the immutability of a published definition begins with the beta (ADR-0029). When suspension was allowed in the diploma's definition, the hash changed and earlier test diplomas were reissued (SPEC-SCHEMA-0002 §3.1); with no real users, no backward-compatibility code was written.

8.5 Today's types

Table 13. Credential types in the catalogue (day of writing; the `packages/schemas` catalogue, SPEC-SCHEMA-0002/0003, FW-RB-0002…0005).

Type (`vct`, `urn:tamga:` prefix omitted)	Display name	Format · revocation · suspension · minimum level · rulebook
`edu:StudentCredential:1`	student certificate	SD-JWT VC · no status list, at most 90 days · no suspension · T1 · FW-RB-0002
`edu:DiplomaCredential:1`	diploma	SD-JWT VC · Status List, 2 bits · suspension allowed · T2 · FW-RB-0002
`id:IdentityAttestation:1`	identity credential	not PID · SD-JWT VC + mdoc · Status List, 1 bit · no suspension · T2 · FW-RB-0003
`contact:EmailAddress:1`, `contact:PhoneNumber:1`	e-mail, phone	verified contact · SD-JWT VC · Status List, 1 bit · no suspension · T0 · FW-RB-0005
`tkt:EventTicket:1`	event ticket	SD-JWT VC · Status List · no suspension · T0 · FW-RB-0004
`id:DrivingLicenceAttestation:1`	driving licence information	not an official document · SD-JWT VC · Status List, 1 bit · no suspension · T2 · FW-RB-0003
`id:PseudonymSeed:1`	pseudonym seed	never shown to any verifier · SD-JWT VC · no status list · T2 · ADR-0031, ADR-0061
`id:ShortLivedIdentityAttestation:1`	ZK copy	mdoc · no status list, at most 24 hours · no suspension · T2 · ADR-0044

The student certificate does not use a status list; its short lifetime takes the place of revocation. The diploma has no expiry and uses a status list; there are rare but real reasons for revocation, such as plagiarism or a fraudulent enrolment. Through its coded fields the diploma is mapped to the European Learning Model (ELM [61]): the European Qualifications Framework level (EQF) and the ISCED-F field code. An employer in Germany does not need to read the words "Bilgisayar Mühendisliği"; it understands the field code `0613` and level 7 (SPEC-SCHEMA-0001 §8.3). The driving licence information is neither an official driving licence nor a mobile driving licence; it is not valid for traffic checks, and it says so plainly on the card (ADR-0039). The national identity number appears only in the identity credential, and only as a selectively disclosable field; no diploma, card or ticket carries it (FW-ARF-0001 §5.1). The details of the types that derive from the identity credential are in Chapter 14.

8.6 Category signal and assurance

In EU law, qualified attestations of attributes and attestations of attributes issued on behalf of a public source carry, inside the credential, a category indicator that can be processed automatically; non-qualified ones do not. Tamga mirrors this structure in its own context (ADR-0010 K5). If the class of the issuer entry is `PUB`, the credential carries `urn:tamga:eaa:pub` in the `category` field; if it is `QUALIFIED`, `urn:tamga:eaa:qualified` issuers whose class is `EAA`, that is, those at the registered or contracted level, carry no category. An institution can only set the signal of its registered class; in the trust step the verifier compares the category in the credential with the list and rejects the credential if they do not match (C4). A forged signal is thus of no use. The EU's own category names (`urn:etsi:esi:eaa:eu:*`) are not used; the network is outside the EU context.

The second rule concerns the person: **the person's identity verification level is never written into the credential** (C18). The level is a precondition of the type; a diploma is issued only with at least T2 binding (Table 13), and the binding method is written only into the issuer's audit record (PR7). The EU does not write the level into the credential either (ADR-0010, alternative E).

Today's picture is simple: all issuers on the network issue non-qualified attestations of attributes, and no credential carries a category field. The identity service is not qualified either; in the EU this title requires independent conformity assessment and supervision (ADR-0022). Nor is a separate "not qualified" indicator written into the credential (ADR-0047). When the highest institution level (I3) will be opened for diplomas has been left until after the pilot.

9 Issuance: The OpenID4VCI Profile

Aynur's master's diploma is ready. After Elif approves the graduation record in the university's student information system, a link is sent to Aynur from the same system. Aynur opens the link on her phone, the wallet asks for consent to request her identity, and a few seconds later the diploma card appears. In those few seconds a series of messages goes back and forth between the wallet and the university's issuance service. This chapter describes those messages. The protocol is the OpenID Foundation's OpenID for Verifiable Credential Issuance 1.0 (OpenID4VCI [30]); Tamga builds a strict profile on top of it (SPEC-PROTO-0001). The eighth article of the series [73] explains the protocol itself from scratch; here we look at the profile's choices and their rationale.

9.1 Two starting points

A credential can be requested in two ways (FW-ARF-0001 §2.1). On the **institution-initiated** path, the institution produces an **offer** (*credential offer*) and delivers it to the person as a QR code or a link. On the **wallet-initiated** path, the person chooses the institution in the wallet and requests their credential; the wallet reads the directory of institutions from the trust list and does not ask a separate server (PR15). On both paths the institution first introduces itself: every issuance service publishes a standard description document (*issuer metadata*). The wallet requests this document in signed form; if the signer is not the institution's certificate in the list, it does not use it. The document also carries the institution's registration certificate; the wallet checks in advance that the requested type is registered (SPEC-PROTO-0001 §2.1).

The offer is not embedded in the QR code; the QR code carries only the address of the offer (`credential_offer_uri`), and the address is **single-use** (PR3). When a used offer is scanned a second time, the wallet says "this invitation has been used"; the moment Aynur says "my QR code doesn't work", a leak is noticed. On the institution-initiated path, offers fall into three classes (Table 14).

Table 14. Offer classes and protection (SPEC-PROTO-0001 §3.3).

Class	Where it appears	Lifetime	Second factor	Additional rule
`on-screen`	on the institution's screen where the person is logged in	5 minutes, single-use	6-digit transaction code, in the same session	the offer is burnt after 3 wrong attempts
`out-of-band`	QR code sent by e-mail or text message	at most 72 hours, single-use	6-digit transaction code, **through a different channel**	channel address only from the institution's registered data; after issuance an "added to a wallet" notice goes to both channels

Class	Where it appears	Lifetime	Second factor	Additional rule
`identity-bound`	link delivered through the institution's own channel	7 days, single-use	no transaction code; the person presents their identity credential	the offer is bound to the person's identity (Chapter 9.2)

The transaction code (`tx_code`) is a second factor against someone looking over the person's shoulder at the screen or photographing the QR code, and it cannot be skipped in the pre-authorised flow (PR1). The code is not sent inside the offer. The identity-bound offer, on the other hand, needs no transaction code at all, because the credential can be issued only to the person named in the offer.

TECHNICAL DETAIL

An identity-bound offer object

The identity-bound offer uses the standard's authorisation code flow; the offer contains no pre-authorised code, only an `issuer_state` value that carries the identity of the offer. The wallet puts this value into the authorisation request, and the issuer checks that the offer is valid, unused and for the same credential type (SPEC-PROTO-0001 §3.4). The values are illustrative.

JSON Example: an identity-bound offer for Aynur's diploma

```
{
  "credential_issuer": "https://issuer.sandbox.tamga.network/example-university",
  "credential_configuration_ids": ["urn:tamga:edu:DiplomaCredential:1"],
  "grants": { "authorization_code": { "issuer_state": "b3f1c2…" } }
}
```

TEXT Example: the address carried by the QR code

```
openid-credential-offer://?credential_offer_uri=
  https%3A%2F%2Fissuer.sandbox.tamga.network%2Fexample-university%2Foffers%2F8a3f9c21
```

In the description document, the identifier and the scope (`scope`) of every credential configuration is the type's URN; the format is always `dc+sd-jwt`, the signature and proof algorithm ES256 only, and the batch issuance size 10. The deferred issuance endpoint and the notification endpoint are not advertised today (§2.1, §9, §10).

9.2 The authentic source stays at the institution

Whose is the information inside a diploma? Tamga's answer is categorical: the information is in the institution's own system and stays there. Even in the hosted issuance service the network keeps no records of people; the credential's information is read at signing time from the institution's **authentic source** and discarded from memory once the credential has been issued (ADR-0020). Project management's direction in this decision was clear: no bulk upload of students, the institution sends the offer e-mail itself, and the network has no business with people's data. In the EU too, the attestation provider takes the attribute from the authentic source, and an intermediary is not expected to keep the source data permanently.

Two paths are defined (Figure 13). On **Path A** the institution initiates: the institution's system sends the network's API the credential type, an opaque reference the institution uses for the person (`subject_ref`) and two matching keys, the person's identity number and date of birth. The service does not store these keys in the clear; it keeps a keyed hash per institution (HMAC-SHA-256 [26]). The institution delivers the link to the person itself; the network does not see the person's contact address (AS3). When Aynur opens the link, the wallet presents her identity credential; if the hash of the identity number and date of birth in the presented credential does not match the hash in the offer, the credential is not issued. Even if someone else gets hold of the link, they cannot obtain the credential (AS2). On **Path B** the person initiates: Aynur chooses the university in the wallet and

presents her identity; the issuance service queries the institution's endpoint with a signed, short-lived request. If a record exists, the credential is issued; if not, "not found in the institution's records" is returned and the response is not stored. The only things that persist are the institution's opaque person reference (for revocation and renewal) and the keyed hash in the identity-bound offer (AS1).

The network keeping its own record register (which moves people's data into the network) was left to the test environment only; the network sending the offer e-mail (which exposes contact addresses to the network) was rejected; and relying on the transaction code alone without an identity binding remained as a fallback for those who have no identity credential (ADR-0020). *Status: both paths are live in the hosted service.*

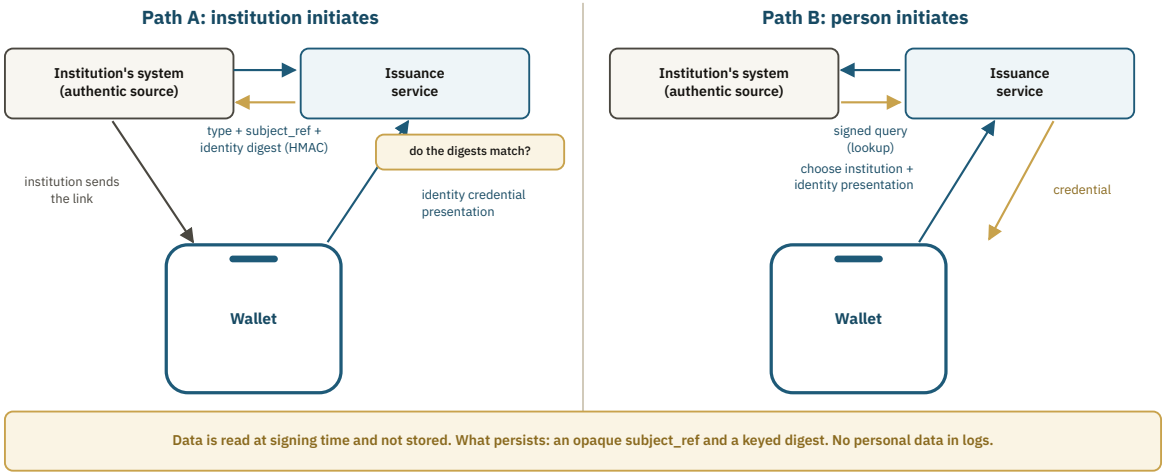


Figure 13. The authentic source stays at the institution: Path A and Path B

TECHNICAL DETAIL

Wallet-initiated issuance

On the wallet-initiated path the authorisation code flow works together with OAuth's security extensions: the authorisation request is first pushed over the back channel (PAR [21], RFC 9126), the code exchange is protected with PKCE [22] (S256), and the client identity is not a password but the wallet instance attestation (PR13). The person's identity is matched through a standard presentation made to the institution's issuance service (SPEC-PROTO-0001 §11.2).

1	`Wallet → Issuer`	**PAR.** Pushes the requested type (`scope` = the type URN), the redirect address, the PKCE value and, if present, `issuer_state` over the back channel; the wallet instance attestation and its proof of possession are attached to the request.	$\text{request_uri} \leftarrow \text{PAR}(s, \text{code_challenge}, \text{WIA})$
2	`Wallet → Issuer`	**Authorisation.** Calls the authorisation endpoint; the issuer returns a signed presentation request asking for the identity credential (identity number, date of birth, first name, family name).	$\text{request} \leftarrow \text{authorize}(\text{request_uri})$
3	`Wallet → Issuer`	**Presentation.** Runs the standard presentation flow; the issuer passes the submission through the full verification pipeline.	$\text{vp_token} \rightarrow \text{T0} + \text{A...E}$
4	`Issuer`	**Matching.** Matches the identity number and date of birth against the hash in the	$\text{HMAC}_k(\text{id no}, \text{birth d.}) \stackrel{?}{=} \text{offer hash}$

		offer or against the record in the institution's source; if they do not match, `access_denied`.	
5	`Wallet → Issuer`	**Token.** Exchanges the authorisation code for a token with the PKCE secret; the code is single-use and valid for at most 60 seconds.	$\text{access_token} \leftarrow (\text{code}, v)$
6	`Wallet → Issuer`	**Credential.** Nonce, key proofs (`proof`) and the credential request; the steps are the same as in the institution-initiated flow (Chapter 9.4).	$\text{proofs} \rightarrow \text{credential}$

If a used authorisation code arrives a second time, the issuer first revokes the tokens issued from that code. This is a deliberate choice that, when the code is suspected of having leaked, puts closing the person's session ahead of preventing the attacker from using the code (RFC 9700 [23] §4.5; SPEC-PROTO-0001 §11.2).

9.3 Only to genuine wallets

The issuer wants to know whether the party it is talking to is a wallet recognised in the list or a fake client. In the EU model the answer is two attestations signed by the wallet provider (ADR-0025; FW-POL-0002). The **wallet instance attestation** (*Wallet Instance Attestation*, WIA) says that the wallet is a solution of a provider registered in the list. Its lifetime is shorter than 24 hours, and it is obtained for each transaction with a new key and a new revocation entry; no two institutions see the same WIA, and the provider does not learn how many institutions the wallet has dealt with. The **key attestation** (*key attestation*, KA), on the other hand, says in which store the keys the credential will be bound to are held, in software or in the phone's secure area; its level must tell the truth, and an unverified claim is not written into the attestation (WIA3).

The issuer checks the WIA's signature, that its signer belongs to a wallet provider in the list, its validity period, the proof of possession and the revocation status; it checks the KA's signature, its revocation status and that the store level meets the institution's minimum. No credential is issued to the wallet of a provider that is not on the list, nor with a revoked attestation (PR11, PR19). Institutions can raise the minimum through their own policies. On the real network the identity service accepts only requests with a key attestation and applies the secure-area level as its minimum; the sandbox and local development continue to accept the software level (SPEC-PROTO-0001 §11.1.1). The old model was a single wallet attestation, valid for 30 days and shown identically to every institution; it was abandoned because it was linkable and could not be revoked (ADR-0025). The details are in Chapter 13.

9.4 DPoP, nonce and key proof

In the issuance flow three separate mechanisms answer three separate questions. The first concerns the token: what happens if the access token is stolen? In Tamga the access token is bound to its sender with **DPoP** [20] (RFC 9449). The wallet sends a proof signed with an ephemeral P-256 key, and the issuer binds the token to that key's fingerprint; whoever steals the token cannot use it, because they do not have the key. The proof is single-use and has a window of ±5 minutes; the token's lifetime is 5 minutes (PR9, PR17).

The second concerns freshness: was the wallet's proof produced just now, or copied from somewhere else? The issuer's **nonce endpoint** gives out a single-use value (`c_nonce`) valid for 5 minutes, and the value is consumed **atomically** consumption done in two steps, "check first, then delete", would

leave a race that allowed the same proof to be used twice (PR4). In OpenID4VCI 1.0 this value comes only from the nonce endpoint.

The third concerns the key: is the key the credential will be bound to really in the wallet? The wallet signs a small JWT with this key, the **key proof** (`proof`, a proof of possession of type `openid4vci-proof+jwt`); it contains which issuer the proof is for (`aud`), the moment of production (`iat`) and the `nonce` just obtained. The public key in the proof's header is the key that will go into the credential's `cnf` field; the KA also travels in this header. Only ES256 is accepted in the proof (PR5).

TECHNICAL DETAIL

The DPoP binding and the steps of institution-initiated issuance

In the DPoP binding the token is bound to the RFC 7638 [24] fingerprint of the public key in the proof. The fingerprint is the SHA-256 hash of the JSON of the key's required fields, written in lexicographic order and without whitespace. At the credential endpoint every request also carries the hash of the token (`ath`):

$$\text{jkt} = \text{BASE64URL}(\text{SHA-256}(\text{JSON}(\{\text{crv}, \text{kty}, \text{x}, \text{y}\})))$$

$$\text{token.cnf.jkt} \stackrel{?}{=} \text{jkt}(\text{jwk in the DPoP proof})$$

$$\text{ath} = \text{BASE64URL}(\text{SHA-256}(\text{access token}))$$

For the sample P-256 key in the specification (`x = f83OJ3D2…VEU`, `y = x_FEzRu9…I5a0`) the fingerprint comes out as `oKIywvGUpTVTyxMQ3bwIIeQUudfr_CkLMjCE19ECD-U` the values are illustrative. The institution-initiated flow with a pre-authorised code proceeds through these steps (SPEC-PROTO-0001 §1–§8; Figure 14):

1	Institution → Aynur	**Offer.** Shows a QR code on screen and, separately, a 6-digit transaction code; the offer address is single-use.	$\text{offer_uri}, \text{tx_code}$
2	Wallet → Issuer	**Offer and description.** Fetches the offer and the signed description document; matches the signer with the institution certificate in the list.	$\text{metadata} \rightarrow \text{list}$
3	Wallet → Issuer	**Token.** Sends the pre-authorised code and the transaction code, with a DPoP proof and the wallet instance attestation.	$\text{access_token} \leftarrow (\text{code}, \text{tx_code}, \text{DPoP}, \text{WIA})$
4	Wallet → Issuer	**Nonce.** Obtains a fresh value from the nonce endpoint.	$\text{c_nonce} \leftarrow \text{nonce endpoint}$
5	Wallet	**Keys.** Generates ten separate keys for ten copies; obtains a key attestation (KA) from the provider and signs the key proof.	$k_1 \cdots k_{10} \quad \pi = \text{sign}(\text{aud}, \text{iat}, \text{c_nonce})$
6	Wallet → Issuer	**Credential request.** `Authorization: DPoP` header, a new DPoP proof with the same key (including `ath`) and the key proof, which carries the KA in its header.	$\text{POST } /\text{credential}$
7	Issuer	**Checks.** Token and scope; proof signature, `aud`, `iat` consume the nonce atomically; keys distinct; is the type authorisation still valid.	$\text{nonce} \in \text{fresh set} \Rightarrow \text{delete}$

8	`Issuer`	**Signature.** Reads the information from the authentic source, binds each copy to a separate key, reserves a random position in the status list for each copy and signs with the institution's key.	$\mathrm{cnf}_i = k_i \quad \mathrm{idx}_i \leftarrow \mathrm{random}$
9	`Issuer → Wallet`	**Response.** Returns the copies; each is an SD-JWT VC string ending with the final tilde.	$\mathrm{credentials}[1 \cdots 10]$

Asking again about the type authorisation at the credential endpoint may look redundant; it was already checked when the description document was produced (PR2). But the authorisation may have been withdrawn after the description document was cached; it is a cheap check, and the cost of producing a wrong credential is high (SPEC-PROTO-0001 §7.3).

The error codes are the standard's own codes and contain no personal data: it does not say "no record found for Aynur Məmmədova", it says `credential_request_denied` (PR8). Some details of the flow came out of the self-test carried out on the sandbox in October 2026 with the OpenID Foundation's conformance test tool (ADR-0059, ADR-0060); this is a self-test, and certification is a separate process (Chapter 16.5).

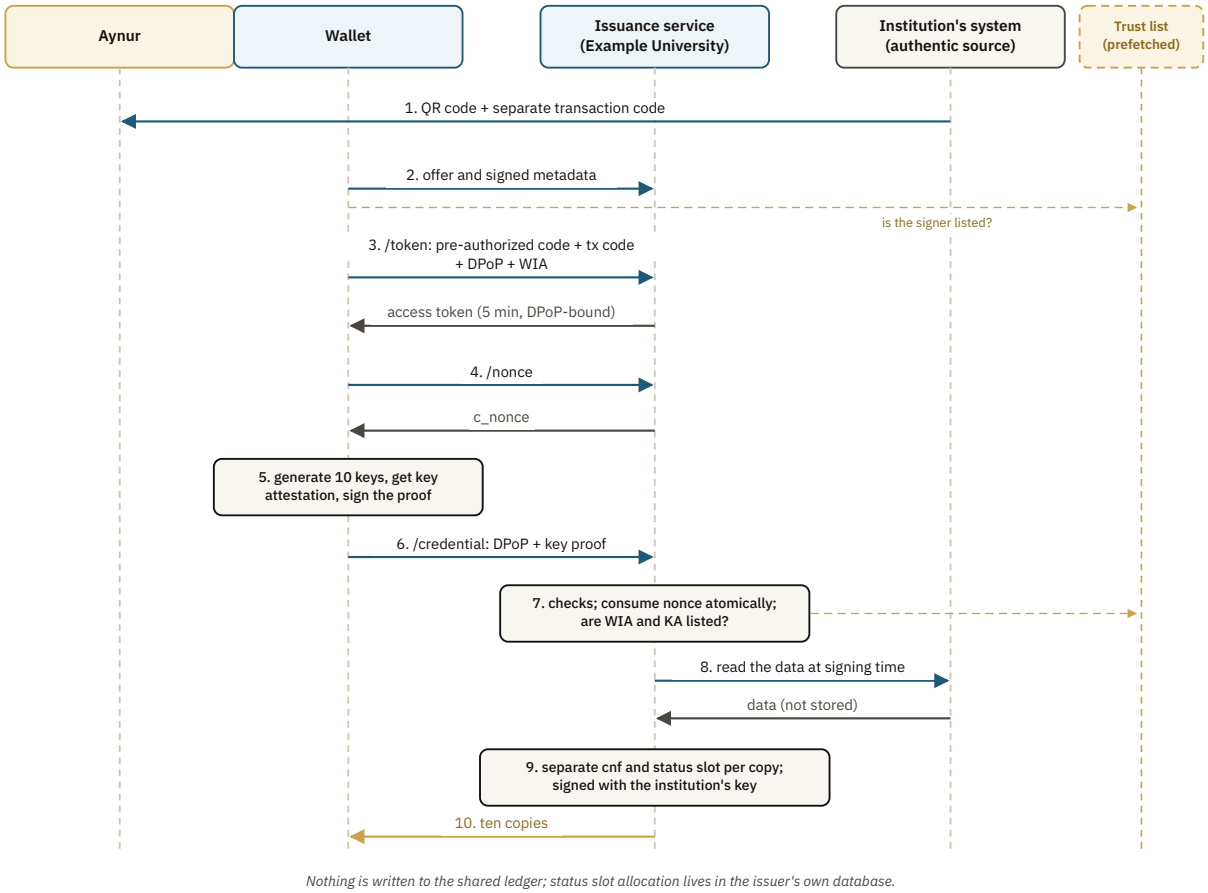


Figure 14. Institution-initiated issuance: sequence diagram

9.5 Batch issuance: ten copies, ten keys

Aynur may show her diploma to Timur, then to another employer, then to a scholarship body. If she always showed the same copy, these bodies could tell from the same `cnf` key and the same status

position that all three were dealing with the same person. The solution is to use a different copy for each presentation (SPEC-PROTO-0001 §8.1). In Tamga, **ten copies** are issued in one issuance, and each copy is bound to **a different device key** (PR6). If two proofs with the same key arrive in one request, the issuer rejects the request. The wallet shows each verifier a separate copy and keeps showing the same copy to the same verifier (Chapter 13.4).

The number ten is a balance: a single copy leaves linkability open, fifty copies produce waste; the value will be readjusted with pilot data (SPEC-PROTO-0001 §8.3, Open Issues 4). Each diploma copy uses up **a separate position** in the status list. When a diploma is revoked, all ten positions are marked; which positions belong to the same diploma is known only to the institution, in its own database, and this mapping never leaves it (PR10). Ten bits changing at once could be a signal from the outside; but because status lists are published at fixed intervals whether or not anything has changed, which bits changed together is not visible (Chapter 12.4).

An access token can be used for several credential requests within its 5-minute lifetime; but only for the configuration it covers, up to ten copies in total, and always with the DPoP key it is bound to. The lifetime is not extended by reuse (ADR-0059, AT1–AT3). A single-use token diverged from the EU's reference issuer and required a new authorisation when the network connection dropped; unlimited reuse could have exhausted status positions. Tickets and ZK copies remain a single batch.

9.6 Silent renewal

Copies run out by design. For institutional credentials (student certificate and diploma; tickets excluded) the wallet can obtain new copies without asking the person when copies are running low or the lifetime is about to expire (ADR-0023). The thresholds are announced by the issuer: when two unused copies remain, or when seven days of lifetime remain (SPEC-PROTO-0001 §2.1). The wallet renews while the application is in the foreground and after a random delay.

Renewal is done with a **refresh token** given in the first issuance. The token is single-use, is replaced with a new one at each use, and the issuer stores only its hash. On renewal the issuer reads the record from the authentic source again; if the person is no longer in the source, the token lapses and no credential is issued (PR18). What the token is bound to changed once. In the first decision the token was bound to the DPoP key of the first transaction. OAuth's profile for client authentication with a wallet attestation, however, requires the binding to be to the **client instance key**, that is, the `cnf` key of the wallet instance attestation in the first transaction, and allows the DPoP key to change. Tamga changed the binding accordingly (ADR-0060). Because the wallet uses a new WIA key for each transaction, the binding key is stored only with that credential, and on renewal a fresh WIA for this key is requested from the provider; only that institution sees the key. A single permanent instance key would have been simpler, and it was rejected because all institutions would see the same key.

There is no silent renewal for types whose issuer does not keep the person's information: the identity credential and the contact credentials do not issue refresh tokens, and renewal happens through the person's own action. The identity service's only exception is the short-lived copies used for zero-knowledge proofs; their token does not renew the identity credential, it only obtains a short-lived copy, and it is issued only if the wallet asks for this scope separately (ADR-0044, ADR-0062; Chapter 15.4). *Status: silent renewal and the client instance binding are live (in the packages since 0.7.2).*

9.7 Notification and "if this wasn't you"

The last step of the issuance flow concerns the person. The network's architecture document provides that when a credential is added to a wallet, the person receives the message "your credential has been added to a wallet; if this wasn't you, report it" (FW-ARF-0001 §4.3). For offers sent by e-mail or text message, this message goes to both channels after the credential has been issued

(SPEC-PROTO-0001 §3.3). A credential collected into a wallet without the person's knowledge is thus noticed; together with the used-offer warning, it is a second signal that tracks a compromised link.

Separately, OpenID4VCI defines a **notification endpoint** through which the wallet tells the issuer that it has accepted the credential. Tamga issuers do not advertise this endpoint today (SPEC-PROTO-0001 §10). If the endpoint is added, notifications will be used only as counters and will not be stored per person; the wallet tells no issuer that a credential was later deleted. A deferred issuance endpoint is not offered either: if the record is not ready, the request is rejected and the institution produces a new offer later (SPEC-PROTO-0001 §9). *Status: the rule on notifying the person is defined; the standard notification endpoint and deferred issuance are not offered.*

Aynur's diploma is now in her wallet, in ten copies, each bound to a separate key. How Timur will ask her for it, what the wallet will show and in what order the verifier will check what are the subjects of the following chapters.

10 Presentation: OpenID4VP, DCQL and Proximity

Aynur is applying for a position advertised by the fictional Example Holding. For her diploma from Baku this path is not open today: only the Türkiye list is active on the network, and a slot has been reserved for Azerbaijan (this is not the announcement of an agreement or of negotiations with any state). So we build the example around the diploma Aynur received from the fictional Example University on the Türkiye list. A QR code appears on the screen of Timur, the recruiter; Aynur scans it, her wallet tells her who is asking for what, Aynur approves, and a few seconds later the screen says "accepted". A diploma is issued once but shown dozens of times, and every presentation raises three questions: Who is asking? What are they asking for, and why? Does the answer reach only them? Tamga answers these questions with the protocol the EU has chosen, **OpenID4VP 1.0** [31] (*OpenID for Verifiable Presentations*), and its high-assurance profile in the EU, **HAIP 1.0** [32] (SPEC-PROTO-0002). The basics of the protocol were explained in the eighth article of the series; here we focus on what Tamga chose and why.

10.1 The signed request and the verifier's identity

The QR code contains no credential and no personal data; it contains only an address from which the request is to be downloaded (`request_uri`). From this address the wallet downloads a **signed request object**. The request is a JWT signed with the **verifier's** access certificate; its header contains the certificate chain (`x5c`). An unsigned request is rejected (PV6); without a signature the wallet cannot know who is on the other side, nor can it warn the person against over-asking.

The verifier introduces itself with a **client identifier**. HAIP 1.0 §5 requires that in signed requests the verifier use the `x509_hash` prefix and that the wallet accept it. The value is computed from the hash of the leaf certificate that signs the request. Tamga accepts only this prefix; the domain-based prefix used earlier (`x509_san_dns`) and the unsigned `redirect_uri` prefix are rejected (ADR-0034). The security side of the domain-name rule is kept: the domain name of the response address must be listed in the SAN field of the certificate that signs the request.

TECHNICAL DETAIL

How the client identifier is computed, and why a second identity is needed

The `x509_hash` value is the base64url representation of the SHA-256 hash of the DER encoding of the leaf certificate (OpenID4VP 1.0 §5.9.3):

$$\text{client_id} = \text{x509_hash:} \parallel \text{base64url}(\text{SHA-256}(\text{DER}(\text{leaf certificate})))$$

> The list publisher computes the same value from the verifier's access certificate and writes it into the entry in the trust list. The wallet matches the value in the request with the entry in the list and finds the verifier's registered name, scope and status. The value is not assigned by hand; the packages compute it from the certificate (ADR-0034 CI1).
>
> This identity has a weak side: when the certificate is renewed, the hash changes too. If pseudonyms, the mapping of credential copies and pass cards were bound to this value, the person's accounts and cards would be lost at every renewal. That is why every verifier entry also carries a **permanent identity**: the domain name in the certificate's SAN field (`dns_name`). Everything that must stay independent of the certificate is bound to this field (ADR-0034 CI3, CI4). `rp_id` was also considered for the permanent identity, but it was not chosen because it too derives from the certificate.

The request carries one more thing: the **registration certificate** the verifier has obtained for that use (ETSI TS 119 475 [46]). The access certificate says "who I am"; the registration certificate says "what I am registered to ask for, and for what purpose". The certificate arrives in the request's `verifier_info` field; it is produced only from the entry in the trust list and is signed with the registrar's separate key (ADR-0026). The wallet checks four things in order: that the signature belongs to the registrar key in the list of lists, the validity period (at most 12 months), that the organisation identifier in the certificate (`sub`) is the same as the `organizationIdentifier` in the access certificate, and that the requested fields stay within the certificate's scope. If any of the first three fails, the wallet sends no data (ADR-0026 WRC4).

The EU's Implementing Regulation 2026/1731 [7] makes this verification mandatory in the wallet from 2028-08-11. Tamga had considered a transition with warnings until that date; on 2026-10-19 the transition was dropped, and a request that carries no registration certificate is rejected from today, without asking the person (ADR-0056 K10). A warning left a door open to unregistered use, and the cheapest moment for a breaking change was before wallets became widespread. Since 2026-10-29 registration certificates also carry a policy identifier and an entry in the registrar's 1-bit status list; the wallet sends no data to a request with a revoked certificate (ADR-0068, FW-POL-0003). **Status:** live (real network and sandbox).

10.2 What is requested, with DCQL

The verifier states what it wants with **DCQL** (*Digital Credentials Query Language*). Presentation Exchange, from earlier drafts of OpenID4VP, is not supported at all in Tamga; a request carrying `presentation_definition` is rejected (PV1). For a network with no legacy burden, maintaining two query engines side by side would only have meant more attack surface.

The most concrete benefit of DCQL is being able to ask the smallest question. A cinema checking for a student discount asks only "is this a student?".

JSON Example: the smallest DCQL query for a student discount (values are illustrative)

```
{
  "credentials": [
    {
      "id": "student",
      "format": "dc+sd-jwt",
      "meta": { "vct_values": ["urn:tamga:edu:StudentCredential:1"] },
      "claims": [ { "path": ["is_enrolled"], "values": [true] } ]
    }
  ]
}
```

With this query the cinema does not see the name, the university, the department or the year of enrolment. Timur's hiring policy, on the other hand, asks for eight fields of the diploma (graduation, title, level, field code, awarding body, date, first name, family name); the grade and the thesis title do not leave the wallet, because they are not in the query. `vct_values` is an array, and verifiers are

advised to accept at least two schema versions together; otherwise a schema upgrade would leave earlier graduates out (SPEC-PROTO-0002 §4.2).

A query can also offer options (`credential_sets`: “a diploma or a student certificate”; `claim_sets`: “with a thesis first, otherwise without”). Every option is a complexity the person has to understand on the consent screen; so a request may contain at most three credentials and two `credential_sets` entries (PV9). The specification states that this limit is an estimate and will be adjusted through user testing. An optional set is not shared by default; a credential that does not carry one of the requested fields is not sent at all (PV12). A verifier asking for age from the identity credential in mdoc [34] format requests only the path `["tamga.id.1", "age_over_18"]` and sees only `true`.

10.3 The consent screen and over-asking

The consent screen is the only face the person sees, and its order is fixed by rule: who is asking (the registered name from the list and a registration mark), for what (the purpose text in the registration certificate), what will be shared (field by field, with values), what will not be shared (only the names of the fields that stay hidden), and then approve or decline (SPEC-WALLET-0001 §5.1). The fourth item is unusual. The line “Your grade average will not be shared” shows the person that selective disclosure is working; a protection that cannot be seen is, for the person, as good as absent.

What happens if a request exceeds the registered scope? There were two paths here: the wallet could block the request, or warn the person and leave the decision to them. Tamga chose to warn. The wallet is the person’s tool; the person may knowingly want to show a credential to an unregistered researcher or to a test. But the warning must actually be seen. A small grey line of text next to the approve button does not achieve this; the rule requires a separate visual block and a button that becomes active with a delay (WL8). To prevent warning fatigue, there are no warnings at all in the normal flow (Table 15).

Table 15. The wallet’s behaviour depending on the state of the request.

Situation	What the wallet does	Source
Verifier registered, all fields within scope	Normal consent screen, no warning	SPEC-WALLET-0001 §5.2
Registered, but some fields outside scope	Out-of-scope fields in a separate block and a different colour; approve button delayed by 3 seconds	WL8
Verifier not registered in the list	A separate screen that interrupts the flow: “We cannot verify who this is” → Continue / Cancel	SPEC-PROTO-0002 §6.1
No registration certificate in the request, or the certificate is invalid or revoked	Rejected without asking the person; no data is sent	ADR-0026, ADR-0056 K10, ADR-0068
The issuer’s sharing rule is not met or cannot be evaluated	A separate warning block, “Read the rule” if available; default button “Don’t share”, “Share anyway” delayed	ADR-0046
More than 3 different queries from the same verifier within 24 hours	Information for the person: “This verifier asked for 4 different credentials today”	SPEC-WALLET-0001 §5.3

The fifth row is the issuer’s voice: an institution may want a type to be shown only to certain verifiers (EU ARF [11] Topic 43). The rule was not put inside the credential; so that the credential format does not change, the rule is not exposed to verifiers and no network request is needed at presentation, it is published as a value in the institution’s signed issuance information (*Credential Issuer metadata*), and the wallet stores it together with the credential (ADR-0046). If the rule is not met, the final decision is still the person’s; a hard block was rejected because it would make the same credential behave

differently in an EU wallet. The last row makes visible a verifier mapping which credentials a person holds by means of different queries.

10.4 Response and encryption

When Aynur approves, the wallet selects only the disclosures for the requested fields and attaches a **KB-JWT** (*Key Binding JWT*, the device-binding signature) to them. The KB-JWT is signed with the device key the credential is bound to and ties three things together: the verifier's full client identifier (`aud`, including the prefix; PV7), the request's single-use value (`nonce`) and the hash of the string sent (`sd_hash` computed as in Chapter 8). A recorded presentation can thus be replayed neither to another verifier nor in another request of the same verifier.

> TECHNICAL DETAIL
>
> **Why the single-use value is 128 bits, and how the binding is built in mdoc**
>
> The `nonce` and `state` in the request are random values of at least 128 bits (SPEC-PROTO-0002 §3). The probability of an attacker hitting the right value in a single attempt is:
>
> $$P = 2^{-128} \approx 2.9 \cdot 10^{-39}$$
>
> In the mdoc format the same binding is provided by the session transcript (*SessionTranscript*) on which the device signature is built. According to OpenID4VP 1.0 Annex B.2.6.1, the transcript hashes together the client identifier, the `nonce`, the RFC 7638 [24] fingerprint of the key the response is encrypted to, and the response address:
>
> $$\text{SessionTranscript} = [\text{null}, \text{null}, [\text{OpenID4VPHandover}, \text{SHA-256}(\text{CBOR}([\text{client_id}, \text{nonce}, \text{jwkThumbprint}, \text{response_uri}]))]]$$
>
> A device response carried over to another request is rejected at step A6 of verification (PV11).

A presentation carries personal data. That is why the response is always encrypted: it is sent to the response address as a JWE to the verifier key in the request object (`ECDH-ES`, `A128GCM` or `A256GCM` HAIP §5) (`direct_post.jwt`). Unencrypted response modes are never used (PV3). Transport-layer encryption is not enough; a reverse proxy, firewall or logging system in front of the response address could see the content. The response endpoint gives a valid response only a redirect address; nothing else is returned (OpenID4VP 1.0 §8.2).

If Aynur chooses not to share, the wallet says only "declined" (`access_denied`) and does not say why (PV5). If the difference between "the person does not have this credential" and "the person did not want to share it" leaked to the verifier, the verifier could work out, by querying, which credentials the person holds. The steps below and Figure 15 show the whole flow.

1	`Timur's server`	**Open a presentation.** Produces DCQL from the policy and prepares the request object with single-use values; only the address goes into the QR.	$\text{nonce}, \text{state} \leftarrow \text{random}_{\geq 128\ \text{bit}}$
2	`Wallet → Verifier`	**Fetch the request.** Downloads the signed request object from the address; each fetch is a separate branch (§10.5).	GET request_uri
3	`Wallet`	**Check.** Signature and chain, the list entry for the client identifier, the registration certificate and its status, the sharing rule, the scope.	$\text{client_id} \stackrel{?}{=} \text{entry.client_id}$
4	`Aynur`	**Approve.** Sees on screen who is asking, for what and for which fields; approves with the device biometrics or passcode.	user verification

5	`Wallet`	**Build the response.** Selects only the requested disclosures and signs the KB-JWT.	$\text{aud} = \text{client_id}, \quad \text{sd_hash}$
6	`Wallet → Verifier`	**Send.** Encrypts the response with the verifier's key and sends it to the response address.	$\text{JWE}(\text{vp_token})$
7	`Verifier`	**Verify.** Decrypts the response and runs the verification pipeline (Chapter 11); gives the result as one of three values.	$\text{T0} \rightarrow \text{A} \rightarrow \text{B} \rightarrow \text{C} \rightarrow \text{D} \rightarrow \text{E}$

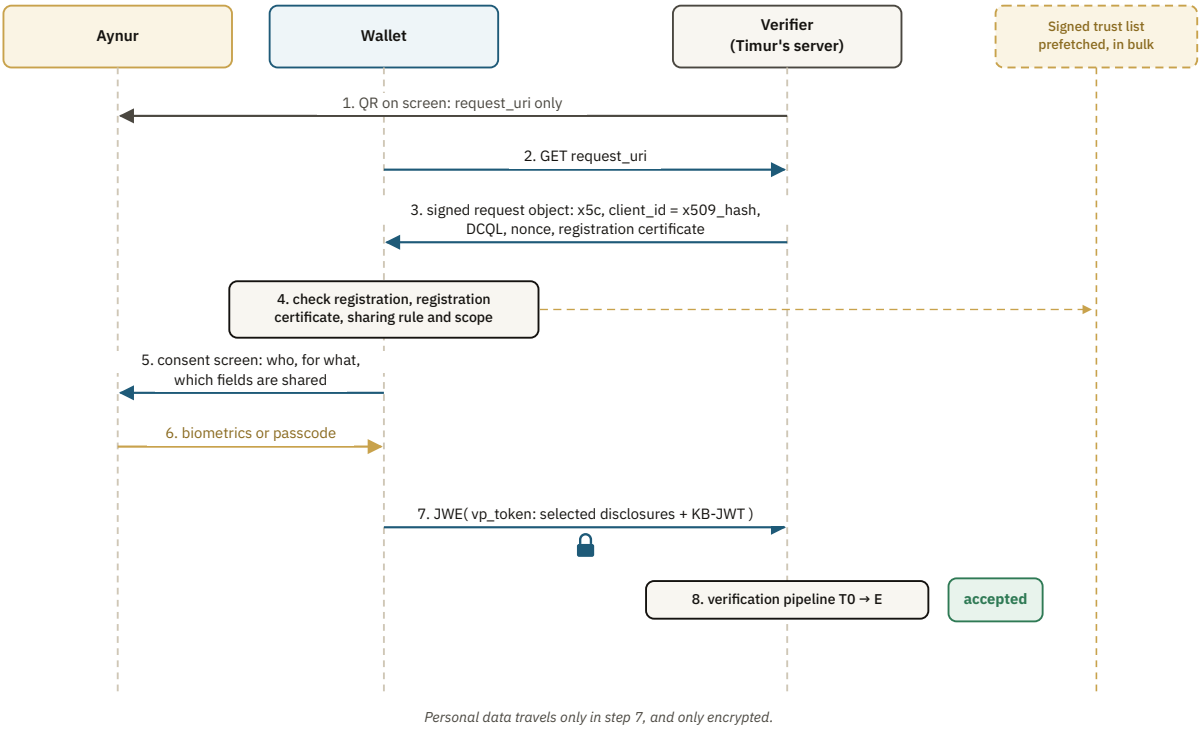


Figure 15. Remote presentation: signed request, consent and encrypted response

10.5 Fetch branches against a fake decline

A gap closed on 2026-10-29 illustrates a blind spot of the standard well. In OpenID4VP 1.0 the wallet's decline response is unsigned and may be sent unencrypted; the only thing that ties a decline to a presentation is the `state` value. In Tamga the `state` was in the signed request object, and the request object could be fetched by anyone from the address in the QR code, without authentication. Someone who saw the QR code on Timur's screen from the next desk could fetch the object, send a fake "the person declined" response and spoil Aynur's application. No personal data would leak, but the transaction would be blocked.

The solution is to open a new **fetch branch** at every fetch of the request address (ADR-0067). Every fetch receives a request object re-signed with the same content; but the `state`, the `nonce` and the response encryption key are fresh in every branch. A person who sees the QR code learns only the `state` of their own branch. Their fake decline closes only their own branch; Aynur's wallet completes the presentation in its own branch. A presentation as a whole counts as declined only if it has a single fetch and that branch has been closed; if there are several fetches, it stays open until it expires, and the first valid presentation wins (Table 16).

Table 16. Options considered for the fake decline problem (ADR-0067).

Option	Outcome	Why
The first decline closes the presentation (common practice)	rejected	Anyone who sees the QR code can spoil the real person's transaction
The wallet signs the decline with the device key	rejected	Non-standard; ties the decline to the device it came from in the eyes of the verifier, and conflicts with the principle that "the reason for declining does not leak"
A decline never closes the presentation	rejected	In the normal flow, when the person says "I declined", the verifier waits until expiry
Each fetch a separate branch, a decline closes only its own branch	**chosen**	Stays within the standard; a stricter counterpart of HAIP's "ephemeral key for every request" rule

Branches have a memory cost. The fixed limit in the first design (10 branches per presentation) was itself a way of blocking; today a fetch beyond 10 replaces the oldest branch that has received no response and is at least 120 seconds old, at 32 the age condition is dropped, and a branch whose response has been processed is never discarded. Responses that fail to reach proof of possession are counted per branch, and at the fifth only that branch is closed. The remaining risk is on record: someone who fetches the QR code before the real wallet and declines at once can close a single-branch presentation; this is a known limit of the cross-device flow (OpenID4VP 1.0 §14), and the verifier opens a new presentation. **Status:** live (since packages 0.7.4) (Figure 16).

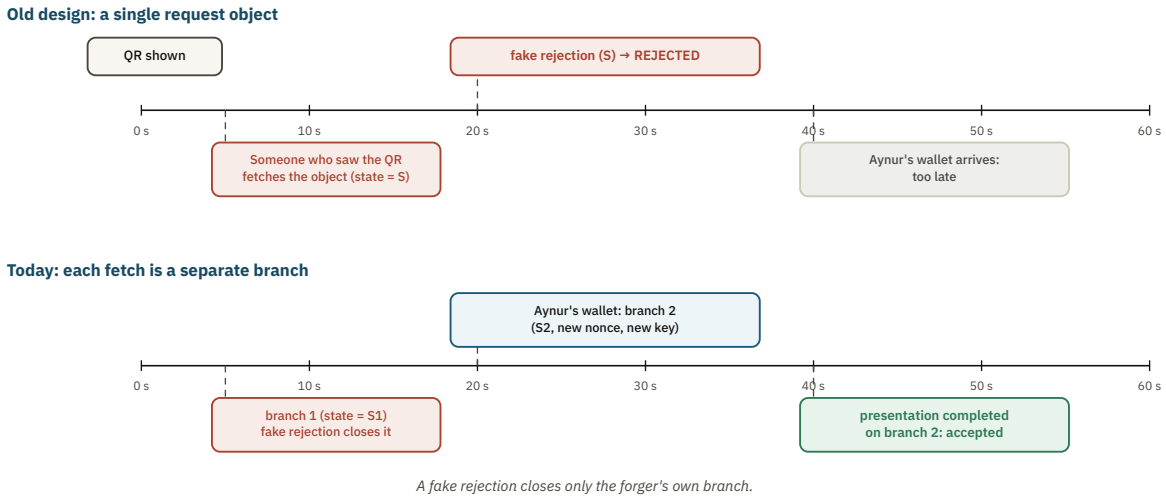


Figure 16. The fake decline attack and fetch branches

10.6 Presentation from the browser

Had Aynur applied from her phone, on the company's website, there would have been no need for a QR code. The W3C's **Digital Credentials API** [36] lets the browser call the wallet directly; the response mode is `dc_api.jwt` (OpenID4VP 1.0 Annex A). This path has a strong side: the target of the presentation is the origin (*origin*) value that the browser itself provides. A fake site cannot claim an origin other than its own; this is a strong binding against phishing. But the origin alone does not say what the verifier is authorised to request. Tamga therefore uses the signed request object on this path too: the origin addresses phishing, and `x509_hash` addresses the authorisation check (SPEC-PROTO-0002 §7.2).

Some browsers do not carry OpenID4VP over this interface and request mdoc through ISO/IEC 18013-7 [35] Annex C. In that case the verifier produces a second request for the same presentation; the response is encrypted with HPKE [25] (RFC 9180), and the session transcript includes the page's

origin. On the desktop, if the browser interface is available, it is the default path; the QR code remains alongside it as a fallback. **Status:** the verifier side is live; the wallet side is planned (in the network's first wallet the Android code has been written but not yet built or tried on a device; there is no iOS; FW-ARF-0001 §2.8).

10.7 Logging in to websites

Dilnoza is a site developer and wants to put a "Sign in with Tamga" button on her site (product name ADR-0030). This flow is the same OpenID4VP request; the difference is that the site receives **a pseudonym per site** as its account key, and none of the credential values becomes an account key (ADR-0031). At registration the site sees only the fields its policy allows (for example first name and family name) and a pseudonym key specific to that site. Two different sites cannot match the same person; when the person changes phones and verifies their identity again, the same pseudonyms come back. Day-to-day login is done with the site's own passkey, and no credential field is shared. How the pseudonym is derived, the remaining risk (that the identity service could in theory derive the pseudonym) and the goal of removing it with zero-knowledge proofs are described in Chapter 15. **Status:** live.

10.8 Proximity: bridges and the target

In remote presentation the verifier shows the QR code and the wallet reads it. At a gate, a counter or in front of an official, however, the reverse is needed: the wallet shows the QR code. The ARF solves this area with ISO/IEC 18013-5. The QR code shown by the wallet is only an introduction (*device engagement*); the actual request and response run over Bluetooth or NFC, with session encryption, and the credential is in mdoc format (the ninth article of the series [74]).

Tamga has coded this target but has not yet tested it on devices. Until then two bridge paths are used (ADR-0012). The principle both rest on is this: **the single-use value for verification is produced by the party that wants to be convinced.** If the wallet shows a QR code, either a second channel is opened (ISO 18013-5) or a short time window and a replay list have to suffice. The roughly 2.9 KB a single QR code can carry is not enough for an SD-JWT [15] VC and the certificate chain; the QR code carries either a reference address or a small, signed token with no personal data.

- **B, the pass card.** The person shows their credential once, through the normal remote flow, to a registered verifier and receives a pass entitlement in return. After that, at every entry the wallet shows a 60-second signed token containing no personal data (§10.9).
- **C, the face-to-face check.** The person starts the check from the wallet; the presentation goes to Tamga Verify by the normal remote path. On acceptance, the address returned to the wallet carries a viewing key valid for five minutes; the wallet shows it as a QR code, and the official sees the result by scanning it (SPEC-PROTO-0002 §5.4). The person has approved the fields before the presentation.
- **The target, ISO/IEC 18013-5.** mdoc over Bluetooth. The reader sends the registration certificate inside the request in CBOR [29] format and signs the request with its own certificate; the wallet performs the checks of the remote flow here as well and also verifies that the reader certificate is chained to the list (SPEC-PROTO-0002 §7.5). NFC is not available at this stage.

The bridges do not imitate the standard: C is standard OpenID4VP, and B is a versioned token that is explicitly documented as non-standard. The "Show" screen is the same on all three paths; when Bluetooth arrives, only the transport behind the QR code changes (Figure 17) (Table 17).

Table 17. Presentation channels and their status today.

Channel	Who shows the QR	Mechanism	Status
Same device (link)	none	OpenID4VP, `direct_post.jwt`	Live
Cross-device (QR)	verifier	OpenID4VP, `direct_post.jwt`, fetch branches	Live
Browser (Digital Credentials API, 18013-7 Annex C)	none	OpenID4VP `dc_api.jwt` Annex C for mdoc	Verifier live; wallet planned
Pass card (B)	wallet	60 s signed token + terminal key	Live (sandbox; no gate policy on the real network today)
Face-to-face check (C)	wallet	Normal presentation + 5 min viewing key	Live (Tamga Verify)
Bluetooth (ISO/IEC 18013-5)	wallet	Engagement QR + BLE session, mdoc	Planned (coded, awaiting device testing)
NFC	—	—	Not available at this stage

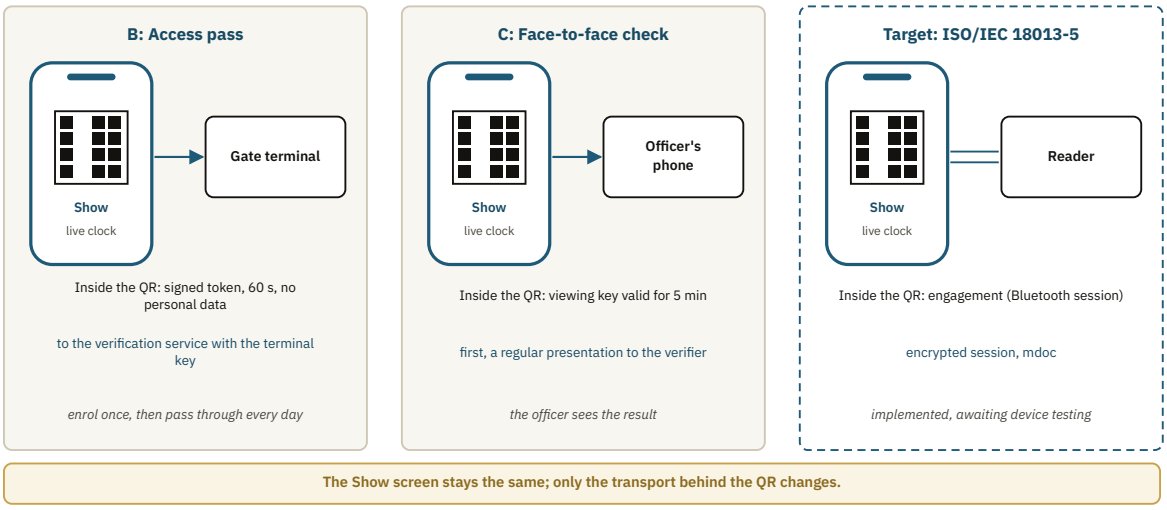


Figure 17. Three paths in proximity: the pass card, the face-to-face check and the ISO/IEC 18013-5 target

10.9 Gates and tickets

Nurlan is going to a concert. His ticket is a credential issued by the ticket seller and carries no personal data: it contains the event, the venue, the ticket class, the seat and a hash of the seller's ticket number, but no name (FW-RB-0004). The ticket is bound to a device key; Nurlan cannot copy it to his friend's phone.

Before the concert Nurlan shows the ticket once to the gate's verifier and receives a pass entitlement. At the gate the wallet signs a token and shows it as a QR code. The token contains only an opaque pass identifier, the target verifier, time fields and a replay identifier; the QR code does not exceed 400 bytes. The screen shows a live clock and a 60-second countdown; a screenshot is useless once the time runs out.

1	`Nurlan → Verifier`	**Registration.** Shows the ticket once through the normal remote flow; the verifier grants a pass entitlement only on an accepted result.	$\text{pass_grant} \leftarrow \text{ACCEPTED}$

2	`Wallet`	**Token.** At the gate, signs the short-lived token with the copy key; only the token goes into the QR.	$\exp - \mathrm{iat} \leq 60\ \mathrm{s}$
3	`Gate → Tamga Verify`	**Verification request.** Sends the token with the terminal key bound to the terminal group.	$\mathrm{Authorization:\ Bearer\ tk_...}$
4	`Tamga Verify`	**Check.** Checks the key, that the group is active in the list, the signature, the time, the replay identifier and that the ticket is unused.	$\mathrm{jti} \notin \mathrm{replay\ list}$
5	`Tamga Verify → Gate`	**Entry.** On acceptance, consumes the ticket; a second entry with the same ticket is rejected.	$\mathrm{used} = 1$

Against the same token being scanned twice, the gates of a terminal group keep token identifiers (`jti`) in a shared list. Against the same ticket being used twice, the ticket is marked "used" by a bit in the ticket status list; because the list is published at fixed intervals (Chapter 12), a second entry within the interval is stopped by the gates' shared "used" list. An offline gate checks only the time and accepts the risk that a QR code copied within 60 seconds gets through at another gate (ADR-0012 K3).

The security review of 2026-10-26 found that the endpoint the gates send requests to did not require authentication: someone who saw the QR code could submit the token themselves and consume the ticket, stopping Nurlan at the real gate. The decision is that each terminal group authenticates with a 192-bit **terminal key** obtained from the operator; a request without the key does not touch the token at all, and the server stores only the key's hash (ADR-0065). Mutual TLS and a gate certificate remain the target; distributing the private key of the access certificate to every gate device was rejected. Since 2026-10-29 gate groups sit in the signed list, under the verifier entry, together with the institution operating the gates and the accepted policies; an institution manages only the keys of its own gates, and the gates of a group withdrawn from the list stop at once (ADR-0069).

Because the organiser is both the issuing and the verifying party, unlinkability is meaningless for the ticket, and this has been accepted. The pass card does not ask for biometrics at every presentation; this rests on a time-limited (at most about 6 months) consent with a defined scope, given at registration; every presentation is written to the wallet's history, and the consent can be withdrawn at any time (WL13, WL14). **Status:** live in the sandbox; on the real network no gate policy is defined today; the field and the reader for certified and offline gate identity are ready but unused (planned).

11 The Verification Pipeline: Five Layers, Three Outcomes

Before "accepted" appeared on Timur's screen, more than thirty small checks ran in order on his server. Verifying a credential is not just a matter of "does the signature hold". The signature may be valid while the institution that signed the credential is not authorised to issue that type; it may be authorised while the credential has been revoked; everything may be in order while the verifier has received more than it asked for.

11.1 Why a fixed pipeline

Tamga ties verification to a single normative order and gives each step a permanent code (SPEC-API-0001 §1). There are three reasons for this. The first is consistency: the same credential must get the same result whichever verifier, and whichever package, verifies it. The second is explainability: instead of "verification failed" one can say "it failed at C2; the institution is not authorised to issue

this type”. The third is auditing: results are kept in audit records for years. That is why the meaning of a step code never changes; a new step gets a new code, and a removed code is not reused (AP1). If the meaning of C2 changed in 2029, the 2027 records would be misread.

The steps run in order and stop at the first failure; only the audit record (E4) is written in every case. The HTTP status code does not carry the result: a rejected credential is a successful API call and returns 200, and 4xx is only for request errors (AP5). If the two were mixed up, clients could not tell a network error from an invalid credential, and monitoring systems would mistake rejected credentials for faults.

11.2 The layers

Table 18 gives the layers and selected steps of each.

Table 18. The layers of the verification pipeline and selected step codes (full list in SPEC-API-0001 §1).

Layer	The question it asks	Selected steps
T0 Precondition	Is the trust list I hold fresh?	If the list is stale or unreachable, or the policy’s freshness limits are missing: could not be verified
A Format	Is the credential intact, signed, and does it belong to this request?	A2 header (`ES256` , `dc+sd-jwt` , `x5c`) · A3 chain reaches the root · **A3b** institution identity from the certificate · A3d device binding (`cnf`) present · A5 hash of every disclosure in the credential · A6 KB-JWT (`aud` , `nonce` , `sd_hash`) · A7 validity period
Z1 Zero-knowledge path	Is the proof valid?	Circuit on the list and file hash matches; only the requested items disclosed (Chapter 15)
B Type	Is the credential type recognised?	B2 type registered and not withdrawn · B4 hash of the type definition equal to `vct#integrity` · B6 conformance to the JSON Schema
C Trust	Is the institution on the list, and is it authorised for this type?	C1 was the institution acceptable at the moment of issuance · **C2** was the institution authorised for this type (cannot be skipped) · C3 recognition · C4 category indicator consistent with the entry
D Status	Is the credential revoked or suspended?	D2 status list from the prefetch cache · D3 list signer is the institution’s registered status key · D4 freshness · D5 matches the anchor log, version has not gone backwards · D6 bit value
E Policy	Are the verifier’s requirements met?	E1 institution class threshold · E2 requested fields disclosed · E3 registered scope not exceeded · E4 audit record written

Two steps must not get lost in the table. **A3b** derives the institution’s identity not from the credential’s `iss` field but from the fingerprint of the signing leaf certificate. Why this matters is seen through an attack: if the verifier read the identity from `iss` , any institution with a valid certificate under the same root could write another university’s address into the `iss` field and produce credentials in its name. The signature would be valid with its own certificate, the chain would be valid, and `iss` would be forged. `iss` is therefore used only in a consistency check (AP12). How the identity is derived is in Chapter 6.

C2, for its part, cannot be skipped by any configuration (AP8). A verifier may relax its policy as much as it likes, but it cannot switch off the question “was this institution authorised to issue this credential type”. If it could, every institution on the list could pass off any kind of credential as valid.

The packages implement this order in a single function and do not allow security inputs to be forgotten. If the trust anchor, the verifier entry or the status list signer is not supplied, the function rejects; anyone who wants to skip a check deliberately has to write it with an explicit `"none"` value, and

the skipped step appears in the result (ADR-0056 MR1). Forgetting now means rejection; skipping deliberately is a decision written in the code and visible in review.

11.3 Time-bound authorisation

C1 and C2 ask about the moment of issuance: was the institution active in the list and authorised for this type at the credential's `iat` (AP11)? If instead the question were "can the institution issue credentials today", two silent errors would follow. All the diplomas a closed institution had issued earlier would appear invalid overnight. When a type moved to a new version and the old one was withdrawn, every credential issued with the old version would be rejected. Even a planned certificate renewal would knock credentials out. Verification is a retrospective operation: the credential was issued in the past, and what is decisive is the state on that day (FW-ARF-0001 §4.4).

This rule has a limit, and that limit is revocation. If the institution was authorised on the day the credential was issued, the credential passes layer C; but if the credential was later revoked, it fails at layer D. The time axis looks back for trust and to the present for status.

11.4 The three-valued outcome

The outcome of the pipeline is one of three values: **accepted** (`ACCEPTED`), **rejected** (`REJECTED`) and **could not be verified** (`INDETERMINATE`). The third is not a verdict; it says that the infrastructure could not be reached or that the information is stale. The difference between "this diploma is forged" and "I cannot check right now" is whether or not a person gets hired. That is why the could-not-be-verified outcome is not put in the same bucket as a rejection and is shown separately in the user interface (AP2). The reason for a could-not-be-verified outcome comes in a mandatory field: the type definition could not be reached, the status list could not be reached, the status list is stale, the value in the status list has no defined meaning, the trust list is stale, and so on.

TECHNICAL DETAIL

How the outcome is combined

Let us write the steps of the pipeline in their fixed order as $s_1, s_2, \ldots, s_n$ (T0, A1 … E3). The output of each step is "passed", "rejected" or "could not be verified". Because the pipeline stops at the first failure, the outcome is the output of the first step that does not pass; if there is none, it is accepted:

$$k^* = \min(k : s_k \neq \text{passed})$$

$$\text{outcome} = s_{k^*} \quad (\text{ACCEPTED if no such step exists})$$

This rule has a consequence: if the trust list is stale (T0), the outcome is could not be verified and the later steps do not run at all; even if the credential is forged, it is not called "rejected". A rejection given with a stale list could also reject the correct credential of an institution newly added to the list. An unexpected software error likewise yields could not be verified under the same rule, not a rejection.

Two things never appear in the result object. The **values** of the disclosed fields do not go into the result object, only their names (AP3); the values are obtained from a separate endpoint, with separate authorisation. The position in the status list (`idx`) appears in no response and no record (AP4). The result object is written to the audit record and kept for a long time; these two rules keep that record from turning into a tracking tool.

JSON Example: a shortened result object; no values, no idx (values are illustrative)

```json
{
  "verification_id": "vrf_01J8XKQ2M4",
  "outcome": "ACCEPTED",
  "failed_step": null,
  "indeterminate_reason": null,
  "spec_version": "SPEC-API-0001@1.0.0",
  "sdk_version": "@tamga-network/verifier@0.8.2",
  "checks_performed": ["T0", "A1", "A2", "A3", "A3b", "…", "D6", "E1", "E2", "E3", "E4"],
  "checks_skipped": [],
  "issuer": { "issuer_id": "0x7f3a…", "state_code": "TR", "category": "EDUCATION", "assurance": "I2" },
  "schema": { "vct": "urn:tamga:edu:DiplomaCredential:1", "status": "ACTIVE" },
  "disclosed_claims": ["is_graduate", "qualification_title", "eqf_level", "isced_f_code",
                       "awarding_body_name", "awarding_date", "family_name", "given_name"],
  "status": { "value": "VALID", "token_age_sec": 1830 },
  "evaluated_at": "2026-11-04T09:12:44Z"
}
```

If `checks_skipped` is not empty, the verifier must make this visible; silently accepting that a check was skipped defeats the purpose of skipping it (Figure 18).

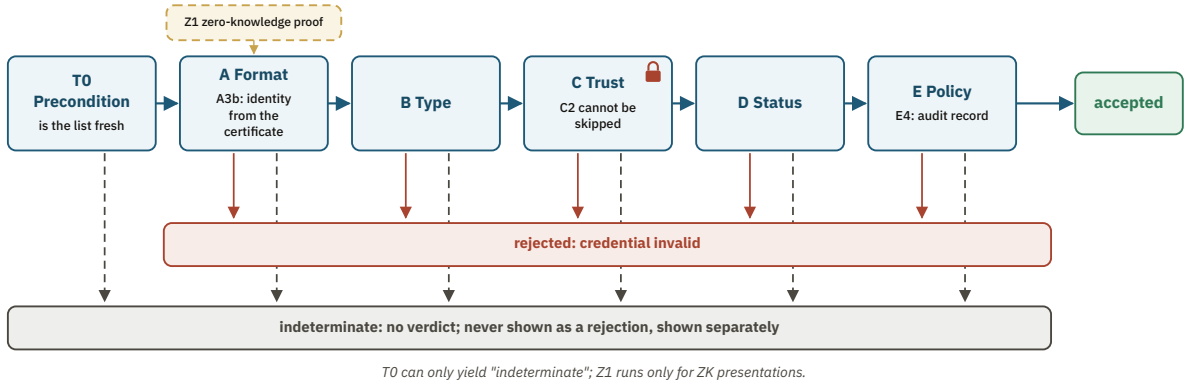


Figure 18. The verification pipeline: six gates, three exits

11.5 The hosted verifier

Every verifier can run this pipeline on its own server; the packages are open, and the values pass through no intermediary. For those who do not want to set up their own infrastructure, the verifier hosted by the network is **Tamga Verify** (ADR-0030). An intermediary brings a new risk, and this risk was narrowed with ADR-0017. In the first design the value endpoints answered anyone who knew the presentation identifier; the identifier could show up in browser history or during screen sharing. Today every endpoint that returns values is open only to the verifier that opened the presentation. The verifier proves its identity with a non-replayable statement, valid for at most 60 seconds, signed with the key of the access certificate registered in the list; no new secret is needed. Values are read once and deleted from memory after five minutes at the latest; no token sent to the browser carries the right to read values (ADR-0017 HV1–HV5). A static API key per site, a separate OAuth server and mutual TLS were not chosen because they give the same assurance with more secrets or more operational burden. When Tamga Verify opens a request on behalf of a verifier, the wallet shows the registered name of the **actual verifier**, indicates the intermediary separately and checks the scope against the actual verifier's entry; if the intermediary relationship is not written in both entries, the request is rejected (PV14). **Status:** live.

12 Revocation and Lifecycle

Elif works in the student affairs office of Example University. One morning a letter arrives: a graduate's thesis is suspected of plagiarism. The review will take weeks. If Elif had only two bad options, she would either revoke the diploma permanently and perhaps unjustly, or do nothing until the review

ends. This section explains how a credential is later withdrawn or suspended, and why this has to be done without tracking anyone. The groundwork for the topic was laid in the seventh paper of the series [72].

12.1 Withdrawing without tracking

For an institution to be able to say “this credential is no longer valid”, the verifier has to look somewhere. The easiest way is to ask the institution at every verification; but then the institution learns which employers its graduates applied to and when, and a tracking channel appears that the paper diploma never had.

Tamga’s answer is the IETF **Token Status List** draft [17] (revocation list, status list; the network follows draft-20, the version the EU fixed with 2026/1731 [7]; SPEC-CRED-0003). The institution gives each credential a random position in a large bit array. When the credential is revoked, the value at that position changes. The array is compressed, signed and published at fixed intervals. The verifier downloads the array in advance and, when it sees the credential, checks its own copy without asking anyone. The institution cannot learn where or when the credential was shown.

TECHNICAL DETAIL

Reading the status of a credential

The credential carries its position (`idx`) and the address of the list (`uri`) in `status.status_list` this field cannot be hidden by selective disclosure. The list uses b bits per credential (1 or 2 in Tamga). The credential with the smaller index sits in the least significant bit of the byte. If we write $D[n]$ for the nth byte of the decompressed array:

$$n = \left\lfloor \frac{i \cdot b}{8} \right\rfloor$$

$$k = (i \cdot b) \bmod 8$$

$$\text{status} = \left\lfloor \frac{D[n]}{2^k} \right\rfloor \bmod 2^b$$

With example values, a diploma at position 48213 in a two-bit institution list:

$$i \cdot b = 48213 \cdot 2 = 96426$$

$$n = \left\lfloor \frac{96426}{8} \right\rfloor = 12053, \quad k = 96426 \bmod 8 = 2$$

$$\text{status} = \left\lfloor \frac{D[12053]}{4} \right\rfloor \bmod 4$$

If the same position were in a one-bit identity service list, we would have $n = \lfloor \frac{48213}{8} \rfloor = 6026$, $k = 48213 \bmod 8 = 5$ and a single bit would be read. The size of the list is also easy to compute. With the minimum capacity of 100,000 positions:

$$2 \text{ bits:} \quad 100.000 \cdot 2 = 200.000 \text{ bits} = 25.000 \text{ bytes}$$

$$1 \text{ bit:} \quad 100.000 \cdot 1 = 100.000 \text{ bits} = 12.500 \text{ bytes}$$

Since the list consists largely of zeros, its compressed size is typically a few hundred bytes (SPEC-CRED-0003 §3.3).

Figure 19 follows the same example from the credential down to the bit.

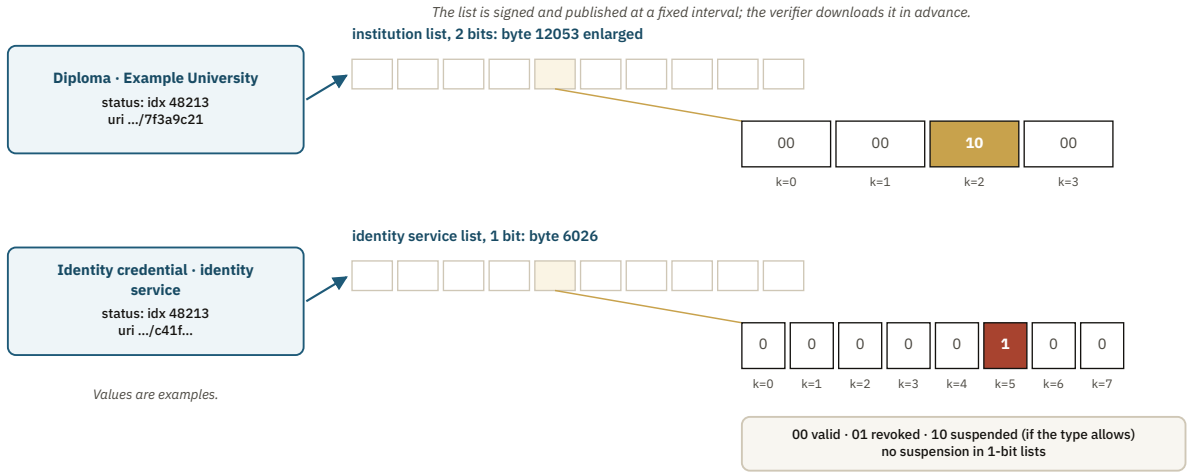


Figure 19. Revocation list: from credential to position, from position to bit

12.2 Why not on the chain

The first form of this decision grew out of a contradiction. In the repository audit of 2026-09-09 the specification said “the list is off-chain, the pointer is on-chain”, while the contract code kept the bit array on the chain and every revocation was a chain transaction. ADR-0008 resolved the contradiction in favour of the off-chain list. The main reason is privacy. In a permissioned ledger every transaction is visible to every validator node, together with a timestamp. The fact that “this university revoked the credential at this position on this day at this hour” does not name a person on its own. But combined with this timestamp, the date of a disciplinary decision, the day someone left a job or the closure of a department narrows it down to a person (Table 19).

Table 19. Options considered for where the revocation list lives (ADR-0008).

Option	Result	Reason
Bit array entirely on the chain	rejected	The moment of revocation leaks to all nodes; permanent chain state grows; departs from the standard’s transport model
Revocation with a cryptographic accumulator or zero knowledge	deferred (research)	Strongest privacy; but no mature libraries and no wallet support
Short-lived credential, no revocation	partly adopted	Right for the student certificate (at most 90 days); wrong for a diploma with no expiry
Urgent revocation on the chain, ordinary revocation off it	rejected	A revocation written to the chain is precisely the most sensitive one; it concentrates the leak
Signed list off the chain, only its digest anchored	**chosen**	The moment of revocation is invisible; the standard’s own model; the verifier caches aggressively

Cost pointed the same way. A one-bit list of 100,000 positions is 12.5 KB; for about 200 higher education institutions this comes to 2.5 MB of permanent chain state, and every revocation is a transaction (ADR-0008). Today the anchor is the list publisher’s anchor log; if a shared ledger arrives, only the digests of the publications will be written to it (Section 19).

12.3 Bit size and suspension

The standard allows 1, 2, 4 or 8 bits per credential. Tamga uses two values, and the meaning of the type decides which one is used (ADR-0048) (Table 20).

Table 20. Status values and the types in which they are used.

Value	Standard name	Meaning in Tamga	Where
`0x00`	VALID	Valid	All lists
`0x01`	INVALID	Permanent revocation; no way back	All lists
`0x02`	SUSPENDED	Temporary suspension; can be lifted	Only in 2-bit institution lists and only for types whose schema allows suspension (today, the diploma)
`0x03`	reserved	Not used; rejected if read	—

The identity service's types (the identity credential, driving licence information, the e-mail and phone credentials) are published with 1-bit lists and have no suspension. This is an alignment with the EU rule for person identification data (PID): Annex II of Regulation 2024/2979 [5], as amended by 2026/1731, defines PID status only as "revoked / not revoked". Tamga's identity credential is not a PID, but it uses the names of the EU PID and is the type closest to being replaced by a state's PID when one arrives. Nor does a situation arise in which an identity would be called "temporarily invalid during a review"; when in doubt the credential is revoked and the person is verified again.

Institution lists are 2-bit; suspension, however, is used only in types whose schema says `suspension_allowed: true`. This is where Elif's problem is solved: she suspends the diploma for the duration of the review, and when the review ends she either lifts the suspension or turns it into a revocation. The Institution Console shows the "Suspend" button only for these types. Granting suspension per type rather than per institution is deliberate; suspension depends on the meaning of the type, and the schema states the same rule for everyone.

If the credential was also issued as an mdoc [34], the same logical list is published in two representations, at separate and opaque addresses: the SD-JWT [15] copy points to the JWT representation, the mdoc copy to the CWT representation. Both representations carry the same bits and are signed with the same key in the same cycle; this way an mdoc reader does not have to carry a JWT parser.

12.4 Privacy rules

The privacy benefit of the revocation list can easily be broken in a few places. The specification closes these places one by one (SPEC-CRED-0003 §5–§6, §9).

- **The position is random.** The position is visible in every presentation; if it were assigned sequentially, the order of graduation and the time between two graduates could be read from it, and the date hidden by selective disclosure would leak.
- **Capacity is large.** Every list has at least 100,000 positions and is filled to at most 80%.
- **The address is opaque and lists are split only by type.** An address like `…/edu-2026-a`, or an arrangement such as "2026 graduates are in list A", would itself reveal the hidden year of graduation; the address is a meaningless string such as `…/7f3a9c21`.
- **Fetching per verification is forbidden.** The verifier obtains lists by scheduled bulk prefetching; the packages do this by default.
- **The list signer is pinned.** The revocation list is signed with a key separate from the credential key; before checking the signature, the verifier pins the signer to the institution's registered status key in the list (ADR-0056 K6). Even if this key is compromised, no forged diploma can be produced.

TECHNICAL DETAIL

What a random position hides and what it does not

With sequential assignment, the order of two credentials' positions always matches the order in which they were issued. With random assignment this link is broken. Let credential A be issued before B; when positions are chosen independently and uniformly from the capacity:

$$\text{sequential:} \quad P(\text{idx}_A < \text{idx}_B) = 1$$

$$\text{random:} \quad P(\text{idx}_A < \text{idx}_B) = \frac{1}{2}$$

So someone looking at the order of positions cannot guess better than a coin toss. The bit of an unused position is the same as the bit of a valid credential (`0x00`); an outside observer cannot even see how many credentials are in the list. For this reason an initial noise rule that tried to make empty positions look "occupied" was removed on 2026-10-09, since it gave no observable protection.

There are two things a random position cannot hide. The first is the institution itself: a college with 300 graduates means 300 occupied positions in a list of 100,000; the list is large, but the "crowd" is limited to the institution, and the `iss` field names the institution anyway. This is a limit accepted in the specification. The second is repeated presentation of the same credential: the position and address are fixed within a copy, so two verifiers that see the same copy can link it if they collude. The solution is to show each verifier a separate copy with a different position (§13.4, Section 9).

12.5 Freshness and time to take effect

The list is published at a fixed interval whether or not anything has changed; today this interval is **2 minutes**. If it were published only when there was a revocation, the appearance of a new version would mean "a revocation happened in this minute". Nor is there an off-cycle "urgent" publication; in an emergency the right tool is suspending the institution or revoking its certificate (SPEC-CRED-0003 §5.3). ADR-0008 had proposed an interval of one hour; the specification chose a short interval, so that revocations become visible within a few minutes, together with a long validity, to withstand outages (with the approval of project management, 2026-10-09).

The list token has two time fields. `ttl` is how long the verifier may wait before fetching a new one, and equals the publication interval (120 seconds). `exp` is the token's hard end: **6 hours** after publication. If the status server goes down, the verifier keeps verifying with the last list it holds for up to 6 hours; the result does not drop straight to could-not-verify.

TECHNICAL DETAIL

When a revocation takes effect

A revocation first waits for the next publication, then for the verifier's next prefetch. If the publication interval is Δ_{publish} and the prefetch interval is Δ_{prefetch}, the worst-case delay is:

$$t_{\text{effective}} \leq \Delta_{\text{publish}} + \Delta_{\text{prefetch}}$$

If the publication interval is 120 seconds and the verifier fetches at the `ttl` interval as recommended:

$$t_{\text{effective}} \leq 120 + 120 = 240 \text{ s} = 4 \text{ minutes}$$

If the verifier fetches the list every five minutes, the bound becomes $120 + 300 = 420$ seconds, that is seven minutes. On the outage side the window is $\text{exp} - \text{iat} = 6 \text{ h} = 21.600 \text{ s}$; this is the same as the maximum token age in the reference policies (`max_status_token_age_sec = 21600`).

A verifier can be stricter, depending on its risk. Suppose a token was published at 09:00 and the verification takes place at 10:30:

$$\text{age} = 1.5\ \text{h} = 5.400\ \text{s}$$

A low-risk verifier (limit 21,600 s) verifies with this list. A high-risk verifier such as an official procedure (limit 600 s), in the same situation, says “could not verify, list is stale” and waits for the new list (SPEC-CRED-0003 §8.2).

The long `exp` has a price, and that price has been calculated too. Someone who controls the network path can hide a revocation for at most 6 hours by presenting an old but signed token. The anchor check narrows this window: the digest of every publication is written to the anchor log, and the verifier checks that the version of the token it holds has not gone backwards (D5). If the prefetch happened before the anchor, the result is could-not-verify; if after, rejection. This also catches an institution that quietly shows a credential it has revoked as “valid” again on its own server (Figure 20).

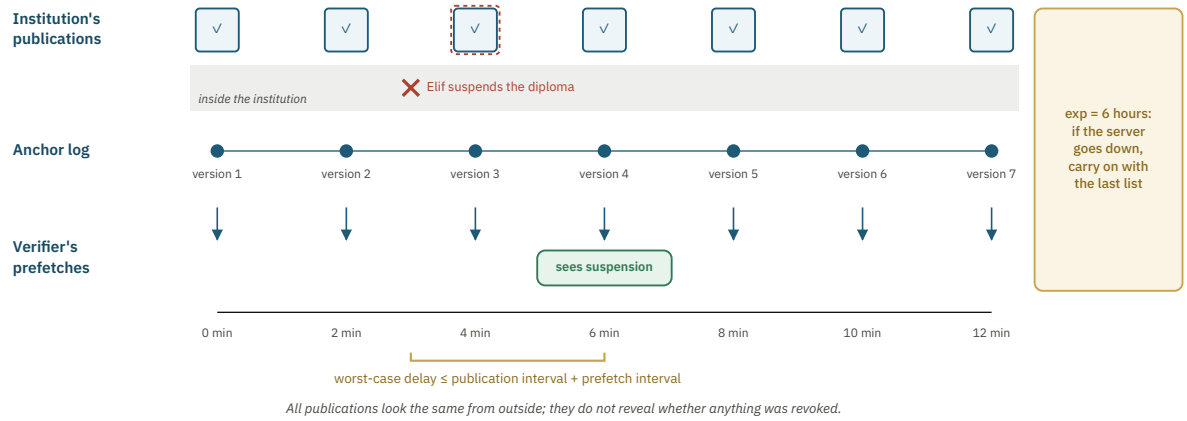


Figure 20. Publication cycle: a fixed interval, whether or not anything has changed

12.6 Revocation policy

Who may revoke, and under what conditions, is collected in a single policy document (FW-POL-0001; EU ARF [11] VCR_05). The policy sets no new rules; it compiles the rulebooks of the types and the decisions. Common conditions apply to every revocable type: the person withdraws consent, the person objects to the notification “your credential was added to a wallet”, the credential was issued in error, a new copy set of the same type is issued to the same person (the old set is revoked), and the institution’s signing key has leaked. Type-specific conditions are written down as well: for the diploma, forgery or a court decision; for the ticket, a refund, cancellation of the event and passage through the gate; for the identity credential, the person’s request for deletion or a report that the credential was lost.

The policy also lists what is **not** a reason for revocation, and this list is at least as important as the first. Suspending an institution or removing it from the list does not invalidate its earlier credentials; it only stops new ones from being issued. Neither an institution’s certificate renewal nor a credential type moving to a new version revokes credentials (§11.3). Only the issuer revokes a credential; the network’s operator does not revoke credentials, and if necessary it suspends the institution.

An institution may, if it wishes, publish its own additional conditions on its own page; the link sits in the `revocation_policy_uri` field of its entry in the trust list, and the wallet shows it on the institution’s page. Additional conditions cannot narrow the common policy, only add to it (ADR-0047 K2).

The reason for revocation does not appear in the list or in the credential; the list carries no personal data and no record keeps position information. The institution’s API answers a revocation request

with “queued, effective from this moment”; there is no instant revocation and the API says so explicitly, so the caller’s expectation is set correctly from the start (SPEC-API-0001 §5.3).

12.7 Wallet unit revocation

When a phone is lost, what should be revoked? The EU ARF makes it mandatory for the PID provider, and optional for others, that issuers revoke their own credentials when a wallet unit is revoked. Tamga’s rule is this (ADR-0047 K1): the identity service checks the unit within 24 hours at the latest and revokes its own credentials on that unit; institution credentials are not revoked.

Institution credentials nonetheless become unusable: every copy is bound to a non-exportable device key and every presentation requires user verification; no institution issues a new credential or a refresh to a revoked unit; a wallet that sees the revocation deletes its credentials; short-lived types end when they expire. Cascading revocation, on the other hand, would require writing a wallet identifier into every credential record. The remaining risk is recorded: someone who obtains both the phone and the unlock credentials can, as long as the phone does not connect to the network, show an institution credential that has not yet expired; for this, the person asks the institution to revoke it. Cascading revocation would not close this risk, because a phone that does not connect to the network does not learn of the revocation either. Revoking the unit without the phone is covered in Section 13.5.

13 The Wallet: Rules, Keys and Attestations

The value of Aynur’s diploma depends on a key in her phone. If the key could be copied elsewhere, the diploma could be copied too; if the key were lost, the diploma could not be shown. This section explains how a wallet is recognised in the eyes of the network, where and how it keeps its keys, how it proves this to the issuer, and the control the person has over their own data. The general framework of wallet security is in the tenth paper of the series [75].

13.1 How the network sees the wallet

Tamga Network operates no wallet’s application, wallet provider or website (ADR-0042). The network’s relationship with wallets consists of three things: rules (SPEC-WALLET-0001, Tamga ARF), open packages (`@tamga-network/wallet-core` and the others) and the **wallet provider** entry in the trust list (`wallet_providers[]`: address, attestation signing certificate, solution name). In the EU, too, each wallet is operated by the organisation that offers it; the trust framework only lists the providers. Having the network host a provider of its own was considered and rejected, because it would compromise the network’s neutrality and, when the network is handed over to the foundation, would leave a wallet’s service tied to the network.

A wallet enters the list in four steps (FW-ONB-0001 §4): the wallet solution declaration (platforms, secure hardware level, PIN and biometrics, backup model), the provider agreement (attestations, update and revocation periods, holding no recovery key), conformance tests, and entry into the list. A wallet developer first registers its provider in the sandbox list and tries its wallet with the example institutions there. The first wallet to enter the list, Tamga Wallet, is a separate product and entered by this route, on the same terms as every wallet. The network’s interfaces refer to the wallet by a generic name; when a wallet’s name is needed, it comes from the registration data in the list (ADR-0042 NW4).

13.2 Key architecture and levels

The wallet specification begins with the resolution of a contradiction (SPEC-WALLET-0001 §1). The credential key was never supposed to leave the secure area; yet the early project notes contained

the idea of “backup with a 24-word seed”. If the seed brings the wallet back in a usable state, it brings back the keys as well. Deriving the keys from the seed was tempting, but it would rot the device binding: if the seed can be shared, the credential can be transferred, and the loophole closed at issuance, “having the student certificate taken into a friend’s wallet”, reopens at the moment of recovery. The platforms’ keys synchronised across devices were rejected too; trust shifts to the Apple or Google account, another device on the same account can obtain the key, and the EU does not count this class as the highest wallet level.

Decision: holder keys are not derived from the seed and never leave the secure area (WL1); the backup carries the credentials and their list, not the keys (WL2). A credential restored on a new phone can be read but not shown, and is obtained again from the institution; the seed’s job is to offer the person a one-tap list saying “request these four credentials again”. Under no circumstances does the network or the provider hold a recovery key on the person’s behalf (WL10); if it did, a centre able to open every wallet would come into being (Table 21).

Table 21. Wallet assurance levels (SPEC-WALLET-0001 §2.2, FW-ARF-0001 §6.5).

Level	Key store	Place in the network	Device attestation
W1	Software	Not supported; no credentials are issued (only the network’s own test key in the sandbox)	—
W2	The device’s secure area (Secure Enclave, StrongBox, at least TEE)	Today’s minimum level	Optional; the provider’s decision
W3	Certified secure hardware	In the state stage	Mandatory (ADR-0047 K5)

Every presentation requires user verification (WL11). On a device with a secure hardware key, the credential key is bound to the phone’s lock, and approving a presentation is the operating system’s biometric or device passcode prompt; the application’s settings cannot turn this off. If the person dismisses the prompt there is no fallback; the presentation is not made. This prevents an unlocked wallet from quietly making presentations in the background.

TECHNICAL DETAIL

Calculating the PIN limits

The application PIN has at least 6 digits; after 5 wrong attempts there is a 30-second wait, and after 10 the wallet locks and the seed is needed (SPEC-WALLET-0001 §2.3). The probability that someone who has taken the phone finds the PIN by random guessing before it locks:

$$P_{\text{guess}} \leq \frac{10}{10^6} = 10^{-5} = 0.001\%$$

This limit also has a price: the same person can lock the wallet by entering a wrong PIN 10 times. The specification records this as an accepted risk; the alternative is leaving the PIN open to brute force.

13.3 WIA and KA

Before issuing a credential, the institution wants to know that the application in front of it is a wallet recognised in the list and that the keys are kept in secure hardware. In the first design, the wallet showed a single attestation valid for 30 days to every institution; institutions could link the same wallet to one another, and the attestation had no revocation path. Tamga replaced this with the EU’s TS3 [12] model (ADR-0025).

- **WIA** (*Wallet Instance Attestation*) identifies the wallet itself. Its lifetime is shorter than 24 hours and **a new one is obtained for every issuance**: with a new possession key and a new, unlinkable

entry in the revocation list. The option of reuse per institution was deliberately not taken; had it been, the provider would learn how many institutions the wallet deals with.

- **KA** (*key attestation*) states in which store and with which user verification the credential keys are protected. It carries all the credential keys of a batch and is used once. Its revocation is done through one shared entry per key store **type** this way the identity of the unit cannot be derived from the KA.

HAIP 1.0 [32] §4.4.1 adds another rule: the WIA's "who" field (`sub`) must be a value shared by all instances that use the same wallet solution. In Tamga this is the name of the solution; it carries no phone-specific value (ADR-0034 CI6). What the institution sees points to the solution, not to the person.

JSON Example: the abridged content of a WIA; the field structure is simplified (the values are examples)

```json
{
  "iss": "https://saglayici.example",
  "sub": "ornek-cuzdan-cozumu",
  "iat": 1795000000,
  "exp": 1795082800,
  "wallet_name": "Örnek Cüzdan",
  "wallet_version": "1.4.0",
  "cnf": { "jwk": { "kty": "EC", "crv": "P-256", "x": "…", "y": "…" } },
  "client_status": {
    "status": { "status_list": { "idx": 5127, "uri": "https://saglayici.example/status/wia/3" } },
    "exp": 1800184000
  }
}
```

TECHNICAL DETAIL

The WIA's lifetime and unlinkability

With the values in the example, the WIA's lifetime and the revocation maintenance period are calculated as follows:

$$\exp - \mathrm{iat} = 1.795.082.800 - 1.795.000.000 = 82.800\ \mathrm{s} = 23\ \mathrm{h} < 24\ \mathrm{h}$$

$$\mathrm{client_status.exp} - \mathrm{iat} = 5.184.000\ \mathrm{s} = 60\ \mathrm{days} \geq 31\ \mathrm{days}$$

23 hours is the lifetime Tamga chose, and 60 days is the ordinary maintenance period; if an institution announces a longer period, the provider grants it up to its own upper limit. The unlinkability rule is a single line: if i and j are two separate issuance transactions,

$$\mathrm{cnf}_i \neq \mathrm{cnf}_j \quad \text{and} \quad \mathrm{idx}_i \neq \mathrm{idx}_j$$

That is, two institutions see no shared key and no shared revocation entry in attestations coming from the same wallet. The WIA and KA revocation lists each have at least 10,000 entries (Annex Ib of Regulation 2024/2979 [5]); an institution does not accept an attestation that relies on a list below this limit.

Before issuing a credential, the institution checks the WIA's signature, that the provider is in the list, the validity period, the proof of possession and the revocation status; at the credential endpoint it checks the KA and that the key store level meets its own minimum. No credential is issued with a revoked WIA or KA (ADR-0025 WIA4). Nor is a credential issued to the wallet of a provider that is not in the list.

The most important rule of the KA is the rule "the level tells the truth" (ADR-0025 WIA3): an unverified claim is not written into the KA. Device attestation (Apple App Attest, Android key attestation, Play Integrity) is the source of this truth. The network's rule makes device attestation mandatory only at the highest level: before every KA that declares W3, the provider verifies the device attestation; at W2 this is the provider's decision (ADR-0047 K5). Making it mandatory at every level was considered;

it was rejected because device attestation is not available on every platform and every device, so it would have shut out W2 wallets. **Status:** the WIA and KA format and their verification are live; hardware keys and device attestation are coded and awaiting device testing (planned; FW-ARF-0001 §2.8); a hardware claim that cannot be verified does not go into the KA (Figure 21).

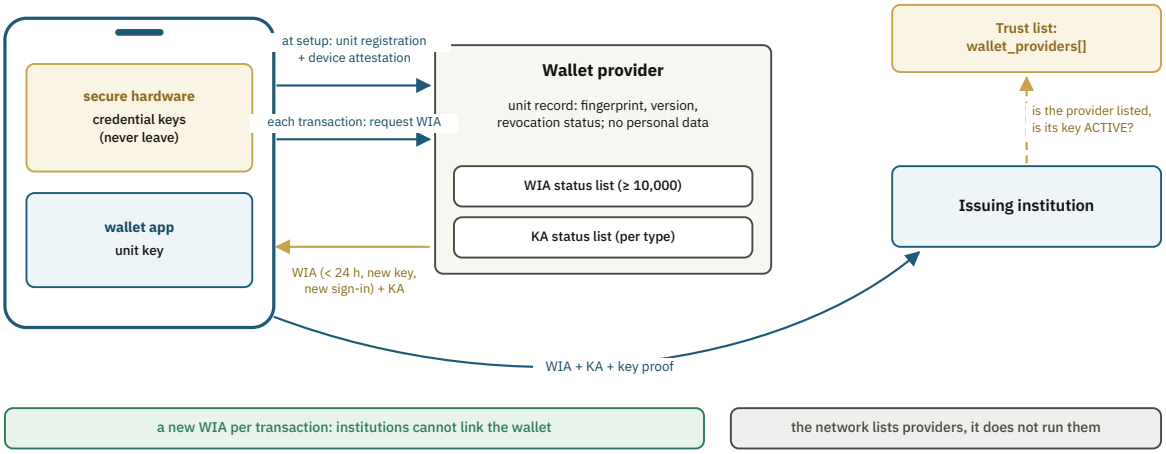


Figure 21. Wallet unit, wallet provider and attestations

13.4 Copies

Institution credentials are issued as ten copies; each copy is bound to a separate device key and to a separate position in the revocation list (Section 9). How the copies are used is governed by a two-way rule: a verifier is **always shown the same** copy, and different verifiers are shown **different** copies (WL5). Showing the same verifier a different copy gains nothing; Timur already knows Aynur from her application, and a different copy only uses up copies. Showing different copies to different verifiers, on the other hand, prevents two verifiers from colluding over the device key or the revocation position to link Aynur. The key of the mapping is the verifier's permanent identity (`dns_name`); it does not break even if the certificate is renewed.

In repeated presentations of the same type to the same verifier, the set of disclosed fields also stays consistent (WL6). If eight fields were disclosed in the first presentation and six in the second, the verifier could infer something about the hidden fields from the difference. If the verifier asks for less, the wallet does not send more, but it shows the person "you previously gave this verifier these fields".

Copies run out. With a known verifier this is not a problem; with a new verifier the person either refreshes or reuses a copy with a linkability warning. The wallet also refreshes copies without asking the person, at thresholds the institution announces (ADR-0023): for institution credentials that have a refresh token, while the application is in the foreground and unlocked, after a random delay. The old "no automatic refresh" rule changed because of the EU ARF [11] requirement that reissuance should, as far as possible, need no user action. Identity and contact credentials are out of scope; the identity service does not keep the person's attributes after issuing the credential.

TECHNICAL DETAIL

The remaining trace of silent refresh

Today the institution issues a batch of ten copies and triggers a refresh when two unused copies remain. Since a repeated presentation to the same verifier uses up no copy, one batch is enough for this many **new** verifiers:

$$10 - 2 = 8 \text{ new verifiers}$$

From the frequency of refresh requests, the institution can infer roughly how many new verifiers the credential has been shown to: one request for every eight new verifiers. This trace is an accepted trade-off and is narrowed by four measures: the same copy for the same verifier, a random delay of between 0 and 6 hours, the refresh request containing nothing about which verifier it was made for, and the person being able to turn the setting off (ADR-0023 K6). A refresh is also triggered 7 days before the credential expires.

13.5 The person's control

The wallet records every presentation locally: when, which verifier, which fields, whether there was an excessive request. This record stays on the device and is never sent to any server; if it were, exactly the behavioural profile that is meant to be protected would be gathered in one centre (SPEC-PROTO-0002 PV8, SPEC-WALLET-0001 WL4). The mapping that records which copy was shown to which verifier is subject to the same rule and is not included in the backup.

The EU, for its part, requires that the person be able to export their transaction log and the list of their credentials (Regulation 2024/2979, TS10). Encrypted backup of the log on a server (metadata still accumulates) and plain JSON export (it stays readable in sharing apps) were rejected. Decision: the log leaves the device only in a file that the person starts themselves and encrypts with their own password; credential values, copies and keys do not go into the file (ADR-0027) (Table 22).

Table 22. The person's rights and how the wallet meets them.

Right or need	How the wallet meets it	Source
Knowing what I showed to whom	History on the device: time, verifier, field names, excessive request	WL4, FW-ARF-0001 §2.7
Getting my data and taking it elsewhere	A password-protected TS10 file started by the person (transfer list and log)	ADR-0027
Choosing how long history is kept	30 / 90 / 180 / 365 days or indefinitely; a warning before deletion	SPEC-WALLET-0001 §5.7
Deleting everything	"Reset the wallet and delete my data": the record at the identity service, the unit record at the provider, everything on the device	SPEC-WALLET-0001 §7.6
Asking an institution to delete my data	"Ask them to delete my data" from the history	FW-ARF-0001 §2.7
Lodging a complaint	A path to the data protection authority the verifier answers to	FW-ARF-0001 §2.7
Closing the wallet when my phone is lost	A revocation path with no phone and no account (a revocation secret given at installation)	ADR-0047 K3
Learning that my wallet was revoked	At least one path outside the wallet	ADR-0047 K4

The order of deletion matters: first the identity service (the wallet requests deletion with a presentation of possession without disclosing any field; the service deletes the record, revokes the copies and has the session at the remote identity verification provider deleted), then the wallet provider (the

unit is revoked and its record deleted), and the device last. If there is no network connection, deletion on the device still goes ahead and the person is shown the remaining steps.

For a lost phone, the EU ARF envisages a user account at the provider; in Tamga there is no account. So every provider must offer a revocation path that works without the phone and without opening an account: a revocation secret generated when the unit is activated and shown to the person once, kept at the provider only as a slow hash (ADR-0047 K3). This is an explicitly recorded deviation from the ARF; notification by SMS was rejected as a network rule because it would go to the lost phone and would require personal data.

13.6 "Listed on Tamga Network"

The EU has a trust mark for certified wallets; its form and colours are set by regulation, and it is only for a certified wallet that a member state provides or recognises. No wallet in the network is an EU wallet, and none may use this mark. But the need the mark meets exists here too: the person wants to know whether the application on their phone is a wallet that follows the rules and is registered in the list.

Tamga's answer is a written indicator: **"Listed on Tamga Network"** (ADR-0049). There is no logo, badge or seal; the EU stars and colours and the words "trust mark" or "certified" are not used. When the indicator is tapped, the wallet shows its own provider entry from the list whose signature has been verified: the official name, the status of the entry, its level and the list's publication time. The indicator is a verifiable statement, not decoration. It is hidden if the unit has been revoked, if the provider or solution entry is not active, if the list cannot be verified or is stale, or if the wallet is bound only to the sandbox list. A "Tamga trust mark" with its own logo was also considered; it was rejected because its name evokes the EU mark and a logo says nothing verifiable. **Status:** live (since packages 0.6.0).

13.7 No age limit

eIDAS 2.0 [2] sets no minimum age for the European Digital Identity Wallet, and Tamga sets no age limit either: neither for registering wallets in the list nor for the identity service issuing the identity credential (ADR-0043). The only condition is identity verification with a valid identity document. Who may receive a credential is decided by whoever issues it; the university issues the student certificate only to an enrolled student. A service tied to age, as a verifier, likewise asks only for the information it needs (such as `age_over_18` Section 14). A network-wide age limit of 18 or of 13–16 was considered; the first was rejected because it would shut out credentials also used by younger people, such as students, athletes and event-goers, and the second because it is not an age limit but a parental consent rule for consent-based services.

The open item is parental consent. Article 8 of the GDPR [8] requires parental consent under the age of 16 for consent-based information society services (member states may lower this age to 13); KVKK [9] sets no specific age. The arrangement needed for the identity service's consent flow will be dealt with in a separate decision after legal review; the remote identity verification provider's condition for minors is also awaiting confirmation. **Status:** having no age limit is live; the parental consent flow is an open item.

14 Identity: The Provisional Identity Credential Provider

Before applying for a job in Istanbul, Aynur wants to get her credential from the institution she graduated from into her wallet. The institution asks her a single question: "Is it really you?" If every institution asks this question separately, each one asks every time for a photo of the identity card, a selfie and a waiting period. In the European Union this question is answered by person identification data (PID) issued by the state: the person shows their PID in the wallet, the institution matches it

against its own record and issues the credential. Today there is no such state provider in Türkiye or in any country of the Turkic world. This section explains how, and within what limits, the network fills this gap.

14.1 What to do when there is no PID

There were three paths. Wait for the state's PID provider, but there was no date for that. Leave identity verification to each institution's own issuance service; in that case the person is verified again at every institution and every institution builds a separate provider integration. Or carry out identity verification in a single place and give the result to the person's wallet as a portable credential. Project management chose the third path (ADR-0011): the network's identity service (`id.tamga.network`) verifies the person remotely once and issues them an **identity credential** that it signs itself. With this credential the person goes to any institution they wish; the institution receives the credential by presentation, matches it against its own record and issues its own credential.

This credential is not a PID; in the EU's language it is a non-qualified electronic attestation of attributes (EAA). The place of PID providers in the trust list (`pid_providers[]`) is deliberately left empty, and the identity service is an ordinary issuer entry (category `IDENTITY`). The practical consequence of the distinction shows at hand-over: when a state appoints a PID provider, the identity service's entry is handed over with a successor indicator (`successor_id`), no new credentials are issued, and credentials already issued remain verifiable until they expire (FW-RB-0003 §4.7). Since the attribute names are the same as the EU PID's, institutions' matching code does not change; only the signer changes. This is the same as the ARF's [11] pattern of "issuing an EAA on presentation of a PID" (FW-TF-0001 §3.5). *Status: live.* Today the identity service is the only active issuer in the real network's Türkiye list (Figure 22).

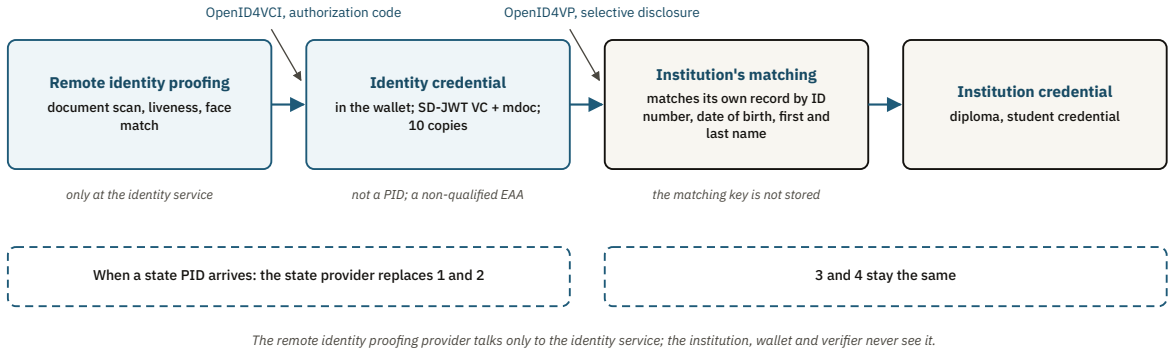


Figure 22. The identity chain: verify once, go to every institution with the same credential

14.2 Remote identity verification

Remote identity verification combines three checks: scanning the identity document and examining its authenticity, establishing that the person in front of the camera is alive (liveness), and matching the face against the photo in the document. This work is done by a licensed remote identity verification provider. The design is not tied to a particular provider: the identity service talks to the provider through a narrow adapter interface (open a session, fetch the decision, verify the notification), and a second provider can be added behind the same interface (SPEC-ID-0003 §6). Adding a second, domestic provider is an open topic (SPEC-ID-0003, Open Topics 3).

The provider is the external component of the network with the widest view; it sees the person's document and face. For this reason strict rules are drawn around it (SPEC-ID-0003 §3, §8). Only the identity service talks to the provider; institutions, wallets and verifiers do not. The provider session is linked to the person by an opaque reference issued by the identity service; no name, identity number

or e-mail is written into this field. In the workflow only document, liveness and face matching are switched on; anti-money laundering screening and contact verification are switched off, because the aim is only to meet the precondition for issuance. The provider's notification (webhook) is checked by signature and timestamp, but it is only a trigger; the decision is always fetched again from the provider's decision endpoint. The document image, portrait, video and character recognition output are not stored at the identity service; what the service keeps is a short summary of the result. Logs record the event type, session reference and level; they do not record the name, document number or match score.

Failure cases are also built to fail safe. With an "in review" or "rejected" decision no credential is issued and the provider's reasoning is not passed on to the person; a provider outage does not lower the level, it only stops issuance. Before moving to the provider, the person sees the privacy notice and gives explicit consent; without consent, verification does not start.

One weak point of this step must be stated plainly: liveness and face matching are only as strong as the provider's ability to detect artificially generated faces and attacks made by injecting into the video stream (deepfake and injection attacks [55]). The network narrows this risk with two rules: the highest level (T3) is never granted by any remote face verification, and the contract with the provider refers to ETSI TS 119 461 [47] (FW-TF-0001 §3.5). The topic is covered in detail in the series paper "Deepfake Çağında Kimlik Doğrulama" [78] (Identity Verification in the Age of Deepfakes).

TECHNICAL DETAIL

The identity credential issuance flow

The identity credential is started by the wallet, not by an institution; the flow is the authorization code path of OpenID4VCI [30] (Section 9.1) and is defined in SPEC-ID-0003 §9 and SPEC-PROTO-0001 §11.2. At every step the wallet carries the wallet instance attestation (WIA) issued by a wallet provider in the list (Section 13.3).

1	`Wallet → Identity service`	**Authorization request.** The request is pushed with PAR; the client identity is the WIA and a PKCE code is added. Besides the identity credential scope, the ZK copy scope may also be requested.	$\text{code_challenge} = \text{SHA-256}(\text{code_verifier})$
2	`Identity service → Person`	**Notice and consent.** The privacy notice is shown in the browser and explicit consent is obtained; without consent the flow ends with `access_denied`.	
3	`Identity service → Provider`	**Session.** A session is opened with an opaque person reference; the person scans their document, and liveness and face matching are performed.	$\text{vendor_data} = \text{subject_ref}$
4	`Identity service`	**Decision.** Even if a notification arrives, the decision is fetched from the provider's decision endpoint; if all three checks pass, the level is T2.	$\text{T2} \Longleftarrow \text{document} \wedge \text{liveness} \wedge \text{face}$
5	`Identity service → Wallet`	**Authorization code and token.** The single-use code is exchanged for an access token with PKCE	$\text{jkt} = \text{SHA-256}(\text{JWK}_{\text{dpop}})$

		verification and the WIA; the token is bound to the DPoP key.	
6	`Wallet → Identity service`	**Credential request.** For each copy, a key proof with a separate device key and the key attestation (KA) are sent.	$\mathrm{cnf}_i \neq \mathrm{cnf}_j \quad (i \neq j)$
7	`Identity service → Wallet`	**Issuance.** 10 copies in SD-JWT VC and mdoc format; short-lived ZK copies if requested; then, in a separate request with the same token, the pseudonym seed.	
8	`Identity service`	**Clean-up.** The person's attributes are dropped from memory; the persistent record keeps only the opaque reference, a keyed hash of the document number, the validity period and the revocation list positions.	$\mathrm{document_number_hash} = \mathrm{HMAC\text{-}SHA256}(k_{\mathrm{doc}}, \mathrm{country} \parallel \mathrm{type} \parallel \mathrm{no})$

Issuing the seed in a separate request is a standards conformance decision: OpenID4VCI 1.0 does not allow extra fields in the credential response, so the seed is announced as a separate credential configuration and can be requested only once with the token that issued the identity credential (ADR-0061).

14.3 Levels

The network measures trust on two independent axes (ADR-0005). The first axis is how strongly the person's identity has been verified: from T0 to T3. The second is how thoroughly the issuer has been audited: from I1 to I3 (Section 18.6). A verifier's trust is the product of the two, not their sum; if a very well verified person carries a credential from an unaudited institution, or an accredited institution has issued a credential to someone whose identity was never verified, the result is worthless. The levels on the person's side map one to one onto the eIDAS levels of assurance [4] and the levels of ETSI TS 119 461 for identity proofing; this way the network uses its own measure while speaking the same language as the EU (Table 23).

Table 23. Person assurance levels and their mappings (ADR-0005; SPEC-ID-0003 §1; FW-ARF-0001 §6.5).

Level	eIDAS level	ETSI TS 119 461	Typical path	At the identity service
T0	none	none	device key, e-mail or phone code; no identity claim	contact credentials
T1	Low	Baseline	a code from a separate channel, line or account ownership	not used
T2	Substantial	Substantial	remote document + liveness + face matching, or an in-person registration desk	the identity credential is at this level today
T3	High	High	signing a nonce with a qualified electronic signature; PID in the state stage	not granted by remote face verification

Two rules complete the table. First, the level is not written into the credential. A credential type carries a minimum level as a precondition; the institution ensures this level before issuing the credential and records in its own audit log the path by which it did so (SPEC-ID-0003, Scope). If an "assurance" field were put into the credential, every verifier would learn which path the person went through. Second, even if the chip has been read by NFC, the result does not legally count as T3; the

credential carries this fact only as a fact, in the `document_chip_verified` field (FW-RB-0003 §4.3). Levels can also erode over time: events such as a device change or a long period of non-use lower the level (ADR-0005, decision 4).

14.4 Class: not qualified

The identity service was first registered in the trust list in the highest class. The EU gap analysis that followed showed that this could not be defended (ADR-0022). In eIDAS 2.0 [2] "qualified" is a legal status; it requires an audit by an independent conformity assessment body and supervision by the supervisory body. In this service, however, the network is at once the list operator, the registrar and the issuer; it would have written itself into the highest class. Of the four options considered, "non-qualified EAA, I2" was accepted: it describes the real situation, and in the EU anyone may issue a non-qualified EAA. I1 was rejected too, because identity proofing and key management met the I2 requirements.

There is a visible trace of this in the credential, or rather the absence of a trace. ETSI TS 119 472-1 [49] requires that a non-qualified EAA not issued by or on behalf of a public body carry no legal category field; for this reason the identity credential carries no `category` field, and the credential's class is read from the issuer's entry in the list (FW-RB-0003 §2.1). Two invariants protect this decision: a service the network itself operates is not registered as qualified or I3 without independent assessment, and until the class is raised no policy requires I3 for the identity credential. After independent assessment the class can be raised by a new ADR. *Status: the upgrade is planned.*

14.5 Attributes

The identity credential uses the attribute names and encoding of the EU PID (ADR-0045; Implementing Regulation (EU) 2026/1731 [7]). The differences in names and encoding are the EU's own: the date of birth is written as `birthdate` in SD-JWT VC [16] and as `birth_date` in mdoc [34], with the ISO date tag. The type and namespace (`urn:tamga:id:IdentityAttestation:1`, `tamga.id.1`) belong to the network; the EU's PID type and namespace are not used, because the credential is not a PID. The alternative to this choice was to keep network-specific names and give every verifier a mapping table; it was rejected because it would force every EU verifier to learn the network's names (Table 24).

Table 24. The attributes of the identity credential (FW-RB-0003 §2.2, §3.1, §3.2). Every person attribute can be disclosed separately; there is no portrait, address or assurance level attribute.

SD-JWT VC name	mdoc element	What it carries	Note
`given_name`, `family_name`	same	given name, family name	EU PID name
`birthdate`	`birth_date`	date of birth	EU PID encoding
`nationalities`	`nationality`	array of nationalities	each element disclosed separately
`personal_administrative_number`	same	national identity number	found only in this type
`issuing_country`	same	in the EU sense, the country of the provider issuing the credential	today, the country that issued the scanned identity document
`document_type`	same	type of the verified document	identity card, passport, residence permit, driving licence
`document_number_hash`	same	keyed hash of the document number	not the number itself

SD-JWT VC name	mdoc element	What it carries	Note
`document_chip_verified`	same	whether the NFC chip was read	a fact, not a level
`verification_method`	same	verification path	remote, remote with NFC, in person
`age_over_18`, `age_over_15`	same	whether an age threshold has been passed	derived yes/no

The identity number deliberately sits only in this credential and is disclosed only to a verifier whose registered scope includes this field (SPEC-ID-0003 §8). Leaving the number out was also tried: matching on name and date of birth alone becomes ambiguous for people with the same name, and rejections by institutions increase; this option was rejected (ADR-0011).

For age attributes, the verifier usually does not need the date of birth; it is enough to know whether a threshold has been passed. The identity service derives this answer from the date of birth at the moment it issues the credential and signs it; the wallet does not compute the threshold itself, because then the issuer's signature would not cover the result. The names follow the `age_over_NN` pattern of ISO/IEC 18013-5, and the set of thresholds is closed: today 15 and 18; a new threshold is added only by ADR (ADR-0064). One of the reasons for the 15-year threshold is the age-15 rule introduced for social network providers in Türkiye by Law No. 7578 [10], which entered into force on 1 November 2026. This is not a legal opinion; it does not determine how a platform should meet its obligation, it only makes it possible for the network's identity credential to answer this question with the least data.

TECHNICAL DETAIL

Deriving the age attributes

The derivation is made on the day the credential is issued, according to the UTC calendar day of the service clock. A person passes the threshold on the day their Nth birthday begins; those born on 29 February, on 1 March in non-leap years (ADR-0064, K1):

$$\text{age_over_N} = (\text{date_of_birth} + N \text{ years} \le \text{issuance_day}) \qquad N \in \{15, 18\}$$

$$\text{example:} \quad 1998\text{-}05\text{-}17 + 18 \text{ years} = 2016\text{-}05\text{-}17 \le 2026\text{-}11\text{-}04 \quad \Rightarrow \quad \text{age_over_18} = \text{true}$$

The values are examples. The verifier sees only yes or no. Since disclosing both thresholds together could reveal an age range (if one is yes and the other no, the person is between 15 and 17), the network's verifier policies ask for a single threshold; a scope that asks for both thresholds at once must be justified separately in the verifier's registration (ADR-0064, K3).

14.6 Credentials that grow out of identity

The identity service issues three more credential types on the same infrastructure. Each one came out of a separate decision, and the same question was asked for all of them: should this information be put inside the identity credential, or should it be a separate credential? Every time the answer was "a separate credential", because separate credentials are shown separately, live separately and are revoked separately (Table 25).

Table 25. The types issued by the identity service.

Type	What it proves	Precondition	Validity	Format	Decision	Status
Identity credential	who the person is	remote identity verification (T2)	at most 2 years	SD-JWT VC + mdoc	ADR-0011, ADR-0013	live
ZK copy	only the age thresholds	identity credential	at most 24 hours	mdoc	ADR-0044	live at the identity

Type	What it proves	Precondition	Validity	Format	Decision	Status
						service; wallet side planned
Pseudonym seed	nothing; never shown	identity credential	same as the identity credential	SD-JWT VC	ADR-0031, ADR-0061	live
E-mail, phone	that the address is in that wallet's hands	single-use code (T0)	at most 1 year	SD-JWT VC	ADR-0021	e-mail live; real SMS sending planned
Driving licence information	the categories and dates written on the card	presentation of the identity credential	the card's expiry or 1 year, whichever is earlier	SD-JWT VC	ADR-0039	in the sandbox; for real people after legal review

The contact credentials do not say who the person is; they say only "this address was in the hands of this wallet at the moment the credential was issued". For this reason they require no identity verification and carry no identity information. The address stays in memory only for the duration of the flow and is deleted once the credential is issued; only its keyed hash is written to the database, and neither the address nor the code is written to the log (ADR-0021). Since numbers and addresses can pass to someone else over time, validity is limited to one year.

Driving licence information is the type most hemmed in by limits. In tasks such as car rental or hiring couriers, it answers the counterparty's question "in which categories do you hold a valid licence?", but it is not an official driving licence, nor is it a mobile driving licence (mDL). It says so explicitly in four places: in the type's display information, in the `not_official_licence: true` field that every verifier sees and that can never be hidden, on the front of the card in the wallet, and on verifier screens (ADR-0039). It does not show whether the card is suspended today; the network has no access to the official register. The national identity number and the restriction and health codes do not go into the credential. The match between the card and the identity credential is established at the identity service with a keyed hash, without sending a name to the provider. When a country's competent authority starts issuing digital driving licences, the network stops issuing this type for that country.

The pseudonym seed, finally, is the only type that is never shown. Its job is explained in Section 15.3.

14.7 Retention and deletion

The identity service is the data controller for this data (FW-TF-0001 §3.6). For this reason the sentence the network used to use, "Tamga sees no personal data", was narrowed: the network sees identity verification data, but not the content of education and sector credentials (ADR-0011, K4). After the credential is issued, the person's attributes are not kept; the persistent record keeps only an opaque person reference, a keyed hash of the document number, the validity periods and the revocation list positions (SPEC-ID-0003 §8). Records and event logs are kept for short, defined periods; these periods will be finalised by legal review. The image retention period on the provider's side is reduced to the minimum by contract.

A deletion request solves an interesting design problem: the person has no account, so how does the service recognise whoever says "this record is mine"? The answer is the credentials the service itself issued. The person sends a presentation of one or more identity credentials to the deletion endpoint; no field is disclosed, only the signature and the device binding are checked. The record is found from

the position in the revocation list. As a result all copies of the record become invalid, the record and the log lines linked to it are deleted, and the provider is asked to delete the session (SPEC-ID-0003 §9.1). Only bits remain in the revocation list. Since the pseudonym seed is never stored on the service side, there is nothing to delete for it.

14.8 App store review code

Before a wallet application enters an app store, reviewers want to try all its flows. Since the identity flow requires a real identity document and a face scan, a reviewer cannot do this. A permanent "test mode" was rejected: a real user could turn it on too, and fake credentials could look real. The accepted solution is a time-limited, single-use review code (ADR-0033). The code is at least 128 bits of randomness, is stored only as a hash, is valid for at most 14 days and is entered in a small field on the privacy notice page. With a valid code, a fake verification is used for that session and the credential is signed by a separate test signer. This signer sits in the list in the lowest class (I1); since all real policies require I2, a test credential passes no real verification. The code is a service of the network and is open to every wallet in the list on the same terms. *Status: planned.* The code is ready; the test signer's list entry stands as a pending application, and until the entry is published the review path answers "not active".

15 Privacy Engineering

Timur does the hiring at a company and is verifying Aynur's diploma. The same evening Aynur signs up to a site that Dilnoza has built, using the "Sign in with Tamga" button. What happens if, the following week, Timur's company and Dilnoza's site decide to compare their customer lists? If the two records share a value, whether a key, a number or a timestamp falling on the same second, Aynur's two lives are linked to each other. Privacy is not only the question "which field did I show"; it is the question "can the things I showed be combined with others". This section sets out the network's engineering answers to this second question. The concept itself is explained in detail in the series paper "Bağlanamazlık" (Unlinkability).

15.1 Linkability as a threat

Linkability arises from several separate channels, and each channel has its own countermeasure. If the same copy of the same credential is shown to two verifiers, the signature and the device key are the same in both places. The second at which a credential was issued is almost like a fingerprint. The position in the revocation list is specific to the credential. If the identifier used to sign in to a site is the same on every site, the sites can be joined up. Finally, the issuing institution recognises its own signature; if the institution cooperates with a verifier, it can still find the person. The network cannot fully close this last channel today and records it as residual risk L3 (FW-ARF-0001 §7.4) (Figure 23).

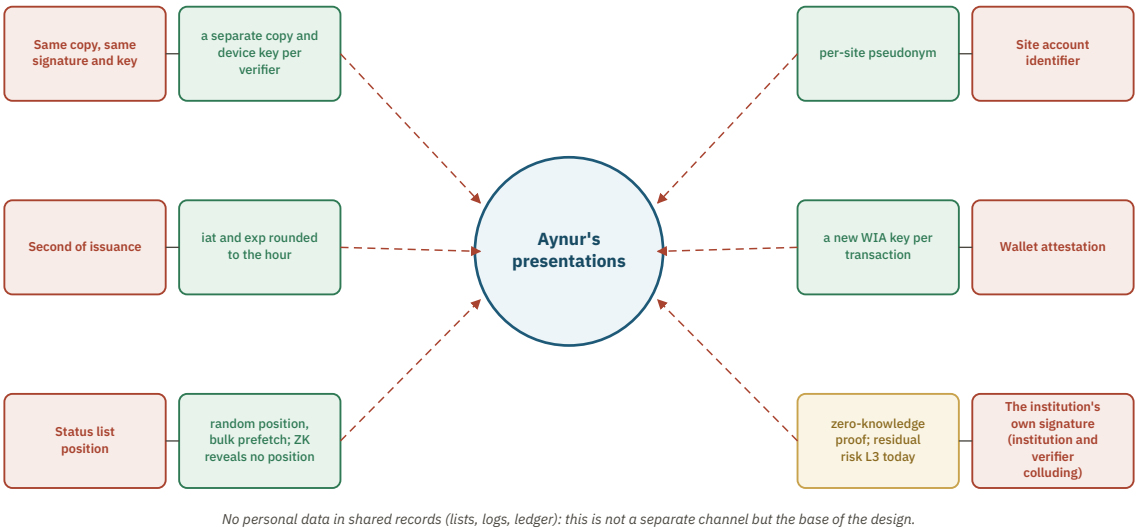


Figure 23. The channels of linkability and the countermeasure for each

15.2 A copy per verifier and rounded time

The wallet receives a credential not as a single instance but as ten copies, and each copy is bound to a separate device key (SPEC-PROTO-0001 §8). The rule is also enforced on the issuer's side: proofs that come with the same key are rejected, because the same key would link the copies to each other again. The wallet shows each verifier a separate copy and always shows the same verifier the same copy (the sticky copy rule, Section 13.4). So even if two verifiers compare the signatures they hold, they find no shared value. As the copies run low, institution credentials are refreshed silently (ADR-0023).

The second countermeasure is time. If a credential's issuance and expiry moments were written to the second, the credentials in the same copy batch, or the small number of credentials issued on the same day, could be told apart by their timestamps. The issuance package therefore rounds the `iat` and `exp` values down to the hour; all copies in the same batch get the same values. If rounding would break the verifiability of the credential (for example, if the signing certificate started within that hour), the real moment is kept: verifiability comes before unlinkability. *Status: live.*

15.3 Per-site pseudonym

In its first version, "Sign in with Tamga" sent every site the document number hash from the identity credential. The site did not store the value as it was, but if two sites colluded they would see the same value and find the same person. On top of that, when the person renewed their identity card the document number changed, so the account on the site was lost as well. ADR-0031 compared five options to solve both problems together.

Deriving a key from the wallet's own random secret would give full unlinkability, but all accounts would be lost when the phone changed. Having the issuer generate an identifier per site would preserve accounts, but the identity service would learn which site the person signed in to. A passkey carries no identity on its own; it remained for everyday sign-in. An identifier derived with a zero-knowledge proof is the right long-term solution, but today it requires a store build and a ZK library. The path chosen is a seed derived from the identity.

When the identity service issues the identity credential, it derives a seed from the person's unchanging identity (for Türkiye, the identity number). The seed reaches the wallet as a separate credential type that is never shown, and it is not stored on the server; it is recomputed from the same input at every verification. From this seed the wallet derives a separate key for each site. The site recognises

the person by that key's fingerprint. Since two sites see different keys, they cannot link the person; when the person verifies their identity again on a new phone, the same seed, and therefore the same pseudonyms, come back. By default there is one pseudonym per site, which makes fake multiple accounts harder; a site may, in its registration, allow more than one pseudonym. At sign-up only the fields allowed by policy (for example, given name and family name) go to the site, and at sign-in no credential field goes at all. *Status: live.*

TECHNICAL DETAIL

Deriving the pseudonym

Derivation has two stages (ADR-0031, K1 and K2; SPEC-WALLET-0001 §5.4). The label is a version string; the constants are abbreviated:

$$\begin{aligned} \text{seed} &= \text{HMAC-SHA256}\big(k_{\text{ps}},\quad \text{label} \parallel \text{country} \parallel \text{id_no}\big) \\ d_{\text{site}} &= \text{HKDF-SHA256}(\text{seed},\quad \text{info} = \text{label} \parallel \text{dns_name} \parallel \text{index}) \bmod n \\ Q_{\text{site}} &= d_{\text{site}} \cdot G \quad \text{(P-256)} \\ \text{pseudonym} &= \text{RFC7638-fingerprint}(Q_{\text{site}}) \end{aligned}$$

The first line is computed at the identity service, the other three in the wallet after PIN or biometric approval; the derived private key is not stored. k_{ps} is a key separate from the key of the document number hash and is held only at the identity service. The site identity is the domain name that is the verifier's permanent entry in the trust list (`dns_name`); the client identity derived from the certificate is not used, because it changes when the certificate is renewed and would change the pseudonym too (ADR-0034). Why are the keys of two sites independent? To someone who does not know the seed, the outputs HKDF [27] gives for different `info` values look like unrelated random values; neither the seed nor the identity can be recovered from a pseudonym. What goes to the site is a short token signed with the pseudonym key (`aud` = site, `nonce`) and a new WIA showing that it comes from a wallet unit that has not been revoked.

This design has a known weakening, and it is written plainly in the ADR: someone who holds both the seed key and a person's identity number, for example the party operating the identity service colluding with a site, can compute that person's pseudonym on that site. The countermeasures are moving the key into a hardware security module in the pilot, access logging, counting the uses of the key in the transparency report, and the possibility of handing the key over to a state provider later. The permanent solution is derivation with a zero-knowledge proof. *Status: research.* Despite this weakening, the new situation is markedly better than the old one: before, every site could link everyone; now only someone holding both of these pieces together can do so (Figure 24).

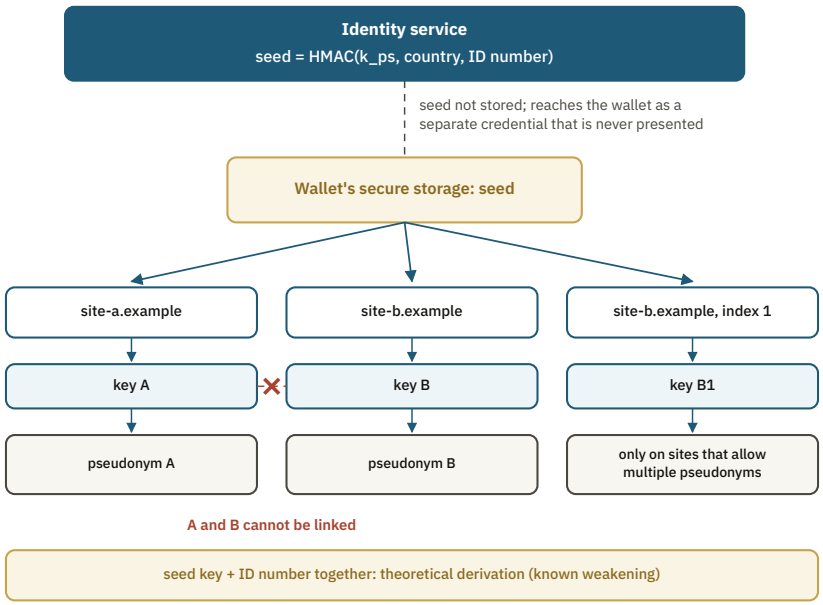


Figure 24. Pseudonym derivation tree: one seed, keys with no link between sites

15.4 Zero-knowledge proof

Selective disclosure lets the person show only the field that is needed, but the signature on the field shown is still the institution's signature; cooperation between the institution and the verifier (L3) works through this signature. A zero-knowledge proof closes this last channel: the wallet proves the statement "the `age_over_18` field is true in a credential signed by the institution" without showing the credential, the signature or the date of birth. For this the network chose the Longfellow [56, 57] ZK system (ADR-0032). BBS-family signatures were rejected, because they would require institutions to change their signing key and format, and they are not on the EU's list of approved mechanisms. Longfellow does not touch the institution's current ES256-signed mdoc [34] credential, requires no trusted setup, and the EU's technical specification for the age verification profile (TS13 [12]) is built on the same system. The batch copy method was not removed; it continues as a fallback when a proof cannot be made.

Two further rules make this path safe. The verifier accepts only circuit hashes that are published in the list of trusted lists and are active. In a ZK presentation the revocation list position is not disclosed either, because if it were, two presentations would be linked again. The second rule creates a problem: if a revoked identity credential is shown with ZK, the verifier cannot see this. ADR-0044 chose the EU ARF's [11] short-lived credential path: only ZK copies, issued separately by the identity service, valid for at most 24 hours and carrying no revocation list, are shown with ZK. The wallet receives these copies in small batches and refreshes them without asking the person; if the main credential has been revoked, no new copy is issued, and the revocation takes effect in ZK presentation within 24 hours at the latest. Seven-day copies were rejected, because the ARF's "no revocation needed" threshold is 24 hours.

Status: the verifier side is live; the wallet side is planned. The prover is an open package of the network (`@tamga-network/zk`) and has been connected to the wallet; the Android native library has been built, the iOS library is pending and measurement on a phone has not yet been done (FW-ARF-0001 §2.8).

TECHNICAL DETAIL

Proving age with ZK

The verifier asks for the `mso_mdoc_zk` format in the DCQL [31] query. The outline of the flow (ADR-0032, ADR-0044; SPEC-WALLET-0001 §4.5):

1	`Verifier → Wallet`	**Request.** A signed OpenID4VP request; in DCQL, the `mso_mdoc_zk` format and a single element: `age_over_18 = true`.	nonce, aud
2	`Wallet`	**Copy selection.** A valid ZK copy is selected; if there is no copy, the ZK query is not satisfied and the classic option is offered.	$\text{validUntil} - \text{validFrom} \leq 24\ \text{h}$
3	`Wallet (secure hardware)`	**Ordinary device signature.** The session transcript is signed in the ordinary way with the device key; the key does not leave the hardware.	$\sigma_{\text{device}} = \text{Sign}(d_{\text{device}}, \text{SessionTranscript})$
4	`Wallet (prover)`	**Proof.** The circuit is selected from the list and its bytes are compared with the published hash; the proof is generated.	$\text{SHA-256}(\text{circuit}) = \text{combined_hash}$
5	`Wallet → Verifier`	**Response.** The response contains only the proof; the credential, signatures and salts are not sent.	
6	`Verifier`	**Check.** Is the circuit hash in the list and active; the institution key comes from the list; the proof is verified; if the type the proof binds is a ZK copy, no revocation check is needed.	$\text{status} = \text{NOT_APPLICABLE}$

Inside the circuit, the institution's signature, the field's digest, that the value is `true`, the validity period and the device signature are checked; the details are in the series paper "Sıfır Bilgi İspatları ve Kimlik" [69] (Zero-Knowledge Proofs and Identity). In the desktop measurement in ADR-0032, the proof was generated in about half a second, took up about 343 KB and was verified in a fifth of a second; because of this size the proof is not carried by QR. One detail turned into a schema rule: the circuit version used binds the institution key, the credential type, the field name and the value, but not the namespace. So within a credential type the same field name may appear in only one namespace, and the catalogue checks this at build time (ADR-0032, K8). The same circuit is an equality proof; the threshold is not fixed in the circuit, so no new circuit was needed for `age_over_15` (ADR-0064, K4).

Figure 25 compares what the verifier sees in classic selective disclosure and in a zero-knowledge presentation.

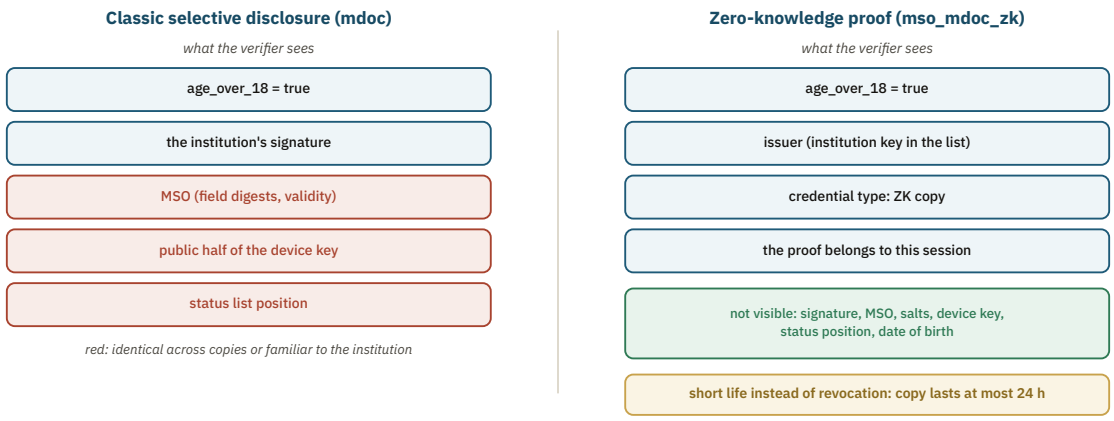


Figure 25. ZK presentation: what is hidden, what is visible

15.5 No data in shared records

The trust lists, the anchor log, the shared ledger that will come later and the service logs are the network's public or shared records. None of these records contains personal data; neither the content of a credential nor a credential hash is written (FW-ARF-0001 §1.6, principle P2). Not writing a hash is a deliberate choice: a credential's hash looks as if it were not personal data, but anyone holding the credential could find it in the record and conclude "this credential was used in this transaction at this moment". The services do not record IP addresses; the logs do not contain the values of credential fields or the revocation list position (FW-ARF-0001 §4.5). Revocation lists are published at a fixed interval whether or not anything has changed, so the moment of revocation does not leak (Section 12.4). Usage statistics are published only in aggregate and in groups of at least 50 (FW-TF-0001 §1.7). The verification result object carries only the names of the fields, not their values, and never carries the revocation position; this prevents this long-kept object from turning into a tracking surface (SPEC-API-0001 §7) (Table 26).

Table 26. Privacy countermeasures, the threat each closes and their status.

Countermeasure	Threat it closes	Decision or rule	Status
Selective disclosure, age thresholds	excess data	ADR-0006, ADR-0064	live
A copy with a separate key for each verifier	linking across verifiers	SPEC-PROTO-0001 §8	live
Time rounded to the hour	linking by timestamp	issuer package	live
A new WIA key per transaction	linking by wallet attestation	ADR-0025	live
Per-site pseudonym	linking accounts across sites	ADR-0031, ADR-0061	live
Random revocation position, bulk prefetching, fixed-interval publication	tracking through the revocation list	SPEC-CRED-0003	live
Zero-knowledge proof and short-lived copy	cooperation between institution and verifier (L3)	ADR-0032, ADR-0044	verifier side live, wallet side planned
No personal data or hashes in shared records, no IP logging	inference from shared records	FW-ARF-0001 §1.6, §4.5	live
The provider talks only to the identity service	the provider tracking the person across institutions	SPEC-ID-0003 §8	live
Pseudonym derivation with ZK	theoretical derivation by the identity service	ADR-0031, option E	research

15.6 Legal framework

The network's privacy rules are as much legal as technical. In Türkiye the basis is the Personal Data Protection Law No. 6698 [9]; in relations with the EU the General Data Protection Regulation [8] (GDPR) is decisive. The Trust Framework assigns the roles as follows (FW-TF-0001 §3.6): the issuing institution and the authentic source are the data controllers of their own data; the network is a data processor under contract in the issuance service it hosts, and the data controller in the identity service; the wallet provider has no access to the data on the device; the verifier is responsible for the fields it receives. The person's rights take concrete form in the wallet: the presentation history is kept on the device, the path to complain to the data protection authority is visible in the wallet, and withdrawing consent means revoking the credential. Before identity verification, a privacy notice is given and explicit consent is obtained.

Before the pilot, the framework, together with the contract annexes, undergoes legal review with respect to the Personal Data Protection Law and the Electronic Signature Law No. 5070 (FW-TF-0001 §1.4). The assignment of roles in this section summarises the network's own rules; it is not a legal opinion. The parental consent flow for minors is an open topic: the network sets no age limit (ADR-0043), Article 8 of the GDPR requires parental consent for minors in consent-based services, and how this is reflected in the network will be dealt with in a separate decision after legal review.

15.7 Remaining privacy risks

Three risks openly remain today. The first is L3: if credentials from the same institution are combined across different verifiers, the person can be linked; this risk goes away as zero-knowledge proofs reach wallets. The second is the known weakening of pseudonym derivation; it is limited by key protection and transparency, and its permanent solution is at the research stage. The third is the refresh frequency of short-lived ZK copies: from refreshes roughly once a day, the identity service can learn that a wallet is active; it does not learn what was shown to which verifier. A random delay and an automatic refresh setting the person can turn off reduce this (ADR-0044, Consequences). These risks are collected, together with the conditions under which they would go away, in the table of residual risks in Section 23.

16 Security Model and Threats

Nurlan is waiting in line in front of a concert gate. The ticket on his phone has turned into a pass, and a 60-second QR code is on the screen. Someone behind him takes a photo of the screen. What can be done with this photo? A security model means asking exactly this kind of question in advance: what are we protecting, whom do we trust, who can try what, and what happens if they do? This section gathers the network's answers to these questions in one place.

16.1 Assets and trust assumptions

Each of the keys to be protected has its own place and its own requirements (FW-TF-0001 §2.3). The root certificate is generated in an offline ceremony, with two people and minutes. As a rule, the list signing key is held with at least two rolling certificates in a hardware-protected environment; according to SECURITY.md [66], today the list is published with a single signing key, and a second key will be added before the pilot. The issuer's signing key is under the institution's control; the real network does not accept an institution key read from a file (ADR-0057). The holder's key is generated in the device's secure area, cannot be exported and is not derived from a recovery seed. At the identity service, the credential signing key, the key of the document number hash and the key of the pseudonym seed are separate from one another.

Wallets and verifiers trust one thing: the root that signs the list of trusted lists. The list server, the connection or a domain name are not trusted; no entry is used until the signature, version chain and freshness have been checked (FW-ARF-0001 §4.5). An issuer is trusted only for its own credentials, and the identity verification provider only for the identity verification decision, and that decision is confirmed again every time (Figure 26).

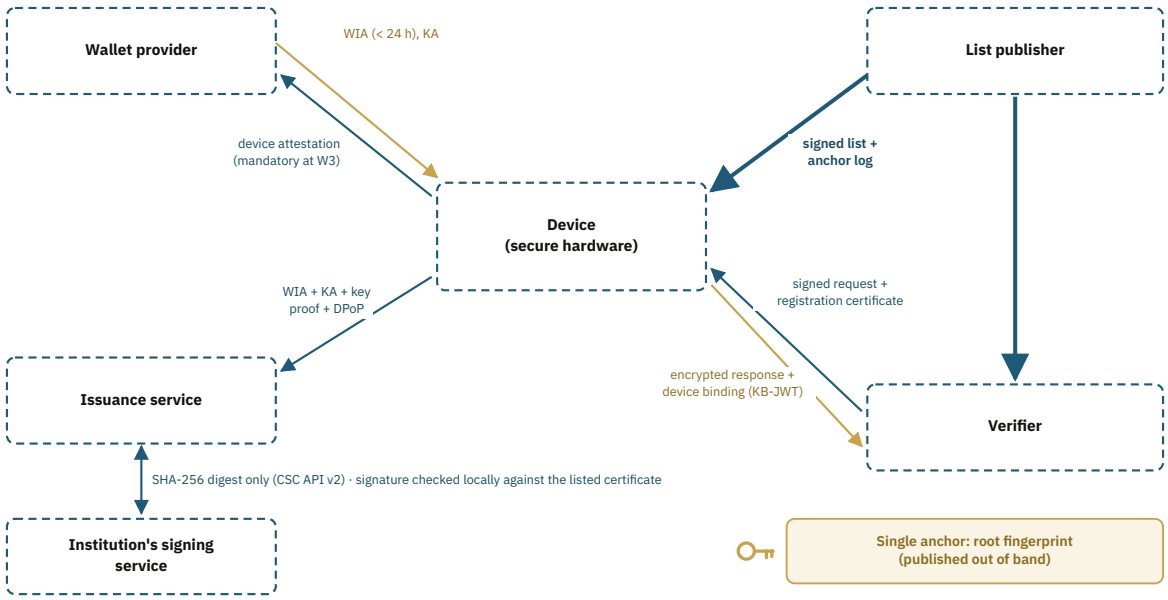


Figure 26. Trust boundaries and the evidence that crosses them

KEY POINT

The single anchor of trust today

Today the anchor of trust is the signature of a single operator (residual risk L1; FW-ARF-0001 §6.6). If the operator and an issuer act together, an inconsistent entry could be published in the list. The public anchor log makes a rollback visible, and the transparency report and audits deter it, but none of them makes it impossible. This limit goes away only with multiple independent signers and a shared ledger (Section 19).

16.2 Attacker models

The model considers eight attackers separately: one who produces forged credentials, one who steals the phone, one who copies the application, a verifier who asks for more than it needs or combines data with others, one who watches the QR code, one who rolls back the list, an institution acting together with the operator, and one who uses a fake face or document in identity verification. Each has different means at hand; Table 27 gives the countermeasure and the remaining risk for each.

16.3 Threat table

Table 27. Threat model: threat, countermeasure, basis and remaining risk.

Threat	Countermeasure	Basis	Remaining risk
Credential in the name of a fake institution	institution identity is derived from the X.509 certificate, not from the `iss` field; type authorisation (C2) cannot be skipped by any setting	ADR-0004; SPEC-API-0001 §7	theft of the institution key; incident process and revocation
Moving the credential to another wallet	device binding mandatory without exception; every presentation	ADR-0006	next to none; the key cannot be exported

Threat	Countermeasure	Basis	Remaining risk
	requires a signature with the device key		
Theft of the phone	PIN or biometrics at every presentation; wallet unit revocation without an account, with the revocation secret; revocation can be learned from outside the wallet	ADR-0047	with the phone and unlock credentials together, an unexpired institution credential on a phone that does not connect to the network
Fake or copied wallet	WIA and KA from a provider in the list; no credentials for a wallet with software keys; device attestation mandatory at the highest level	ADR-0025, ADR-0047	hardware keys and device attestation planned; not yet tested on devices
Verifier making excessive requests	signed request, registration certificate, scope check, warning to the person; a request without a certificate is rejected	ADR-0026, ADR-0056	the final decision rests with the person, who can click through the warning
Colluding verifiers	separate copy, rounded time, pseudonym, ZK	ADR-0031, ADR-0032	L3, until ZK reaches wallets
Replay	`nonce`, `aud`, KB-JWT, DPoP, single-use code	SPEC-PROTO-0001; SPEC-PROTO-0002	next to none
False decline by someone who sees the QR	every fetch of the request is a separate branch with a fresh `state`, `nonce` and encryption key; a decline closes only its own branch	ADR-0067	next to none; the attacker closes only their own branch
Someone who sees the QR using up the ticket	the gate identifies itself with a terminal key; a request without a key does not touch the token; gate groups are in the list	ADR-0065, ADR-0069	leak of the terminal key; it is revoked; certified gates planned
List rollback	version chain, digest of the previous version, anchor log; rollback protection on by default	SPEC-TRUST-0001; ADR-0056	single signer (L1)
Collusion between operator and institution	public change log and anchor log, transparency report	FW-ARF-0001 §6.6	L1; goes away with a shared ledger
Institution key in the hosted service	remote signing: only the hash goes to the service, the signature is checked locally; the real network rejects an institution key from a file	ADR-0057	planned; no institution uses it in the real network
ZK presentation with a revoked identity	only a short-lived ZK copy; no new copy if the main credential is revoked	ADR-0044	revocation takes effect within 24 hours at the latest
Identity verification with a fake face or document	liveness and face matching; no portrait in the credential; T3 is not granted with a remote face	SPEC-ID-0003 §1, §8	depends on the provider's detection capability
An integrator switching off a check by mistake	secure defaults; an explicit `"none"` value to skip	ADR-0056	a check skipped on purpose

The gate attack shows well how an attack is noticed and closed (Figure 27). The gate used to send the pass token to the verification service, and the service did not ask who the gate was. The person who took the photo could send the token first and use up the single-use ticket, and when Nurlan reached the gate the ticket would appear "used". Now the gate identifies itself with the terminal key that the operator issued for that gate group; a request without a key never touches the token (ADR-0065).

Gate groups are published in the trust list, and each group names the institution that operates the gates; an institution sees and revokes only the keys of its own gates (ADR-0069). The false decline attack belongs to the same family and is described in Section 10.5. *Status: live.*

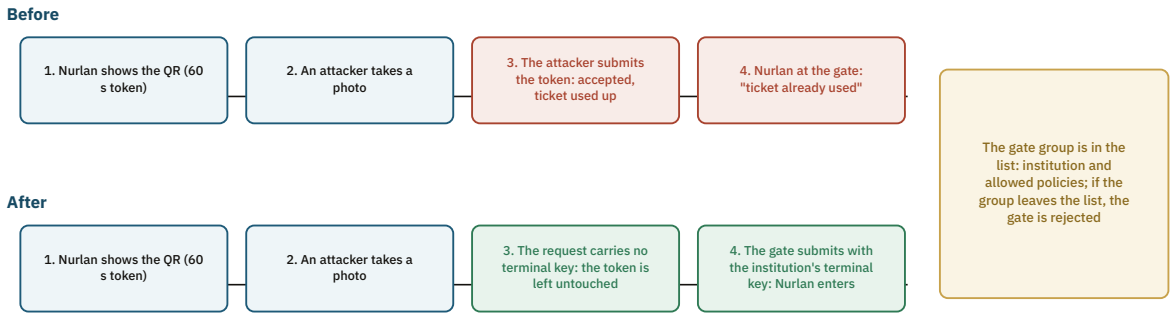


Figure 27. Fake ticket consumption attack: before and after the terminal key

16.4 Secure defaults

The security of a library depends on what happens when the developer using it takes the easiest path. In version 0.7.0 of the packages this principle was made into a decision (ADR-0056): the trust anchor, the redirect address allow list, the status check and the verifier registration became mandatory inputs. Skipping a check is still possible, but only by writing `"none"` explicitly; it cannot be skipped by forgetting. The same decision rejected, from today, requests that carry no registration certificate, even though the EU allows a longer transition period; it treated an mdoc [34] without a device key as invalid; and it switched trust list rollback protection on by default. The alternative considered, keeping loose defaults and moving over with a warning period, was rejected. In version 0.8.0 of the packages the same principle went a step further: the verifier package now opens a separate branch for every fetch of the request by default and does not produce a shared request object (CHANGELOG 0.8.0). *Status: live.*

16.5 Conformance and testing

The network's current conformance regime is "light conformance" (FW-TF-0001 §2.4, §4.3). The public conformance test vectors carry frozen inputs and expected outputs; each of the negative cases (no device binding proof, wrong `nonce`, expired credential...) must be rejected. The commitment tests require at least three things: a stale list gives the result "could not verify", processing stops on an unknown format, and processing stops on a signature error. An implementation that returns `REJECTED` where `INDETERMINATE` is expected is counted as non-conformant (GUIDE-0009).

In October 2026 the identity service and Tamga Verify were self-tested on the sandbox with the OpenID Foundation's conformance test plans [33]; the scope and results are in Section 20.5. This was a self-test; certification is a separate process. Close to twenty changes came out of the work, and four of them changed earlier decisions through recorded ADRs (for example ADR-0061 and ADR-0062).

So far the network has carried out its own security reviews; the gate vulnerability was found this way, in the October 2026 security round, and closed. As SECURITY.md states, the network has not yet undergone an independent external audit; a package for external review, containing the scope, the threat model, the data flows, the catalogue of invariants and the test results, is kept ready in the repository. The packages have no post-install scripts; eight of the ten packages are published only from continuous integration, with provenance. The prover package is published by hand because its phone libraries cannot yet be built there; the first release of the onboarding tool was also published by hand, because npm's trusted publishing can only be set up for a package that already exists, and the tool's later releases come from continuous integration with provenance.

16.6 Incident response and responsible disclosure

The Trust Framework classifies incidents by severity (FW-TF-0001 §4.6). Incidents that endanger trust itself (a leak of an issuer signing key, suspicion about the list key, a vulnerability in a wallet solution) are reported within 4 hours at the latest, and those affecting a service or a participant within 24 hours at the latest. An issuer whose key has leaked is suspended, and its certificate and the affected credentials are revoked; on suspicion about the list key, the switch is made to the second rolling certificate. A personal data breach is reported to the KVKK authority [9] within 72 hours. For a participant that breaks the rules there is a sanctions ladder reaching from a warning to removal, and removal does not invalidate earlier credentials (Section 18.6).

Security vulnerabilities are reported to `security@tamga.network` the network responds within 72 hours and applies a 90-day coordinated disclosure window. Wallets in the list are out of scope and are reported to their own operators (SECURITY.md). The same document also lists the limits that have been knowingly accepted; a finding that shows their impact is still welcome.

17 Sandbox, Open Packages and Reference Services

Elif works in the student affairs office of Example University and wonders how its diplomas will look in the wallet and what an employer will see. Dilnoza, for her part, wants to add the “Sign in with Tamga” button to her site. Both want to try things out without touching a real person’s data, without polluting the real network and without waiting for anyone’s permission. How open a network is can be measured by how easily someone who wants to join can make a first attempt. This section describes the tools for that first step.

17.1 Sandbox

The sandbox is a test network completely separate from the real network (ADR-0038). Its services run the same code as the real network and repeat its address layout under the `sandbox` subdomain; a wallet or verifier moves over by changing only the addresses and the trust anchor. It has its own test root, its own keys and lists that clearly mark themselves as test. The real network’s root signs nothing in the sandbox, the sandbox root appears in none of the real network’s lists, and software configured for the real network does not accept a sandbox list. The data returns to its initial state every night. The options of a local development environment only (phones and other servers cannot reach it) and test institutions in the real network (test credentials would be valid with real verifiers) were rejected.

The sandbox has example institutions, thirteen fake people from different countries and in different situations, and example credentials of every type. Some people are prepared for trying out negative results: one whose diploma is revoked as soon as it is issued, one who is suspended, one who is 17 years old, one who has no record at any institution. The identity numbers of the example people are deliberately in an invalid format (GUIDE-0013). Identity verification is done by default with a fake provider. For those who want to see the real identity verification steps, there is also a separate real path (ADR-0040); this path is capped and limited. Before scanning, the person confirms a clear test environment warning, only the given name, family name and date of birth pass into the credential, and the identity and document numbers are replaced by a random value that is clearly a test value; so a sandbox credential cannot be linked to credentials and pseudonyms in the real network. This path shares the real network’s provider account; the risks this brings and their mitigations are written in ADR-0040.

Institutions can also open their own test institutions in the sandbox (ADR-0041). Elif enters a made-up institution name and type; no e-mail, phone or person’s name is asked for. The institution is added to the sandbox list at once with a “test institution” mark; Elif signs in to the Institution Console in

the sandbox with a passkey, uploads made-up records and issues credentials at the desk. A record carrying a number that passes the identity number checksum rule is rejected, because it might belong to a real person. The certificates of test institutions are not issued directly by the sandbox root; they are issued by a separate intermediate certificate authority, signed by the root, that can issue certificates only one level down. The root's private key sits on no server; if the intermediate authority is compromised, only it is revoked and a new one signed. Wallet developers today register their own wallet providers in the sandbox list by applying to project management; the network does not operate a wallet provider in the sandbox either (ADR-0042). *Status: live.* Table 28 compares the sandbox with the real network.

Table 28. The sandbox and the real network.

Topic	Real network	Sandbox
Trust root and lists	real root, `trust.tamga.network`	separate test root, `trust.sandbox.tamga.network`, test mark in the list
People	real people	fake people; an optional, capped real identity path
Identity verification	remote identity verification provider	fake provider by default
Institutions	institutions that have passed the participation gates	example institutions and self-service test institutions
Persistence	entries are not deleted, changes are appended to the log	reset every night
Gate keys	issued by the operator	test keys open to everyone
Mutual trust	does not trust the sandbox	does not mix with the real network

17.2 Ten packages

The network's rules do not live only in documents; they are also distributed as code. There are ten open source packages under the name `@tamga-network/*`. The code is licensed under Apache-2.0 and the documents under CC BY 4.0. The packages are published on npm as the 0.8.2 pre-release; until the stable 1.0.0 release the interfaces may change (README) (Table 29).

Table 29. The open packages.

Package	Role	Platform note
`@tamga-network/core`	hashes, identifiers, certificate helpers, EU PID name table	separate subpaths for React Native
`@tamga-network/trust`	loads and verifies signed lists; single read interface `TrustSource`	`/core` platform-independent, including React Native
`@tamga-network/schemas`	credential type catalogue: Type Metadata, JSON Schema, integrity hashes	everywhere, including React Native
`@tamga-network/sd-jwt`	SD-JWT VC: selective disclosure, device binding, status list	
`@tamga-network/mdoc`	ISO/IEC 18013-5 mdoc: CBOR, COSE, issuance and verification	pure TypeScript, React Native compatible
`@tamga-network/issuer`	issuance (OpenID4VCI) and status list publication; hosted service client	server
`@tamga-network/verifier`	verification pipeline and OpenID4VP; page kit; ZK verification	server; `/web` page kit
`@tamga-network/wallet-core`	wallet core: keys, credential retrieval, local checks, presentation	Node and React Native

Package	Role	Platform note
`@tamga-network/zk`	wallet-side zero-knowledge prover for mdoc	the core everywhere; a native prover on the phone
`@tamga-network/onboard`	onboarding tool for institutions: application files, keys and CSRs, setup and trust list checks; node steps; local MCP server	command line (`tamga-onboard`), Node.js 22+

The most important design decision in the packages is the single trust interface (ADR-0015). Every client, including the wallet, asks trust questions through the same interface; so the same rule is not written twice in two different forms. Behind the interface today stand the signed lists; when the shared ledger arrives, it moves in behind the interface without the interface changing (Sections 6.6 and 19.8). Since the wallet runs on React Native, the verification core has been split into a subpath that does not depend on the file system or on platform-specific libraries.

TYPESCRIPT Example: verifying a presentation on your own server (abridged, 0.8.2 pre-release)

```typescript
import { fetchTrustSource } from "@tamga-network/wallet-core";
import { verifyPresentation } from "@tamga-network/verifier";

// Trust anchor: root fingerprints embedded in the application; the list server is not trusted
const { source: trust } = await fetchTrustSource("https://trust.sandbox.tamga.network", http, {
  pins: { lotlSigners: [SANDBOX_LOTL_SIGNER_FINGERPRINT], environment: "sandbox" },
});

// After the encrypted response from the wallet has been decrypted (with the request branch and state check)
const { result, claims } = await verifyPresentation({
  presentation, aud: clientId, nonce: branch.nonce, policy, policyCredentialId: "diploma",
  trust, statusCache, rootCertsDer,
  rp: trust.relyingParty(clientId),   // registration mandatory; "none" to skip on purpose
  audit: (entry) => log(entry),       // audit log
});
// result.outcome: "ACCEPTED", "REJECTED" or "INDETERMINATE"
```

The example is abridged and the values are examples; the full flow, which opens a separate branch for every fetch of the request, is in the example projects that run against the real packages in continuous integration (`examples/02-verify-own-server`). Someone who does not want to write their own verifier can use the hosted Tamga Verify.

17.3 Reference services

The network operates four reference services (ADR-0037): the hosted issuance service, the Institution Console, Tamga Verify and the identity service. These exist so that the network can work, can be tried out and institutions can join; they are not sold and are open to everyone on the same terms. An external institution reaches the hosted issuance service from its own server through a tenant-bound API with scoped authorisation; a single shared administrator key was rejected (ADR-0016). The Institution Console is the single place where staff open accounts by invitation and sign in with a passkey, and where they manage credentials, revocation and suspension and the register; the old student portal was removed, because the person now requests the credential from the wallet (ADR-0019). In Tamga Verify, only the verifier that opened the presentation can access the result and the disclosed fields, with a short-lived statement signed with its key from the list, and only once (ADR-0017).

The same sentence holds for every service: you can set up your own software under the same rules (FW-ARF-0001 §4.1). An institution can run its own issuance service, and a verifier its own verification software; using the network's service is not a requirement (Figure 28).

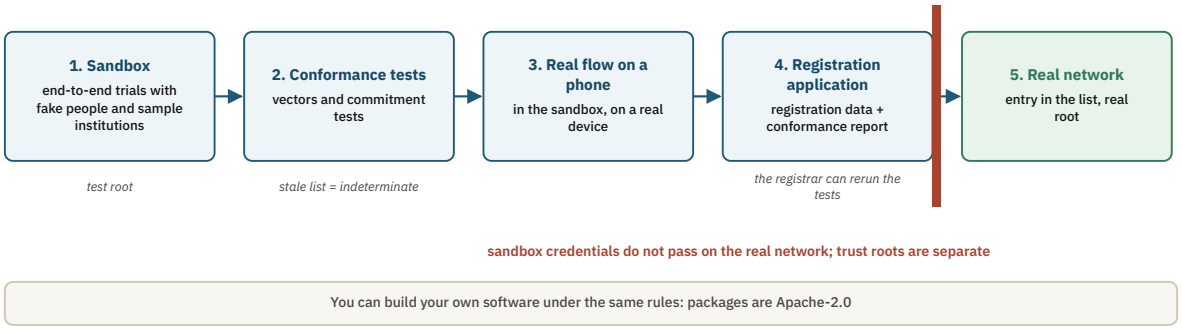


Figure 28. A developer's path: from the sandbox to the real network

17.4 The three doors to the documentation

The network's outward-facing documentation, in an arrangement similar to the EU's, is published through three separate doors (ADR-0018). The general overview is at tamga.network; developer documentation, guides, specifications and decision records are at docs.tamga.network; the architecture and reference framework (Tamga ARF) and its annexes are at arf.tamga.network. Readers choose the door that suits them: an institution's manager starts with the concepts, a developer with a guide, a regulator with the framework. Tamga ARF is published in Turkish and English; the Turkish text is the source, the English text is the official translation of the same version, and any version drift between the two languages is caught at build time. All the ADR, SPEC and FW numbers given in this document can be found publicly through these doors.

18 Governance and Sovereignty

Suppose two states join this network. The first wants to add a professional body in its own country to the list as an issuer. Does it have to wait for the second state's vote? If so, no state would enter such a network; it would have made its own internal decisions subject to someone else's approval. If not, does the network have anything shared left? This section describes the path Tamga Network has chosen between these two extremes, who decides what today, and how this arrangement will change hands.

First, the current situation. Today only the Türkiye section of the lists is active. Places are reserved for Azerbaijan, Kazakhstan, Kyrgyzstan and Uzbekistan, members of the Organization of Turkic States (OTS), and for the observers Hungary and Turkmenistan (FW-TF-0001 §1.3). These places are empty slots; they are not a notice of any agreement or negotiation with any state. Everything described below as happening "when states join" consists of rules that will apply if that day comes.

18.1 Three-layer sovereignty

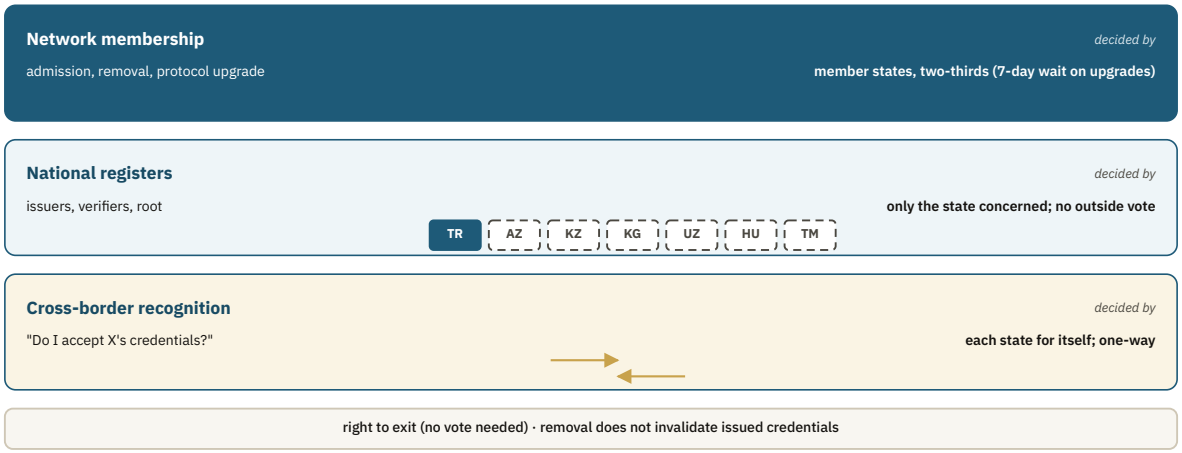
The European Union answered this question with its own trust lists: each member state publishes its own list independently, the Commission keeps only the list of trusted lists that brings these lists together, and no state votes on which institutions another state will list. Tamga Network follows this precedent and divides governance into three layers, in each of which the decision rests with a different actor (ADR-0002; Figure 29).

Network membership. Which states sit at the table is a shared decision. Admitting a new state, removing a state and upgrading the shared protocol take a two-thirds vote of the member states. Unanimity was deliberately not chosen; it would have meant that a single state could block the growth of the network.

National registers. A state's issuers, verifiers and root certificates are solely within that state's authority; there is no outside vote. The principle is written as P1 in FW-ARF-0001 §1.6: each state is the sole author of its own national registers. In the list stage this rule is protected by signature: the national list is signed only with that register's signing key. In the ledger stage the same rule is enforced by the ledger itself and stops being a promise of good faith (ADR-0002 sub-decision 2; ADR-0054 K2).

Cross-border recognition. Each state answers the question "do I accept the credentials of country X?" on its own behalf and unilaterally. Under the initial arrangement in ADR-0002, the founding members recognise one another from the start, and a state that joins later opens recognition itself, at the pace of its own legislation. This avoids the "all or nothing" trap.

Above these layers there are two safeguards. A state can **withdraw from the network** unilaterally, without a vote. And **removing a state does not invalidate its citizens' credentials**: the removed state cannot write new entries, but the credentials in wallets remain, and what happens to them depends on the other states' recognition decisions (ADR-0002 sub-decisions 4–5; FW-TF-0001 §3.3). This is the first question a state will ask when entering the network: "If I leave one day, what do my citizens lose?"



Today only the Türkiye list is active. Slots do not indicate any agreement or negotiation.

Figure 29. The three layers of sovereignty: who decides?

TECHNICAL DETAIL

Voting rules

Let n be the number of active members at the time of the decision and e the number of yes votes. Writing the threshold in integers removes the rounding question:

$$\text{admission} \iff 3 \cdot e \geq 2 \cdot n$$

$$\text{removal}: \quad n = n_{\text{active}} - 1 \quad \text{(the vote of the member being removed is not counted)}$$

$$\text{upgrade}: \quad t_{\text{queue}} + 7 \text{ days} \leq t_{\text{apply}} \leq t_{\text{queue}} + 37 \text{ days}$$

In a network of four members, admission needs at least three yes votes ($3 \cdot 3 \geq 8$); with five members three is not enough ($9 < 10$) and four are needed. For an upgrade, once the threshold is reached the proposal enters the queue, is applied at the earliest seven days later, and at the moment of application the threshold is recounted from the members active at that moment (ADR-0055; Section 19.6). Today none of these rules runs in code: in the list stage, governance lives in documents (ADR-0009 K5).

18.2 Today's bodies

This arrangement assumes states, but today no state has joined the network. The Trust Framework (FW-TF-0001) chooses to name this gap: a body that cannot yet be set up is written in the table as "not yet", and a provisional situation is called provisional (Table 30).

Today the **provisional operator** carries out day-to-day operation, the infrastructure, list operation and the registrar role on behalf of the state. Since the network has no legal personality, this work is done on behalf of the non-profit foundation to be established; in the lists the operator name is always "Tamga Network", and its status is marked `provisional` (ADR-0070 OP1). The **technical board** runs specification changes, the approval of decision records and the shared credential types. There is no **council** it is not set up while there are no member states. The governance body (foundation or council) is set up when one or two states are willing to join, and the lists are handed over to it (FW-ARF-0001 §8.3).

Table 30. Bodies and their powers (FW-TF-0001 §1.6, §4.2).

Topic	Today	When states join
Country list, registrar, root certificate	Provisional operator, on behalf of the state	Each state for its own list
Admission of members, removal, protocol upgrade	None (no member states)	Council, two thirds
Specifications, decision records, shared types	Technical board	Subject to council policies
Scheme owner and accreditation (ISO/IEC 17000 [40])	Provisional operator	Council; national accreditation body
Conformity assessment	Self-declaration and open conformance tests	Independent assessment bodies

The most honest row in the table is the second: today there is no decision on which a state would vote, because there is no state to vote. It is precisely for this reason that the broad powers of the provisional operator and the technical board are bound to written limits, measurable thresholds and the transparency report (Section 18.5).

18.3 Stages

The network's evolution is defined in four stages, and the stages are defined by conditions, not by a calendar (FW-ARF-0001 §8.1; Table 31, Figure 30). No dates are given, because each transition depends on something the network cannot provide on its own: an independent second operator, or a state's decision to join.

Table 31. Governance stages (FW-ARF-0001 §8.1; ADR-0009 K4).

Stage	Anchor of trust	Who governs	Transition condition	Status
List stage	Signed lists and the anchor log	Provisional operator	—	Live
Ledger stage	Shared ledger (projection of the lists)	First operators	Written acceptance by at least two independent operators; equivalence tests	Planned (code ready, switched off)
State participation	Shared ledger	Council, two thirds	The first state operator going into production	Planned
Institutional expansion	Shared ledger	Council	The council's thresholds	Planned

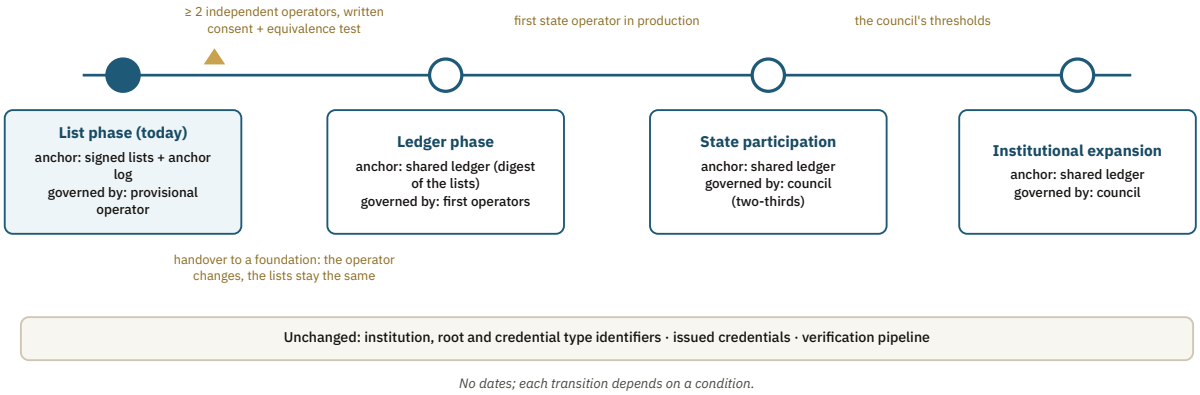


Figure 30. Governance stages: the anchor of trust and who governs

The two transitions answer different questions. The ledger stage changes **how many signers** trust rests on; state participation changes **whom** trust belongs to. The two may also come in a different order. Section 19 deals with the first, and the hand-over plan below with the second.

18.4 Hand-over plan

Every state role Tamga takes on today is designed to be handed over (FW-ARF-0001 §1.6 P4: no identifier, role or structure assumes a single operator). The trace of this can be seen in the lists: the root's name has the form "TR National Root CA (provisional operator)", the name belongs to the state and the operator is written in a separate field (ADR-0009 K5). At hand-over this field changes; the institution, root and credential type identifiers do not.

Hand-over consists of two separate events. **Hand-over to the foundation** changes the operator of the network's own services when the foundation gains legal personality. A single configuration value is changed, and the entries and certificates linked to it are renewed; the list operator name, the root and credential type identifiers and the institutions' permanent identities do not change (ADR-0070 K4, OP3). The hand-over is carried out with a ready tool and a written guide; the tool can be run in dry-run mode. The only known side effect is at the identity service: the institution identification number will be added to the credential signing certificate with a new key at the hand-over to the foundation, and identity credentials will be obtained again once on that day; this was chosen so that people would not have to go through this re-issuance twice (ADR-0058; Section 14).

Hand-over to a state happens when a state takes over its own country list, and is defined in six steps (Table 32). The order is flexible; a state may first take over list operation and take over the registrar later.

Table 32. Steps of hand-over to a state (FW-TF-0001 §7).

Step	What is handed over	How
1	Operation of the country list	The operator field changes; the state's signing certificate is added as a rolling certificate; the identifiers stay fixed
2	Registrar	Registration authority passes to the state; the provisional operator can no longer register
3	National root certificate	Its name stays fixed and its operator changes; or the state's root is added as a rolling root and the old root retires
4	The place of the person identification data (PID) provider	The state fills it; the high identity verification levels pass to the PID
5	Shared ledger	A ledger with state operators; the list archive is transferred as is and passes an equivalence test
6	Trust Framework	Passes into the council's ownership; version numbering continues

The Trust Framework puts a single sentence under the table: “Hand-over invalidates no credential, entry or identifier.” For the wallet and the verifier, the whole effect of the hand-over is that the list’s address and signer change (ADR-0035 PO3). Assets that code cannot protect, namely domain names, root certificates, the list archive and keys, are bound by written rules: once the foundation is formed the domain name is registered in its name, transfer lock and DNSSEC apply, and it is renewed at least ten years ahead; on liquidation or hand-over these pass to the council or a custodian under a succession agreement (FW-TF-0001 §5.7; ADR-0070 K5).

18.5 Measurable thresholds and transparency

Power that can be limited by code is limited by code: someone without the signing key cannot change the list. But an operator that hosts the services, holds the domain name, keeps records and collects statistics can gain quiet weight without breaking any rule. The Trust Framework calls this **soft power** and limits it too (G-B; FW-ARF-0001 §1.6 P7): every such power is bound to a written policy, a measurable threshold and the transparency report (Table 33).

Table 33. Soft powers and their limits (FW-TF-0001 §1.6–§1.7; FW-RB-0001 RB-OP-09…RB-OP-13).

Power	Limit
Hosting the issuance service	The list of hosted institutions is public; if their share exceeds 30%, the matter goes on the council’s agenda
Operating ledger nodes	When there are at least four state operators, the first operator’s nodes are handed over
Indexing the lists	The operator offers no hosted indexing service; the indexing software is open source
Collecting statistics	Only aggregate counters; groups smaller than 50 are not published; no counters per institution or per credential; raw counters kept at most 13 months
Changing the list	Public change log (who, when, what, reason); anchor log

The transparency report is published every three months: list versions and changes, the hosting share, type usage counters in groups of at least 50, incidents and audit findings; it contains no personal data (FW-TF-0001 §1.7). The limit of this arrangement is clear and will come up again in Section 23 as a residual risk: today the anchor of trust is the signature of a single operator. If the operator and an issuer act together, an inconsistent entry could be published; the log, the report and audits deter this but do not make it impossible (FW-ARF-0001 §6.6, L1). What will remove this limit is the multi-signer arrangement in Section 19.

18.6 Participation gates and the conformance regime

The first principle of the Trust Framework draws a line: **registration is not authorisation** (G-A). The registrar records; it does not approve. A university’s legal authority to issue diplomas is granted outside the network, in the legislation of its own country; the network only keeps the scope within the network: which type it may issue, and with which fields.

There are four gates for issuers (FW-TF-0001 §3.2). **I1 (registered)** requires domain name ownership, contact information and technical conformance, and appears to the verifier as “not accredited”. **I2 (contracted)** adds confirmation of legal personality and of the authorised signatory, the participation agreement, an X.509 [28] certificate and the personal data annexes. **I3 (accredited)** requires keys to be held in a hardware security module or a qualified electronic seal, record keeping, incident reporting deadlines, an annual review and liability insurance. The **Public** class is for state institutions and authentic sources and is registered by the registrar of the state concerned. Credential type authorisation is independent of the gate: there is a separate allow list for each type, closed by default. The verifier and wallet provider gates are described in Section 20.3. Supervision is a mixed model,

as in the EU wallet ecosystem: credentials with a qualified equivalent are supervised in advance, the others afterwards (Table 34).

Table 34. Conformance regime (FW-TF-0001 §4.1).

Class	Regime	Content
I3 / qualified equivalent	Prior supervision	Technical and organisational assessment before registration; annual audit
I2	Subsequent supervision	Self-declaration, conformance tests; audit on a complaint or an incident
I1	Self-declaration	Technical conformance test; “not accredited” label
Wallet provider	Today self-declaration and conformance tests	When states join, prior supervision and a certified solution
Verifier	Subsequent supervision	On a complaint of scope violation or excessive requests

An institution’s IT team prepares and tests its readiness for a gate with the network’s open onboarding tool (`@tamga-network/onboard`, command `tamga-onboard`). The tool checks the application files against the registration rules (ADR-0024), generates the institution’s two signing keys on the institution’s own computer and writes the certificate signing requests (CSRs) for the registrar (in production, generating the keys in a hardware security module or a remote signing service is preferred; the tool then only checks the request), and tests the domain, the DNS confirmation, the https addresses, the metadata and the lookup endpoint; after registration it checks how the institution appears in the signed trust list, verified against the root fingerprints embedded in the tool. The same steps are offered as a local MCP server, so the institution’s own AI assistant can run them. The tool never writes to the network or the trust list, asks for no personal data, and private keys never leave the computer; the registration decision and the write to the list stay with the registrar, today the provisional operator (GUIDE-0014). These steps work in today’s list-based setup.

If a rule is broken, a five-step sanctions ladder applies: a warning with thirty days to fix, narrowing of type authorisation, suspension, removal with a successor appointed, and termination of the agreement (FW-TF-0001 §4.5). The most important rule of the ladder again protects credentials: removal does not invalidate earlier credentials, because validity is assessed by the date on which the credential was issued (Section 11.3). There are no fines; if the council is formed, it may introduce them by its own decision. Disputes are settled first before the scheme owner and then at the place of jurisdiction in the agreement; the law of the state where the institution is located applies, between states the council is competent, and there is no authority above it (FW-TF-0001 §4.7, §5.8). Before the pilot the framework will undergo legal review with respect to Turkish personal data and electronic signature legislation (FW-TF-0001 §1.4); this document is not a legal opinion.

18.7 Funding principle

Tamga Network is non-profit and sells no products or services (ADR-0037). Only the principles that affect the network’s neutrality are written here (ADR-0071; FW-TF-0001 §5.5). The network is always free for people. In the provisional phase the network charges no participant for list registration, issuance, verification, the identity service or the list service. A financial contribution has no effect on a registration decision, a place in the list, the participation gates or governance votes. Paid services are offered by companies outside the network under their own names, and no registration decision can be tied to them. If the question of fees is reopened, this requires a decision of the governance body and a new decision record.

18.8 The rulebook arrangement

Tamga’s architecture and reference framework (FW-ARF-0001), like the EU ARF [11], consists of a main document and annexes. Annex A is the Trust Framework, and Annex B is the **Tamga Rulebook**

(FW-RB-0001): it collects the numbered, binding rules each role must follow and is the counterpart of the EU ARF's annex of high-level requirements. Rules take the form `RB-<ROLE>-<NN>` (e.g. RB-OP-15: the shared ledger is not set up without the written acceptance of at least two independent operators) and use the MUST, SHOULD, MAY language of RFC 2119. The rulebook of each credential type (Education, Identity, Event Ticket, Contact) branches from this book, inherits all its rules and follows the EU's Attestation Rulebook [13] template.

These documents do not produce decisions. The order of precedence is decision records, specifications, the Trust Framework, the Tamga Rulebook and contract templates; in a conflict the higher one prevails (FW-TF-0001 §0). Every change rests on a decision record and is published at `arf.tamga.network` a major version that changes participants' obligations requires the agreements to be signed again (FW-TF-0001 §8). Every deviation from the rules is recorded with its reason and a closing date; an unrecorded deviation is a violation (RB-ENF-04). How decisions are made is covered in Section 21.

19 The Shared Ledger: Why Not Now, and How It Will Come

KEY POINT

Status of this section: planned

There is no running chain today, neither on the real network nor in the sandbox. The code of a permissioned shared ledger has been written and tested; it runs only on developers' machines and on the four-validator test network in the public repository, and it is not in production and is switched off. It will not be switched on without a second independent operator (ADR-0009, ADR-0051). What follows are the rules that will apply if the ledger is switched on; their scope and the transition are set by ADR-0073, ADR-0074 and ADR-0075. Today trust rests on the signed lists and the anchor log in Section 6, and no step of verification depends on a chain.

"Where is the blockchain?" is one of the questions Tamga is asked most often, because the network's first design began with a chain. Today's answer is this: a chain adds nothing at the moment, and setting one up during a period when it adds nothing makes trust look greater than it is. This section explains the reasoning behind this, the rules under which the ledger will come, and how the transition will be made. The question of when a chain is useful for identity is discussed in general terms in the twelfth paper of the series [77].

19.1 When a ledger adds something

The promise of a shared ledger is that several parties who do not fully trust one another keep a record that none of them can change alone. Consensus methods tolerant of Byzantine [58] faults work even if some of the parties are faulty or malicious; but they rely on the rest being independent of one another.

In the old plan, the first stage had four block validators, and all four were to belong to the same operator. ADR-0009 asked a simple question: what do four nodes under the same hand produce beyond the assumption that this hand is honest? They produce resilience to outages; they do not produce trust. In terms of trust, a single operator's chain is the same as a hash-chained log signed by a single operator; the latter is cheap, is an ETSI standard and is the EU wallet ecosystem's own model (ADR-0009 F1).

This observation became a principle (FW-ARF-0001 §1.6 P5): **a shared ledger is not a storage choice, it is a choice of signers.** The value comes not from where the data sits but from how many independent parties confirm it. That is why the starting threshold is written down: the chain is set up only when at least one institution that is legally and operationally independent of the provisional

operator (such as a second university, a chamber or a state institution) accepts in writing to run a validator (ADR-0009 K4; RB-OP-15). Today there is no such operator. The alternatives considered are recorded too: waiting for the chain tied the pilot to infrastructure without any gain in assurance; a single-operator "development chain" would give the appearance of a chain without giving trust; and a demo without lists, certificates and a status list, not being the same architecture, would have required everything to be rewritten at the transition.

19.2 Why Besu and QBFT

Although the ledger will not be set up today, its technology has been chosen: Hyperledger Besu [59] and the QBFT consensus method (ADR-0001). The network is a permissioned, independent private network; it has its own genesis block and chain identifier and is connected to no public network. In QBFT a block is finalised in a single block with the approval of more than two thirds of the validators, and voting power is equal. In the design, the validators are states, while trusted institutions run full nodes that do not validate blocks; since QBFT struggles above a few dozen validators, this split also solves the problem of scale (Table 35).

Table 35. Options considered for the ledger engine (ADR-0001; ADR-0051).

Option	Result	Reason
Hyperledger Besu + QBFT	Chosen	Permissioned network, equal votes, immediate finality built in; Apache 2.0, can be forked; EBSI [60] is also Besu-based
Cosmos SDK (CometBFT)	Rejected	Better scale and speed; but the advantage of a multi-chain structure is idle in a single shared ledger, and it is a different stack from EBSI
A consensus method built from scratch	Rejected	High risk and long timeline, no contribution to sovereignty
A public chain or a layer on top of one	Rejected	Loss of sovereignty; the personal data boundary cannot be enforced on an external chain

Among the original reasons in ADR-0001 was that the ledger could later carry value transfer; this direction is suspended today (Section 19.9). The reasons that keep the choice standing are the permissioned structure, equal votes, immediate finality, sovereignty and the precedent in the EU.

19.3 The projection principle

If the ledger comes, does it replace the lists? ADR-0051 gives the narrowest and safest answer: **the chain is a projection of the signed lists.** The source is always the signed lists and the anchor log; the chain is a second record that repeats in digests what the lists say (Figure 31).

Two decisions set what is written to the ledger. ADR-0051 took the first step: the digest of each list version (which list, which version number, the SHA-256 digest of the content, the digest of the previous version, publication time) and the digest of the last line of the anchor log are written. Since the lines of the log are linked to one another by a hash chain, the last line binds the whole log. ADR-0074 widened the scope: every entry in the signed lists that affects a trust decision has a counterpart in the ledger. This includes root certificates, issuers, verifiers and terminal groups, schemas, wallet providers and their signing keys, zero-knowledge circuits, external lists, list signers and the list operator. The entries themselves are not written to the ledger; their digests and fingerprints are. These are digests of identifiers, key and certificate fingerprints, closed-set values, dates, state codes and account addresses. Free text such as names, descriptions and contact details stays only in the signed list; the ledger holds a single digest taken from its canonical form. Credentials, credential hashes, status bits and personal data are never written to the ledger (ADR-0051 CH2; ADR-0074 PJ1, PJ2; Table 36). Sandbox lists are not written to the production ledger either (ADR-0074 PJ4).

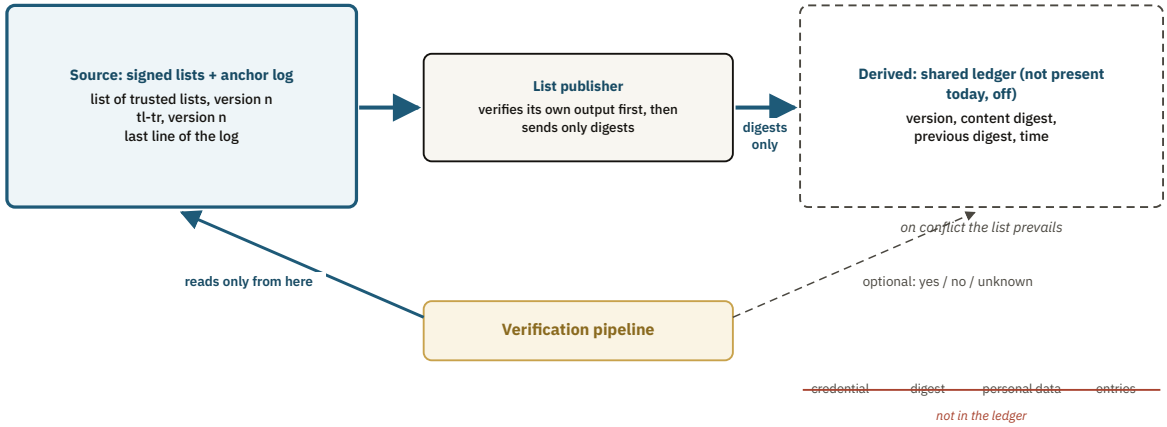


Figure 31. Projection: the list is the source, the ledger is derived

The most important rule of the projection is its direction. The verification pipeline and the single interface through which clients ask trust questions (`TrustSource`, Section 6.6) read only from the lists; the chain is not required at any step and will not be. A verifier may, if it wishes, compare the digest of its list with the confirmed digest on the chain and receive one of three answers. **Yes**: the confirmed digest is the same. **No**: there is a different confirmed digest for the same version; this is a sign that two verifiers have been shown two different lists; it does not change the verification result, but it raises an alarm for the operator and goes into the transparency report. **Unknown**: the feature is switched off or the chain cannot be reached; the result does not get worse. In a conflict the list prevails; the chain entry is not corrected, a new version is added next to it (ADR-0051 K1, K5, CH1).

Table 36. What is in the ledger and what is not (ADR-0051 CH2; ADR-0063 BL2; ADR-0074 PJ2; FW-ARF-0001 §1.6 P2).

In the ledger	Not in the ledger
The list version number, content digest, previous digest, publication time	The text of the list; names, descriptions and contact details in the entries
The sequence number, digest and time of the last line of the anchor log	Credentials and credential hashes
Digests of identifiers, fingerprints, statuses and dates of institution, verifier, schema, wallet provider and list signer entries	Personal data, identity numbers, field values
Which candidate the anchorers support, conflict events	Wallet instance, device or pseudonym identifiers
The address, digest, version, size and bit size of a status list	Status bits, positions in the list, credential type name

The last row shows the discipline of the projection well. The identity service's status lists use one bit per entry, institution lists two (Section 12.3). The ledger's old draft accepted only two bits, and identity lists could not have been anchored at all. ADR-0063 turned the rule around: the ledger records how the list describes itself and accepts one of the values 1, 2, 4 or 8 that the IETF Token Status List [17] allows. How many bits a type uses is a rule of the publisher and the verifier; the ledger does not know the credential type.

19.4 Threshold anchoring and competing candidates

For a digest on the chain to count as confirmed, a submission by a single anchorer is not enough: as many different authorised anchorers as the threshold must submit exactly the same data, and in production the threshold is at least two. A single operator cannot produce a confirmed anchor; this is the ledger's counterpart of the "second independent operator" rule (ADR-0051 K3, CH3).

What happens if the anchorers disagree? In the first design, the anchorer that opened the version first determined what the data would be, and one that sent different data was rejected. A security review found two weaknesses in this: a single anchorer could open the version with wrong data and permanently block the honest anchorers, and since a rejection left no trace on the chain, this lock remained invisible. ADR-0053 changed the rule: for the same version, each different piece of data is recorded as **a separate candidate** every second and subsequent different candidate emits a conflict event that everyone can see; and the first candidate to reach the threshold wins (Figure 32). After confirmation the version is closed; the confirmed entry does not change and is not deleted. The support of an anchorer removed from the set is not counted, so an operator that rotates its key cannot cast two votes for the same version; nor can the threshold be set higher than the number of anchorers (ADR-0053 K4).

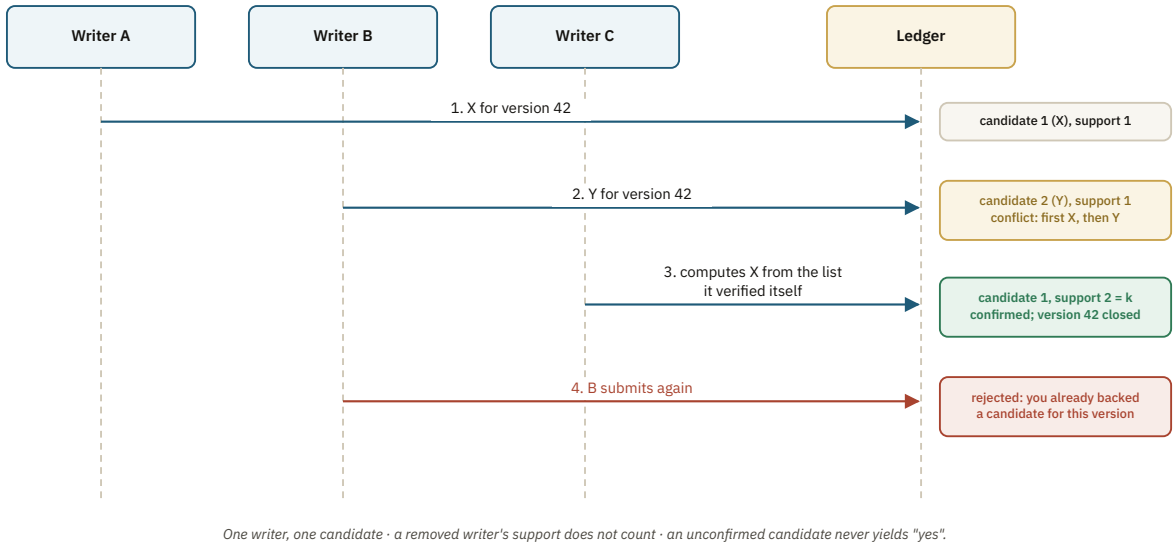


Figure 32. Competing candidates: two different digests for the same version (threshold k = 2)

TECHNICAL DETAIL

The rule of threshold confirmation and the path of an anchor

Let W be the set of authorised anchorers, k the threshold, and $D(v, a)$ the authorised anchorers supporting candidate a for version v (ADR-0051 CH3; ADR-0053 AC1–AC4):

$$\begin{aligned} \text{confirmed}(v, a) &\iff |D(v, a)| \geq k \\ 2 \leq k &\leq |W| \quad \text{(in production)} \\ D(v, a) \cap D(v, b) &= \varnothing \quad \text{for all } a \neq b \end{aligned}$$

The third line says that an anchorer cannot support two candidates for the same version; otherwise a single operator could support two different digests and hide its double-talk within itself. The path of a list version to the chain:

1	`List publisher`	**Publication.** Signs the list; writes the digest of the previous version into the list.	$\text{prev}_n = \text{SHA-256}(L_{n-1})$
2	`List publisher`	**Self-check.** Verifies the signature, the hash chain and freshness; an unhealthy set is not anchored.	$\text{Verify}(L_n) = \text{valid}$
3	`Anchorer → Ledger`	**Submission.** Sends only the digest; this is a vote.	$h_n = \text{SHA-256}(L_n)$

4	Ledger	**Candidate.** The same digest increases support; a different digest opens a new candidate and emits a conflict event.	$\lvert D(n, h_n)\rvert + 1$
5	Ledger	**Confirmation.** When support reaches the threshold, the version is closed.	$\lvert D(n, h_n)\rvert \geq k$
6	Verifier	**Optional check.** Compares the digest of its list with the confirmed anchor.	$h \stackrel{?}{=} h_n$

The feature flag is off by default; while it is off, no connection is made to the chain. In production the flag is not switched on without a second independent operator and a threshold of at least two (ADR-0051 CH5).

19.5 Namespace, cross-state links, quotas

The principle "only that state writes to its national registers" becomes a rule of code in the ledger, and ADR-0054 closed three edges of it. **Names:** shared types have the form `urn:tamga:<domain>:<Type>:<major>`, and types specific to a state the form `urn:tamga:<cc>:<domain>:<Type>:<major>` (Section 8.4). A national type may exist only in its own state's namespace, and a shared type may exist in no state's namespace; this way a state cannot claim in advance the name of a shared type that is voted on in the council. **Links:** an institution links only to its own state's root and names a successor only from its own state; one state's suspension decision cannot affect another state's institutions. **Quotas:** the daily caps that limit unwanted writes are counted per state and per entry type; status list publication is limited to 48 a day per list (hourly publication plus room for retries), and new list registrations per institution per day are limited; the cap cannot be bypassed by opening a new list.

19.6 Upgrade delay

The most powerful operation that changes the network's rules is upgrading the registry programs (smart contracts) on the ledger. The right to withdraw in Section 18.1 does not work if an upgrade takes effect the moment the vote passes: the new rules would already be applied before the objecting state could decide. ADR-0055 therefore puts a seven-day delay on upgrades.

TECHNICAL DETAIL

The steps of a protocol upgrade

1	Member state → Ledger	**Proposal.** A proposal pointing to the new version is opened; it carries no free data.	$\text{proposal} = (\text{target}, \text{new version})$
2	Member states	**Vote.** The active members vote.	$3 \cdot e \geq 2 \cdot n$
3	Ledger	**Queue.** When the threshold is reached, the proposal is not applied; it enters the queue.	$\text{eta} = t_{\text{queue}} + 7 \text{ days}$
4	Member states	**Withdrawal window.** Everyone sees what will happen; a state that does not agree can withdraw.	$t_{\text{queue}} \leq t < \text{eta}$
5	Ledger	**Recount.** The threshold is recounted from the members active at that	$3 \cdot e' \geq 2 \cdot n'$

		moment; the vote of one that has withdrawn drops.	
6	Ledger	**Application.** It is applied if the threshold is met; if it is not applied within thirty days, the proposal lapses.	$\text{eta} \leq t_{\text{apply}} \leq \text{eta} + 30\ \text{days}$

Two days leaves state institutions no time to react, and fourteen days needlessly delays an urgent fix; seven days is common practice. A separate timelock program was rejected because it would create a new holder of authority. The delay applies only to upgrades; admission of members, removal and registration of shared types have no delay.

It is also a rule that what is voted on stays readable. With an upgrade, only an initialisation function without parameters may be called; the initial values are in the new version's code, and that code is what is voted on. Administrative operations such as adding an anchorer, changing the threshold or removing a shared type are done through separate proposals of a specific type. A general "execute this call" proposal was deliberately not built: it would open a free data field on the ledger and make it harder for a state to read what it is voting on (ADR-0055 GE2, GE3).

19.7 Permissioning and operation

The ledger is permissioned: only approved nodes connect and only approved accounts send transactions. The early documents envisaged this with Besu's on-chain permissioning mechanism; Besu deprecated this mechanism in 24.12 and removed it in 25.6.0. ADR-0052 chose the remaining path, the local permissions file on each node, and added a rule: the file is not written by hand but generated from the ledger's own governance registry; each operator generates it itself, all validators carry the same list, and any difference is reported as an operational incident. The permissions list is the second line of defence; the real control of write authority lies in the ledger's rules, and an error in the list does not extend that authority. The nodes' remote call interface is not exposed to the internet; external access is given only to defined clients, from behind a reverse proxy that verifies mutual TLS (ADR-0052 LP4, LP5).

For the day the ledger opens, the onboarding tool also has node steps for a state or an operator (`tamga-onboard node`): it generates the node key on the node's own machine, writes a permissioned configuration template and the node declaration sent to the operators, and checks the running node read-only; it writes nothing to the ledger or the allowlist, and votes and allowlist changes stay with the operators.

19.8 Transition

The transition from lists to the ledger will not be a rewrite. The transition is a **replay** of the list version archive onto the ledger: each version is processed in order and the times in the entries' status history are preserved (ADR-0009 K7). The aim is this: an old diploma from an institution that has closed is valid because the institution was active on the date it was issued (Section 11.3), and it must get the same answer after the transition. The acceptance criterion is written accordingly: for every trust question recorded during the pilot, the trust source based on the lists and the trust source based on the ledger must give the same answer; if acceptance and rejection diverge in a single query, the transition is not complete. Credentials already issued are not reissued; the wallet and the issuance service do not change; clients change only the implementation behind the `TrustSource` interface (ADR-0015; FW-ARF-0001 §8.2). The transition can also be reversed, and the lists continue to be published in the ledger stage as well (ADR-0009 Rationale 3).

ADR-0073 sets how the replay is done. Each registry contract has a **migration window** that a governance vote opens only once. The window lasts at most 30 days, closes by itself when the time is up and cannot be opened again. While it is open, entries with past dates can be written, but no date can be later than the block time at that moment. The transition does not count as complete as long as any acceptance-versus-rejection difference remains between the answers the lists and the ledger give to trust questions. The same decision also defines **hard revocation**: if an institution's key has been compromised, the revocation entry carries a start date and credentials issued after that date are not accepted. Credentials that a suspended institution issued before the suspension, on the other hand, remain valid. A verifier's identifier in the ledger is the digest of its domain name and does not change when its certificate is renewed. Reassigning that identifier to another state, or registering it again after revocation, takes a two-thirds vote, and the history of the earlier period is not deleted (ADR-0075).

19.9 The value layer: suspended

In the first design some decisions were made so that the ledger could later carry a value layer (ADR-0003). These are no longer binding and remain on record only as a research direction (ADR-0072). Tamga Network issues no token or coin; it processes no payments, settlement or value transfer, and these are part neither of the first version nor of the pilot. The ledger code is only a projection of the lists. Reopening this direction requires a decision of the governance body, a privacy study, an independent security review and a new decision record.

20 EU Alignment and Third-Country Recognition

Aynur is applying for a job in Istanbul; the employer has a partner in Europe, and the partner also wants to see Aynur's credential. The partner's system can read credentials coming from EU wallets; Aynur's credential, too, is in the format the EU chose and is signed. Will the credential be accepted there?

The answer has two halves. The first half is technical: can the credential be read, can its signature be checked, can the issuing institution be found in a trusted list? Tamga's design tries to answer this half. The second half is legal: what value is given in Europe to the credential once it has been read? This half is not in the network's hands. One more note: a diploma Aynur obtained in Baku does not appear in the network's lists today; only the Türkiye list is active, and the place reserved for Azerbaijan is an empty slot that will be filled when a state joins; it is not a notice of any agreement.

20.1 Three levels of interoperability

The Trust Framework defines three levels (FW-TF-0001 §6). **Portability**: credentials are in SD-JWT VC [16] and mdoc [34] format and are issued and presented with OpenID4VCI [30] and OpenID4VP [31]; an EU wallet can technically process a Tamga credential. **Trust**: the lists follow the ETSI model, are also published in an ETSI TS 119 602 [42] JSON view, the root fingerprints are announced out of band, and the list of trusted lists has room for other parties' lists. **Legal recognition**: a credential being treated as legally valid in another country. The first two levels are the network's job and largely work today; the third is the job of states, and the network is not a party to these agreements.

20.2 Standards alignment map

That the technical layer is the same as the EU's is written as P3 in FW-ARF-0001 §1.6: every Tamga-specific addition to a standard is made through an extension point and does not break standard clients (ADR-0035 PO1). Table 37 shows the standards on which the EU ecosystem rests, their counterparts in Tamga and their status; "live" means live in the real network or in the sandbox.

Table 37. Standards alignment map (FW-ARF-0001 §2.8, §8.4; FW-REF-0001; the relevant decision records).

Area	Standard or EU rule	Counterpart in Tamga	Status
Trust list	ETSI TS 119 602 (LoTE, JSON)	External lists are read in this format (ADR-0036); LoTE view of the Tamga lists (Section 6.8)	Reading live; publication of the views planned
Trust list	ETSI TS 119 612 V2.4.1 (XML)	A XAdES-signed view from the same signed source, with the same version (ADR-0066)	Live in the sandbox; planned in the real network
Institution identity	X.509 (RFC 5280), ETSI EN 319 401; TS 119 412-6, EN 319 412-3	National root and institution certificates, institution identification number (ADR-0004, ADR-0050)	Live
Access certificate	ETSI TS 119 411-8	Trade name, support address, service identifier (ADR-0058)	Live; policy identifier planned
Issuer policy	ETSI TS 119 471	Issuer rules in the Tamga Rulebook	Incorporated into the rules
Credential format	IETF SD-JWT VC, ETSI TS 119 472-1, ISO/IEC 18013-5 mdoc	SD-JWT VC primary; identity also as mdoc (ADR-0006, ADR-0013)	Live
Identity attributes	EU Implementing Regulation 2026/1731	EU PID attribute names; the credential is not a PID (ADR-0045)	Live
Issuance and presentation	OpenID4VCI 1.0, OpenID4VP 1.0, DCQL, HAIP 1.0, ETSI TS 119 472-2/–3	Tamga issuance and presentation profiles (Sections 9–10; ADR-0034)	Live
Presentation from the browser	W3C Digital Credentials API, ISO/IEC 18013-7	Verifier side	Verifier ready; wallet planned
Proximity	ISO/IEC 18013-5 (Bluetooth)	Target flow; bridge paths today (ADR-0012)	Planned (awaiting device testing)
Wallet attestations	EU technical specification TS3	WIA shorter than 24 hours and key attestation (ADR-0025)	Live; device attestation planned
Revocation	IETF Token Status List	Status lists; CWT for mdoc (ADR-0008, ADR-0048)	Live
Registration	EU Implementing Regulation 2025/848 (as amended by 2026/1730), ETSI TS 119 475	Common registration data set; registration certificate, policy and status list (ADR-0024, ADR-0026, ADR-0068)	Live
Sharing rule and pseudonym	EU ARF Topic 43 and Topic 11	Embedded disclosure policy; per-site pseudonym (ADR-0046, ADR-0031)	Live
Identity proofing	ETSI TS 119 461	Level mapping; the provider contract refers to it	Incorporated into the rules
Incident notification	EU Implementing Regulation 2025/847	Severity levels and deadlines (FW-TF-0001 §4.6)	Incorporated into the rules
List of certified wallets	EU Implementing Regulation 2025/849	Counterpart when states join	Planned
Credential type rules	EU Attestation Rulebook template 1.5	Branches of the Tamga Rulebook	Live
Zero-knowledge proof	Longfellow ZK (mdoc)	Age proof; circuits in the list (ADR-0032, ADR-0044)	Verifier live; wallet planned

Area	Standard or EU rule	Counterpart in Tamga	Status
Educational meaning	ELM 3 / Europass, ISCED-F, EQF	Meaning of the diploma fields (Education Rulebook)	Live
Trust mark	EU wallet trust mark	Not used; “Listed on Tamga Network” indicator (ADR-0049)	Live

The table makes a claim of alignment, not a claim of certification: “live” says that the standard has been implemented and that this can be shown from the source; it does not say that an independent body has approved it (Section 20.5).

20.3 EU registration data and certificates

In the EU’s approach, every organisation that requests data from a wallet registers first and cannot ask for more than it declared at registration (eIDAS 2.0 [2] Article 5b). Tamga builds the same logic with its own registrar and with the EU’s own data set and certificate types, so that a state taking over this role, or an EU verifier looking at these entries, does not run into an unfamiliar structure.

Entries carry the EU’s common registration data set (Implementing Regulation 2025/848 [6] Annex I, as amended by 2026/1730 [7]): official and trade name, identification number, address, contact details, the purpose and privacy policy for each intended use, whether it is a public body, intermediary relationships and the data protection authority. Only legal persons register; the wallet’s consent screen, the deletion request and the complaint path rely on this data (ADR-0024). A verifier carries two certificates. The **access certificate** says who it is (ETSI TS 119 411-8 [45]; ADR-0058). The **registration certificate** says what it is registered for: a certificate in ETSI TS 119 475 [46] format, whose content comes only from the entry in the signed list, which is signed with a separate registrar key and is valid for at most 12 months. The wallet compares the requested fields against it; a request without a certificate is rejected, and no data is sent to a request whose certificate has been revoked (ADR-0026, ADR-0056, ADR-0068). Wallet providers, for their part, declare their solutions, pass the conformance tests, and their attestation signing keys are added to the list of trusted lists (FW-TF-0001 §3.2).

Two topics of the EU ARF [11] were adopted in the same way. Under Topic 43, an issuer may ask that its credential be shown only to certain verifiers; in Tamga this rule is published in the institution’s signed display information, the wallet compares it with the verifier’s certificates, warns if they do not match and leaves the final decision to the person (ADR-0046). The pseudonym rules of Topic 11 are mapped point by point onto the per-site pseudonym arrangement (SPEC-WALLET-0001 §5.4.1; Section 15.3).

20.4 Legal recognition is not in the network’s hands

The most important sentence in this section is this: technical alignment with EU standards does not mean legal recognition in the EU. The eleventh paper of the series [76] showed this in detail from the text of the regulation; here we summarise the consequences for Tamga (ADR-0035 legal note; FW-ARF-0001 §6.2).

A common mistake is to take Article 5f for the route by which third countries are recognised. Article 5f is the obligation of organisations within the EU to accept **EU wallets** its subject is that wallets provided under the regulation are relied upon within the EU. The regulation contains no provision that treats the wallet of a country outside the EU as a European Digital Identity Wallet or as equivalent to one.

The main article in which the expression “third country” appears is Article 14, headed “International aspects”, and it is limited to **trust services**. Under Article 14(1), the services of trust service providers established in a third country are considered legally equivalent to qualified trust services in the

EU if they are recognised by an implementing act or by an agreement between the EU and that country concluded under Article 218 of the Treaty on the Functioning of the European Union. Article 14(2) requires that the providers in the third country meet the requirements applicable to qualified providers in the EU and that the country establish and publish a trust list of its recognised providers; Article 14(3) is the reciprocity requirement. The parties to this route are states: Türkiye or another Turkic state can take this route, but Tamga Network cannot be a party to an agreement.

The network's role is **technical preparation**: lists in ETSI format, certificates with ETSI profiles and state roles that can be handed over. If a state wishes to take this route, the network can offer it a tested tool and template; the owner of the list will be that state. This is one of the reasons for the ETSI TS 119 612 [41] XML view (ADR-0066). The Commission has also opened an interim route [14] for third countries' signature and seal services: a list of third-country trusted lists and an associated international compliance pilot. This route covers signature and seal providers supervised by a state and does not confer legal equivalence; the institutions in Tamga's list are not the subject of this route, and since Tamga is not a state its own list does not go there (ADR-0066) (Figure 33).

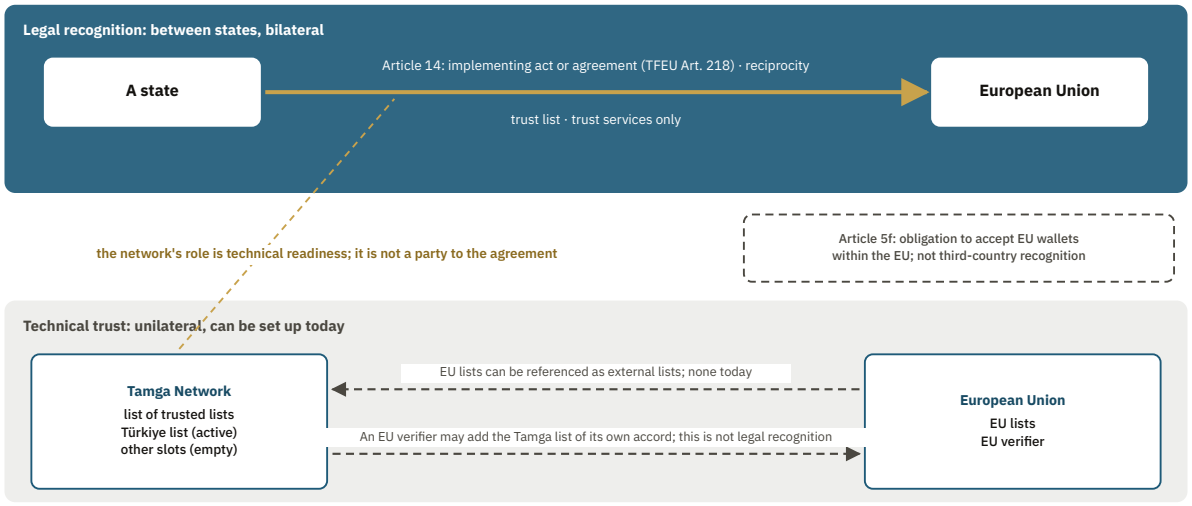


Figure 33. Routes to recognition: technical trust and legal recognition

In the short term the picture is as follows. Tamga's list of trusted lists can show the EU's lists through the same federation mechanism, with the scope limited by credential type (Section 6.9); this is technical trust, and today the list contains no external lists. In the other direction, a verifier in the EU can accept Tamga credentials only of its own accord, by adding Tamga's list to its own trust source; this, too, is not legal recognition and is not described as such. For Aynur's European partner, today's answer is that the credential can be read technically, but the value given to it depends on that organisation's own rules and on the applicable law.

20.5 How we show alignment

"EU-aligned" is a claim and needs evidence. Today alignment is shown in four ways; none of them is a certification.

Open conformance tests. What the issuer, the verifier and the wallet provider are tested against is public and versioned in the repository; the vectors contain no personal data and no private keys. The commitment tests check at least the following: a stale list gives the result "could not verify", and processing stops on an unknown format and on a signature error. The tests are mandatory before every release (FW-TF-0001 §4.3; RB-ENF-01).

OpenID self-test. In October 2026 the identity service and Tamga Verify ran the OpenID Foundation's conformance test plans [33] in the sandbox: OpenID4VCI with HAIP [32] and FAPI 2.0

(63 modules) and OpenID4VP with HAIP (14 modules). The last run on the issuance side ended with no failed modules, and the one on the verifier side with no failed modules and no warnings. The verifier run predates the change to request handling on 29 October and will be run again; the wallet plans were not run because they require a device build. This is a self-test carried out with the OpenID Foundation's own tool; certification is a separate process. What was learned has been published as an open source test kit.

Reading the ETSI list with the EU tool. The ETSI TS 119 612 XML list in the sandbox was checked against ETSI's official XML schema and the EU's signature validation tool (DSS). The tool found the signature and the references sound; since the signer is not a trust anchor in the EU, the result came out as "indeterminate", which is the expected result (ADR-0066). The check proves only that the format is correct; it carries no meaning of recognition.

Interoperability events. Participation in the EU's interoperability events is envisaged in the framework (FW-ARF-0001 §7.3) and is **planned**. When states join, independent assessment bodies and national certification will be added on top of this light conformance arrangement (FW-TF-0001 §2.4).

20.6 Name and mark

The language of alignment is part of alignment too. "EUDI Wallet", that is, the European Digital Identity Wallet, is the legal name of a wallet provided or recognised by an EU member state and certified under EU rules; the wallet of an organisation outside the EU cannot take this title and cannot use the EU trust mark (FW-ARF-0001 §1.4; ADR-0035 PO4). For the wallets in its list, the network uses its own written indicator: "Listed on Tamga Network". The indicator has no logo, and the EU stars and colours are not used; when tapped, it opens the provider entry in the signed list, and the indicator disappears when the entry leaves the list (ADR-0049). Table 38 summarises the language followed in every public text.

Table 38. What we can say and what we cannot (ADR-0035 legal note and PO4; ADR-0049; ADR-0066 TX2).

Expression	Used?	Reason
"EU-aligned", "to EU standards"	Yes	The same formats, protocols and list model; backed by tests
"OpenID self-test carried out"	Yes	With its scope and date stated
"Listed on Tamga Network"	Yes	The network's own written indicator
"EUDI Wallet", "European Digital Identity Wallet"	No	A legal title belonging to member states
"EU trust mark", the EU stars	No	Cannot be used outside the EU
"Certified"	No	Certification is a separate process and has not been done
"Qualified", "notified list"	No	The issuers are not qualified; the list has not been notified under 910/2014
"Valid in the EU", "mutual recognition with the EU"	No	Legal recognition requires an agreement between states
"National wallet"	No	The network operates no wallet and speaks on behalf of no state

The purpose of these rules is not to lead the reader to believe that Tamga is something bigger than it is. What the network can say is that it speaks the language Europe has chosen and shows this in a way anyone can test. What that language will correspond to legally in Europe is for states to decide.

21 Decisions and Their Rationale

Throughout this document we have tied every important choice to a decision record. When readers wonder about the reasoning behind a choice, they can go from the ADR number to the full text of the decision record; there they will find how the problem arose, which options were weighed, and which one was chosen and why. This section presents the decisions together. It describes first how a decision is made, then the ten major decisions in depth, then all accepted decisions by theme, and finally the decisions that have changed over time.

21.1 How a decision is made

In Tamga a binding choice begins with a written decision record. The rule is short and is repeated in the same words in every repository of the network: first the decision record, then the code. A decision record answers four questions. What situation called for a decision, which options were considered, which one was chosen, and what were its consequences? Most records also list the binding rules the decision gives rise to, that is, the invariants, with short codes; for example, the rules of ADR-0017 are referred to as `HV1`, `HV2`, and the conformance tests cite these codes.

A record passes through three states. In the **Proposed** stage the decision has been written but is not binding. When project management accepts the decision, the record becomes **Active** and the date of acceptance is recorded; the affected specifications and framework documents are updated in the same piece of work. A closed decision changes only through a new decision record. The record that changes is not deleted; it is marked **Superseded**, or the new record states explicitly which clause of the old record it changes. This way one can read not only the current form of a decision but also how it came to be that way.

At the time this edition was prepared there are 75 decision records: 73 active, one in the proposed state (ADR-0028) and one superseded by another decision (ADR-0003). The number, title, status and date of acceptance of every record are in Appendix B.

21.2 Ten major decisions

Not all records carry the same weight. The ten decisions below determine the shape of the network; most of the rest are details of these. For each we briefly give the question, the options, the choice, the reasoning and the price of the choice. The details are in the relevant sections.

1. Credential format: SD-JWT VC [16], and mdoc [34] as well for identity (ADR-0006, ADR-0013). The question was in which format the credential would be encoded. SD-JWT VC offers selective disclosure built in, is the EU's main format and is simpler than JSON-LD-based formats; so it became the primary format. For the identity credential a single format was not enough. Presentation through the iOS browser and proximity require mdoc, and the EU defines person identification data in two formats. The other two paths considered were staying with SD-JWT VC only and moving entirely to mdoc; the first would close the browser path, and the second would break the pipeline that is simpler for web flows. The price is a second issuance and verification code path for the identity credential, with its tests (Section 8).

2. Institution identity by X.509 [28], no global identity for the person (ADR-0004). For institutions' identity, the choice was between a network-specific decentralised identifier profile and X.509 certificates. Institutions already use X.509 for electronic signatures and seals, it has a counterpart in legislation, and the EU's qualified certificate regime stands on this ground; the network-specific profile was invalidated. The same decision sets the opposite principle for people: a person is given no fixed, network-wide identifier. The price is that an institution's identity changes when its certificate is renewed, and continuity is established through a successor link (Sections 6.7, 7.1).

3. A chainless start and a threshold of two independent operators (ADR-0009, ADR-0051). The question was when a shared ledger would be set up. The options were tying the pilot to setting up the ledger, starting with a single-operator development chain, and tying the ledger to a threshold while starting with signed lists. The third path was chosen because four nodes of a single operator produce no more trust than a list signed by the same operator. The ledger is set up with the written acceptance of at least two independent operators, and when set up it is a projection of the signed lists. The price is that today trust rests on a single signer; this residual risk is recorded as L1 in Section 23 (Section 19).

4. The status list off the chain (ADR-0008). Keeping the bit array of revocation information on a shared ledger looks permanent and auditable. But which bit changed when can be tracked on a ledger open to all; those running nodes learn the moment a credential was revoked. The decision keeps the bit array in a list that the issuer signs and publishes at a fixed interval; if a ledger is set up, it carries only the digest of the list. Revocation with a cryptographic accumulator or zero knowledge was deferred, and the short-lived credential path was partly adopted. The price is that revocation takes effect with a delay of up to one publication interval (Section 12).

5. The network is only a network and operates no wallet (ADR-0037, ADR-0042). The first positioning decision also envisaged products and services on top of the network, and itself noted that the party managing the list selling services carried a tension. ADR-0037 removed this tension: commercial services are offered by companies outside the network under their own names. ADR-0042 applied the same principle to wallets; the network continuing to operate a wallet's provider service, and setting up a separate test environment for wallets, were rejected. The price is that even the network's first wallet had to set up its own provider outside the network (Sections 4.3, 5.4).

6. Provisional identity credential provider, not qualified (ADR-0011, ADR-0022). With no state provider of person identification data, institutions still needed to recognise a person reliably. The options were each institution doing its own identity verification, waiting for the state, and a credential carrying no identity number; the first makes the person verify again at every institution, the second has no date, and the third makes matching ambiguous for people with the same name. The path chosen is that the network operates a provisional identity service and issues a credential that is not a PID. The class of the service was also fixed, by a separate decision, as a non-qualified attestation of attributes and I2; "qualified" requires independent assessment. The price is that the network is the data controller for this service (Section 14).

7. The authentic source at the institution, and the signing key at the institution too (ADR-0020, ADR-0057). The hosted issuance service is easy for institutions, but carries two risks: personal records accumulating in the network, and the institution's key sitting with the operator. ADR-0020 rejected keeping personal records in the network; the information is read from the institution's query endpoint at the moment of signing and is not stored. ADR-0057 rejected keeping the key in a file on the server, tying the service to a single cloud provider, and defining a network-specific signing endpoint; the service requests the signature through CSC API v2 [54] and sends the other side only a hash. The price is that the institution runs a query endpoint and a signing service (Sections 5.2, 7.6, 9.2).

8. Per-site pseudonym (ADR-0031). "Sign in with Tamga" had to tell a site who the person is in the same way every time, but two sites must not be able to link the same person. Five methods were weighed: a random secret of the wallet (accounts are lost when the phone changes), a passkey (carries no identity), the issuer generating an identifier per site (it learns which site was signed in to), a seed derived from the identity, and derivation with a zero-knowledge proof. Today the fourth is implemented; the fifth is the goal. The price is that the identity service could theoretically derive the pseudonym by using the seed key together with the person's identity number (Section 15.3).

9. Zero-knowledge proof and short-lived copies (ADR-0032, ADR-0044). The institution and the verifier can link a person by comparing the signature of the same credential. Producing a proof about the credential without changing it breaks this link; the first predicate is an age threshold. But since the proof also hides the position in the revocation list, revocation cannot be checked at presentation. A proof with a status list and a long-lived copy were rejected; ZK presentation is made with copies valid for at most 24 hours and refreshed silently. The price is that revocation takes effect in ZK presentation within 24 hours at the latest, and that copy refreshes leave a trace of activity at the identity service (Section 15.4).

10. The EU's path: WIA and KA, HAIP [32], registration certificate, secure defaults (ADR-0025, ADR-0034, ADR-0026, ADR-0056). These four decisions apply the same principle: where the EU has chosen a solution, no network-specific solution is written. Instead of a single wallet attestation valid for 30 days, the EU's WIA, with a lifetime under 24 hours and a new key for every transaction, and the key attestation were adopted. The verifier's client identifier became the hash of the access certificate, as HAIP requires. Not producing a registration certificate was optional in the EU, but producing one was chosen so that EU wallets can know the scope of Tamga verifiers. Loose defaults in the packages that let checks be bypassed were also removed; skipping is now a value that has to be written explicitly in code. The price is that integrators have to adapt to stricter rules with each release (Sections 7.5, 10.1, 13.3, 16.4).

Figure 34 shows these decisions and the "builds on" and "changes" links between them, by theme.

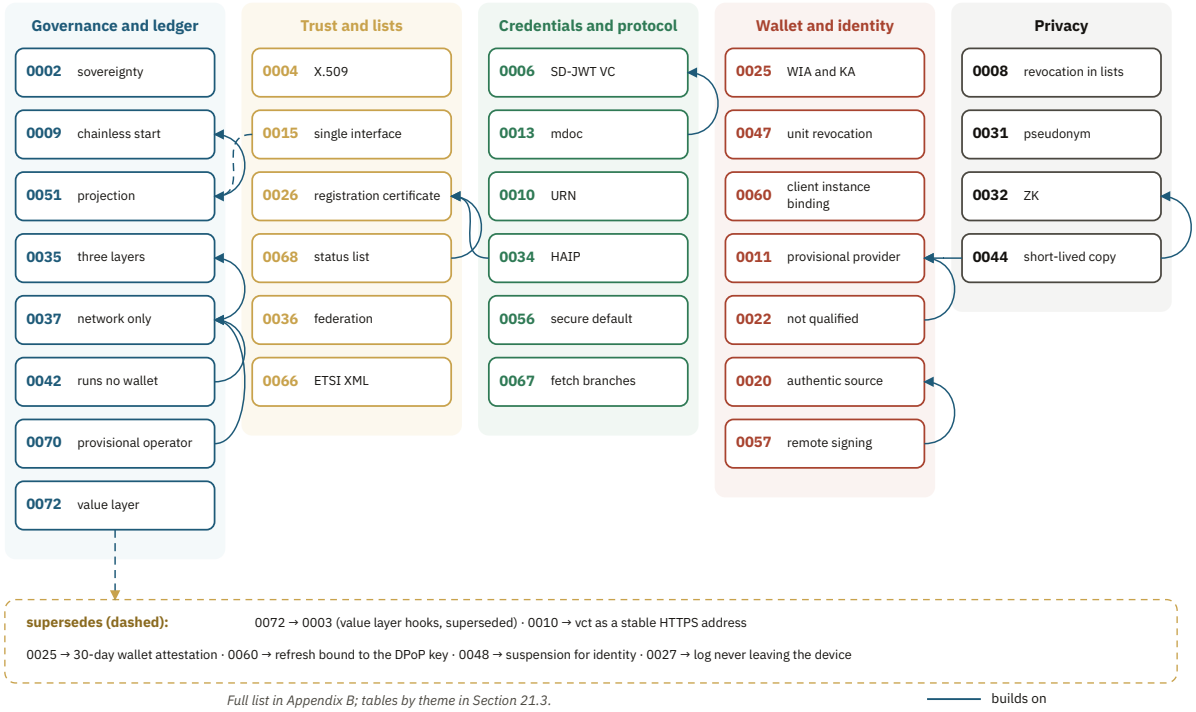


Figure 34. Decision map: the major decisions and the links between them

21.3 All decisions

The seven tables below list all active decisions by theme: trust and lists (Table 39), credentials and schemas (Table 40), protocol (Table 41), wallet (Table 42), identity (Table 43), privacy (Table 44), and governance, positioning and the ledger (Table 45). Each row gives the decision in one sentence, its rationale and the main option left behind in the decision record. The rationale and option columns are summarised from the "Context" and "Options considered" sections of the decision records;

where a decision record does not explicitly discuss an option, the column gives only the record's own comparison.

Table 39. Trust and list decisions.

Decision	Rationale	Option left behind
ADR-0004. Institution identity by X.509; no global identity for the person	Institutions already have certificates; it has a counterpart in legislation	A network-specific DID institution profile
ADR-0015. A single trust interface (`TrustSource`), including the wallet	The same rule is not written twice; the interface stays fixed in the move to the ledger	Separate verification in the wallet; asking the network's server every question
ADR-0024. The EU common registration data set in entries	The consent screen, deletion and complaints rely on this data	The old narrow entry
ADR-0026. Registration certificate (ETSI TS 119 475)	So that the wallet can check the verifier's scope	Producing no registration certificate; a single certificate per verifier
ADR-0036. Federation with external lists: address, pinned signer, scope, approval	To be able to recognise state lists and EU types	Copying external entries into its own list
ADR-0046. Embedded disclosure policy (EU ARF Topic 43)	The institution's sharing rule; the final decision rests with the person	Embedding the rule in the credential; downloading it by link
ADR-0050. Institution certificate profile ETSI TS 119 412-6	The institution number matching the entry is in the certificate	Keeping the number only in the list
ADR-0058. Access certificate ETSI TS 119 411-8; the identity service certificate is renewed at the hand-over to the foundation	ETSI profile; a single re-issuance	Changing the identity service certificate immediately
ADR-0066. ETSI TS 119 612 XML view, from the same source and with the same version	EU and third-country tools require XML	XML from a separate register; "qualified" ETSI URIs
ADR-0068. Registration certificate policy and a 1-bit status list	So that the certificate can be withdrawn	A certificate without status

Table 40. Credential and schema decisions.

Decision	Rationale	Option left behind
ADR-0006. SD-JWT VC primary; OpenID4VCI and OpenID4VP; ES256; device binding without exception	The EU's main stack; without binding the credential passes to someone else	A JSON-LD-based format (compared in the rationale)
ADR-0007. Schema catalogue off the chain, integrity hash mandatory, versioned	The verifier must notice that a definition has changed	Keeping the whole schema on the chain; a free-form `vct`
ADR-0010. `vct` is a URN, resolved from the catalogue; category signal	A type identifier must not be tied to a domain name	`vct` as a stable HTTPS address
ADR-0013. The identity credential also as mdoc	The browser and proximity require mdoc; the EU PID precedent	SD-JWT VC only; entirely mdoc
ADR-0014. Only the events class is added to the institution classes	No class is opened before real use arrives	Also adding transport and communication classes
ADR-0021. E-mail and phone credentials; the address is not kept	Need for verified contact details	Adding the address to the identity credential; both in a single credential
ADR-0029. In the development stage schemas are corrected in place	No backward compatibility burden is carried in this stage	A new version for every correction

Decision	Rationale	Option left behind
ADR-0039. Driving licence information (not an official document, not an mDL)	Need for verified information; must not be confused with the official document	Issuing it as an official mDL credential type; adding the information to the identity credential
ADR-0045. Identity attributes with the EU PID encoding	Alignment with Implementing Regulation 2026/1731	The old attribute names
ADR-0064. `age_over_15` is added; age thresholds are a closed set	Need for an age-15 threshold (not a legal opinion)	18 only; an open set

Table 41. Protocol decisions.

Decision	Rationale	Option left behind
ADR-0012. Bridge paths for proximity; target ISO/IEC 18013-5	Until Bluetooth is ready on the device	Doing ISO/IEC 18013-5 straight away; putting the whole credential in the QR
ADR-0016. Tenant-bound scoped access to hosted issuance	So that the institution can call from its own server	A single shared administrator key
ADR-0017. Access to the verification result only with a signed statement and a single read	The result address was open to everyone	Answering anyone who knows the identifier
ADR-0034. HAIP 1.0: `x509_hash` client identifier; WIA `sub` shared	A HAIP requirement; the permanent entry is `dns_name`	Staying with `x509_san_dns` accepting both prefixes
ADR-0048. No suspension for identity types; CWT list for mdoc	The EU PID rule	Suspension for identity
ADR-0056. Secure defaults in the package APIs	No default that lets a check be bypassed	Loose defaults and a warning
ADR-0059. Multiple credential requests with one access token (at most 10 copies)	OpenID4VCI 1.0 and the EU reference	A single-use token
ADR-0060. Refresh token bound to the client instance key	Attestation profile; the DPoP key can change	Binding to the DPoP key
ADR-0062. ZK copy refresh token only when its scope is requested	The scope principle (RFC 6749 [19] §6)	Issuing it with every identity authorisation
ADR-0065. The gate terminal identifies itself with a terminal key	So that someone who sees the QR cannot use up the ticket	An endpoint without identification
ADR-0067. Each fetch of the request object is a separate branch	The false decline attack	A single request object
ADR-0069. Gate groups in the list; terminal keys on behalf of the institution	So that an institution manages only its own gates	An operator-wide key

Table 42. Wallet decisions.

Decision	Rationale	Option left behind
ADR-0023. Copies are refreshed silently	Copies run out; EU rules	Asking the person at every refresh
ADR-0025. WIA (shorter than 24 hours) and key attestation, the EU TS3 model	Unlinkability; the EU model	A single 30-day wallet attestation
ADR-0047. Unit revocation, a revocation path outside the wallet; device attestation mandatory only at the highest level	Open topics in the EU template	Cascading revocation of institution credentials; device attestation at every level
ADR-0049. The written indicator “Listed on Tamga Network”	The EU trust mark cannot be used outside the EU	The EU mark or a logo

Table 43. Identity decisions.

Decision	Rationale	Option left behind
ADR-0005. Two-axis assurance (person T0–T3, institution I1–I3); stateless start	Mapping to the eIDAS levels of assurance; inheriting existing trust while there is no state	Measuring trust with a single number
ADR-0011. A provisional identity credential provider while there is no PID (not a PID)	Identity verified in a single place; institutions able to match	Separate verification at each institution; a credential without an identity number
ADR-0020. The authentic source at the institution; the network keeps no personal records	The data stays at its source	Keeping personal records in the network
ADR-0022. The identity service is not qualified, I2	"Qualified" requires independent assessment	Qualified class or I3
ADR-0033. A single-use code for app store review	Review without a real identity; equal for every wallet	A permanent test mode in the application
ADR-0043. No age limit	eIDAS 2.0 sets no minimum age	Setting an age limit
ADR-0057. In hosted issuance the institution key stays with the institution (CSC API v2)	The key cannot remain with the operator	Keeping the key in a file in the service

Table 44. Privacy decisions.

Decision	Rationale	Option left behind
ADR-0008. The revocation bit array off the chain, in a signed list	So that the moment of revocation does not leak to nodes	Keeping the bit array on the chain
ADR-0027. The log leaves only by an encrypted export started by the person	The EU TS10 requirement and the principle of staying on the device	The log never leaving the device
ADR-0031. Per-site pseudonym; a seed derived from the identity	Sites cannot link; the same account on a new phone	The wallet's random secret; an identifier generated by the issuer
ADR-0032. mdoc presentation with Longfellow ZK; the first predicate is age	An unlinkable proof without changing the credential	Batch copies only (kept as a fallback)
ADR-0044. ZK presentation with copies of at most 24 hours	Revocation cannot be checked in ZK	ZK with a status list; long-lived copies
ADR-0061. The pseudonym seed as a separate credential configuration	Standards conformance	A non-standard response field

Table 45. Governance, positioning and ledger decisions.

Decision	Rationale	Option left behind
ADR-0001. If a ledger comes, Hyperledger Besu and QBFT	Permissioned, equal votes, immediate finality; EU precedent	Cosmos SDK; consensus from scratch; a public chain
ADR-0002. Sovereignty-first three-layer governance	Each state the sole author of its own register; the right to exit	A founding consortium and joint voting
ADR-0009. A chainless start; a chain only with at least two independent operators	A single operator's chain produces no trust	Waiting for the chain; a single-operator development chain
ADR-0018. Three doors to the documentation; Turkish source, English official translation	Separation by reader; the EU arrangement	Gathering all documents on a single site
ADR-0019. Institution Console and database	Institution work in one place; the person requests from the wallet	A student portal and file-based records
ADR-0030. Product names	Consistent names	The old product name
ADR-0035. Three-layer positioning	Each layer carries value on its own	An EU-aligned wallet only; heavy institutions first

Decision	Rationale	Option left behind
ADR-0037. The network is only a network; commercial services outside	Neutrality; transferability	Services remaining inside the network
ADR-0038. A separate sandbox test network	Full separation from the real network	Test institutions in the real network
ADR-0040. A capped real identity verification path in the sandbox	So that the real flow can be tried	Fake people only
ADR-0041. Institution test accounts in the sandbox	Institutions trying things out on their own	A sandbox without a console
ADR-0042. The network operates no wallet; it lists them	The EU separation of roles; neutrality	The network operating a wallet's provider; a separate wallet sandbox
ADR-0051. The chain is a projection of the signed lists	A single source; verification does not depend on the chain	The chain being the source
ADR-0052. Besu local permissioning	Besu 25.6.0 removed on-chain permissioning	An on-chain permissioning contract
ADR-0053. Competing candidates in the list anchor	So that the first writer cannot lock things	The first writer's value locks
ADR-0054. Schema namespace, cross-state links, quota scope	No name squatting and no quota leakage	Name reservation; adding a state code to the schema identifier
ADR-0055. A 7-day delay for upgrades; registry proposals of a specific type	The right of a non-agreeing state to withdraw	Immediate application; a general call proposal
ADR-0063. The on-chain status entry accepts the list's bit size	The projection principle	A fixed 2 bits
ADR-0070. A provisional operator until the foundation is established; the name in the list is "Tamga Network"	The network has no legal personality; hand-over from a single point	The operating company's name in the list; waiting for work that requires a legal person
ADR-0071. No fees from participants in the provisional phase	Neutrality; a financial contribution does not affect registration	An annual fee from institutions
ADR-0072. The value layer suspended, a research direction	The network handles no tokens or payments; the chain is only a projection	Keeping the ADR-0003 hooks binding
ADR-0073. A one-time migration window (at most 30 days) for the move to the ledger, hard revocation, schema version digests are append-only	The list history can be carried to the ledger exactly; both sources give the same answer	Not carrying the history; a migration authority that stays open
ADR-0074. All trust records in the lists go on the ledger, only as digests and fingerprints	Record-level queries and equivalence; personal data and free text cannot be deleted from a ledger	List digests only; writing the detail text in the clear
ADR-0075. Reassigning a verifier identifier and re-registering it after revocation only by a two-thirds vote	The first state to register must not capture the identifier; revocation must not be a permanent lock	Treating a domain-name proof as sufficient on its own; doing nothing

21.4 Decisions that changed

The honesty of a series of decisions shows in whether it hides the decisions that changed. In Tamga's decision records six changes are particularly instructive; each is the result of new information, a standard or a review.

The first is the value layer. In the network's early design, five binding rules had been set so that a possible ledger could later carry value transfer (ADR-0003). ADR-0072 made these rules non-

binding and suspended them as a research direction; ADR-0003 is now in the “Superseded” state. The second is the credential type identifier. The first design identified the type by a stable HTTPS address; once it became clear that in a multi-state network a type identifier cannot stay tied to a single domain name, the identifier became a URN and the definition came to be resolved from the catalogue (ADR-0010). The third is the wallet attestation: a single attestation valid for 30 days was replaced, once the EU technical specification was published, by the short-lived WIA and key attestation (ADR-0025).

The fourth is the transaction log. The wallet rules required that the log never leave the device; the EU, however, requires that the person be able to export their log. The rule was narrowed so that the log can leave only in an export that the person starts themselves and encrypts with their own password (ADR-0027). The fifth is suspension: the identity service’s credentials had suspension, and it was removed when aligning with the EU rule for person identification data (ADR-0048). The sixth is the binding of the refresh token. The token was first bound to the DPoP [20] key; during the conformance work it became clear that the DPoP key can change and that the standard binds it to the client instance key, so the rule changed (ADR-0060).

These changes have one thing in common: none of them is silent. Each leaves the old record in place, states what it changes and updates the affected specification in the same piece of work.

22 Status, Roadmap and Open Decisions

For those who will use a trust network, the first need is for it to say plainly which functions it offers today and which it has only decided on. This section gathers into a single table the status labels given piecemeal throughout the document, gives the roadmap as stages and conditions, and lists the decision in the proposed state and the open decisions. No dates are given, because each of the stages depends on conditions that are not in the network’s own hands: the decisions of independent operators, institutions and states.

22.1 What is live today

Table 46 lists the functions under three status labels. The labels mean what they mean in the reading guide: **live** means live in the real network or in the sandbox, **planned** means decided but not live, and **research** means a function with no decision or one that is suspended. The table reflects the date on which this edition was prepared and is updated together with the function status table of the main framework document (FW-ARF-0001 §2.8).

Table 46. Status of the functions.

Function	Status	Note	Section
Signed trust lists, list of trusted lists, anchor log, archive	Live	real network and sandbox	6
Credential type catalogue	Live	immutable files, integrity hash	8.4
Institution-initiated and wallet-initiated issuance	Live	two paths in the hosted service	9
Remote presentation, Tamga Verify, verification pipeline	Live	three-valued result	10, 11
Status lists (JWT; CWT for mdoc)	Live	fixed-interval publication	12
Sign-in to websites and per-site pseudonym	Live		10.7, 15.3
Tickets and single-use gate passage	Live (sandbox)	no gate policy defined in the real network	10.9
Data deletion, history, export	Live		13.5

Function	Status	Note	Section
Provisional identity service and identity credential	Live	the only active issuer in the real network	14
E-mail credential	Live		14.6
Registration certificates, policy fields and status list	Live		7.5
Federation mechanism with external lists	Live	no external list in the list today	6.9
Wallet provider registration	Live	first listed wallet, real network and sandbox	5.4
Zero-knowledge proof, verifier side	Live		15.4
Sandbox	Live	open to everyone; identity verification capped	17.1
Open packages	Live	0.8.2 pre-release on npm, Apache-2.0	17.2
ETSI TS 119 612 XML view	Live in the sandbox	planned in the real network	6.8
Publication of the ETSI TS 119 602 views	Planned	generator ready	6.8
Second list signing certificate and hardware key store	Planned	open item in the specification	6.3
Proximity over Bluetooth (ISO/IEC 18013-5)	Planned	coded, awaiting device testing	10.8
Presentation from the browser, wallet side	Planned	verifier ready	10.6
Zero-knowledge proof, wallet side	Planned	no device testing	15.4
Hardware keys and device attestation	Planned	coded, awaiting device testing	13.2
First use of remote signing in the real network	Planned	code and tests ready	7.6
Real SMS sending for the phone credential	Planned		14.6
Opening driving licence information to real people	Planned	after legal review; in the sandbox today	14.6
App store review code	Planned	code ready; the test signer’s list entry is pending	14.8
Raising the identity service to I3	Planned	after independent assessment, by a new decision	14.4
Policy identifier in the access certificate	Planned	when the certificate practice statement is published	7.4
Certified and offline gate identity	Planned	field and reader ready	10.9
Rerunning the OpenID verifier plan; the wallet plans	Planned		20.5
Shared ledger	Planned	code ready; runs on a local network and on the public test network, switched off on the real network and in the sandbox	19
Foundation, council and hand-over of the lists	Planned		18.4
Participation in EU interoperability events	Planned		20.5
Pseudonym derivation with a zero-knowledge proof	Research		15.3

Function	Status	Note	Section
Revocation with a cryptographic accumulator or zero knowledge	Research	deferred	12.2
Migration to post-quantum algorithms	Research	no decision	23.3
Value layer	Research	suspended; no tokens, coins or payments	19.9

A note on how to read the table. The “live” label says that a function can be shown from the source; it does not say that an institution uses this function in the real network. Today the only active issuer in the real network’s Türkiye list is the network’s provisional identity service; institution credentials will be issued by the same route as the first institutions join.

22.2 Roadmap

The roadmap consists of six steps. Each step depends on a condition, and no step changes the identifiers set up in an earlier step (Table 47). The governance side of the first four steps was described in Section 18.3 and the ledger side in Section 19.8; Figure 30 shows the same path as governance stages.

Table 47. Steps of the roadmap: condition, what changes, what does not.

Step	Condition	What changes	What does not change
1. List stage (today)		signed lists and the anchor log; sandbox; packages in pre-release; OpenID self-test	
2. Preparation	store releases and device tests of the listed wallets	device attestation, Bluetooth and browser paths go live; the first institutions join the real network	credential types, root and institution identifiers
3. Foundation	the foundation gaining legal personality	operation passes to the foundation; XML list in the real network; the identity service certificate is renewed	the list operator’s name, the root identifier, credential types, credentials already issued
4. Ledger	written acceptance by at least two independent operators and equivalence tests	the trust records in the lists are also written to the ledger as digests and fingerprints; the history is carried over in a one-time migration window	the signed lists remain the source; the verification pipeline; no personal data is written to the ledger
5. State participation	a state publishing its own list	the council is set up; the PID place is filled; provisional roles are handed over	institution identifiers, credential types, credentials already issued
6. Institutional expansion	thresholds set by the council	new sector schemas are added by their own decisions	the network’s principles

In the first row of the table the condition and “what does not change” columns are empty, because this step is today. The institution side of the second step is deliberately left unnamed: this document announces no agreement or negotiation with any institution. The condition of the fifth step is not in the network’s hands either; a state joining is that state’s own decision.

22.3 The decision in the proposed state

The only record that is not active concerns credentials in the health sector (ADR-0028). The proposal describes three complementary credentials for health professionals: a licence to practise, a membership credential from a professional body, and a role credential that an institution issues to its own staff. A hospital could ask for these credentials as a verifier when hiring. The credentials contain no health data and no identity number; the patient side is out of scope. The proposal is on hold by

decision of project management: since the first sector is education it is not being worked on, but the record is not deleted. If the health sector is opened, this proposal will be reassessed in the light of new information and, if accepted, will come with its own rules.

22.4 Open decisions and next steps

The “open topics” sections of the decision records and specifications explicitly list the questions that have not yet been decided. Table 48 gives the public ones, together with the relevant source. Some await a technical measurement, some a legal review, and some the network’s next stage.

Table 48. Open decisions.

Question	Why it is open	Source
Approved transfer of credentials when the device changes	Credentials are obtained again on the new device; the institution needs to recognise the person years later	FW-ARF-0001 §7.4 L4; SPEC-WALLET-0001
Multiple devices (phone and tablet)	Each device means a separate device key and separate issuance	SPEC-WALLET-0001
How the highest wallet level will be established in the state stage	Device attestation or separate hardware	SPEC-WALLET-0001
Parental consent flow for minors	Awaiting legal review and the provider’s condition for minors	ADR-0043; SPEC-ID-0003
A second identity verification provider	Avoiding dependence on a single provider	SPEC-ID-0003
Is collecting status lists mandatory; multiple status providers	“Recommended” today; may need to be written explicitly	SPEC-CRED-0003
Tying verifier scope to credential type identifiers	The problem of updating every verifier for every new type	SPEC-PROTO-0002
If the EU chooses another revocation method for ZK	The short-lived copy decision will be reassessed	ADR-0044
Overlap period in root certificate rollover; intermediate certificate authority	Proposed 12 months; depends on the states’ preference	SPEC-ID-0002
Out-of-scope functions: PID issuance, payments, organisational wallet, W3C VCDM representation, qualified electronic signature	Each can be opened only by a separate decision	FW-ARF-0001 §1.7

23 Limits and Open Questions

Every architecture removes some risks, reduces some and knowingly carries others. This section looks at the third group: the risks Tamga knows about and accepts today, the questions that do not yet have an answer, and the research directions. Writing these down openly is less an admission of weakness than a commitment. When readers know what the network does not guarantee, they can trust more in what it does guarantee.

23.1 Declared residual risks

The main framework document lists five limits by number (FW-ARF-0001 §7.4). To these are added several risks described in the privacy, identity and operation sections. Table 49 gives each one, why it exists today, what mitigates it and under what condition it will go away.

Table 49. Residual risks.

Risk	Why it exists today	Mitigation	Condition for removal
L1. The trust anchor rests on a single operator’s signature; if the operator and an issuer act	In the list stage there is a single signer	public change log and anchor log, transparency report, audit	a shared ledger and multiple independent signers (Section 19)

Risk	Why it exists today	Mitigation	Condition for removal
together, an inconsistent entry could be published			
L2. Revocation takes effect within a few minutes	the status list is published at a fixed interval and fetched in advance	short publication interval (2 minutes), frequent prefetching by the verifier	does not go away; it is a deliberate privacy trade-off (Section 12.5)
L3. If credentials from the same institution are combined across different verifiers, the person can be linked	the institution's signature is recognisable across copies	a copy per verifier, rounded time	zero-knowledge proofs reaching wallets (Section 15.4)
L4. Credentials are obtained again when the device changes	the design of approved transfer is open	reissuance by the institution; silent refresh	a decision on approved transfer (Table 48)
L5. Revocation cannot be checked in a ZK presentation	the proof hides the position in the status list	copies of at most 24 hours; the copies of a revoked credential are not refreshed	the EU choosing another revocation method for ZK (ADR-0044)
Known weakening of pseudonym derivation	the seed is derived from the identity at the identity service	key protection and transparency; the seed is not stored	derivation with a zero-knowledge proof (research)
Activity trace of ZK copy refreshes	copies are refreshed roughly once a day	random delay; automatic refresh the person can turn off	no permanent solution; what was shown to which verifier is not learned
Fake faces and injection attacks in remote identity verification; dependence on a single provider	verification relies on a remote identity verification provider	liveness and face matching; no portrait in the credential; the highest level is not granted with a remote face	the state's PID; a second provider (Table 48)
A single list signing certificate	the second rolling certificate is not yet in service	the rule that key changes are announced 30 days in advance	a second certificate and a hardware key store (Section 6.3)
Identity verification of minors	no age limit; parental consent flow not defined	the provider's condition is awaiting confirmation	a decision on parental consent (Table 48)
An unexpired credential on an offline phone	revocation does not reach a device that does not connect to the network	unit revocation, short validity, the verifier's revocation check	does not go away; limited by short lifetimes

The first row deserves particular emphasis, because it draws the limit of the network's current trust model most clearly. The published lists are files that anyone can download, whose versions are linked to one another and every change to which is written to the log; an inconsistent entry cannot be hidden, but it can be published. What will remove this limit is the multi-signer arrangement, and that arrangement can be set up only when independent parties join.

23.2 Questions that do not yet have an answer

Some questions go beyond being an open topic of a decision record and affect the long-term shape of the network. We mention four of them separately.

The first is the binding of the credential to the device. Device binding prevents the credential from being copied, but it also makes it harder for the same person to change phones. When a graduate changes phones ten years later, their university still needs to recognise them. Approved transfer and multiple devices are the two pieces of this balance between security and usability that have not yet been put in place.

The second is the verifier's scope. Today the fields a verifier may ask for are written in the registration certificate. Tying this scope tightly to credential type identifiers makes checking easier, but requires every verifier's entry to be updated for every new credential type.

The third is the source of identity verification. The provisional identity service works today with a single remote identity verification provider. A second provider, especially a domestic source, reduces dependence; when the state's person identification data arrives, most of this question goes away.

The fourth is minors. eIDAS 2.0 [2] sets no minimum age, and Tamga sets no age limit either (ADR-0043). But how parental consent will be obtained for identity verification of a minor, and the provider's condition for people of that age, are questions awaiting legal review.

23.3 Research directions

Three directions are undecided today and are referred to as such. The first is **pseudonym derivation with a zero-knowledge proof**. The current pseudonym method allows the identity service theoretically to construct the pseudonym. Verifying the derivation with a proof removes this weakening; the decision record sets this as the goal, but it will not be implemented until the zero-knowledge library has matured in wallets (ADR-0031).

The second is **migration to post-quantum algorithms**. Today's signatures rely on elliptic curve cryptography. A large-scale quantum computer could break these signatures; long-lived credentials and root certificates are therefore where migration matters most. Tamga has no decision on this; the topic stands as a question to be dealt with by following the choices of the EU and of standards bodies. The series paper on the post-quantum era [79] gives the technical background of the problem.

The third is **the value layer**. The decisions made in the first design so that the ledger could later carry a value layer are no longer binding and remain on record only as a research direction (ADR-0072). Tamga Network issues no token or coin; it processes no payments, settlement or value transfer. Reopening this direction requires a decision of the governance body, a privacy study, an independent security review and a new decision record (Section 19.9).

24 Conclusion

We began with Aynur's application. To show the diploma she obtained in Baku to an employer in Istanbul, she needed scanned copies, notarised translations and e-mails whose answers took weeks; even at the end, Timur could not prove that the diploma was genuine. The structure this document describes sets up the same scene by another route. The university issues the diploma as a signed credential, Aynur carries it on her phone and shows only the fields that are asked for, and Timur's software checks the signature, the authorisation, the revocation status and the device binding without calling the university. The university does not learn where the diploma was shown; none of the shared records knows Aynur.

It also has to be said honestly how open this path is for Aynur today. The Türkiye list is active and the whole flow works; but for Azerbaijan a place has only been reserved in the lists. This is not a notice of any agreement or negotiation; it is an empty slot in which a state, when it joins, can publish its own list. Whether Aynur's university in Baku can issue credentials by this route depends on that slot being filled. The structure is built to wait for this: when the slot is filled, no new field is added; an existing place is filled.

Three choices came up again and again throughout the document. The technical layer is the same as the EU's, because the value of working together comes from no one having to write a special adaptation. Trust today comes from signed lists, because a single operator's chain produces no more trust than a signed list; a shared ledger comes only when independent parties run it together, and

even then it carries only digests and fingerprints of the records in the lists. Each state is the sole author of its own register, and every role carried out today on behalf of a state is designed so that it can be handed over without changing any credential or identifier.

The road is long and includes steps whose conditions are not in the network's hands: independent operators, institutions, states. That is why the roadmap gives conditions, not dates. Operators may change, domain names may be handed over, the ledger may come or may be delayed. What lasts is the trust model: signed records that anyone can check, verification without asking the source, and shared records that do not know the person.

Appendix A — Glossary

The terms are in alphabetical order. Technical terms are not translated. The definitions are consistent with the network's glossary (FW-DEF-0001) and with the papers of the series (Table 50).

Table 50. Glossary.

Term	Definition
Access certificate	The X.509 certificate with which a verifier signs its requests; the client identifier is the hash of this certificate.
Anchor log	A public log that keeps status list publications and credential type digests in hourly signed lines.
Authentic source	The system that keeps the original record of the information in a credential; for example, a university's student information system.
Copy	One of the instances of the same credential bound to separate keys; the wallet shows each verifier a separate copy.
Country list (`tl-<cc>`)	A signed list carrying a country's root certificates, issuers, verifiers and national credential types.
Credential (*attestation*)	An electronic document that an issuer signs about a person and that is carried in the person's wallet.
Credential type catalogue	The place where credential type definitions and schemas are published as immutable files.
DCQL	The query language in which a verifier writes which credential and which fields it requests from the wallet (*Digital Credentials Query Language*).
Device attestation	The operating system's signed statement confirming that a key was generated in the secure area and that the application has not been modified.
Device binding (*key binding, holder binding*)	Binding a credential to a key generated in the device's secure hardware; presentation requires a signature with that key.
DPoP	An OAuth extension that binds an access token to a key of the client and requires a proof signed with this key in every request.
Embedded disclosure policy	The rule in which an issuer writes, in its signed display information, to which verifiers its credential may be shown; the final decision rests with the person.
Federation	The model in which country lists are operated by their own owners and brought together in the list of trusted lists.
Fetch branch	A separate session opened at each fetch of the signed request object, with its own `state` , `nonce` and encryption key; a decline closes only its own branch.
HAIP	The profile that narrows the options of OpenID4VCI and OpenID4VP for uses that require high assurance.
HKDF	An HMAC-based key derivation function that derives further keys from a key.
HMAC	A digest computed with a secret key, which someone who does not know the key cannot produce.
Holder	The person who carries the credential in their wallet and decides whom to show it to.

Term	Definition
Hosted issuance service (*hosted issuer*)	The issuance service the network operates on behalf of institutions; the signing key stays with the institution.
INDETERMINATE (could not verify)	The result in which verification could not reach a verdict; it does not mean “invalid”.
Intermediary	A service that requests and verifies credentials from the wallet on behalf of a verifier; the wallet shows the name of the actual verifier. In Tamga, Tamga Verify.
Issuer (*attestation provider*)	The institution that issues the credential: a university, a professional body, a ticket seller and so on.
Key attestation (KA)	A signed document in which the wallet provider declares that the keys to which the credential will be bound were generated and are protected in the device’s secure hardware.
Key proof (*proof of possession*, `proof`)	A short proof that the wallet attaches to its credential request, signed with the key to which the credential will be bound (the OpenID4VCI JWT proof); it shows that the key is in the wallet and that the request is fresh (`aud`, `iat`, `nonce`). Not to be confused with the key attestation (KA): the wallet provider signs the KA, the wallet signs the key proof.
Ledger	A ledger (chain) in which the digests of trust entries are kept by multiple independent operators; it does not exist today.
Ledger stage	The stage in which the trust records in the lists are also written, as digests and fingerprints, to a shared ledger kept by multiple independent operators.
List of Trusted Lists (LoTL)	A signed list showing the addresses, signers and recognition status of the country lists.
mdoc	The binary credential format defined by ISO/IEC 18013-5 and encoded in CBOR.
Non-qualified attestation of attributes (EAA)	A credential issued by any institution that is not a qualified trust service provider.
Out-of-band trust anchor	The fingerprint of the certificate that signs the list of trusted lists, published through channels separate from the lists.
PAR	An OAuth extension in which the authorisation request is first sent directly to the server and only a reference address is carried in the browser.
Pass	A short-lived signed token carrying no personal data, used for proximity until the permanent solution arrives.
PID	Person identification data; an identity credential issued by the state or by an organisation the state authorises. Tamga does not issue PIDs.
PKCE	An OAuth extension in which the client uses a single-use verifier value against interception of the authorisation code.
Pre-authorized code	A single-use code used in institution-initiated issuance, because the person’s identity is already known.
Projection	The shared ledger carrying only digests and fingerprints of the records in the signed lists; the lists are the source, and in a conflict the list prevails.
Provisional identity credential	The credential the identity service issues through remote identity verification while there is no PID provider; it is not a PID.
Provisional operator	The legal person that operates the network’s services “on behalf of Tamga Network” until the foundation is established.
Pseudonym	An account identifier that the wallet generates separately for each site; stable, but impossible to link across sites.
Pseudonym seed	A secret value that the identity service derives from the person’s identity without storing it, and that stays only in the wallet.
Registrar	The organisation that registers issuers, verifiers and wallet providers; it does not grant legal authority.
Registration certificate	The registrar’s signed document carrying the purpose of a verifier’s intended use and the fields it may request.

Term	Definition
Relying party (*verifier*)	A registered organisation that requests credentials from the wallet and verifies them.
Remote signing	The arrangement in which the institution's key stays in its own signing service and the hosted service sends only a hash and receives a signature (CSC API).
Revocation	A credential being treated as permanently invalid.
Sandbox	A public test network running with a root separate from the real network.
SD-JWT VC	A signed JSON credential format whose fields can be hidden one by one.
Selective disclosure	The person showing only the requested fields of a credential.
Single trust interface (`TrustSource`)	The single interface through which the issuer, the verifier and the wallet ask all their trust questions.
Status list	The list in which the issuer keeps the status of each credential in a few bits, and which it signs and publishes; also called the revocation list.
Suspension	A credential being treated as temporarily invalid; it exists only for institution credentials whose schema allows it, not for identity types.
Terminal key	A key issued on behalf of the institution with which a gate terminal identifies itself to the verification service.
Test signer	The signer of credentials issued with the app store review code, which do not pass in the real ecosystem.
Trust anchor	The single value a verifier trusts from the outset: the fingerprint of the certificate that signs the list of trusted lists.
Trust list	A signed list carrying a country's root certificates, issuers and verifiers.
Unlinkability	Different verifiers being unable to link presentations by the same person to one another.
Verification pipeline	The fixed layers in which a verifier checks a presentation: preconditions, format, type, trust, status, policy.
Wallet Instance Attestation (WIA)	A statement that the wallet provider signs for a wallet unit, valid for less than 24 hours; obtained with a new key for every issuance.
Wallet provider	The organisation that offers the wallet, registers units and signs the WIA and the key attestation.
Wallet unit	The installation of a wallet on a particular device.
Zero-knowledge proof (ZK)	A proof that shows a statement to be true without showing the information on which the statement rests.
ZK copy	A short-lived mdoc copy issued for zero-knowledge presentation, valid for at most 24 hours and carrying no status list.

Appendix B — Decision records index

Table 51 gives all decision records in numerical order. The date is the date on which the record was created; for active records the date of acceptance is usually the same, and if not, the record states the date of acceptance separately. The "Section" column shows the main sections in which the record is cited in this document. The full text of the records is under `docs.tamga.network/adr/`.

Table 51. Decision records.

ADR	Title	Status	Date	Section
0001	Besu QBFT ledger	Active	2026-07-29	19
0002	Sovereignty-first governance	Active	2026-08-05	2, 4, 18
0003	Value layer hooks	Superseded	2026-08-06	19
0004	Institutional identity: X.509	Active	2026-08-06	7, 16, 20

ADR	Title	Status	Date	Section
0005	Assurance model and stateless bootstrap	Active	2026-09-03	14
0006	Credential format: SD-JWT VC	Active	2026-09-03	4, 8, 15
0007	Schema registry	Active	2026-09-09	8
0008	Where the status list lives	Active	2026-09-09	12, 20
0009	Chainless beta and chain threshold	Active	2026-09-24	4, 18, 19
0010	Credential type identifier (URN)	Active	2026-09-24	8
0011	Provisional identity attestation provider	Active	2026-09-25	3, 5, 14
0012	Proximity presentation	Active	2026-09-25	10, 20
0013	mdoc for the identity credential	Active	2026-09-26	8, 14, 20
0014	Events category	Active	2026-09-27	21
0015	Single trust interface	Active	2026-09-27	5, 6, 17
0016	Access to hosted issuance	Active	2026-09-27	7, 17
0017	Access to verification results	Active	2026-09-27	11, 17
0018	Three doors to the documentation	Active	2026-09-27	17
0019	Institution Console	Active	2026-09-28	17
0020	The authentic source is the institution	Active	2026-09-29	5, 9
0021	E-mail and phone credentials	Active	2026-09-29	14
0022	Class of the identity service	Active	2026-09-29	3, 7, 8
0023	Automatic copy refresh	Active	2026-09-29	9, 13, 15
0024	Participant registration data	Active	2026-09-29	6, 20
0025	Wallet and key attestations	Active	2026-09-29	9, 13, 15
0026	Registration certificates	Active	2026-09-29	7, 10, 20
0027	Exporting the transaction log	Active	2026-09-29	13
0028	Health credentials	Proposed	2026-09-29	22
0029	Schemas in the development stage	Active	2026-09-30	8
0030	Product names	Active	2026-09-30	10, 11
0031	Per-site pseudonyms	Active	2026-10-01	8, 10, 15
0032	Zero-knowledge proofs (ZK)	Active	2026-10-01	15, 16, 20
0033	App store review code	Active	2026-10-01	14
0034	HAIP 1.0 conformance	Active	2026-10-01	3, 10, 13
0035	Positioning	Active	2026-10-01	3, 4, 20
0036	Trust federation	Active	2026-10-01	6, 20
0037	Tamga Network is only a network	Active	2026-10-02	4, 17, 18
0038	Sandbox: the test network	Active	2026-10-03	6, 17
0039	Verified driving licence information	Active	2026-10-03	8, 14
0040	Real identity checks in sandbox	Active	2026-10-04	17
0041	Institution test accounts in the sandbox	Active	2026-10-04	17
0042	The network and wallets: the network operates no wallet	Active	2026-10-06	4, 5, 13
0043	No age limit: the EU approach	Active	2026-10-08	13, 15, 22
0044	Short-lived copies for ZK presentation	Active	2026-10-09	8, 9, 15

ADR	Title	Status	Date	Section
0045	Identity credential attribute names: the EU PID encoding	Active	2026-10-09	8, 14, 20
0046	Embedded disclosure policy	Active	2026-10-09	10, 20
0047	Wallet unit revocation, out-of-wallet revocation path and device attestation	Active	2026-10-12	12, 13, 16
0048	No suspension for identity service credentials; mdoc status list as CWT	Active	2026-10-13	8, 12, 20
0049	The “Listed on Tamga Network” indicator	Active	2026-10-13	5, 13, 20
0050	Institution issuer certificate profile	Active	2026-10-13	7, 20
0051	The chain is a projection of the signed lists	Active	2026-10-17	4, 19
0052	Besu local permissioning	Active	2026-10-19	19
0053	Competing candidates in the list anchor registry	Active	2026-10-19	19
0054	On-chain schema namespaces, cross-state references and quota scope	Active	2026-10-19	8, 18, 19
0055	Governance: upgrade delay and registry administration proposals	Active	2026-10-19	18, 19
0056	Misuse-resistant defaults in the package APIs	Active	2026-10-19	7, 10, 16
0057	The institution’s signing key in hosted issuance: remote signing (CSC API)	Active	2026-10-20	5, 7, 16
0058	Access certificate profile (ETSI TS 119 411-8) and timing of the identity service certificate change	Active	2026-10-21	7, 18, 20
0059	Multiple credential requests within the access token lifetime	Active	2026-10-21	9
0060	Refresh token bound to the client instance key	Active	2026-10-22	9
0061	Pseudonym seed as a separate credential configuration, with a standard credential request	Active	2026-10-22	8, 14, 15
0062	ZK copy refresh token only when the ZK copy scope is requested	Active	2026-10-23	9, 16
0063	The on-chain status list registry accepts the list’s own bit size	Active	2026-10-23	19
0064	Age thresholds in the identity credential: age_over_15 and the age_over_NN pattern	Active	2026-10-23	14, 15
0065	Gate terminals authenticate to the verification service: terminal key	Active	2026-10-26	10, 16
0066	ETSI TS 119 612 XML list view	Active	2026-10-29	6, 20
0067	Each fetch of the request object is its own branch; a decline closes only its own branch	Active	2026-10-29	10, 16
0068	Registration certificate policy and status list	Active	2026-10-29	7, 10, 20
0069	Gate groups in the trust list: institution, policy, certificate; terminal keys on behalf of the institution	Active	2026-10-29	10, 16
0070	Provisional operator chain	Active	2026-10-30	4, 18
0071	Funding the network in the provisional phase: no service fees; the foundation is funded by grants and state or member contributions	Active	2026-10-30	4, 18
0072	Value layer suspended: the ADR-0003 hooks are a research direction	Active	2026-10-30	4, 19, 23
0073	Feasibility of chain–list equivalence: migration mode, hard revocation, schema versions, verifier identifier, status mapping	Active	2026-11-04	19

ADR	Title	Status	Date	Section
0074	Projection scope 0.8: all trust records in the signed lists on the chain	Active	2026-11-04	4, 19
0075	Ownership of the verifier domain-name identifier and re-registration after revocation	Active	2026-11-04	19

Appendix C — Standards index

Table 52 gives the external standards and regulations cited in the document, their versions and the sections in which they are used in Tamga. The versions are those current at the time this edition was prepared; the content of the standards is not quoted, only the place where they are used is shown.

Table 52. Standards and regulations.

Body	Document	Version	In Tamga	Section
EU	Regulation 910/2014 [1] and 2024/1183 [2] (eIDAS 2.0)	2024/1183, 30 April 2024	framework, roles, credential classes	3, 20
EU	Implementing Regulations 2024/2977–2982 [5]	December 2024; as amended by 2026/1731	PID and EAA encoding, wallet functions	3, 13, 14
EU	Implementing Regulations 2025/847 [6], 2025/848, 2025/849	May 2025; 2025/848 as amended by 2026/1730	incident notification, verifier registration, list of certified wallets	7, 18, 20
EU	Implementing Regulations 2026/1730 [7], 2026/1731, 2026/1735	July 2026	current references to standards; identity attributes	3, 14, 20
EU	Architecture and Reference Framework (ARF [11])	3.0.0, July 2026	set of roles, rules, topics	3, 13, 20
EU	EUDI technical specifications (TS3 [12], TS10, TS13 …)	living documents	WIA and KA, export, ZK	13, 15
EU	Attestation Rulebook [13] template	1.5	branches of the Tamga Rulebook	18.8
IETF	RFC 9901 [15] SD-JWT	November 2025	credential format	8
IETF	SD-JWT VC [16]	Internet-Draft; the version pinned by 2026/1731	credential format	8
IETF	Token Status List [17]	draft-20 (referenced by the EU), draft-21	status lists	12
IETF	OAuth 2.0 Attestation-Based Client Authentication [18]	draft	client authentication with the WIA	9, 13
IETF	RFC 9449 DPoP [20] · RFC 9126 PAR [21] · RFC 7636 PKCE [22] · RFC 9700 [23]	published	issuance profile	9
IETF	RFC 5280 [28] X.509 · RFC 8949 CBOR [29] · RFC 7638 [24] · RFC 9180 HPKE [25]	published	certificates, mdoc, key thumbprint, response encryption	7, 8, 10
OpenID Foundation	OpenID4VCI 1.0 [30]	Final, September 2025	issuance	9

Body	Document	Version	In Tamga	Section
OpenID Foundation	OpenID4VP 1.0 [31] and DCQL	Final, July 2025	presentation	10
OpenID Foundation	HAIP 1.0 [32]	Final, December 2025	high assurance profile	9, 10
ISO/IEC	18013-5 [34]	2021	mdoc, proximity	8.3, 10.8
ISO/IEC	TS 18013-7 [35]	2025	mdoc through the browser	10.6
W3C	Digital Credentials API [36]	working draft	presentation from the browser	10.6
ETSI	TS 119 612 [41]	V2.4.1	XML trust list view	6.8
ETSI	TS 119 602 [42]	V1.1.1	LoTE views, external lists	6.8, 6.9
ETSI	TS 119 412-6 [43] and EN 319 412-3 [44]	V1.2.1	institution certificate profile	7.3
ETSI	TS 119 411-8 [45]	V1.1.1	verifier access certificate	7.4
ETSI	TS 119 475 [46]	V1.2.1	registration certificate	7.5
ETSI	TS 119 461 [47]	V2.1.1	remote identity proofing	14
ETSI	TS 119 471 [48]; TS 119 472-1 [49]; TS 119 472-2 [50]; TS 119 472-3 [51]	V1.1.1; V1.2.1; V1.2.1; V1.1.1	issuer policy, credential, issuance and presentation profiles	8, 9, 10, 20
ETSI	EN 319 401 [52]; EN 319 132-1 (XAdES [53])	published	general policy; XML signature	6.8, 20
Cloud Signature Consortium	CSC API [54]	v2	remote signing	7.6
Longfellow ZK	proof system and CFRG draft	draft-00	age proof	15.4
EU	European Learning Model / Europass [61]	3	meaning of the diploma fields	8.5

Appendix D — Abbreviations

Table 53 expands the abbreviations used in the document; most of them are also defined in Appendix A.

Table 53. Abbreviations.

Abbreviation	Expansion
ADR	Architecture Decision Record
ARF	Architecture and Reference Framework
CBOR	Concise Binary Object Representation
CIR	Commission Implementing Regulation
CSC	Cloud Signature Consortium
CWT	CBOR Web Token
DC API	Digital Credentials API
DCQL	Digital Credentials Query Language

Abbreviation	Expansion
DPoP	Demonstrating Proof of Possession
EAA	Electronic Attestation of Attributes
EBSI	European Blockchain Services Infrastructure
ELM	European Learning Model
ETSI	European Telecommunications Standards Institute
EUDI	European Digital Identity
FW	Identifier of a Tamga framework document
HAIP	OpenID4VC High Assurance Interoperability Profile
HKDF	HMAC-based Key Derivation Function
HMAC	Hash-based Message Authentication Code
HPKE	Hybrid Public Key Encryption
JWE / JWS / JWT	JSON Web Encryption / Signature / Token
KA	Key Attestation
KB-JWT	Key Binding JWT, the device binding signature
KVKK	Turkish Personal Data Protection Law No. 6698 (Kişisel Verilerin Korunması Kanunu)
LoTE	Lists of Trusted Entities (ETSI TS 119 602)
LoTL	List of Trusted Lists
mDL	mobile Driving Licence
OpenID4VCI	OpenID for Verifiable Credential Issuance
OpenID4VP	OpenID for Verifiable Presentations
OTS	Organization of Turkic States
PAR	Pushed Authorization Requests
PID	Person Identification Data
PKCE	Proof Key for Code Exchange
PuB-EAA	Electronic attestation of attributes issued by or on behalf of a public body
QBFT	Quorum Byzantine Fault Tolerance
QEAA	Qualified EAA
SD-JWT VC	Selective Disclosure JWT Verifiable Credential
SPEC	Identifier of a Tamga specification
TS	Technical Specification
VCDM	W3C Verifiable Credentials Data Model
WIA	Wallet Instance Attestation
XAdES	XML Advanced Electronic Signatures
ZK	Zero-Knowledge

Appendix E — Document set index

Tamga's framework documents are at `arf.tamga.network/`, and its specifications and guides at `docs.tamga.network/`. Table 54 maps the identifiers cited in this document to their addresses. The address is the path after the root; the framework documents are published in English and Turkish (the Turkish versions under `/tr/`).

Table 54. Framework documents, specifications and guides.

Identifier	Title	Address
FW-ARF-0001	Architecture and Reference Framework	`arf.tamga.network/architecture`
FW-TF-0001	Annex A: Trust Framework	`arf.tamga.network/trust-framework`
FW-RB-0001	Annex B: Tamga Rulebook	`arf.tamga.network/rulebook`
FW-RB-0002	Education Rulebook	`arf.tamga.network/rulebooks/education`
FW-RB-0003	Identity Rulebook	`arf.tamga.network/rulebooks/identity`
FW-RB-0004	Event Ticket Rulebook	`arf.tamga.network/rulebooks/event-ticket`
FW-RB-0005	Contact Rulebook	`arf.tamga.network/rulebooks/contact`
FW-DEF-0001	Annex D: Definitions	`arf.tamga.network/definitions`
FW-REF-0001	Annex E: References	`arf.tamga.network/references`
FW-ROLE-0001	Roles	`arf.tamga.network/roles`
FW-ONB-0001	Onboarding process	`arf.tamga.network/onboarding`
FW-POL-0001	Revocation Policy	`arf.tamga.network/policies/revocation`
FW-POL-0002	Wallet Attestation Policy	`arf.tamga.network/policies/wallet-attestation`
FW-POL-0003	Registration Certificate Policy	`arf.tamga.network/policies/registration-certificate`
SPEC-TRUST-0001	Trust lists	`docs.tamga.network/specifications/trust-lists`
SPEC-ID-0002	Institutional identity (X.509)	`docs.tamga.network/specifications/x509-identity`
SPEC-ID-0003	Identity proofing	`docs.tamga.network/specifications/identity-proofing`
SPEC-CRED-0001	Credential format and protocols	`docs.tamga.network/specifications/credential-format`
SPEC-CRED-0002	SD-JWT VC profile	`docs.tamga.network/specifications/sd-jwt-vc`
SPEC-CRED-0003	Revocation and status list	`docs.tamga.network/specifications/status-list`
SPEC-SCHEMA-0001	Schema catalogue	`docs.tamga.network/specifications/schema-catalog`
SPEC-SCHEMA-0002	Education schemas	`docs.tamga.network/specifications/education-schemas`
SPEC-SCHEMA-0003	Sector schemas	`docs.tamga.network/specifications/sector-schemas`
SPEC-PROTO-0001	OpenID4VCI profile	`docs.tamga.network/specifications/openid4vci`
SPEC-PROTO-0002	OpenID4VP profile	`docs.tamga.network/specifications/openid4vp`
SPEC-API-0001	Verification pipeline and API	`docs.tamga.network/specifications/verification-api`
SPEC-WALLET-0001	Wallet rules	`docs.tamga.network/specifications/wallet`
GUIDE-0009	Conformance tests	`docs.tamga.network/guides/conformance`
GUIDE-0013	Sandbox: the test network	`docs.tamga.network/guides/sandbox`
GUIDE-0014	Onboarding tool: for the IT team	`docs.tamga.network/guides/onboarding-tool`
ADR-0001 … ADR-0075	Decision records (Appendix B)	`docs.tamga.network/adr/`

References

[1] European Parliament and Council (2014). *Regulation (EU) No 910/2014 on electronic identification and trust services for electronic transactions in the internal market.* Official Journal of the European Union, L 257, 28 August 2014; consolidated text as amended by 2024/1183, CELEX 02014R0910-20241018.

[2] European Parliament and Council (2024). *Regulation (EU) 2024/1183 of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework.* Official Journal of the European Union, 30 April 2024. http://data.europa.eu/eli/reg/2024/1183/oj

[3] European Commission (2021). *Commission Recommendation (EU) 2021/946 on a common Union Toolbox for a coordinated approach towards a European Digital Identity Framework.* 3 June 2021.

[4] European Commission (2015). *Commission Implementing Regulation (EU) 2015/1502 on setting out minimum technical specifications and procedures for assurance levels for electronic identification means.* Official Journal of the European Union, L 235, 9 September 2015.

[5] European Commission (2024). *Commission Implementing Regulations (EU) 2024/2977, 2024/2979, 2024/2980, 2024/2981 and 2024/2982* (European Digital Identity Wallets). 28 November 2024; Official Journal of the European Union, 4 December 2024.

[6] European Commission (2025). *Commission Implementing Regulations (EU) 2025/846, 2025/847 (reactions to security breaches of wallets), 2025/848 (registration of wallet-relying parties) and 2025/849 (list of certified wallets).* 6 May 2025; Official Journal of the European Union, 7 May 2025.

[7] European Commission (2026). *Commission Implementing Regulations (EU) 2026/1730, 2026/1731 and 2026/1735*, as regards the standards and specifications to be applied. 15 July 2026; Official Journal of the European Union, 22 July 2026.

[8] European Parliament and Council (2016). *Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation).* Official Journal of the European Union, L 119, 4 May 2016.

[9] *6698 sayılı Kişisel Verilerin Korunması Kanunu* [Law No. 6698 on the Protection of Personal Data]. Resmî Gazete (Official Gazette of the Republic of Türkiye), 7 April 2016, issue 29677.

[10] *7578 sayılı Sosyal Hizmetler Kanunu ve Bazı Kanunlarda Değişiklik Yapılmasına Dair Kanun* [Law No. 7578 Amending the Social Services Law and Certain Laws]. Resmî Gazete (Official Gazette of the Republic of Türkiye), 1 May 2026, issue 33240.

[11] European Commission and eIDAS Expert Group (2026). *European Digital Identity Wallet: Architecture and Reference Framework (ARF)*, version 3.0.0, 23 July 2026. https://eu-digital-identity-wallet.github.io/eudi-doc-architecture-and-reference-framework/

[12] European Commission. *EUDI Wallet Standards and Technical Specifications* (TS3 wallet unit attestations, TS5 and TS6 relying party registration, TS9 wallet-to-wallet interaction, TS10 data portability, TS13 zero-knowledge proofs with arithmetic circuits). https://github.com/eu-digital-identity-wallet/eudi-doc-standards-and-technical-specifications

[13] European Commission. *EUDI Wallet attestation rulebooks catalog*: Attestation Rulebook template, version 1.5; PID and mDL Rulebooks. https://github.com/eu-digital-identity-wallet/eudi-doc-attestation-rulebooks-catalog

[14] European Commission. *Pilot for the International Compatibility of Trust Services* and third-country trusted lists. https://ec.europa.eu (accessed November 2026).

[15] Fett, D., Yasuda, K. and Campbell, B. (2025). *Selective Disclosure for JSON Web Tokens (SD-JWT).* IETF RFC 9901, November 2025.

[16] Terbu, O., Fett, D. and Campbell, B. *SD-JWT-based Verifiable Digital Credentials (SD-JWT VC).* IETF OAuth Working Group Internet-Draft draft-ietf-oauth-sd-jwt-vc; the version pinned by the EU's Implementing Regulation 2026/1731 is followed. https://datatracker.ietf.org/doc/draft-ietf-oauth-sd-jwt-vc/ (accessed 11 November 2026).

[17] Looker, T., Bastian, P. and Bormann, C. *Token Status List.* IETF OAuth Working Group Internet-Draft draft-ietf-oauth-status-list-20 (20 April 2026; the version referenced by the EU in 2026/1731) and draft-21 (21 June 2026). https://datatracker.ietf.org/doc/draft-ietf-oauth-status-list/

[18] Looker, T., Bastian, P. and Bormann, C. *OAuth 2.0 Attestation-Based Client Authentication.* IETF OAuth Working Group Internet-Draft (draft-ietf-oauth-attestation-based-client-auth).

[19] Hardt, D. (Ed.) (2012). *The OAuth 2.0 Authorization Framework.* IETF RFC 6749, October 2012.

[20] Fett, D., Campbell, B., Bradley, J., Lodderstedt, T., Jones, M. and Waite, D. (2023). *OAuth 2.0 Demonstrating Proof of Possession (DPoP).* IETF RFC 9449, September 2023.

[21] Lodderstedt, T., Campbell, B., Sakimura, N., Tonge, D. and Skokan, F. (2021). *OAuth 2.0 Pushed Authorization Requests.* IETF RFC 9126, September 2021.

[22] Sakimura, N., Bradley, J. and Agarwal, N. (2015). *Proof Key for Code Exchange by OAuth Public Clients.* IETF RFC 7636, September 2015.

[23] Lodderstedt, T., Bradley, J., Labunets, A. and Fett, D. (2025). *Best Current Practice for OAuth 2.0 Security.* IETF RFC 9700, January 2025.

[24] Jones, M. and Sakimura, N. (2015). *JSON Web Key (JWK) Thumbprint.* IETF RFC 7638, September 2015.

[25] Barnes, R., Bhargavan, K., Lipp, B. and Wood, C. (2022). *Hybrid Public Key Encryption.* IETF RFC 9180, February 2022.

[26] Krawczyk, H., Bellare, M. and Canetti, R. (1997). *HMAC: Keyed-Hashing for Message Authentication.* IETF RFC 2104, February 1997.

[27] Krawczyk, H. and Eronen, P. (2010). *HMAC-based Extract-and-Expand Key Derivation Function (HKDF).* IETF RFC 5869, May 2010.

[28] Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R. and Polk, W. (2008). *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile.* IETF RFC 5280, May 2008.

[29] Bormann, C. and Hoffman, P. (2020). *Concise Binary Object Representation (CBOR).* IETF RFC 8949, December 2020.

[30] Lodderstedt, T., Yasuda, K., Looker, T. and Bastian, P. (2025). *OpenID for Verifiable Credential Issuance 1.0.* OpenID Foundation, final specification, 16 September 2025. https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0.html

[31] Terbu, O., Lodderstedt, T., Yasuda, K., Fett, D. and Heenan, J. (2025). *OpenID for Verifiable Presentations 1.0.* OpenID Foundation, final specification, 9 July 2025. https://openid.net/specs/openid-4-verifiable-presentations-1_0.html

[32] Yasuda, K., Lodderstedt, T., Bormann, C. and Heenan, J. (2025). *OpenID4VC High Assurance Interoperability Profile (HAIP) 1.0.* OpenID Foundation, final specification, 24 December 2025. https://openid.net/specs/openid4vc-high-assurance-interoperability-profile-1_0.html

[33] OpenID Foundation. *OpenID Conformance Suite* and self-certification. https://openid.net/certification/ · Tamga Network, *oidf-conformance-kit*. https://github.com/tamga-network/oidf-conformance-kit

[34] ISO/IEC (2021). *ISO/IEC 18013-5:2021 Personal identification: ISO-compliant driving licence, Part 5: Mobile driving licence (mDL) application.* ISO/IEC JTC 1/SC 17. https://www.iso.org/standard/69084.html

[35] ISO/IEC (2025). *ISO/IEC TS 18013-7:2025 Personal identification: ISO-compliant driving licence, Part 7: Mobile driving licence (mDL) add-on functions.* Second edition, May 2025 (first edition October 2024).

[36] Caceres, M., Cappalli, T. and Yosef, M. A. (Ed.) (2026). *Digital Credentials.* W3C Working Draft, Federated Identity Working Group, 29 October 2026. https://www.w3.org/TR/digital-credentials/

[37] W3C (2025). *Verifiable Credentials Data Model v2.0.* W3C Recommendation, 15 May 2025. https://www.w3.org/TR/vc-data-model-2.0/

[38] W3C (2016). *Subresource Integrity.* W3C Recommendation, June 2016. https://www.w3.org/TR/SRI/

[39] JSON Schema. *JSON Schema: A Media Type for Describing JSON Documents*, draft 2020-12. https://json-schema.org/draft/2020-12

[40] ISO/IEC (2020). *ISO/IEC 17000:2020 Conformity assessment: Vocabulary and general principles.*

[41] ETSI (2025). *ETSI TS 119 612 V2.4.1: Electronic Signatures and Trust Infrastructures (ESI); Trusted Lists.* August 2025.

[42] ETSI (2025). *ETSI TS 119 602 V1.1.1: Electronic Signatures and Trust Infrastructures (ESI); Lists of Trusted Entities; Data model.* November 2025.

[43] ETSI (2026). *ETSI TS 119 412-6 V1.2.1: ESI; Certificate Profiles; Part 6: Certificate profile requirements for PID, Wallet, EAA, QEAA and PSBEAA providers.* April 2026.

[44] ETSI. *ETSI EN 319 412-3: ESI; Certificate Profiles; Part 3: Certificate profile for certificates issued to legal persons.*

[45] ETSI (2025). *ETSI TS 119 411-8 V1.1.1: ESI; Policy and security requirements for Trust Service Providers issuing certificates; Part 8: Access Certificate Policy for EUDI Wallet Relying Parties.* October 2025.

[46] ETSI (2026). *ETSI TS 119 475 V1.2.1: ESI; Relying party attributes supporting EUDI Wallet user's authorisation decisions.* March 2026.

[47] ETSI (2025). *ETSI TS 119 461 V2.1.1: ESI; Policy and security requirements for trust service components providing identity proofing of trust service subjects.* February 2025.

[48] ETSI (2025). *ETSI TS 119 471 V1.1.1: ESI; Policy and security requirements for providers of electronic attestation of attributes services.* May 2025.

[49] ETSI (2026). *ETSI TS 119 472-1 V1.2.1: ESI; Profiles for Electronic Attestation of Attributes; Part 1: General requirements.* February 2026.

[50] ETSI (2026). *ETSI TS 119 472-2 V1.2.1: ESI; Profiles for Electronic Attestation of Attributes; Part 2: Profiles for EAA/PID Presentations to Relying Party.* March 2026.

[51] ETSI (2026). *ETSI TS 119 472-3 V1.1.1: ESI; Profiles for Electronic Attestation of Attributes; Part 3: Profiles for issuance of EAA or PID.* March 2026.

[52] ETSI. *ETSI EN 319 401: ESI; General Policy Requirements for Trust Service Providers.*

[53] ETSI. *ETSI EN 319 132-1: ESI; XAdES digital signatures; Part 1: Building blocks and XAdES baseline signatures.*

[54] Cloud Signature Consortium. *Architectures and protocols for remote signature applications* (CSC API), version 2. https://cloudsignatureconsortium.org/

[55] ENISA (2022). *Remote Identity Proofing: Attacks & Countermeasures.* European Union Agency for Cybersecurity, January 2022.

[56] Frigo, M. and shelat, a. (2024). "Anonymous Credentials from ECDSA." *Cryptology ePrint Archive*, Report 2024/2010.

[57] Frigo, M. and shelat, a. (2026). *Longfellow ZK.* IRTF CFRG Internet-Draft draft-irtf-cfrg-longfellow-00, 19 October 2026; open source implementation https://github.com/longfellow-zk/longfellow-zk

[58] Lamport, L., Shostak, R. and Pease, M. (1982). "The Byzantine Generals Problem." *ACM Transactions on Programming Languages and Systems*, 4(3), 382–401.

[59] Hyperledger Besu documentation: “QBFT”, “Local permissioning” and the 25.6.0 release notes. https://besu.hyperledger.org (accessed November 2026).
[60] European Blockchain Services Infrastructure (EBSI). Documentation. https://hub.ebsi.eu (accessed November 2026).
[61] European Commission. *Europass and the European Learning Model (ELM)*, version 3. https://europa.eu/europass/
[62] Tamga Network (2026). *We are building the modern counterpart of the ancient seal* (manifesto), version 1.0, November 2026. https://tamga.network/manifesto-en.pdf
[63] Tamga Network (2026). *Architecture and Reference Framework* (FW-ARF-0001) and its annexes: Trust Framework, Tamga Rulebook and the credential type rulebooks, Definitions, References, Roles, Onboarding, and the Revocation, Wallet Attestation and Registration Certificate policies; version 1.0.0. https://arf.tamga.network/ (identifiers in Appendix E).
[64] Tamga Network (2026). *Specifications* (SPEC-TRUST-0001, SPEC-ID-0002/0003, SPEC-CRED-0001/0002/0003, SPEC-SCHEMA-0001/0002/0003, SPEC-PROTO-0001/0002, SPEC-API-0001, SPEC-WALLET-0001), version 1.0.0; guides and concept pages. https://docs.tamga.network/
[65] Tamga Network (2026). *Architecture decision records* ADR-0001…ADR-0075. https://docs.tamga.network/adr/ (index in Appendix B).
[66] Tamga Network (2026). *tamga-network* repository: README, SECURITY.md, CHANGELOG (0.8.2, 5 November 2026) and the `@tamga-network/*` packages, Apache-2.0. https://github.com/tamga-network/tamga-network
[67] Tamga Network Academic Papers A1 (2026). *Dijital Kimliğin Evrimi: Kullanıcı Adından Kimlik Cüzdanına* [The Evolution of Digital Identity: From Username to Identity Wallet]. https://tamga.network/files/publications/evolution-of-digital-identity-tr.pdf
[68] Tamga Network Academic Papers A3. *Seçici Açıklama: Gerekeni Göster, Gerisi Sende Kalsın* [Selective Disclosure: Show What Is Needed, Keep the Rest]. Forthcoming.
[69] Tamga Network Academic Papers A4. *Sıfır Bilgi İspatları ve Kimlik* [Zero-Knowledge Proofs and Identity]. Forthcoming.
[70] Tamga Network Academic Papers A5. *Bağlanamazlık: Doğrulayıcılar Seni Birbirine Anlatmasın* [Unlinkability: Verifiers Should Not Tell Each Other About You]. Forthcoming.
[71] Tamga Network Academic Papers A6. *Kime Güveniyoruz? Güven Listeleri ve Dijital Güven Altyapısı* [Whom Do We Trust? Trust Lists and Digital Trust Infrastructure]. Forthcoming.
[72] Tamga Network Academic Papers A7. *İptal: Bir Belgeyi Geri Almak, Kimseyi İzlemeden* [Revocation: Withdrawing a Credential Without Tracking Anyone]. Forthcoming.
[73] Tamga Network Academic Papers A8. *Belge Nasıl Verilir, Nasıl Gösterilir* [How a Credential Is Issued and How It Is Presented]. Forthcoming.
[74] Tamga Network Academic Papers A9. *Yüz Yüze Doğrulama: NFC, Bluetooth ve Mobil Ehliyet* [In-Person Verification: NFC, Bluetooth and the Mobile Driving Licence]. Forthcoming.
[75] Tamga Network Academic Papers A10. *Cüzdan Güvenliği: Anahtar Nerede Saklanır, Telefon Gerçek mi?* [Wallet Security: Where Is the Key Kept, Is the Phone Genuine?]. Forthcoming.
[76] Tamga Network Academic Papers A11. *eIDAS 2.0'a Hukuk Dışından Bakış* [eIDAS 2.0 Seen from Outside the Law]. Forthcoming.
[77] Tamga Network Academic Papers A12. *Blokzincir ve Dijital Kimlik* [Blockchain and Digital Identity]. Forthcoming.
[78] Tamga Network Academic Papers A14. *Deepfake Çağında Kimlik Doğrulama* [Identity Verification in the Age of Deepfakes]. Forthcoming.
[79] Tamga Network Academic Papers A15. *Kuantum Sonrası Dönemde Dijital Kimlik* [Digital Identity in the Post-Quantum Era]. Forthcoming.